

UNIVERSIDAD MAYOR DE SAN ANDRÉS
FACULTAD DE CIENCIAS ECONÓMICAS Y FINANCIERAS
CARRERA DE CONTADURÍA PÚBLICA
INSTITUTO DE INVESTIGACIÓN DE CIENCIAS CONTABLES,
FINANCIERAS Y AUDITORIA



TESIS DE MAESTRIA
MAESTRÍA EN AUDITORIA Y CONTROL FINANCIERO

MODELO DE GESTIÓN Y CONTROL INTEGRAL DE RIESGOS
DE SEGURIDAD DE LA INFORMACIÓN EN LA
ADMINISTRACIÓN PÚBLICA

Por : Bernabé Huanca Choquehuanca

Tutor : Mg.Sc. Víctor Hugo Chávez Salazar

La Paz - Bolivia
2020

Dedicatoria

*Dedicado en primer lugar a Dios, a mis padres
Clemente y Juana, que me dieron la vida,
a mis hermanos Eloy, Raúl y Wilma
con quienes crecí en la familia,
en especial a las personas que están a mi lado día a día
Marina Irma, Maya Almira, Selva Nahir y Amir Inti
que son el motor de mi vida.*

Berny

AGRADECIMIENTO

En primer lugar, a mi Tutor y Docente, MSc. Víctor Hugo Chávez S., por brindarme su apoyo incondicional con su conocimiento asesorando de manera profesional en la realización del presente trabajo. Con quien he compartido muy gratos momentos académicos durante mi vida universitaria.

A mis compañeros de la maestría, con quienes pasé bellos momentos en el postgrado, conocí nuevos amigos y amigas, practicamos deporte, etc.

A todo el personal del Servicio General de Identificación Personal SEGIP quienes he compartido conocimientos y me han colaborado de manera desinteresada en la investigación y a los que en última instancia deseo que este estudio les repercuta en mejoras para su ambiente laboral e institucional, a quienes quiero agradecer.

***Con mucho cariño:
Bernabé Huanca Ch.***

RESUMEN

El presente trabajo se desarrolla principalmente para destacar la importancia de Seguridad de la Información en la Gestión Pública.

Para el desarrollo del Modelo de Gestión y Control Integral de Riesgos de Seguridad de la Información en la Administración Pública, se tomó en consideración el manejo de la información utilizados en las instituciones del sector público, las políticas que influyen sobre la administración eficiente de la información y la relación de los elementos identificados con el desarrollo de la seguridad que se ven reflejada en la Administración Pública.

En principio se plantea la metodología de desarrollo del trabajo, planteando el problema principal, la hipótesis, los objetivos, el alcance, entre otros. Posteriormente se lleva acabo al enriquecimiento de conceptos y definiciones teóricos respecto a seguridad de la información y control interno. Seguidamente se plantea la metodología del Modelo de Gestión y Control Integral de Riesgos de Seguridad de la Información en la Administración Pública, abstrayendo los procesos importantes para determinar la metodología correcta para desarrollar el trabajo del modelo e implementación del mismo. Posteriormente en base al planteamiento metodológico del modelo de seguridad de la información, se desarrolla el trabajo aplicando métodos, técnicas y herramientas estadísticas para la obtención de datos y resultados, como objeto de estudio se enfoca al personal de la Dirección Nacional de Tecnologías de la Información DNTIC del Servicio General de Identificación Personal SEGIP de diferentes niveles, utilizando cuestionarios y entrevistas para determinar los niveles de riesgos existentes de la seguridad de la información. A través de auditoria de cumplimiento se determinan los niveles de cumplimiento del modelo respecto sus controles referidos a la seguridad de la información. Por último, se concluye que la Seguridad de la Información en la Administración Pública es fundamental que está destinado para el manejo adecuado de la información orientada a todos los procesos administrativos de la entidad a través de los componentes o controles de Seguridad de la Información en función al desarrollo práctico realizado en la Entidad Pública. Se recomienda a la Máxima Autoridad Ejecutiva y directores, gestionar programas de capacitación, actualización, seguimiento de controles de seguridad de la información y otros, que permitan lograr una mayor eficiencia en la administración de la información de la Entidad Pública.

ABSTRACT

This work is developed mainly to highlight the importance of Information Security in Public Management.

For the development of the Comprehensive Information Security Risk Management and Control Model in the Public Administration, the information management used in public sector institutions, the policies that influence the efficient administration of information, were taken into consideration. and the relationship of the elements identified with the development of security that are reflected in the Public Administration.

In principle, the work development methodology is proposed, posing the main problem, the hypothesis, the objectives, the scope, among others. Subsequently, the enrichment of concepts and theoretical definitions regarding information security and internal control is carried out. Next, the methodology of the Comprehensive Management and Control Model of Information Security Risks in Public Administration is proposed, abstracting the important processes to determine the correct methodology to develop the work of the model and its implementation. Subsequently, based on the methodological approach of the information security model, the work is developed applying methods, techniques and statistical tools to obtain data and results, as an object of study it is focused on the personnel of the National Directorate of Information Technologies DNTIC of the General Service of Personal Identification SEGIP of different levels, using questionnaires and interviews to determine the existing risk levels of information security. Through a compliance audit, the levels of compliance of the model with respect to its controls regarding information security are determined. Finally, it is concluded that Information Security in the Public Administration is essential that it is intended for the proper management of information oriented to all administrative processes of the entity through the components or controls of Information Security based on to the practical development carried out in the Public Entity. It is recommended that the Highest Executive Authority and directors manage training programs, updating, monitoring of information security controls and others, which allow greater efficiency in the administration of the information of the Public Entity.

INDICE GENERAL

DEDICATORIA.....	i
AGRADECIMIENTO.....	ii
RESUMEN	iii
ABSTRACT.....	iv
INTRODUCCIÓN.....	1
CAPITULO I.....	2
DESARROLLO DEL PROBLEMA.....	2
1.1 IDENTIFICACIÓN Y PLANTEAMIENTO DEL PROBLEMA	2
1.1.1 FORMULACIÓN DEL PROBLEMA	3
1.2 OBJETIVOS	3
1.2.1 OBJETIVO GENERAL	3
1.2.2 OBJETIVOS ESPECÍFICOS	3
1.3 PLANTEAMIENTO DE HIPÓTESIS	4
1.4 ALCANCES Y LIMITACIONES	4
1.4.1 ALCANCES	4
1.4.2 LIMITACIONES.....	5
1.5 JUSTIFICACIÓN	5
1.5.1 JUSTIFICACIÓN METODOLÓGICA.....	5
1.5.2 JUSTIFICACIÓN TEÓRICA	5
1.5.3 JUSTIFICACIÓN PRÁCTICA.....	6
CAPITULO II.....	7
FUNDAMENTACIÓN TEÓRICA	7
2.1 MARCO TEORICO.....	7
2.1.1 EVOLUCIÓN HISTORICO.....	7
2.1.2 CULTURA DE SEGURIDAD DE LA INFORMACIÓN	8
2.1.3 SEGURIDAD DE LA INFORMACION	8
2.1.4 EL SISTEMA DE GESTIÓN DE LA SEGURIDAD DE LA INFORMACIÓN (SGSI) 9	
2.1.5 IMPORTANCIA DE UN SISTEMA DE GESTIÓN DE LA SEGURIDAD DE INFORMACIÓN.....	11
2.1.6 ENCARGADO DE SEGURIDAD DE LA INFORMACION.....	12
2.1.7 TECNOLOGIAS INVOLUCRADAS EN SEGURIDAD DE INFORMACION...	13
2.1.8 ATAQUES A LA SEGURIDAD	15
2.1.9 COMPONENTES DE UN SGSI.....	16

2.1.10	IMPLEMENTACION DE UN SGSI	18
2.1.11	TAREAS DE LA GERENCIA EN UN SGSI	23
2.1.12	NORMAS ISO 27000 SERIE.....	26
2.1.13	COBIT, ESTÁNDAR PARA EL BUEN GOBIERNO DE LOS SISTEMAS DE INFORMACIÓN.....	27
2.2	MARCO CONCEPTUAL	30
2.2.1	INFORMACIÓN	30
2.2.2	SEGURIDAD	30
2.2.3	SISTEMA	31
2.2.4	MODELO	32
2.2.5	NORMA	32
2.2.6	POLÍTICA DE SEGURIDAD.....	32
2.2.7	RECURSOS DE INFORMACIÓN	33
2.2.8	SEGURIDAD DE LA INFORMACION	33
2.2.9	RIESGOS.....	34
2.2.10	GESTIÓN DE SEGURIDAD DE LA INFORMACIÓN.....	35
2.2.11	ESTÁNDARES Y NORMAS PARA ASEGURAR LA INFORMACIÓN	35
2.2.12	NORMA ISO 27001	36
2.2.13	COBIT	37
2.3	MARCO REFERENCIAL NORMATIVO	37
2.3.1	A NIVEL NACIONAL	38
2.3.1.1	LEY 164/2011, LEY GENERAL DE TELECOMUNICACIONES, TECNOLOGÍAS DE LA INFORMACIÓN Y COMUNICACIÓN.....	38
2.3.1.2	LEY 1322/1992, LEY DE DERECHOS DE AUTOR	39
2.3.1.3	LEY 2410/2002, LEY DE PRIVACIDAD (HABEAS DATA)	40
2.3.2	A NIVEL INTERNACIONAL.....	40
2.3.2.1	LEY 34/2002, LEY DE SERVICIOS DE LA SOCIEDAD DE LA INFORMACIÓN Y DE COMERCIO ELECTRÓNICO, CON SIGLAS LSSI.	40
2.3.2.2	LEY GENERAL 32/2003, LEY DE TELECOMUNICACIONES	41
2.3.2.3	LEY 39/2015, DEL PROCEDIMIENTO ADMINISTRATIVO COMÚN DE LAS ADMINISTRACIONES PÚBLICAS.....	41
CAPITULO III		42
MARCO METODOLÓGICO		42
3.1	ENFOQUE DE LA INVESTIGACIÓN	42
3.2	TIPO DE INVESTIGACIÓN	42
3.3	DISEÑO DE LA INVESTIGACIÓN	43

3.4	MÉTODO DE INVESTIGACIÓN	44
3.5	TÉCNICAS E INSTRUMENTOS.....	44
3.5.1	TÉCNICAS PARA RECOPIACION DE INFORMACIÓN	44
3.5.1.1	TÉCNICAS FÍSICAS	45
3.5.1.2	TÉCNICAS DOCUMENTALES	45
3.5.1.3	TÉCNICAS VERBALES	45
3.5.1.4	TÉCNICA DE CUESTIONARIO O ENTREVISTA.....	45
3.5.2	FUENTES DE RECOPIACIÓN DE INFORMACIÓN	46
3.5.2.1	FUENTES PRIMARIAS	46
3.5.2.2	FUENTES SECUNDARIAS	46
3.6	POBLACIÓN Y MUESTRA.....	46
3.6.1	POBLACIÓN	46
3.6.2	MUESTRA	47
CAPITULO IV.....		48
MARCO PRÁCTICO Y PROPUESTA		48
INTRODUCCIÓN		48
4.1	PROPUESTA Y MODELADO: FASES DEL MODELO DE GESTIÓN Y CONTROL INTEGRAL DE RIESGOS DE SEGURIDAD DE LA INFORMACIÓN	48
4.1.1	FASE DE PLANIFICACIÓN Y PROGRAMACIÓN DE EVALUACIÓN.....	49
4.1.1.1	ESTABLECER EL ALCANCE Y LOS OBJETIVOS.....	50
4.1.1.2	DEFINICIÓN E IDENTIFICACIÓN DE LA ORGANIZACIÓN.....	50
4.1.1.3	PLANIFICACION PROGRAMA DE ACCIÓN.....	51
4.1.2	FASE DE DIAGNOSTICO DE LA SITUACIÓN ACTUAL Y EVALUACIÓN DE RIESGOS	52
4.1.2.1	DEFINICIÓN DE REQUERIMIENTOS ESPECIFICOS DE EVALUACIÓN .	53
4.1.2.1.1	TÉCNICAS E INSTRUMENTOS DE RECOLECCIÓN DE DATOS	53
4.1.2.1.2	IDENTIFICACIÓN DE PERFIL Y RESPONSABILIDADES.....	54
4.1.2.1.2.1	RESPONSABLE DE SEGURIDAD DE LA INFORMACIÓN	54
4.1.2.1.2.2	COMITÉ DE SEGURIDAD DE LA INFORMACIÓN.....	55
4.1.2.2	DEFINICIÓN DE DOMINIOS O CLAUSULAS PARA EVALUACIÓN	56
4.1.2.2.1	DECLARACIÓN DE APLICABILIDAD Y ARBOL GENERAL DE REQUERIMIENTO.....	56
4.1.2.2.2	CLAUSULAS, OBJETIVOS DE CONTROL Y CONTROLES PARA EVALUACIÓN	66
4.1.2.3	EVALUACIÓN DE RIESGOS DE SEGURIDAD DE LA INFORMACIÓN ...	67
4.1.2.3.1	CRITERIO DE RIESGO ELEMENTAL.....	67

4.1.2.3.2	REPRESENTACIÓN DE NOTACIÓN DE CRITERIOS.....	69
4.1.2.3.3	TIPOS DE CRITERIO DE RIESGO ELEMENTAL	70
4.1.2.3.3.1	CRITERIO ELEMENTAL CON VARIABLE DISCRETA.....	70
4.1.2.3.3.2	CRITERIO ELEMENTAL CON VARIABLE CONTINUA	72
4.1.2.3.4	ASIGNACIÓN DE PESOS.....	73
4.1.3	FASE DE ANÁLISIS INICIAL DE RESULTADOS DE EVALUACIÓN DE LA SITUACIÓN ACTUAL	73
4.1.3.1	RESULTADOS EVALUACIÓN DE RIESGOS ANTES DE IMPLEMENTACIÓN	74
4.1.3.2	ANÁLISIS INICIAL DE RESULTADOS	74
4.1.4	FASE DE IMPLEMENTACION	75
4.1.4.1	IMPLEMENTACION Y DESCRIPCIÓN DEL MODELO.....	75
4.1.4.2	ANÁLISIS DE RESULTADOS DE IMPLEMENTACIÓN.....	107
4.1.4.2.1	DETERMINACIÓN DEL NIVEL FINAL DE LA SEGURIDAD DE INFORMACIÓN	108
4.1.4.2.2	ANÁLISIS COMPARATIVO DE SEGURIDAD DE INFORMACIÓN ANTES Y DESPUÉS DE LA IMPLEMENTACION DEL MODELO	108
4.1.5	FASE DE AUDITORIA DE CUMPLIMIENTO.....	108
4.1.5.1	METODOLOGÍA DE AUDITORIA DE CUMPLIMIENTO	109
4.1.5.2	RESULTADOS DE AUDITORIA DE CUMPLIMIENTO POR DOMINIOS O CLÁUSULAS.....	112
4.1.5.3	RESULTADOS GLOBALES DE AUDITORIA	113
4.1.5.4	PRESENTACION DE INFORME DE AUDITORIA.....	113
4.2	PRÁCTICO Y APLICATIVO DE MODELO	114
4.2.1	DEFINICIÓN DE LA ORGANIZACIÓN E IDENTIFICACIÓN DEL DOMINIO	114
4.2.2	PLANIFICACION DE PROGRAMA DE ACCIÓN.....	116
4.2.3	DEFINICIÓN DE REQUERIMIENTOS ESPECIFICOS DE EVALUACIÓN...	116
4.2.3.1	MUESTRA Y PROCEDIMIENTO	116
4.2.3.1.1	DESCRIPCIÓN DE LA MUESTRA SELECCIONADA	117
4.2.3.2	RESPONSABLE DE SEGURIDAD DE LA INFORMACIÓN	119
4.2.4	REPRESENTACIÓN DE CLAUSULAS, OBJETIVOS Y CONTROLES PARA EVALUACIÓN.....	119
4.2.5	PROCESO DE EVALUACIÓN Y ANÁLISIS DE RIESGOS DE SEGURIDAD DE LA INFORMACIÓN	122
4.2.5.1	CRITERIOS DE EVALUACIÓN DE RIESGOS	123

4.2.5.2	EVALUACIÓN INICIAL DE RIESGOS DE LA SITUACIÓN ACTUAL	124
4.2.6	ANÁLISIS DE RESULTADOS DE EVALUACION DE RIESGOS DE LA SITUACIÓN ACTUAL	129
4.2.7	IMPLEMENTACIÓN Y EVALUACIÓN DE RIESGO DE SEGURIDAD DE LA INFORMACIÓN.....	136
4.2.8	ANÁLISIS DE RESULTADOS.....	142
4.2.8.1	ANÁLISIS COMPARATIVO DE EVALUACIÓN DE RIESGO DE SEGURIDAD DE INFORMACIÓN.....	148
4.2.8.2	INDICADOR DE MINIMIZACIÓN DE RIESGO	150
4.2.9	AUDITORIA DE CUMPLIMIENTO	151
4.2.9.1	METODOLOGÍA DE AUDITORIA	151
4.2.9.2	EVALUACIÓN Y ANÁLISIS DE RESULTADOS DE MADUREZ.....	152
4.2.9.3	RESULTADOS GLOBALES.....	159
4.2.9.4	PRESENTACIÓN DE RESULTADOS Y ENTREGA DE INFORME EJECUTIVO.....	159
CAPITULO V		163
CONCLUSIONES Y RECOMENDACIONES		163
5.1	CONCLUSIONES	163
5.2	RECOMENDACIONES.....	166
BIBLIOGRAFIA.....		168
ANEXOS:		
ANEXO A1: CUESTIONARIO DE CONTROLES DE SISTEMAS DE GESTIÓN DE SEGURIDAD DE LA INFORMACION APLICADOS EN EL SEGIP		
ANEXO A2: DOCUMENTACIÓN DE POLITICAS DE SEGURIDAD		
GLOSARIO		

INDICE DE FIGURAS

Figura 2.1.: Amenazas para la Seguridad	9
Figura 2.2.: Sistema de Gestión de Seguridad de la Información	10
Figura 2.3.: Sistema de Gestión de la Seguridad de la Información SGSI.....	12
Figura 2.4.: Componentes de un SGSI	16
Figura 2.5.: Ciclo PDCA Planificar, Hacer, Verificar y Actuar.....	18
Figura 2.6.: Ciclo de Riesgos.....	21
Figura 4.1.: Fases Principales del Modelo.....	49
Figura 4.2.: Fase de Planificación y Programación de Evaluación	49
Figura 4.3.: Identificación de Organización.....	51
Figura 4.4.: Planificación de Cronograma de Evaluación	52
Figura 4.5.: Diagnostico de la Situación Actual y Evaluación de Riesgos	42
Figura 4.6.: Equipo multidisciplinario – Responsable o Administrador Experto.....	55
Figura 4.7.: Escala de Riesgo Elemental	69
Figura 4.8.: Tipos de Criterio de Riesgo Elemental	70
Figura 4.9.: Fase de Análisis de Resultados de Evaluación de la situación Actual.....	73
Figura 4.10.: Implementación del Modelo en la Entidad Pública	75
Figura 4.11.: Auditoria de Cumplimiento	109
Figura 4.12.: Estructura de la DNTICs del SEGIP	115
Figura 4.13. Muestra de encuestados, según Genero	117
Figura 4.14. Muestra, Según nivel de formación	118
Figura 4.15. Muestra, según Unidad de Trabajo.	118
Figura 4.16.: Proceso de Evaluación y Análisis de Riesgo	123
Figura 4.17.: Evaluación de Riesgo de la Situación Actual	130
Figura 4.18.: Niveles de Riesgos Controlados y No Controlados	132
Figura 4.19.: Indicador del Nivel de Riesgo Controlado INRC	134
Figura 4.20.: Indicador Global del Nivel de Riesgo Controlado IGNRC e Indicador Global del Nivel de Riesgo No controlado GNRNC	135
Figura 4.21.: Resultado de Evaluación de Riesgo de la Seguridad en la Información.....	142
Figura 4.22.: Niveles de Riesgos Controlados y No Controlados	144
Figura 4.23.: Indicador del Nivel de Riesgo Controlado ITNRC.....	146
Figura 4.24: Indicador Global del Nivel de Riesgo Total Controlado IGNRTC e Indicador Global del Nivel de Riesgo Total No controlado IGNRTNC	147
Figura 4.25: Seguridad de la Información antes y después de la implementación del Modelo	150
Figura 4.26.: Madurez medida en la auditoria de cumplimiento.....	158
Figura 4.27.: Cumplimiento Global de Seguridad de la Información según CMM	159

INDICE DE TABLAS

Tabla 4.1: Declaración de Aplicabilidad	56
Tabla 4.2. Estructura de Asignación de Pesos a Clausulas o Dominios.....	73
Tabla 4.3.: Resultados de la Evaluación de Riesgos	74
Tabla 4.4.: Niveles de Evaluación de Seguridad de Información	75
Tabla 4.5.: Implementación y Descripción del Modelo	76
Tabla 4.6.: Resultados Finales de la Evaluación de Riesgos.....	107
Tabla 4.7.: Resultados de Seguridad de la Información antes y después	108
Tabla 4.8.: Modelo de Madurez de la Capacidad CMM - Cumplimiento.....	112
Tabla 4.9.: Programa o cronograma de Acción	116
Tabla 4.10.: Representación de cláusulas, objetivos y controles.....	119
Tabla 4.11.: Muestra por área para obtención de información.....	123
Tabla 4.12.: Evaluación Inicial de Riesgos de Seguridad de la Información	125
Tabla 4.13.: Niveles de Riesgos Controlados y No Controlados	131
Tabla 4.14.: Determinación de pesos para evaluación de riesgos	132
Tabla 4.15.: Determinación del Indicador del Nivel de Riesgo Controlado	133
Tabla 4.16.: Nivel de la Situación Inicial de Seguridad de la Información.....	135
Tabla 4.17.: Nivel de la Situación Inicial del Nivel de Riesgo de Seguridad de la Información	136
Tabla 4.18. Resultado de la Evaluación de Riesgos de Seguridad de la Información posterior a la implementación.....	137
Tabla 4.19.: Niveles de Riesgos Controlados y No Controlados	143
Tabla 4.20: Determinación del Indicador Total del Nivel de Riesgo Controlado.....	145
Tabla 4.21: Nivel de la Situación de Seguridad de la Información.....	147
Tabla 4.22: Nivel de la Situación del Riesgo de Seguridad de la Información.....	148
Tabla 4.23: cuadro comparativo final de seguridad de la Información antes y después de la Implementación del Modelo.....	149
Tabla 4.24.: Resultado de la Capacidad de Madurez - Cumplimiento	152

INTRODUCCIÓN

Los importantes cambios que se han generado en el mundo moderno, representados por su continuo desarrollo en diversas áreas; la precipitada globalización de la economía, la acentuada dependencia que concentra en alto volumen de información y los sistemas que la proveen; el aumento de la vulnerabilidad y el amplio espectro de amenazas cibernéticas; la escala así como los costos de las inversiones actuales y expectantes en información y en sistemas de información; y el potencial que tienen las tecnologías para cambiar drásticamente las organizaciones y el desarrollo de negocio, crear nuevas oportunidades y disminuir o reducir costos, han impuesto nuevos retos a la práctica de la profesión de auditoría, en particular a la auditoría de informática.

La automatización hoy está incorporada en la gestión integral de la organización y por eso las normas y estándares propiamente informáticos deben estar presentes. En consecuencia, las organizaciones informáticas constituyen parte de lo que se ha denominado el *management* o gestión de la empresa. Es importante aclarar que la Informática no gestiona propiamente la empresa, sino, ayuda a la toma de decisiones, pero no decide por sí misma. Por tanto, por su importancia en el funcionamiento de una empresa, existe la Auditoría de Sistemas o Informática.

Las particularidades que prevalecen en el ambiente de cualquier organización moderna en la actualidad, que concentre para su fin las tecnologías de información, mismas sostenidas sobre una base o infraestructura tecnológica con amplio grado de composición de redes de comunicaciones y sistemas de información de punta, para maximizar a través de su soporte logístico el control interno y consecuentemente sus resultados, demanda innovaciones o transformaciones en la práctica de la disciplina encaminada a desarrollar un control superior mediante la auditoría.

En el presente trabajo se plantea aplicar el método de análisis estadístico e identificar los indicadores importantes que lleven adelante en una auditoría, para obtener resultados esperados a través de la aplicación de encuestas y entrevistas a los servidores públicos del área identificada.

De acuerdo al problema, el presente trabajo se encuentra orientado a mostrar que la auditoría de cumplimiento de la gestión de seguridad de la información es el factor importante para la administración eficiente de la información en las Entidades Públicas.

CAPITULO I

DESARROLLO DEL PROBLEMA

1.1 IDENTIFICACIÓN Y PLANTEAMIENTO DEL PROBLEMA

Con el paso del tiempo, se puede evidenciar que la mayor parte de las organizaciones en especial en la Gestión Pública, sin importar el tamaño, ni en la que se desenvuelvan, logran acumular gran cantidad de datos de su personal, proveedores, clientes, productos o servicios, proyectos investigación, su situación financiera, entre otros. El volumen más grande de estos datos, es recolectado, procesado, almacenado y puesto a la disposición de sus usuarios, como información visible y disponible a través de redes de computadores.

En la actualidad, una de las preocupaciones de las organizaciones privadas y públicas es la necesidad de minimizar el nivel de riesgo de seguridad de la información debido a los impactos de fraude, la corrupción, las malas prácticas de control, los ataques de virus y otros, así mismo que las normas y procedimientos de seguridad de la información que son cada vez más complejos y difíciles de implementar en las organizaciones, cambios constantes de riesgos informáticos que exigen mayor control para la administración eficiente de la información, así como la creciente continua de evolución de tecnologías de la información.

Por tanto, las organizaciones o instituciones trabajan día tras día para tratar de excluir o mitigar las vulnerabilidades o ataques posibles que se revelan en las infraestructuras tecnológicas o en los procedimientos que apuntalan al negocio. Lo cual, se hace evidente entonces que la inseguridad informática es un componente propio de la dinámica de las organizaciones en cada uno de sus procesos. Mientras las organizaciones buscan conseguir un nivel superior de seguridad, cada vez más se encuentran con la problemática de la inseguridad, puesto que los procesos en sí mismos, al ser redes de comunicaciones y pactos entre personas, tecnologías y normas, establecen relaciones y distinciones que totalmente no son distinguibles, desempeñando de la labor de protección de la Información más que una función tecnológica, una función que corresponde a las acciones humanas y procesos administrativos y estratégicos.

¿Cuántos han visto al personal de la organización escribir las contraseñas en un papel? ¿Cuántas veces se ha solicitado a compañeros digitar su contraseña en un sistema y en lugar de ponerla nos ha respondido *Es mi nombre* y después de algunos días al volver a pedírsela nos ha respondido *Sigue siendo la misma*? ¿Cuántas veces ha pasado al lado de un computador libre, con la sesión iniciada o se fue ante una impresora a recoger un documento impreso y nos encontramos con otra documentación olvidada por alguna persona?, cuántas veces se ha escuchado ¿Para qué tantos controles, a quién le va interesar lo que estoy haciendo?

Por otra parte, las compañías, delegando esta responsabilidad al departamento de informática, suelen esforzarse en la adquisición de mecanismos y herramientas apropiadas para que un intruso no pueda dañar ningún equipo, colocando bloqueos a través de cortafuegos y herramientas de control de acceso, implementando los antivirus mejores, entre otros.

1.1.1 FORMULACIÓN DEL PROBLEMA

¿Cómo se podrá efectuar la gestión y control integral en seguridad de la información como herramienta para la valoración de riesgos en organismos de la Administración Pública?

1.2 OBJETIVOS

1.2.1 OBJETIVO GENERAL

Determinar el Modelo de Gestión y Control Integral en Seguridad de la Información como factor fundamental que minimiza el nivel de riesgo de Seguridad de Información en los organismos de la Administración Pública.

1.2.2 OBJETIVOS ESPECÍFICOS

- a) Identificar las directrices y el contexto de la seguridad de la información a través de un análisis de los tipos de amenazas y características de la información en los Organismos de la Administración Pública para la correcta análisis, valoración y evaluación de los riesgos de seguridad vinculados a la información.
- b) Analizar su aplicabilidad en el contexto de la Seguridad de la información a partir del

árbol general de requerimientos de dominios, objetivos de control y controles, que se tome en cuenta los estándares ISO 27001, referidos a la seguridad de la información en la Administración Pública.

- c) Diseñar las Políticas de Seguridad de la Información, definido por los riesgos globales y específicos en los Organismos de la Administración Pública para confirmar su permanencia y nivel de eficacia.
- d) Implementar en un caso de estudio real el Modelo de Gestión y Control Integral en Seguridad de la Información aplicando la metodología, controles, estándares, fases y otras descritas sobre seguridad de la información.

1.3 PLANTEAMIENTO DE HIPÓTESIS

El Modelo de Gestión y Control Integral en Seguridad de la Información se constituye en el factor fundamental que minimiza el nivel de riesgo de Seguridad de Información en los organismos de la Administración Pública.

VARIABLE INDEPENDIENTE:

Modelo de Gestión y Control Integral de Seguridad de la Información

VARIABLE INTERVINIENTE:

Organismos de la Administración Pública

VARIABLE DEPENDIENTE:

Riesgo en Seguridad de Información

1.4 ALCANCES Y LIMITACIONES

1.4.1 ALCANCES

La presente investigación examinará recursos e infraestructuras en los Organismos de la Administración Pública, unidades o áreas de Tecnologías de la Información y Comunicación TICs, para el estudio, análisis y su elaboración del Modelo de Gestión y Control Integral de Riesgos de Seguridad de la Información, que sirva el mismo como herramienta para minimizar el riesgo de Seguridad en la Información en los Organismos de la Administración Pública.

1.4.2 LIMITACIONES

La falta de información y profesionales que se apliquen o dediquen exclusivamente en la Gestión y Control de Seguridad de la Información en los Organismo de la Administración Pública, dificulta con la alimentación de información para diseñar un modelo de Gestión y Control de Seguridad de la Información.

Las respuestas que se obtendrán de una entrevista, cuestionario o a través de cualquier otra técnica descrita, dependerán del grado de conocimiento que tengan referente a la gestión y control de seguridad de la información en los organismos de la Administración Pública, por tratarse de tema técnico.

1.5 JUSTIFICACIÓN

1.5.1 JUSTIFICACIÓN METODOLÓGICA

Para lograr los objetivos del presente trabajo, es desarrollado a través del método de investigación científico como guía para diseñar el modelo, permitiendo la apropiada documentación y poder detectar problemas en transcurso del desarrollo, por la finalidad de impedir errores en el tiempo. La elaboración y aplicación del modelo de gestión y control integral de Riesgos de Seguridad de la Información en la gestión pública, se indaga mediante técnicas de investigación orientado a la recolección, análisis y síntesis, que sean demostrados su validez y confiabilidad para ser utilizados en los organismos de la administración pública y otros trabajos de investigación.

1.5.2 JUSTIFICACIÓN TEÓRICA

En el presente trabajo se opta desarrollar una metodología que pueda contener la norma ISO 27001 e interrelacionar con riesgos de Seguridad de la Información que se generan en las entidades públicas, mismo, con el propósito de nutrir con conocimiento existente sobre gestión de seguridad de la información, así mismo como herramientas para diseñar un modelo de gestión y control integral de seguridad de la información, cuyos resultados de dicho modelo se puedan sistematizarse para la administración de manera eficiente la información, así mismo para ser

incorporado como conocimiento en la seguridad de la información en los organismos de la administración pública, ya que se estaría demostrando que, a través de los dominios, objetivos de control y controles minimiza el nivel de riesgo de seguridad de la información.

1.5.3 JUSTIFICACIÓN PRÁCTICA

El presente trabajo se desarrolla por la existencia de necesidad de mejora, control y minimización del nivel de riesgo en la seguridad de la información en los Órganos de la Administración Pública, con la propuesta y diseño de un modelo adecuado y nutrido de cláusulas o características, objetivos de control y controles o atributos de seguridad de la información fundamentadas en base a la norma series ISO 27000, para la aplicación o implementación de dicho modelo.

CAPITULO II

FUNDAMENTACIÓN TEÓRICA

2.1 MARCO TEORICO

2.1.1 EVOLUCIÓN HISTORICO

La información es el pilar principal para que la seguridad se desenvuelva su dinámica y plantee las acciones de protección. En ese sentido, el desafío de consolidar el control y confiabilidad han venido evolucionado con el paso del tiempo.

En la década de los 70, con el surgimiento de la tecnología de sistema de computación, donde se desarrollaban actividades con máquinas de procesamiento de datos centralizados, donde las características de seguridad se agrupaban en controles propios y particulares al hardware y software del proveedor o fabricante de dichas tecnologías.

Posteriormente, en la década de los 80 con el avance de nuevas tecnología y surgimiento de las redes de computadores para flujo de información entre diferentes puntos de red, las incitaciones de seguridad de la información se desprenden de la máquina central, a un conjunto de máquinas, las cuales generan nuevos desafíos para los responsables de las tecnologías de información como buscar soluciones a los problemas que se presentaban en la suite de protocolos TCP/IP, los requerimiento de las aplicaciones en el entorno cliente/servidor, la administración remota de equipos, la administración de la infraestructura de seguridad de la información.

Ya para la década de los 90 con una alta inclinación del uso de Internet, con un sujeto exigente por innovación de nueva tecnología y productos informáticos en la red, con una fuerte demanda de servicios en el web y, los encargados de Tecnologías de Información proponen nuevas herramientas alrededor del tema de seguridad de la información.

En la actualidad, se proponen nuevas innovaciones de foco en la seguridad de la información. Las organizaciones y negocios desarrollan sus actividades en un contexto global, las reuniones se hacen de manera virtual, las operaciones se inician en un país y se terminan en otro y la educación busca desarrollar actividades fuera de las aulas. Por tanto, toda innovación implica

que acudamos a un cambio de las condiciones de la estructura de seguridad de la información.

En consecuencia, “la seguridad de la información pasa de ser un servicio en sí mismo del negocio, a ser parte integral del negocio, pues los riesgos derivados de esta nueva interacción abierta y global, hacen parte inherente de los objetivos corporativos y de las metas grandes y ambiciosas de las empresas en este entorno”. (LACEY, 2009, págs. 15-16)

2.1.2 CULTURA DE SEGURIDAD DE LA INFORMACIÓN

Siguiendo las consideraciones sobre cultura organizacional, una cultura está compuesta por tres componentes: los artefactos, lo que se observa (lo que se ve, lo que se siente y escucha), símbolos y comportamientos; los valores expuestos, es decir, lo que le dicen y finalmente, los supuestos básicos, aquello que los participantes dan por hecho. (Westney 2008)

Por tanto, la cultura de seguridad de la información debe ser para las organizaciones el custodio de variables tan importantes como: los ingresos, percepción del cliente, el cumplimiento a las normas, su reputación, y los flujos de información en los procesos.

2.1.3 SEGURIDAD DE LA INFORMACION

La seguridad de la información induce a una organización que la adopte como parte de su visión y misión, para proteger de un extenso rango de amenazas para asegurar la continuidad del negocio, minimizar los posibles daños y maximizar el retorno de las inversiones y sus las oportunidades. Se consideran como importantes activos de la organización, la información digital o en papel y los procesos que la apoyan, los sistemas y redes.

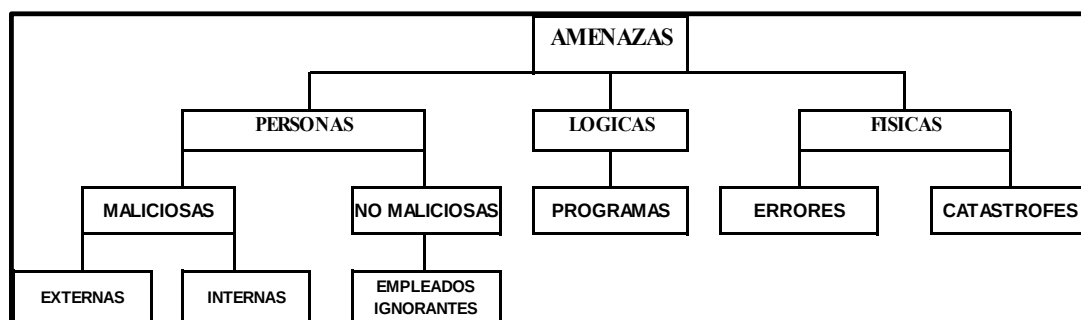
Los negocios y sus sistemas de información se enfrentan cada vez más, con inseguridades y riesgos originados de varios canales o fuentes de información, como: espionaje, sabotaje, vandalismo, fraudes basados en informática, incendios o inundaciones, entre otros. De los cuales las fuentes de perjuicio como ataques de intrusión o de negación de servicios y virus informáticos, se están volviendo cada vez más comunes, sofisticados y ambiciosos.

La seguridad de la información es fundamental en las organizaciones tanto del sector público como del privado para proteger las infraestructuras críticas de sistemas de información. En

ambos ámbitos, la seguridad de información permitirá lograr el gobierno electrónico, impidiendo y minimizando los riesgos relevantes. La interconexión de las redes públicas y privadas y el compartir los recursos de información incrementan la dificultad de lograr el control de los accesos.

Las amenazas para la vulneración de la seguridad de la información están latentes en cualquier tipo de organización, los mismos se muestran en la siguiente figura:

Figura N° 2.1: Amenazas para la Seguridad



Fuente: Villalón, 2002

2.1.4 EL SISTEMA DE GESTIÓN DE LA SEGURIDAD DE LA INFORMACIÓN (SGSI)

Se entiende por la administración de seguridad de la información, todo aquel conjunto de datos organizados en poder de una organización o persona que posean valor, independientemente de la forma o medio en que se guarde o almacene (escrita, oral, en imágenes, impresa en papel, almacenada electrónicamente, proyectada y enviada por e-mail), de su origen (de la propia organización o de fuentes externas) o de la fecha o momento de elaboración. Para este fin se consideran los siguientes aspectos:

- Estándares de seguridad de la información por medio de familia de Normas ISO 27000
- Establecimiento de los requisitos de la seguridad
- Evaluación de requisitos de seguridad
- Selección de Controles
- Factores críticos
- Beneficios.

La seguridad de la información, según Normas ISO 27001, consiste en la preservación de su confidencialidad, integridad y disponibilidad, así como de los sistemas implicados en su tratamiento, dentro de una organización. De esta manera, estos tres términos como principios constituyen la base sobre la que se cimienta toda la estructura de la seguridad de la información:

- Confidencialidad: la información no se pone a disposición ni se revela a personas, organizaciones o procesos no autorizados.
- Integridad: mantenimiento de la exactitud y completitud de la información y sus métodos de proceso.
- Disponibilidad: Es el acceso y utilización de la información y los sistemas de tratamiento de la misma por parte de las personas, entidades o procesos autorizados en el momento cuando lo requieran.

Para garantizar o avalar que la seguridad de la información es tratada o gestionada correctamente, se debe hacer uso de un proceso sistemático, documentado y conocido por toda la organización, desde un enfoque de riesgo empresarial. Por tanto, este proceso es el que constituye un Sistema de Gestión de Seguridad de la Información (SGSI).

Figura N° 2.2.: Sistema de Gestión de Seguridad de la Información



Fuente: ISO 27001

2.1.5 IMPORTANCIA DE UN SISTEMA DE GESTIÓN DE LA SEGURIDAD DE INFORMACIÓN

La información conjuntamente a los procesos y sistemas que hacen uso de ella, son considerados activos muy importantes de una organización. La confidencialidad, integridad y disponibilidad de información sensible pueden llegar a ser esenciales para mantener los niveles de competitividad, conformidad legal, rentabilidad, e imagen corporativo necesarios para lograr los objetivos propuestos de la organización y certificar beneficios económicos.

De manera general, las organizaciones y sus sistemas de información están expuestos cada vez más a un número elevado de amenazas, aprovechando cualquiera de las debilidades existentes en los mismos, pueden someter a activos críticos de información a varias formas de espionaje, fraude, vandalismo o sabotaje.

Los virus informáticos, los ataques de prohibición de servicio son algunos ejemplos frecuentes y conocidos, pero también se deben tomar en cuenta los riesgos de sufrir incidentes de seguridad provocados liberadamente o no desde dentro de la propia organización o aquellos provocados accidentalmente por fallos técnicos o naturales.

Algunos aspectos fundamentales en los que un Sistema de Gestión de Sistemas de Información SGSI es una herramienta de gran utilidad y de importante ayuda para la gestión de las organizaciones son: la obediencia de la legalidad, la adaptación dinámica y puntual a las condiciones variables del entorno, la protección apropiada de los objetivos de negocio para asegurar el máximo beneficio o la apropiación de nuevas oportunidades de negocio, entre otros.

Para una gestión efectiva de la seguridad de información, debe tomar parte activa toda la organización, con la máxima autoridad al frente, tomando en consideración también a los usuarios, clientes y proveedores de bienes y/o servicios. El modelo de gestión de la seguridad de la información debe conformar procedimientos adecuados y la planificación y establecimiento de controles de seguridad fundados en una evaluación de riesgos y una medición de la eficacia de los mismos.

Figura 2.3.: Sistema de Gestión de la Seguridad de la Información SGSI



Fuente: ISO 27001

El Sistema de Gestión de la Seguridad de la Información SGSI llega a determinar estas políticas y procedimientos en relación a los objetivos de la organización, con objeto de mantener un nivel mínimo de riesgo que la propia organización ha decidido asumir.

La organización con un SGSI, conoce los riesgos a los que se encuentra sometida su información y los asume, minimiza, transfiere o controla mediante un procedimiento definido, documentada y conocida por toda la organización, que se revisa, actualiza y mejora constantemente.

2.1.6 ENCARGADO DE SEGURIDAD DE LA INFORMACION

La seguridad de la información ha sido tradicionalmente parte del trabajo del individuo de las tecnologías de la información, o en ocasiones por parte del departamento de auditoría o finanzas. Donde debiera estar, y quién debiera administrarla son fuente de muchas discusiones. Algunas personas creen que la seguridad necesita un perfil más alto del que puede tener como parte del equipo de tecnologías de la información TI. Otros se refieren a que es un conjunto de intereses por parte del oficial en jefe de la información CIO, Chief Information Officer, que a menudo

obstaculiza la velocidad o facilidad de su uso. Pero todos están de acuerdo en que el CIO tiene un papel crucial en esto. Esto porque el CIO efectivamente entiende como las computadoras de la organización deben ser instaladas y operadas, y también ellos saben el papel y las limitaciones de la tecnología en la solución de cualquier problema incluyendo la seguridad.

Pero la seguridad es un trabajo grande, así que un número importante de organizaciones están entregando esta responsabilidad primaria al Oficial Principal de Seguridad OPS con un alto perfil, o al oficial de seguridad en la información OSI. Muchos expertos abogan por que los OPS, deben ser los responsables tanto de la seguridad física como de la información y debe reportar directamente al oficial en jefe ejecutivo CEO, Chief Executive Officer. Otros recomiendan que los OSI pueden o no informar al CIO y deben trabajar de cerca con quien quiera que esté a cargo de la seguridad física.

Al final esto es lo menos importante, los informes del oficial de seguridad, y es más importante que exista alguien encargado de la seguridad que tenga la visión del CEO. El oficial de seguridad necesita tener un contacto directo con el equipo de TI, de seguridad física, auditores, recursos humanos, y del consejero legal. Y aquí existe algo interesante, parte del trabajo del oficial de seguridad es convencer a los empleados de que la seguridad es un trabajo de todos. Hay un viejo refrán que dice que la seguridad es tan fuerte como su eslabón más débil, y este eslabón más débil es aquel empleado que escribe su contraseña en un post-it y lo pega en su monitor.

2.1.7 TECNOLOGIAS INVOLUCRADAS EN SEGURIDAD DE INFORMACION

Cuando se inicia la protección de la organización contra tiempos muertos, o vulnerabilidades de seguridad, el software antivirus, es usualmente usado como primer paso. Este tipo de software busca virus, gusanos, troyanos y otro código malicioso que pueda destruir información y aplicaciones y expenderse, rápidamente de computadora a computadora. El software trabaja buscando comportamiento sospechoso y códigos maliciosos conocidos. Dado que nuevos virus son descubiertos todos los días, el personal de TI necesita estar vigilando permanentemente el que sus usuarios tengan instalados las últimas actualizaciones del software.

Aunque los firewalls son sobrevalorados, ellos siguen siendo cruciales cuando se trata de prevenir problemas de seguridad. Un firewall es un método para proteger la privacidad de la red analizando los datos de entrada como de salida. Los firewalls pueden también proveer de la conversión de direcciones IP NAT, de forma tal, que una dirección IP de una computadora dentro del firewall permanezca oculta a la vista. Firewalls de filtrado de paquetes, usan reglas en los paquetes de origen, de destino, puerto u otra información básica para determinar si debiera permitirse la entrada o no a la red. Algunos más avanzados, como los firewalls que filtran el estado del paquete, tienen acceso a más información, con lo cual toman sus decisiones. Firewalls tipo Proxy, los cuales buscan el contenido y pueden involucrar autenticación y cifrado, pueden ser más flexibles y seguros, pero son más lentos, lo cual debe ser analizados antes de su aplicación entera.

El reconocimiento de que los firewalls son imperfectos, es aprovechado por algunas organizaciones para invertir en sistemas detectores de intrusos IDS. Los IDS es software que busca actividad no autorizada en un sistema de cómputo, para identificar, reportar y tal vez responder a la actividad sospechosa, así como lo haría una alarma contra ladrones casera una vez que ha sido rota una ventana. Los IDS están por lo regular en dos categorías: los basados en red, los cuales analizan el tráfico de paquetes a través de la red; y los basados en host, que monitorean los archivos de bitácora e información en las computadoras individuales.

En la actualidad, la mayoría de los administradores se enfocan al software y hardware de la organización, en busca de malas configuraciones, y huecos que puedan ser explotados por los crackers. Esto implica el no perder de vista las últimas vulnerabilidades, instalando actualizaciones para eliminar estos problemas y asegurarse de que estas actualizaciones no causen problemas. Esto es un proceso crucial, en ocasiones llamado administración de actualizaciones, y es un dolor de cabeza. Existen servicios que envían un increíble y aparente sin fin de advertencias sobre las nuevas vulnerabilidades que afectan a cierta clase de hardware y de software.

2.1.8 ATAQUES A LA SEGURIDAD

a) Ataques Activos

Estos ataques involucran la modificación o cambio del flujo de datos transmitidos o en su caso un diseño de un flujo de información falso.

Las personas que operan los ataques activos son los hackers, piratas informáticos o intrusos remunerados:

- 1) **Intercepción:** Estos ataques propician que una entidad no autorizada gane acceso a un elemento del sistema.
- 2) **Interrupción:** Se dice que un ataque es una interrupción si se logra que un elemento se pierda, quede inutilizable o no disponible.
- 3) **Modificación:** Este ataque se da después de una intercepción, cuando el oponente logra modificar el elemento
- 4) **Fabricación:** Se habla de una fabricación cuando el atacante logra crear un objeto el cual es difícil de distinguir si es un elemento genuino.
- 5) **Destrucción:** Borra la información de la organización

b) Ataques Pasivos

El sujeto atacante no descompone la información, sino que únicamente la almacena o guarda, para utilizar la información que está siendo transmitida con fines personales o delictivos.

Los objetivos que tiene este tipo de ataque son la intercepción de datos y el análisis de tráfico.

Generalmente se recurren para:

- ✓ Obtención del origen y destinatario de la información a través de la lectura de las cabeceras de los paquetes monitorizados.
- ✓ Control del volumen de tráfico intercambiando entre las organizaciones, obteniendo parámetros de actividad o inactividad de información.
- ✓ Control de horas o momentos habituales de intercambio de información entre las organizaciones, para contar con información de periodos de actividad.

2.1.9 COMPONENTES DE UN SGSI

En el marco de la gestión de la calidad según ISO 9001, siempre se ha expuesto gráficamente la documentación del sistema como una pirámide de cuatro niveles. Por tanto, se puede traspasar ese modelo a un Sistema de Gestión de la Seguridad de la Información (SGSI) basado en ISO 27001, tal como se muestra en la siguiente figura:

Figura 2.4.: Componentes de un SGSI



Fuente: ISO 27001

1) Documentos del Nivel 1

Manual de seguridad: Este documento por analogía con el manual de calidad, del SGSI sería el documento que inspira y guía o administra todo el sistema, el que determina y expone el alcance, objetivos, propósitos, responsabilidades, políticas y directrices principales.

2) Documentos del Nivel 2

Procedimientos: Son documentos en el nivel operativo, que aseguran que se realicen de forma eficaz y eficiente la planeación, operación y control de los procesos de seguridad de la información.

3) Documentos del Nivel 3

Instrucciones, checklists y formularios: Son documentos que relatan cómo se realizan las actividades y las tareas específicas relacionadas con la seguridad de la información.

4) Documentos del Nivel 4

Registros: Son documentos que suministran una evidencia objetiva del cumplimiento de los requisitos del SGSI, están asociados a documentos de los otros tres niveles como salida que demuestra que se ha dado cumplimiento a lo indicado en los mismos.

De manera concreta el ISO 27001 describe que un Sistema de Gestión de Seguridad de Información (SGSI) debe estar conformado por los siguientes documentos:

- Alcance del SGSI: Corresponde al ámbito de la organización que queda sometido al SGSI, conteniendo una tipificación clara de las dependencias, límites y relaciones que existen entre el alcance y aquellas partes que no hayan sido consideradas (subconjunto de la organización como procesos, áreas, sistemas o tareas concretas, entre otros).
- Política y objetivos de seguridad: Es el documento de contenido general que establece el compromiso de la alta dirección y el enfoque de la organización referente a la gestión de la seguridad de la información.
- Procedimientos y mecanismos de control que soportan al SGSI: Son aquellos procedimientos que controlan el propio funcionamiento del SGSI.
- Enfoque de evaluación de riesgos: Incluye la descripción de la metodología a emplear, desarrollo de los criterios de aceptación de riesgo y determinación de niveles de riesgo aceptables.
- Informe de evaluación de riesgos: Es el estudio de los resultados aplicados de la metodología de evaluación mencionada sobre los activos de información de la organización.
- Plan de tratamiento de riesgos: Es el documento que describe las acciones de la alta dirección, responsabilidades, recursos, y los aspectos más importantes para gestionar los riesgos de seguridad de la información, de acuerdo a las conclusiones obtenidas de la evaluación de riesgos, de los objetivos de control seleccionados, de los recursos disponibles, entre otros.
- Procedimientos documentados: Son todas las actividades necesarias para cumplir la planificación, operación y control de los procesos de seguridad de la información, así como para la medida de la eficacia de los controles implantados.

- Registros: Son documentos que suministran evidencias de la conformidad con los requisitos y del funcionamiento eficaz del SGSI.
- Declaración de aplicabilidad: Es el documento que contiene los objetivos de control y los controles considerados por el SGSI, apoyados en los resultados de los procesos de evaluación y tratamiento de riesgos, explicando con justificación las inclusiones y exclusiones.

2.1.10 IMPLEMENTACION DE UN SGSI

Para establecer y llevar a cabo un Sistema de Gestión de la Seguridad de la Información SGSI sobre la base de las Normas ISO 27001 y 27002, se toma en cuenta el ciclo continuo PDCA, usual en los sistemas de gestión de la calidad.

Figura 2.5.: Ciclo PDCA (Planificar, Hacer, Verificar y Actuar)



Fuente: ISO 27001

A) Plan: Establecer el SGSI

- Establecer el alcance del SGSI en términos del negocio, la organización, su ubicación, activos y tecnologías, considerando detalles y justificación de cualquier inclusión y exclusión.
- Definir o establecer una política de seguridad que:

- contenga el marco general y los objetivos de seguridad de la información de la organización;
 - tome en cuenta los requerimientos legales o contractuales referidos a la seguridad de la información;
 - sea alineada con el medio estratégico de gestión de riesgos de la organización en el que se mantendrá y establecerá el SGSI;
 - defina los criterios con los que se va a evaluar el riesgo;
 - esté aprobada por la dirección.
- Definir un lineamiento o metodología de evaluación del riesgo adecuada para el SGSI y los requerimientos del negocio, al mismo tiempo de establecer los criterios de aceptación del riesgo y especificar los niveles o parámetros de riesgo aceptable. Lo importante de esta metodología es que los resultados obtenidos sean repetibles y comparables.
 - Identificar los riesgos:
 - identificar los activos que están al alcance del SGSI y a sus responsables directos o propietarios;
 - identificar las debilidades que puedan ser aprovechadas o vulneradas por dichas amenazas;
 - identificar todas las amenazas en relación a los activos identificados;
 - identificar los impactos en los tres elementos: confidencialidad, integridad y disponibilidad de los activos.
 - Analizar y evaluar los riesgos:
 - valorar el impacto en el negocio de un fallo de seguridad que resulte la pérdida de confidencialidad, integridad o disponibilidad de un activo de información;
 - evaluar la probabilidad de ocurrencia de un fallo de seguridad de forma real en relación a las amenazas, vulnerabilidades, impactos en los activos y los controles que ya fueron implementados;
 - valorar los niveles de riesgo;
 - establecer si el riesgo es aceptable o necesita ser tratado. según los criterios de aceptación de riesgo previamente señalados.

- Identificar y evaluar las distintas alternativas u opciones de tratamiento de los riesgos para:
 - aplicar controles adecuados para tratamiento de riesgos;
 - aceptar el riesgo, en caso de que se siga cumpliendo con las políticas y criterios establecidos para la aceptación de los riesgos;
 - evitar el riesgo, por ejemplo, mediante la detención de las actividades que lo originan;
 - transferir el riesgo a terceros, por ejemplo, proveedores de outsourcing o compañías aseguradoras.
- Seleccionar o elegir los objetivos de control y los controles adecuados del Anexo A de la norma ISO 27001 para el tratamiento del riesgo que cumplan con los requerimientos o especificaciones descritos en el proceso de evaluación y valoración del riesgo.
- Aprobar por parte de la gerencia o dirección del área involucrada, tanto los riesgos residuales, así como la implantación y uso del Sistema de Gestión de Seguridad de la Información (SGSI).
- Definir una declaración de aplicabilidad que incluya:
 - los objetivos de control y controles o atributos seleccionados y las justificaciones para su elección;
 - los objetivos de control y controles o atributos que en la actualidad ya se encuentran implantados;
 - los objetivos de control y controles o atributos del Anexo A de la norma ISO 27001 excluidos y los motivos o razones para su exclusión; este es un mecanismo o componente que permite además detectar posibles descuidos involuntarios.

Figura 2.6.: Ciclo de Riesgos



Fuente: ISO 27001

Con relación a los dominios, objetivos de control y controles o atributos de seguridad, el estándar ISO 27002, detalla y proporciona una completa guía de controles de implantación que contiene 133 controles, según 39 objetivos de control agrupados en 11 dominios. Esta norma es marcada en ISO 27001, en su segunda cláusula, en términos de documento indispensable para la aplicación de este documento y deja abierta la posibilidad de agregar controles adicionales en caso de que la guía no conténgase todas las necesidades específicas.

B) Do: Implementar y utilizar el SGSI

- Concretar o establecer un plan de tratamiento de riesgos que describa los recursos, acciones, responsabilidades y prioridades en la gestión de los riesgos de seguridad de la información.
- Implantar el plan de tratamiento de riesgos, con la finalidad de alcanzar los objetivos de control seleccionado, incluyendo la asignación de recursos, responsabilidades y prioridades.
- Implementar los controles seleccionados que guíen a los objetivos de control.
- Elaborar un sistema de métricas que posibilite obtener resultados reproducibles y confrontables para medir la eficacia de los controles.

- Gestionar programas de concienciación y formación en relación a la seguridad de la información a todo el personal de la organización.
- Gestionar las operaciones o actividades del SGSI.
- Encargarse de los recursos necesarios asignados al SGSI para el mantenimiento de la seguridad de la información.
- Implantar procedimientos y controles que permitan de manera rápida la detección y respuesta a los sucesos de seguridad.

C) Check: Monitorizar y revisar el SGSI

La organización para monitorear y revisar el SGSI deberá:

- Ejecutar procedimientos de monitorización y revisión para:
 - identificar brechas y sucesos o incidentes de seguridad de la información;
 - descubrir en el momento o a tiempo los errores en los resultados generados por el procesamiento de la información;
 - apoyar a la dirección a establecer si las acciones desarrolladas por las personas y dispositivos tecnológicos para garantizar la seguridad de la información se desarrollan como lo previsto;
 - prevenir y detectar sucesos e incidentes de seguridad mediante el uso de indicadores;
 - determinar si las acciones o trabajos realizadas para solucionar brechas de seguridad fueron efectivas.
- Examinar regularmente la certeza del SGSI, atendiendo al cumplimiento de la política y objetivos del SGSI, incidentes, resultados de las mediciones de eficacia, los resultados de auditorías de seguridad, sugerencias y observaciones de todas las partes implicadas.
- Computar la efectividad de los controles para verificar el cumplimiento con los requisitos de seguridad.
- Revisar normalmente en intervalos planificados las evaluaciones de riesgo, los riesgos residuales y sus niveles aceptables, tomando en cuenta los posibles cambios que hayan podido suscitarse en la organización, los objetivos, la tecnología y procesos de negocio, las amenazas identificadas, la efectividad de los controles implementados y el entorno exterior, obligaciones contractuales, requerimientos legales, entre otros.

- Efectuar periódicamente auditorías internas del SGSI en periodos planificados.
- Ajustar los planes de seguridad de acuerdo a las conclusiones y nuevos hallazgos encontrados durante las actividades de monitorización y revisión.
- Revisar el sistema de Gestión y Seguridad de la Información por parte de la gerencia periódicamente para garantizar que el alcance definido sigue siendo el adecuado y que las mejoras en el proceso son evidentes.
- Registrar eventos y acciones que puedan haber impactado sobre el rendimiento o efectividad del SGSI.

D) Act: Mantener y mejorar el SGSI

La organización para mantener y mejorar deberá normalmente:

- Implantar en el Sistema de Gestión de Seguridad de la Información, las mejoras identificadas.
- Ejecutar las acciones preventivas y correctivas apropiadas en relación al ISO 27001 y a los saberes aprendidas de las experiencias propias y de otras organizaciones.
- Confirmar que las mejoras incorporadas alcanzan los objetivos previstos.
- Notificar las acciones y mejoras a todas las partes involucradas con el nivel de detalle adecuado y concertar si es posible, la forma de proceder.

2.1.11 TAREAS DE LA GERENCIA EN UN SGSI

Uno de los mecanismos fundamentales en la implantación exitosa de un Sistema de Gestión de Seguridad de la Información es la incorporación de la gerencia. Debe asumirse desde un principio que un SGSI afecta fundamentalmente a la gestión del negocio y requiere, por tanto, de acciones y decisiones que sólo puede tomar la gerencia de la organización. No se debe caer en el error de considerar a un SGSI como una simple cuestión tecnológica o técnica relegada a niveles menores del organigrama; se están gestionando impactos y riesgos de negocio que son responsabilidad y decisión netamente de alta dirección.

La dirección debe observarse siempre desde el punto de vista del alcance del Seguridad de Gestión de Seguridad de la Información (SGSI). Vale decir, se refiere al nivel más alto de gerencia de la organización afectada por el SGSI.

A continuación, se detallan algunas de las actividades esenciales del SGSI que ISO 27001 asigna a la alta dirección:

a) Asignación de recursos

Para el desarrollo correcto de todas las actividades relacionadas con el SGSI, es necesario la asignación de recursos y es responsabilidad de la dirección garantizar que se presupuesten recursos suficientes para:

- Diseñar, implementar, operar, monitorizar, revisar, mantener y mejorar el SGSI.
- Identificar y establecer las obligaciones contractuales de seguridad, así como todos los requerimientos legales y normativos de seguridad.
- Garantizar en materia de seguridad de la información que los procedimientos apoyan los requerimientos de negocio.
- Emplear correctamente todos los controles implementados, de esa manera manteniendo la seguridad adecuada.
- Efectivizar revisiones cada vez que sea necesario y proceder adecuadamente según los resultados de las mismas.
- Optimizar la eficacia del SGSI donde sea preciso.

b) Compromiso de la Dirección

El compromiso de la dirección de la organización es importante para el establecimiento, implementación, operación, monitorización, revisión, mantenimiento y mejora del SGSI. Para lo cual, debe puntualizar las siguientes iniciativas:

- Plantearse una política de seguridad de la información.
- Instituir roles y responsabilidades de seguridad de la información.
- Asegurarse de que se establezcan objetivos y planes del SGSI.
- Informar a la organización la importancia de alcanzar los objetivos y de cumplir con la política de seguridad de la información, como sus responsabilidades legales y la prioridad de mejora continua.
- Fijar suficientes recursos al SGSI en todas sus fases o etapas.
- Seleccionar los criterios de aceptación de riesgos y sus correspondientes niveles.
- Asegurar que se realicen auditorías internas.
- Realizar revisiones del Sistema de Gestión de Seguridad de la Información (SGSI).

c) Formación y concienciación

Por consiguiente, la formación y la concienciación en seguridad de la información son elementos primordiales para el éxito de un SGSI. Para lo cual, la dirección debe establecer que todo el personal de la organización asignados responsabilidades definidas en el SGSI esté adecuadamente capacitado. Por tanto, se deberá:

- Establecer las competencias necesarias para el personal que realiza tareas en aplicación del Sistema de Gestión de Seguridad de la Información (SGSI).
- Satisfacer dichas necesidades por medio de capacitación o de otras acciones como el reclutamiento de personas ya formados.
- Evaluar la eficacia de las operaciones realizadas.
- Tener registros de estudios, formación, experiencia, habilidades y cualificación.

En ese sentido, adicionalmente la dirección debe asegurar que todo el personal relevante esté concientizado sobre la importancia de sus actividades de seguridad de la información y la contribución para consecución de los objetivos del SGSI.

d) Revisión del SGSI

La tarea de revisión de al menos una vez al año del SGSI, es asignado a la dirección de la organización, para asegurar que continúe siendo apropiado y eficaz. Para lo cual, la dirección debe recibir una serie de informaciones, mismo para que le ayuden a tomar decisiones, tales como:

- Resultados de auditorías internas y revisiones del SGSI.
- Observaciones identificadas de todas las partes interesadas.
- Herramientas, técnicas, productos o procedimientos que sean útiles para mejorar el rendimiento y eficacia del SGSI.
- Información de resultados sobre el estado de acciones preventivas y correctivas.
- Debilidades o amenazas que no fueran tratadas de manera adecuada en evaluaciones de riesgos anteriores.
- Resultados de las mediciones de eficacia.
- Estado de los trabajos iniciadas a raíz de revisiones realizadas de la dirección.

- Cualquier otro cambio que pueda perturbar al Sistema de Gestión de la Seguridad de la Información.
- Recomendaciones de la mejora.

En base de todas estas informaciones, la dirección debe examinar el Sistema de Gestión de Seguridad de la Información SGSI y tomar acciones y decisiones relativas a:

- Ajustes de la evaluación de riesgos y del plan de tratamiento de riesgos.
- Mejorar y modificación de los procedimientos y controles que afectan a la seguridad de la información, dando respuesta a cambios internos o externos en los requisitos de negocio, procesos de negocio, requerimientos de seguridad, marco legal, obligaciones contractuales, niveles y criterios de aceptación de riesgos.
- Requerimientos de recursos.
- Mejora y optimización, la forma de medir la efectividad de los controles.

2.1.12 NORMAS ISO 27000 SERIE

La familia de las normas ISO 27000, es un conjunto de estándares internacionales sobre la Seguridad de la Información, que engloba un conjunto de buenas prácticas para el establecimiento, implementación, mantenimiento y mejora de Sistemas de Gestión de la Seguridad de la Información SGSI.

Un SGSI es un conjunto de políticas y procedimientos que es apta para estandarizar la gestión de la Seguridad de la Información.

En ese sentido, a continuación, se describen algunos detalles de cada uno de los estándares que están contenidos en la familia de normas ISO 27000:

- **ISO 27000:** reúne el conjunto de vocabulario en el que se basan el resto de normas. Es equivalente a una guía que narra los términos de todas las normas de la familia.
- **ISO 27001:** es el conjunto de requisitos o exigencias para implementar un SGSI. Es decir, es la única norma certificable basada en el ciclo de mejora continua y un Anexo A de la norma, en el cual se detallan las especificaciones generales de los controles propuestos por el estándar.

- **ISO 27002:** corresponde a una recopilación de buenas prácticas para la Seguridad de la Información, mismo describe los controles y objetivos de control. En la actualidad contempla de 14 dominios, 35 objetivos de control y 114 controles.
- **ISO 27003:** sirve como ayuda a la norma 27001, indicando las directivas generales necesarias para la correcta implementación de un SGSI. Es una guía de apoyo en la implementación de un SGSI.
- **ISO 27004:** narra una serie de recomendaciones sobre la forma de realizar mediciones para la gestión de la Seguridad de la Información, específicamente cómo establecer métricas, qué medir, cómo medirlo, con qué frecuencia y la forma de obtener objetivos.
- **ISO 27005:** es una guía de recomendaciones sobre la forma de abordar la gestión de riesgos de seguridad de la información que puedan comprometer a las organizaciones. En esta norma, no especifica ninguna técnica de análisis y gestión de riesgos concreta, pero contiene ejemplos de posibles amenazas, vulnerabilidades e impactos.
- **ISO 27007:** guía para auditar, establece qué auditar y cuándo, cómo asignar los auditores apropiados, la planificación y ejecución de la auditoría, las actividades claves entre otros.

2.1.13 COBIT, ESTÁNDAR PARA EL BUEN GOBIERNO DE LOS SISTEMAS DE INFORMACIÓN

El Cobit (Control Objectives for Information and related Technology) estándar, brinda un conjunto de mejores prácticas para la gestión de los Sistemas de Información de las organizaciones.

El Cobit está basado en la ideología de que los recursos Tecnologías de la Información TI requieren ser administrados por un conjunto de procesos consecuentemente agrupados para suministrar la información pertinente y confiable que requiere una organización para lograr sus objetivos. Por tanto, se aplica a los sistemas de información de toda la empresa, así como los computadores personales y las redes.

Por consecuente, el objetivo fundamental de Cobit radica en proporcionar una guía a alto nivel sobre puntos en los que instaurar controles internos con tal de:

- Avalar el cumplimiento normativo de la organización, sea esta sector público o privada.

- Asegurar el buen gobierno, protegiendo los intereses de los clientes, accionistas, empleados y todo lo concerniente al buen gobierno.
- Optimizar la eficacia y eficiencia de los procesos y actividades de la organización.
- Garantizar o certificar la confidencialidad, integridad y disponibilidad de la información.

El estándar define el vocablo control como: *Políticas, procedimientos, prácticas y estructuras organizacionales diseñadas para proveer aseguramiento razonable de que se lograrán los objetivos del negocio y se prevendrán, detectarán y corregirán los eventos no deseables.*

Por lo tanto, la definición abarca desde aspectos organizativos (pedir autorización a determinada información, selección de proveedores y procedimiento para reportar sucesos) hasta aspectos más tecnológicos y automatizados (control de acceso a los sistemas de información, monitorización de los sistemas a través de herramientas automatizadas, entre otros).

Por otro lado, todo control tiene por naturaleza un objetivo o resultado. Vale decir, un objetivo de control es un resultado deseable o ansiada como, así, por ejemplo: garantizar la continuidad de las operaciones cuando se presentan situaciones de contingencias.

En consecuencia, para cada objetivo de control de una organización se pueden implementar uno o varios controles (por ejemplo, ejecución de copias de seguridad periódicas, traslado de copias de seguridad a otras instalaciones) que garanticen la obtención del resultado esperado (por ejemplo, continuidad de las operaciones en caso de presentarse situaciones de contingencias).

Indubitablemente, los ejemplos expuestos son de características generales y poco detallados, pero se muestran de forma más práctica las diferentes definiciones.

El Cobit cataloga los procesos de negocio concernientes con las Tecnologías de Información TI en 4 dominios:

- Planificación y Organización
- Adquisición e Implementación
- Entrega y Soporte

- Supervisión y Evaluación

Cada dominio contiene procesos de negocio desglosables en actividades para estos se pueden establecer objetivos de control e implementar controles organizativos o automatizados. (Blanco, 2015)

Además, especificar que la organización dispone de distintos recursos (información, aplicaciones, personas, infraestructura) que son dispuestos por los procesos para cubrir las exigencias del negocio:

- Efectividad
- Eficiencia
- Integridad
- Confidencialidad
- Disponibilidad
- Cumplimiento regulatorio
- Fiabilidad

Es importante subrayar que, el Cobit también brinda componentes para determinación de la medida de las capacidades de los procesos con propósito de conseguir una mejora continua. Para lo cual, a continuación se detallan indicaciones para valorar la madurez en base de la misma clasificación utilizada por estándares:

- Nivel 0 – Proceso incompleto: significa que no existe o no cumple con los objetivos
- Nivel 1 – Proceso ejecutado
- Nivel 2 – Proceso gestionado: el proceso se encuentra en funcionamiento, además es planificado, monitorizado y actualizado o ajustado.
- Nivel 3 – Proceso definido: se define que el proceso, los recursos, los roles y responsabilidades se hallan documentados y formalizados.
- Nivel 4 – Proceso predecible: significa que se han definido técnicas de medición de resultados y controles.
- Nivel 5 – Proceso optimizado: se clasifica cuando todos los cambios son verificados para establecer el impacto y se han definido mecanismos para la mejora continua.

2.2 MARCO CONCEPTUAL

2.2.1 INFORMACIÓN

Información se denomina al conjunto de datos ya procesados y ordenados para su comprensión, que aportan nuevos conocimientos a un sujeto o sistema sobre una cuestión, materia, fenómeno o ente determinado. Este vocablo, como tal, proviene del latín *informatio*, *informatiōnis*, que significa acción y efecto de informar. (7Gaus, 2017)

La importancia de la información radica en que, con base en esta, podemos solucionar problemas, tomar decisiones o determinar cuál alternativa, de un conjunto de ellas, es la que mejor se adapta a nuestras necesidades. El aprovechamiento que hagamos de la información, en este sentido, es la base racional del conocimiento. (7Gaus, 2017)

El efecto más importante de la información es cambiar el estado de conocimiento que un sujeto o sistema maneja con relación a determinado fenómeno o tema, todo lo cual influirá en las operaciones, actitudes, acciones o decisiones que se tomen a partir de la nueva información.

Por otro lado, una de las características esenciales de la información es que esta principalmente debe tener cierto valor de utilidad, pues, con base en ella, el sujeto o sistema modificará las continuas interacciones que efectúe con su entorno. De la misma forma, la información deberá tener vigencia, caso contrario, de nada sirve informarse sobre algún acontecimiento actual. Y, finalmente, la información deberá ser confiable para posteriormente en lo posible a través de una serie de acciones para confirmarla.

2.2.2 SEGURIDAD

La seguridad es el sentimiento de protección frente a carencias y peligros externos que afecten negativamente la calidad de vida; en tanto y en cuanto se hace referencia a un sentimiento, los criterios para determinar los grados de seguridad pecarán de tener algún grado de subjetividad. En general, el término suele utilizarse para hacer referencia al conjunto de medidas y políticas públicas implementadas para guarecer a la población del sufrimiento de delitos, en especial de aquellos que pongan en riesgo la integridad física. (Duarte, 2008)

Es importante tomar en cuenta para analizar los niveles de seguridad de una organización determinada, suele ser el marco legal que marca las reglas de convivencia, esto sirve para mediar en los conflictos y estipula correctivos a los transgresores. Por tanto, las normativas legales deben estar actualizadas para tomar los problemas que el momento determinado plantea. La importancia del momento y el lugar radica esencialmente en la necesidad que la seguridad y sus normas de regulación se adecuen al contexto social.

Teniendo lo anterior en cuenta es importante empezar indicando que la seguridad es un término distinto de otras conceptualizaciones, aunque no hay duda se encuentran entrelazados de una u otra manera.

Por otra parte, por seguridad se entiende como el conjunto de medidas preventivas y reactivas que permiten resguardar y proteger datos, información, tecnología y otros relacionados. Dicho de otro modo, son todas aquellas políticas de uso y medidas que afectan al tratamiento de los datos, información y tecnología, que se utilizan en una organización.

2.2.3 SISTEMA

Se entiende por un sistema a un conjunto ordenado de componentes relacionados entre sí, ya se trate de elementos materiales o conceptuales, dotado de una estructura, una composición y un entorno particulares. Se trata de un término que aplica a diversas áreas del saber, como la física, la biología y la informática o computación. (Raffino, 2019)

El universo puede abordarse desde una representación sistemática, en la que todos los objetos como elementos forman parte de algún tipo de sistema, la democracia representativa o los números enteros, desde las partículas de un átomo hasta la corteza cerebral. Observado de esa forma, se puede afirmar que un sistema no es otra cosa que un segmento o fragmento de la realidad que puede llevar a estudiarse de manera independiente del resto, pero es importante identificar y poner en evidencia, que cada uno de sus componentes se hallan o se encuentran interconectados.

Por otra parte, también se puede describir, que los sistemas son objeto de estudio de la Teoría de Sistemas o Teoría General de Sistemas TGS, un método que los aborda sea cuales sean desde una representación múltiple, interdisciplinaria. Según lo descrito, se dispone que cualquier sistema es identificable dados sus límites y partes interconectados e interdependientes llamados *subsistemas*, a punto tal que, la modificación de un elemento o componente modifica necesariamente el funcionamiento del resto del sistema.

De modo semejante, se considera que un sistema bajo el principio de sinergia es más que la sumatoria de sus partes, es decir, dentro de un sistema es posible predecir el comportamiento de sus componentes si se modifican los demás, y también es importante describir que los sistemas poseen un objetivo a cumplir, un fin último que avala su éxito.

Por última instancia, que todos los sistemas tienden a la entropía o desgaste y de manera eventual se descomponen en uno mayor.

2.2.4 MODELO

Se define como el arquetipo o punto de referencia para imitarlo o reproducirlo (Real Academia Española, 2011). Esquema teórico de un sistema o de una realidad compleja.

2.2.5 NORMA

Las normas son reglas que se establece con el propósito de regular comportamientos y así procurar mantener un orden. Esta regla o conjunto de reglas son articuladas para establecer las bases de un comportamiento aceptado, de esta forma se conserva el orden. (Raffino, Concepto.de, 2019)

2.2.6 POLÍTICA DE SEGURIDAD

Una política de seguridad es un conjunto de directrices, normas, procedimientos e instrucciones que guía las actuaciones de trabajo y define los criterios de seguridad para que sean adoptados a nivel local o institucional, con el objetivo de establecer, estandarizar y normalizar la seguridad tanto en el ámbito humano como en el tecnológico. A partir de sus principios, es posible hacer

de la seguridad de la información un esfuerzo común, en tanto que todos puedan contar con un arsenal informativo documentado y normalizado, dedicado a la estandarización del método de operación de cada uno de los individuos involucrados en la gestión de la seguridad de la información (Harris, 2004).

2.2.7 RECURSOS DE INFORMACIÓN

Recurso de Información define como un conjunto de elementos físicos y no físicos destinados al uso y manejo de la información para resolver una necesidad o llevar a un buen término el negocio de una empresa. (ISO, 2004)

2.2.8 SEGURIDAD DE LA INFORMACION

Se entiende por seguridad de la información como la protección, aseguramiento y cumplimiento de las siguientes características de la información:

- **Confidencialidad:** Los activos de información pueden solo ser accedidos y custodiados por usuarios que tengan los permisos para el mismo.
- **Integridad:** El contenido de los activos de información deben permanecer intacto y completo. Los cambios realizados deben ser registradas asegurando su confiabilidad.
- **Disponibilidad:** Los activos de información sólo pueden ser obtenidos a corto plazo por los usuarios que tengan autorizaciones y permisos adecuados.
- **Autenticidad:** Los activos de información los crean, editan y custodian usuarios encargados de los mismos, quienes validan su contenido.
- **Posibilidad de Auditoría:** Se conservan evidencias y rastros de todas las actividades y acciones que afectan a los activos de información.
- **Protección a la duplicación:** Los activos de información son centro de clasificación, y se llevan registros de las copias generadas de aquellos catalogados considerados como confidenciales.
- **Confiabilidad de la Información:** Es fiable el contenido de los activos de información que guarden la confidencialidad, integridad, autenticidad, disponibilidad y legalidad.
- **No repudio:** Los autores, custodios y propietarios de los activos de información se pueden identificarse plenamente.

- **Legalidad:** Los activos de información deben cumplir los parámetros legales, normativos y estatutarios de la Organización.

2.2.9 RIESGOS

El **riesgo** es la combinación de la probabilidad de que ocurra un evento y sus consecuencias negativas. Los elementos que lo componen son la amenaza y la vulnerabilidad.

Amenaza, es un fenómeno, actividad humana, sustancia, o situación peligrosa que puede causar la muerte, lesiones u otras alteraciones a la salud, la pérdida de medios de sustento, lo mismo que daños a la propiedad y de servicios, perturbaciones sociales y económicos, o perjuicios ambientales. La amenaza se determina en base a la intensidad y la frecuencia.

Vulnerabilidad, son las características y las condiciones de una colectividad, sistema o bien que los crean susceptibles a los efectos perjudiciales de una amenaza. De esta manera, con los factores descritos se compone la siguiente fórmula de riesgo.

$$\text{RIESGO} = \text{AMENAZA} \times \text{VULNERABILIDAD} \quad (1)$$

Los factores que conciertan la vulnerabilidad son la exposición, susceptibilidad y resiliencia, expresando su relación en la siguiente fórmula:

$$\text{VULNERABILIDAD} = \text{EXPOSICIÓN} \times \text{SUSCEPTIBILIDAD} / \text{RESILIENCIA} \quad (1)$$

Exposición, es la situación de desventaja debido a la ubicación, localización o posición de un objeto, sujeto o sistema expuesto al riesgo.

Susceptibilidad, es identificado como el grado de fragilidad (debilidad) interna de un sujeto, objeto o sistema para desafiar o parar una amenaza y recibir un posible impacto debido a la ocurrencia de un suceso adverso.

Resiliencia, es la capacidad de un sistema, sociedad o comunidad expuestos a una amenaza para resistir, adaptarse, absorber y recuperarse de sus efectos de manera oportuna y eficaz, lo que incluye la protección y la restauración de sus estructuras y funciones elementales.

2.2.10 GESTIÓN DE SEGURIDAD DE LA INFORMACIÓN

La seguridad de la información fundada en manuales de políticas y estándares, los cuales requieren ser revisada, para desarrollar con las exigencias de un ambiente altamente competitivo, ágil y de alto riesgo, propio de las organizaciones que localizan en las tecnologías de información, su factor diferenciador y desestabilizador en su entorno.

Por tanto, estas tecnologías proporcionan la colaboración entre las personas, aprueban expresar las opiniones de ellas y compartir, y así mismo buscar información que les provea en su constante necesidad de estar informados sobre los asuntos que son de su interés. En ese sentido, la inseguridad de la información se materializa en quebrantamiento de la privacidad de la información, la fuga de información sensible y el mal uso de los datos para efectos de inteligencia o acciones ilícitas.

Por consiguiente, las organizaciones, de cara a estos nuevos retos que propone la inseguridad, requieren establecer acciones propias de la gestión de la seguridad que permitan enfrentar y asegurar los riesgos que un escenario interconectado, global, poco regulado, altamente consultado y vulnerable establece para los responsables de la seguridad de la información corporativa. (Wilbanks, 2008)

2.2.11 ESTÁNDARES Y NORMAS PARA ASEGURAR LA INFORMACIÓN

Para asegurar la información a través de la correcta administración de la seguridad de la información, se deben instaurar y mantener acciones que induzcan a cumplir con los 3 requerimientos de gran importancia para la información, estos son:

- **Confidencialidad:** a través de este requerimiento se busca prevenir el acceso no autorizado ya sea en forma deliberada o no deliberada a la información. La pérdida de la

confidencialidad puede ocurrir de muchas maneras, así por ejemplo con la divulgación intencional de información confidencial de la organización.

- **Integridad:** Este requerimiento busca asegurar:
 - Que no se realicen alteraciones no autorizadas por personal autorizado a los datos o procesos.
 - Que no se realicen alteraciones por personas no autorizadas a los datos o procesos.
 - Que los datos sean integra tanto interna como externa.
- **Disponibilidad:** Este requerimiento busca asegurar acceso confiable y oportuno a los datos o recursos para el personal autorizado.

Distintas organizaciones nacionales como internacionales han definido estándares y normas que apoyan de varias formas el cumplimiento de los requerimientos respecto a la seguridad de la información.

2.2.12 NORMA ISO 27001

La norma ISO 27001, es un estándar a nivel internacional publicado en octubre de 2005, dirigido a las organizaciones de la información. Es la única norma auditable que establece los requisitos para un SGSI. Esta norma se ha creado para garantizar la selección de controles de seguridad de la información adecuados y proporcionales. Por su importancia, ayuda a proteger los activos de información y otorga confianza a cualquiera de las partes interesadas, especialmente todo a los clientes o usuarios.

La norma ISO 21001, adopta una orientación por procesos para establecer, implantar, operar, supervisar, revisar, mantener y mejorar un SGSI. Es una norma adecuada para cualquier organización, sea grande o pequeña y de cualquier parte o sector del mundo. La norma es un estándar particularmente interesante si la protección de la información es crítica, como en administración, sanidad sector público, finanzas y tecnología de la información TI.

Las principales normas de la familia 27K son las normas 27001 y 27002. Uno de las principales diferencias entre estas dos normas, es que la norma 27001 se basa principalmente en una gestión de la seguridad de forma continuada apoyada en la identificación de los riesgos de forma

continuada en el tiempo. Y la norma 27002, es una guía de buenas prácticas que narra una serie de objetivos de control y gestión que deberían ser alcanzados por las organizaciones.

2.2.13 COBIT

El COBIT es precisamente un modelo para auditar la gestión y control de los sistemas de información y tecnología, orientado a todos los sectores de una organización, es decir, administradores de Información y Tecnología, usuarios y por supuesto, los auditores involucrados en el proceso. (EAFIT, 2007)

El COBIT es un modelo de evaluación y monitoreo que pondera acción en el control de negocios y la seguridad de Información y Tecnología, el cual abarca controles específicos de Información y Tecnología desde una figura de negocios. Las siglas COBIT simbolizan Objetivos de Control para Tecnología de Información y Tecnologías relacionadas y en inglés Control Objectives for Information Systems and Related Technology. Este modelo es el resultado de una investigación con expertos de diferentes países, desarrollado por ISACA Information System.

2.3 MARCO REFERENCIAL NORMATIVO

La progresiva utilización de las nuevas tecnologías, ha instado a la creación de un marco normativo legal y jurídico que protege a todas las organizaciones en el uso de estas tecnologías y el trueque y tratamiento de la información a través de estas tecnologías. Día que pasa, surgen nuevas formas de delito informático que afectan principalmente a la seguridad de la información en las organizaciones. De esta manera, cumplir con la legislación nacional e internacional en las organizaciones es uno de las exigencias que se debe cumplir para implantar un Sistema de Gestión de Seguridad de la Información, el cumplimiento de las leyes protegerá a las empresas u organizaciones tanto públicas como privadas de amenazas internas y externas, permitirá respetar los derechos de los clientes, usuarios y proveedores y de esta manera evitar infracciones involuntarias con las respectivas sanciones.

En ese sentido, a continuación, se hace referencia a la legislación nacional e internacional sobre la seguridad de la información:

2.3.1 A NIVEL NACIONAL

2.3.1.1 LEY 164/2011, LEY GENERAL DE TELECOMUNICACIONES, TECNOLOGÍAS DE LA INFORMACIÓN Y COMUNICACIÓN

Bolivia se integra a la era de la Firma Digital, a través de la Ley N° 164, Ley General de Telecomunicaciones, Tecnologías de Información y Comunicación, de 08 de agosto de 2011, brinda validez jurídica a la firma digital, esta norma estipula que la Autoridad de Regulación y Fiscalización de Telecomunicaciones y Transportes ATT, se constituye como la Entidad Certificadora Raíz y le otorga a las Entidades Certificadoras Públicas y Privadas, las atribuciones para autorizar, regular, fiscalizar, supervisar y controlar.

La Ley 164 tiene por objeto establecer el régimen general de telecomunicaciones y tecnologías de información y comunicación, del servicio postal y el sistema de regulación, en busca del vivir bien avalando el derecho humano individual y colectivo a la comunicación, con respeto a la pluralidad económica, social, jurídica, política y cultural de la totalidad de las bolivianas y los bolivianos, las naciones y pueblos indígena originario campesinos, y las comunidades interculturales y afrobolivianas del Estado Plurinacional de Bolivia.

El Decreto Supremo N° 1793, de 13 de noviembre de 2013, aprueba el Reglamento para el Desarrollo de las Tecnologías de Información y Comunicación y delega a la Autoridad de Regulación y fiscalización de Telecomunicaciones y Transporte ATT la elaboración de los reglamentos y procedimientos específicos o propios que las Entidades considerados Certificadoras corresponden cumplir para la prestación del servicio de certificación digital en el país.

Con la implementación de la Firma Digital se da cumplimiento a la Constitución Política del Estado (CPE), el Plan Nacional de Desarrollo (PND), la Agenda Patriótica y la Ley General de Telecomunicaciones, Tecnologías de Información y Comunicación.

2.3.1.2 LEY 1322/1992, LEY DE DERECHOS DE AUTOR

Sobre derechos de Autor, el primer decreto de 13 de agosto de 1879 fue promulgado por la necesidad de regular estos derechos y también de sancionarlos, pero quedo al olvido y más tarde se promulga la Ley de 13 de noviembre de 1909, que a través de esta norma se estaba protegiendo los derechos de autoría, con resultados poco motivantes para los creadores o autores.

En la actualidad, en Bolivia existe una ley de derechos de autor, la ley N° 1322 del 13 de abril de 1992 y su respectivo decreto reglamentario a través del D.S. 23907 del 7 de diciembre de 1994, derechos del producto de la mente humana, pero a pesar de la existencia de estas normas, la sociedad incurre en la violación de la Ley, probablemente por la necesidad y medio en la que viven, es el claro ejemplo de los de los Cds. Piratas, que es una violación de todos los días a los de derechos de autor de los creadores. De acuerdo Ley, están protegidas en el Art.6 Inc. e). Según la Ley, desde el momento de la creación del trabajo, el autor o creador adquiere una serie de facultades exclusivas de orden moral y patrimonial, sin que medie el cumplimiento de ninguna formalidad adicional, esto se describe porque en el Art. 2 de la ley de derechos de autor dice: *El derecho de autor nace con la creación de la obra sin que sea necesario registro, depósito, ni ninguna otra formalidad para obtener la protección reconocida por la presente ley. Las formalidades que en ella se establecen son para la mayor seguridad jurídica de los titulares de los derechos que se protegen*; es decir, con solamente la divulgación o difusión por un medio de comunicación sin importar la forma, da lugar a la protección de ese derecho de autor.

Por su importancia, la ley de derechos de autor, regula el régimen de protección del derecho de los autores sobre las obras del ingenio de carácter original, sean de índole literaria, artística o científica y los derechos conexos que ella determina.

En legislación boliviana, según el Art. 1 de la ley de derechos de autor, los derechos intelectuales o más conocidos también como derechos de autor alcanza a los derechos morales que amparan la paternidad (creador) e integridad de la obra y los derechos patrimoniales que protegen el aprovechamiento económico de la obra.

2.3.1.3 LEY 2410/2002, LEY DE PRIVACIDAD (HABEAS DATA)

Hablar de este tema es vasto y variado definir como nombre los datos personales, teléfono, dirección, fotografía o huellas dactilares, así como cualquier otra información que le pueda identificar, es fundamental para lo que nos importa estos datos por razones de seguridad y porque es nuestro derecho.

Los datos deben ser protegidos contra el abuso, como el robo de identidad, transmisiones indebidas o ilegales o acceso no autorizado.

Esta Ley brinda una garantía constitucional de carácter procesal para la protección de los datos personales, aquellos que forman parte del núcleo esencial del derecho a la privacidad o a la intimidad de una persona, frente a la obtención, almacenamiento y distribución ilegal, indebida o inadecuada para entidades u organizaciones públicas o privadas (CPE, 2010).

2.3.2 A NIVEL INTERNACIONAL

2.3.2.1 LEY 34/2002, LEY DE SERVICIOS DE LA SOCIEDAD DE LA INFORMACIÓN Y DE COMERCIO ELECTRÓNICO, CON SIGLAS LSSI.

Para esta Ley, son servicios de la sociedad de la información aquellos servicios prestados, normalmente a título oneroso, por vía electrónica, a distancia y a solicitud individual del destinatario. También se incluyen los servicios no remunerados por sus receptores, cuando constituyan una actividad económica para el que presta servicios.

El propósito de esta Ley es normar y regular funcionamiento de prestadores de servicios de la Sociedad de la Información, empresas que realizan comercio electrónico y aquellas que hacen publicidad por vía electrónica, como correo electrónico o SMS. (Belloso, 2009)

2.3.2.2 LEY GENERAL 32/2003, LEY DE TELECOMUNICACIONES

La Ley establece la regulación de las telecomunicaciones, que comprenden la explotación de las redes y la prestación de los servicios de comunicaciones electrónicas y los recursos asociados. Así mismo fomenta la competencia efectiva de los mercados de las telecomunicaciones, promueve el desarrollo del sector y defiende los intereses de los ciudadanos (Alonso, 2005).

2.3.2.3 LEY 39/2015, DEL PROCEDIMIENTO ADMINISTRATIVO COMÚN DE LAS ADMINISTRACIONES PÚBLICAS

Esta Ley norma y regula las relaciones externas entre la administración y la sociedad o ciudadanos. Intenta implantar una administración totalmente electrónica, interconectada y transparente, mejorando su orientación hacia la rapidez de los procedimientos administrativos y minimizando los tiempos de tramitación.

CAPITULO III

MARCO METODOLÓGICO

3.1 ENFOQUE DE LA INVESTIGACIÓN

Una de las vías más importantes y decisivos del presente trabajo, es la elección del método que lleva a obtener de la investigación resultados válidos que respondan a los objetivos planteados de manera general y específicos. La decisión tomada depende de la forma de trabajo propuesto, la recolección de la información, los análisis que se desarrollen y por ende el tipo de resultados que se obtengan. La selección del proceso de la presente investigación guía todo el proceso investigativo y con base en él se alcanza el objetivo o resultado esperado de toda la investigación en el presente trabajo.

En ese sentido, la presente investigación se basará para procesar toda la información a través del enfoque de investigación cuantitativo y proceso deductivo, identificando componentes, estándares, fases, controles, políticas y procedimientos en la construcción de un modelo de gestión y control de seguridad de la información en las organizaciones.

3.2 TIPO DE INVESTIGACIÓN

La metodología aplicada será desde una formulación del problema basada en el tipo o alcance de investigación de estudio *descriptivo y explicativo*, pasando por la determinación de los factores principales relacionados con el tema. Porque tiene como prioridad describir cualidades, características de un fenómeno en este caso seguridad de la información. Su función principal es profundizar, describir o medir conceptos o situaciones referidas a seguridad de la información (fenómeno).

Para alcanzar el objetivo a través de este tipo de investigación, por lo general, se realizan a través de encuestas o censos y cuestionarios para medir el nivel de riesgo de seguridad de la información en la Administración Pública.

3.3 DISEÑO DE LA INVESTIGACIÓN

Para el presente trabajo, el punto de inicio del diseño de investigación es el problema principal de la investigación, el cual se deriva del planteamiento del problema.

De esta manera identificando el tipo de investigación *cuantitativa* No Experimental transversales con características consideradas con la recolección de datos en un momento y así mismo el alcance de investigación de tipo descriptivo y explicativo.

Por tanto, es una investigación aplicada, por lo que está orientada a lograr un nuevo conocimiento destinado a gestionar soluciones que permitan establecer los factores en la implementación exitosa del Modelo Seguridad en Sistemas de Información en la Administración Pública; es una combinación de tipo *descriptivo* y *explicativo*, donde el objeto de estudio obliga a la medición de las variables sin profundizar en las relaciones que se establecen sino desde el punto de vista de responder al cómo es y cómo se manifiesta, posterior a este proceso, como también se determinan las causas a un determinado fenómeno, a través del análisis de la relación entre dos o más variables, esto sea por relación de causalidad, analogía o asociación, en el presente tema, los factores críticos de éxito y su efecto de la intención del usuario.

La investigación se realiza mediante la observación documental a fin de rastrear información bibliográfica recopilada, que, si bien es limitada, servirá de base para conceptuar y explicar el tratamiento de Modelo de Gestión y Control de Seguridad de la Información para minimizar riesgo como instrumento para administración eficiente en las Instituciones públicas.

Para desarrollar el presente trabajo de investigación se toma en cuenta el estudio y análisis de los problemas con la intención de ampliar y profundizar el conocimiento de su medio, con apoyo, principalmente en trabajos previos, información y datos divulgados por medios electrónicos, impresos o audiovisuales. La singularidad del estudio brilla en el enfoque, criterios, conceptos, reflexiones y conclusiones.

Se lleva a cabo en los casos en los que es importante que en el presente trabajo se determinaran datos estadísticos. Estos números proporcionarán una mejor perspectiva para tomar decisiones en la Gestión Pública.

3.4 MÉTODO DE INVESTIGACIÓN

La investigación se realizará en la Administración Pública, de ahí que su alcance e impacto depende de la potencial aplicación en todas las Organizaciones, expresada en la caracterización de la unidad de estudio institucional.

Para su desarrollo se han seleccionado los siguientes métodos de investigación:

- **Método deductivo.** - Se aplicará este método que inicia de los datos generales admitidos como útiles para deducir por medio de razonamiento lógico varias suposiciones, es decir; fracción de verdades previamente establecidas como principios generales, para luego aplicarlo a los casos individuales y demostrar así su validez.
- **Método de modelación.** - Del cual se asumen algunos de sus rasgos para la elaboración de la propuesta en el desarrollo de la investigación.
- **Método estadístico.** - Se utilizará para el procesamiento de los resultados de la encuesta en la Administración Pública a los funcionarios del área, en lo que se refiere a la Seguridad de la información.

3.5 TÉCNICAS E INSTRUMENTOS

Para la realización del presente trabajo, las técnicas y las fuentes de información se aplicarán son:

3.5.1 TÉCNICAS PARA RECOPIACION DE INFORMACIÓN

Para la recopilación de información y tratamientos de los mismos será verificada, ordenada y clasificada para facilitar su análisis y comprensión en base a las siguientes técnicas de investigación formal:

3.5.1.1 TÉCNICAS FÍSICAS

Se constata técnicamente en la Administración Pública, el desarrollo de trabajo que realiza el personal en área de seguridad de la Información, prestando servicio de acuerdo a sus funciones.

La relación permanente con el personal sobre el tipo de trabajo, Seguridad de Información en la que se desarrollan sus trabajos.

3.5.1.2 TÉCNICAS DOCUMENTALES

A través de esta técnica se llevan a cabo los cálculos de datos numéricos por medio de operaciones estadísticos.

Así mismo se realizarán comprobaciones a través de análisis de los registros para la obtención de las evidencias suficientes que certifiquen la información y probando que los documentos requeridos para la investigación son válidos, los registros confiables y las autorizaciones auténticas.

3.5.1.3 TÉCNICAS VERBALES

Se realizarán a través de indagación para averiguar o inquirir sobre el tema de investigación; esta técnica determina la obtención valiosa de las actividades desarrolladas por el personal del área de Seguridad de Información que sirve como apoyo que como evidencia directa.

3.5.1.4 TÉCNICA DE CUESTIONARIO O ENTREVISTA

Debido al tipo de información principalmente se recurrirá a cuestionarios y entrevistas con el personal técnico relacionados en la administración de la información dentro de la administración pública.

De la misma manera por medio de esta técnica se formalizan mediante la aplicación directa o indirecta de los cuestionarios, entrevistas y formularios específicos relacionados con las

operaciones de la Entidad Públicas, dirigida a los funcionarios de la misma con preguntas predefinidas que permiten conocer las tendencias de determinadas actividades.

3.5.2 FUENTES DE RECOPIACIÓN DE INFORMACIÓN

3.5.2.1 FUENTES PRIMARIAS

Son todas aquellas de la cuales se obtiene información directa, es decir de donde se origina la información también es conocida como información de primera mano o desde el lugar de los hechos.

Para el presente trabajo las fuentes primarias son cuestionarios, encuestas, información oral, entrevistas a los profesionales en la materia Seguridad de la Información, así como técnicos de área, información escrita recopilada de relatos y seminarios, informes sobre la seguridad de información, normativas legales vigentes, como también entrevistas a los responsables del área en Entidad Pública.

3.5.2.2 FUENTES SECUNDARIAS

“Son todas aquellas que ofrecen información sobre el tema por investigar, pero que no son de fuente original de los hechos o situaciones, sino que lo referencian”.

Las fuentes secundarias de la presente investigación, la información escrita es recopilada directamente de los libros, artículos publicados y otros como ser glosarios, revistas y páginas de internet.

3.6 POBLACIÓN Y MUESTRA

3.6.1 POBLACIÓN

Es determinar el marco muestral y la unidad de análisis, y posteriormente proceder a delimitar la población de estudio, sobre la cual que se pretende generalizar los resultados; para ello, se toma como referencia la organización, en este caso la Entidad Pública. En base a dicha información se determina:

- Universo: el personal que desarrolla su trabajo en el Servicio General de Identificación Personal (SEGIP).
- Informante: Los servidores públicos o funcionarios de la Dirección Nacional de Tecnologías de Información y Comunicaciones DNTICs de la Entidad Pública.

3.6.2 MUESTRA

Se opta por la selección de una muestra de acuerdo a la actividad que desarrollan el personal en el área de Tecnologías de Información y Comunicaciones, relacionados directamente con la seguridad de la información de la Entidad Pública.

La base, el 100% del personal que trabaja en la Dirección Nacional de Tecnologías de Información y Comunicaciones DNTICs de la Entidad Pública, en diferentes unidades esta Dirección y que tiene relación con sistemas de seguridad de la información.

CAPITULO IV

MARCO PRÁCTICO Y PROPUESTA

INTRODUCCIÓN

En la actualidad, las instituciones tanto privadas como públicas administran mayores cantidades de volumen de información, garantizar un nivel de protección total a dicha información es casi imposible, inclusive en el caso de contar con suficiente presupuesto. En ese sentido, el propósito de un Modelo de Gestión y Control Integral de Riesgos de Seguridad de la Información, es garantizar que los riesgos de la seguridad de la información sean conocidos, asumidos, gestionados, controlados y reducidos por la entidad de una forma documentada, sistemática, estructurada, eficiente y adaptada a los cambios que se generen en los riesgos, el entorno y las tecnologías.

4.1 PROPUESTA Y MODELADO: FASES DEL MODELO DE GESTIÓN Y CONTROL INTEGRAL DE RIESGOS DE SEGURIDAD DE LA INFORMACIÓN

Posterior a un análisis exhaustivo de la información, se establece las fases principales del modelo o fases a seguir para tener un conocimiento preciso de la herramienta para la minimización y control del nivel de riesgo de la seguridad de la información en la Administración Pública.

Las características principales del modelo son:

- Integral; es un conjunto de estrategias, métodos y técnicas bien definidos, aplicados sistemáticamente, producen o generan un indicador o guía esperado en cada uno de las fases del modelo.
- Robusto; permite procesos con resultados repetibles y reproducibles en el tiempo.
- Flexible; permite adicionar o excluir características, comportamientos y atributos de manera modular, conforme a las necesidades del perfil de usuario y contexto organizacional o institucional.

Figura 4.1.: Fases Principales del Modelo



Fuente: Elaboración Propia

4.1.1 FASE DE PLANIFICACIÓN Y PROGRAMACIÓN DE EVALUACIÓN

En esta la fase se pretende establecer los objetivos y procesos necesarios a través de la planificación para llegar a la meta deseada y obtener los resultados deseados por la organización, en este tema en particular, la protección, control y seguridad de la información. Para este fin, es necesario conocer el entorno actual: organización, estructura, áreas de Tecnologías de la Información, seguridad, la identificación del dominio, así mismo planificar y programar tareas o actividades que se van a realizar en cada etapa el Modelo de Gestión y Control de Riesgos de Seguridad de la Información, tal como se muestra en la figura 4.2.

Figura 4.2.: Fase de Planificación y Programación de Evaluación



Fuente: Elaboración Propia

4.1.1.1 ESTABLECER EL ALCANCE Y LOS OBJETIVOS

Para establecer el alcance y los objetivos partir del contexto general de la información y los procesos que tiene la Organización, se debe demarcar el contorno de aplicación que implica el tratamiento concerniente con el flujo de la información, considerando:

- a) Medios de solicitud de información, de decir, de dónde se obtienen la información (normalmente del titular, por medio de una transferencia o fuente de acceso público, entre otros);
- b) Los departamentos o áreas que tratan información para los servicios que brindan o actividades que realizan;
- c) El dominio para la evaluación y las entidades del dominio.
- d) El plan o programa de acción para cada fase del Modelo.

Por otra parte, se debe considerar entre los objetivos del Modelo de Gestión y Control Integral de Seguridad de la Información aquéllos que admitan el tratamiento genuino, controlado e informado de la información en la organización, con el objeto de garantizar la privacidad y el derecho a la autodeterminación informativa. Los objetivos de la seguridad de sistemas de información deben ser expresados generalmente como metas medibles.

4.1.1.2 DEFINICIÓN E IDENTIFICACIÓN DE LA ORGANIZACIÓN

a) Definición de la Organización

Para una adecuada evaluación e implementación del Modelo de Gestión y Control Integral de Seguridad de Información para minimizar los Riesgos, es importante definir la Organización de la Administración Pública en función a conocimiento y comprensión de la actividad que lleva adelante, de manera general, toda la información que nos permita conocer a la organización o Entidad pública lo suficiente para una adecuada evaluación:

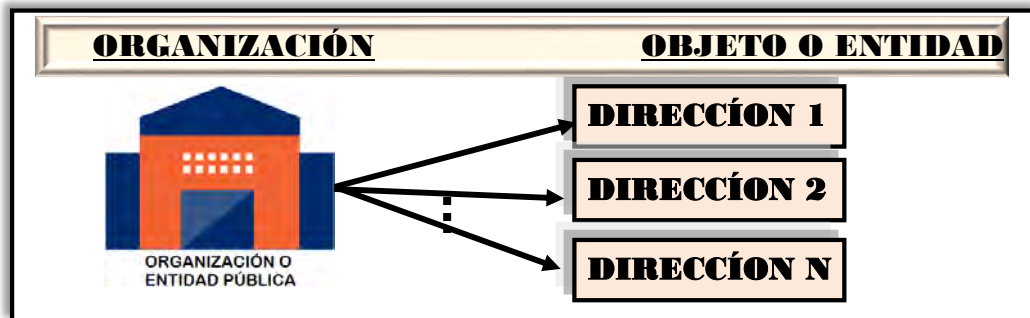
- su filosofía,
- su ambiente,
- su estructura organizativa,
- sus políticas y procedimientos operativos,
- el volumen de sus operaciones o actividades
- sus políticas y procedimientos de control de seguridad de Información,

b) Identificación de la Organización

El dominio es la facultad o la capacidad que dispone una organización o una persona para controlar a otras o para hacer uso de lo propio. Dominio también hace referencia a una cierta estructura u organización de temas o conocimientos; al ambiente físico o simbólico de una disciplina.

El dominio debe tener un conjunto de objetos a los que atribuyen propiedades que manifiestan un comportamiento y se relacionan entre sí.

Figura 4.3.: Identificación de Organización



Fuente: Elaboración Propia

En ese sentido, el dominio se determina como la Organización o Entidad Pública a ser evaluada y a objetos o entidades de dicho dominio se identifica a las Direcciones y Unidades como centro de análisis, comparación, medición y confirmación a través del Modelo de Gestión y Control Integral de Seguridad de la Información.

4.1.1.3 PLANIFICACION PROGRAMA DE ACCIÓN

La planificación de las tareas o programas de acción se realizarán en cada fase, se desarrollará las actividades en cada una de las entidades u objetos (Direcciones y Unidades) identificados para el Modelo de Gestión y Control Integral de Riesgos de Seguridad de la Información en la Administración Pública.

El cronograma de actividades es un instrumento esencial para la gestión del tiempo. El uso de esta herramienta te ayudará a planificar una adecuada distribución de las tareas,

secuenciar las actividades y estimar correctamente el tiempo de duración de cada una, para cumplir con los plazos establecidos.

Figura 4.4.: Planificación de Cronograma de Evaluación



Fuente: Elaboración Propia

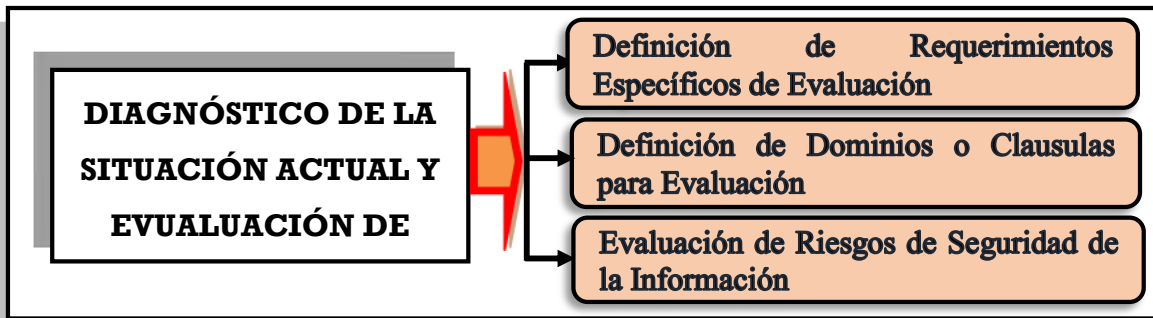
Se planifica el cronograma correspondiente para alcanzar los propósitos en el Dominio (Entidad Publica) a ser evaluado, aplicando las fases o etapas del Modelo, referidas especialmente a la definición y diagnóstico de la situación actual, evaluación de riesgos, implementación, análisis de resultados y auditoria de cumplimiento.

4.1.2 FASE DE DIAGNOSTICO DE LA SITUACIÓN ACTUAL Y EVALUACIÓN DE RIESGOS

La seguridad se fundamenta en el entendimiento de la naturaleza del riesgo al que está expuesto la información, el riesgo no se puede suprimir completamente, pero sí se puede reducir a través de la mejora continua de controles en las Organizaciones.

En esta fase, se definen los requerimientos principales y fundamentales para la evaluación del contexto actual de la Organización a través de la evaluación de los riesgos y análisis de los resultados preliminares obtenidos.

Figura 4.5.: Diagnostico de la Situación Actual y Evaluación de Riesgos



Fuente: Elaboración Propia

4.1.2.1 DEFINICIÓN DE REQUERIMIENTOS ESPECIFICOS DE EVALUACIÓN

4.1.2.1.1 TÉCNICAS E INSTRUMENTOS DE RECOLECCIÓN DE DATOS

Las técnicas e instrumentos de recolección de datos deben ser fundamentales para registrar los datos obtenidos a través de las diferentes fuentes. En ese sentido, para el presente trabajo, se define dos tipos de técnicas e instrumentos de recolección de datos:

a) Entrevistas

A través de esta técnica se recolectará datos a los usuarios que tienen perfil relacionada con la administración de información, así como: administrador de seguridad de información, Administradores de Bases de Datos, Analistas, Desarrolladores de Sistemas y al Personal de Soporte Técnico. Para adquirir información se debe confeccionar el instrumento de la entrevista de acuerdo a los objetivos definidos en el presente trabajo, con el propósito de indagar a los sujetos de estudio, sea de forma individual o grupal.

La estructura de esta técnica debe ser diseñada para obtener datos específicos sobre las dominios, comportamientos y atributos (controles o cláusulas) que el responsable de Seguridad de Información requiere para Implantar el Modelo de Gestión y Control Integral de Riesgos de Seguridad de la Información en la Entidad Pública.

b) Cuestionarios

Un cuestionario consiste en un conjunto de preguntas respecto a una o más variables a medir relacionadas con los indicadores que se obtienen de la operacionalización de los objetivos específicos.

Una de las técnicas identificadas para recolectar la información es la encuesta, la misma permite la obtener de información en forma directa a fin de precisar cómo se encuentra la seguridad de la información específicamente en la Entidad Pública, así como también posterior a la implementación del Modelo de Gestión y Control Integral de la Seguridad

de la Información. R. Hernández, (2003), señala que una técnica es un procedimiento estandarizado que se ha utilizado con éxito en el ámbito de la ciencia.

Para conseguir la información se debe elaborar el instrumento de acuerdo a los objetivos definidos, con el objeto de interrogar a los sujetos de estudio, por medio de un cuestionario constituido con preguntas relacionadas a la seguridad de información.

4.1.2.1.2 IDENTIFICACIÓN DE PERFIL Y RESPONSABILIDADES

Uno de los factores críticos de éxito es el adecuado soporte por parte de representantes de alto nivel de la Entidad para soportar y dar visibilidad a la iniciativa permanente para la implementación del modelo.

4.1.2.1.2.1 RESPONSABLE DE SEGURIDAD DE LA INFORMACIÓN

Es un individuo que cumple la función de supervisar el cumplimiento para la implantación del Modelo de Gestión y Control de Riesgos de Seguridad de la Información y de aconsejar en materia de seguridad de la información al personal de la Entidad Pública, que así lo requieran.

Cuando se requiera, se deberá designarse una persona del equipo del responsable para la rendición de cuentas de la gestión de la organización, de tal forma que tanto el cumplimiento de la normativa legal sobre protección de datos, como la política de gestión y seguridad de información, puedan ser demostrados en dicha rendición.

El responsable de seguridad de la información designado al interior de la organización para la protección, custodio y control de información, debe estar a cargo del cumplimiento de la política de seguridad de la información en todo momento.

Los representantes de alto nivel de la Entidad deben previa evaluación identificar y se deben dar a conocer los perfiles y responsabilidades de cada personaje al grupo de trabajo e identificar las personas idóneas para cada rol.

En ese sentido, dentro del dominio o Entidad pública se debe identificar el *Responsable o Administrador Experto*, en el cual se identifica como el especialista para realizar una Gestión y Control Integral en Seguridad de la Información, para formar parte del equipo multidisciplinarios entre Administradores de Seguridad de Información, Administradores de Base de Datos, Analistas de Sistemas, Desarrolladores de Sistemas, Soporte Técnico de Sistemas, Soporte Técnico de redes de comunicación, entre otros.

Por otro lado, el responsable o Administrador Experto podrá tomar la decisión de contratar así se requiera, los servicios de una persona física o moral, especialista en la materia para llevar a cabo las funciones de responsabilidades relacionadas con el Modelo de Gestión y Control Integral de Seguridad de la Información. Importante señalar, que el responsable tiene como una de sus funciones primordiales, el deber de velar y responder por el tratamiento de la información que se encuentren bajo su cargo.

4.1.2.1.2.2 COMITÉ DE SEGURIDAD DE LA INFORMACIÓN

El Comité de Seguridad de la Información, es un grupo integrado por representantes de todas las áreas de la organización, destinado a garantizar el cumplimiento de las disposiciones de las autoridades o de alta dirección sobre las iniciativas de seguridad.

La Implementación del Modelo de Gestión y Control Integral de Riesgos de Seguridad de la Información, no debe ser realizado por una sola persona o por un grupo de personas de una misma especialidad, sino que debe ser el resultado de un trabajo multidisciplinario en el que participen todos aquellos que de manera integral puedan garantizar el cumplimiento de los objetivos y/o metas planteados.

Figura 4.6.: Equipo multidisciplinario – Responsable o Administrador Experto



Fuente: Elaboración Propia

4.1.2.2 DEFINICIÓN DE DOMINIOS O CLAUSULAS PARA EVALUACIÓN

Para tener conocimiento de la situación actual de la organización frente a la Seguridad de la Información y sobre las normas ISO 27001 e ISO 27002 se ejecuta un análisis de brechas, donde el resultado de dicho análisis por cada dominio identifica situación actual.

4.1.2.2.1 DECLARACIÓN DE APLICABILIDAD Y ARBOL GENERAL DE REQUERIMIENTO

Uno de los puntos requeridos por la norma ISO 27001:2013 es el documento de declaración de aplicabilidad. En la Tabla 4.1, se hace mención de todos los dominios, objetivos de control y controles que hacen parte de la norma. En ese sentido previo un análisis y diagnóstico se especifica si el control o atributo aplica o no en la Entidad Pública de estudio y su respectiva justificación.

La declaración de aplicabilidad y árbol general de requerimiento se basa en la Norma ISO 27001:2013, de 14 Dominios o Clausulas, 35 Objetivos de Control y 114 Controles. Realizando el análisis de aplicabilidad de los elementos de la norma en la Entidad Pública, se determina simplemente 110 Controles aplicables y 4 Controles no aplicables.

Tabla 4.1: Declaración de Aplicabilidad y Árbol General de Requerimiento

CLAUSULA (DOMINIO)	OBJETIVO DE CONTROL (PROCEDIMIENTO)	CONTROL (ATRIBUTO)	APLICA / NO APLICA	JUSTIFICACIÓN
5. POLÍTICAS DE SEGURIDAD.	5.1 Directrices de la Dirección en seguridad de la información.	5.1.1 Conjunto de políticas para la seguridad de la información.	APLICA	Es importante instaurar de manera formal las directrices que se deben seguir en la Entidad para conseguir los objetivos de seguridad de la información. Por tanto, es importante dar a conocer la política de seguridad de la información para informar y concientizar a todo el personal y partes interesadas sobre los requisitos y criterios de protección establecidos para el SGSI.
		5.1.2 Revisión de las políticas para la seguridad de la información.	APLICA	Es fundamental ejecutar una revisión reiterada de las políticas de seguridad para avalar la mejora continua; implementando las acciones de mejora para que las políticas se ajusten a los cambios de la Entidad.
6. ASPECTOS ORGANIZATIVOS DE LA SEGURIDAD DE LA INFORMACIÓN.	6.1 Organización interna.	6.1.1 Asignación de responsabilidades para la seguridad de la información.	APLICA	Es importante que el personal de la Entidad conozca sus roles y responsabilidades concernientes a la seguridad de la información para la correcta ejecución del SGSI y que los miembros de alta Dirección respalden de manera activa las iniciativas de seguridad manifestando su claro apoyo y compromiso, asignando y aprobando

7. SEGURIDAD LIGADA A LOS RECURSOS HUMANOS.				explícitamente las responsabilidades en seguridad de la información en la Entidad.
		6.1.2 Segregación de tareas.	APLICA	Se deben separar visiblemente las responsabilidades para los roles establecidos, con el fin de que no se presenten conflictos de intereses entre las áreas que cuentan con acceso a los activos de información para que hagan un uso debido de los mismos.
		6.1.3 Contacto con las autoridades.	APLICA	Es preciso que la Entidad Pública este en trato con las autoridades relacionadas con temas de seguridad de la información para mantenerse al día con las medidas de lo que debe implementarse, contar con apoyo del experto, además de efectuar una gestión acertada en caso de presentarse los incidentes de seguridad de la información.
		6.1.4 Contacto con grupos de interés especial.	APLICA	Es fundamental crear contacto con grupos de interés especial en seguridad de la información, así como: asociaciones de profesionales para la atención de dificultades que se puedan presentar en la Entidad (fraudes, alertas, amenazas, vulnerabilidades, fallas de sistemas, problemas en productos de comunicación, desarrollo, entre otras).
		6.1.5 Seguridad de la información en la gestión de proyectos.	APLICA	La utilización de información en los proyectos por la importancia y sensibilidad, que se llevan a cabo dentro de las diferentes áreas de la Entidad es importante la implementación de controles para ello.
	6.2 Dispositivos para movilidad y teletrabajo.	6.2.1 Política de uso de dispositivos para movilidad.	APLICA	El personal que conserva información de la Entidad en dispositivos móviles, debe ser manipulada de acuerdo a los lineamientos del SGSI.
		6.2.2 Teletrabajo.	APLICA	El personal puede tener acceso remoto a los sistemas de información de la Entidad para desarrollar sus trabajos. En nuestro medio el TELETRABAJO es una forma de cumplir con trabajo, que consiste en el desarrollo de actividades remuneradas o prestación de servicios, utilizando como soporte las TICs para relacionar entre el trabajador y la Entidad, sin necesidad de la presencia física del trabajador en un sitio de trabajo.
	7.1 Antes de la contratación.	7.1.1 Investigación de antecedentes.	APLICA	Se debe realizar una revisión de antecedentes y de aspectos de seguridad antes de la contratación del personal con el fin de conservar el riesgo operativo en los niveles aceptables. Para llevar adelante las actividades de consultoría, pruebas u otros contratos, la entidad requiere contratar personal, los cuales tienen acceso a la información de la organización, lo cual, es fundamental implementar controles en base a los reglamentos, la ética y las normativas legales adecuados, que aseguren un proceso de revisión de antecedentes, responsabilidades, asignación de roles, términos de contratación y condiciones laborales antes del acceso a la información.
		7.1.2 Términos y condiciones de contratación.	APLICA	Es importante que en los contratos del personal y la Entidad Pública se instauren de manera clara las responsabilidades con relación a la seguridad de la información.
	7.2 Durante la contratación.	7.2.1 Responsabilidades de gestión.	APLICA	Es preciso que la alta dirección de la Entidad Pública encabece y se comprometa con la implementación del SGSI y de esta forma asegurar la ejecución de las políticas y los objetivos de seguridad de la información; para que estos estén vinculados con la dirección estratégica de la organización.

		7.2.2 Concienciación, educación y capacitación en seguridad de la información.	APLICA	Se debe concienciar al personal de la Entidad para que tengan presente en todo momento sobre los riesgos de seguridad.
		7.2.3 Proceso disciplinario.	APLICA	Se preciso crear un proceso disciplinario formal para las posibles faltas que puedan cometer respecto a la seguridad de la información y para saber de qué forma proceder en dichos casos con las personas vinculadas con la Entidad.
	7.3 Cese o cambio de puesto de trabajo.	7.3.1 Cese o cambio de puesto de trabajo.	APLICA	Los colaboradores de la Entidad Pública deben tener conocimiento de sus deberes y responsabilidades respecto a la seguridad de la información, en transcurso de su vinculación y cuando esta haya finalizado. También, cada vez que se le asignen nuevas responsabilidades o haya cambios en ellas, deben adquirir conocimiento al respecto.
8. GESTIÓN DE ACTIVOS.	8.1 Responsabilidad sobre los activos.	8.1.1 Inventario de activos.	APLICA	Es importante establecer información de los activos vinculados con la información que están implicados en los procesos de tratamiento de información de la Entidad, con el fin de concretar las responsabilidades de protección apropiada.
		8.1.2 Propiedad de los activos.	APLICA	Es importante designar los responsables para cada activo y comprometerles de: gestionar los riesgos de la información vinculados a los activos a su cargo, cumplir los controles determinados sobre el activo y establecer los custodios de estos activos.
		8.1.3 Uso aceptable de los activos.	APLICA	El personal, aprendiz, practicante y los usuarios externos en general que utilizan o tienen acceso a los activos de la organización, deben ser conscientes del uso admisible de los recursos, de los requisitos de seguridad de la información determinados en las políticas, y tener claro sobre la responsabilidad de los activos a su cargo.
		8.1.4 Devolución de activos.	APLICA	Se debe crear un procedimiento que obligue la devolución de los equipos y activos de información al momento de su finalización de relación laboral con el personal.
	8.2 Clasificación de la información.	8.2.1 Directrices de clasificación.	APLICA	Según su importancia para su aseguramiento, es necesario clasificar la información basados en normativa legales vigente, valor, criticidad, modificación, susceptibilidad a divulgación o acceso no autorizado.
		8.2.2 Etiquetado y manipulado de la información.	APLICA	Por la necesidad de asegurar que los activos de información de la Entidad Pública reciben el nivel de protección adecuado, los mismos se deben clasificar tomando en cuenta la normativa vigente, las prioridades y el grado de protección esperado en el uso de activos.
		8.2.3 Manipulación de activos.	APLICA	Se deben incorporar procedimientos que salvaguarden para la correcta manipulación de los activos.
	8.3 Manejo de los soportes de almacenamiento.	8.3.1 Gestión de soportes extraíbles.	APLICA	La Entidad administra información de carácter confidencial en dispositivos removibles que deben ser tratados adecuadamente con el objeto de asegurar que reciben el nivel de protección apropiado de acuerdo a las necesidades del mismo.
		8.3.2 Eliminación de soportes.	APLICA	En la Entidad hay información sensible en la prestación del servicio, el cual debe ser dispuesta de manera segura en caso de su eliminación de medios tecnológicos, de la reutilización de equipos o del cambio de área del personal.

		8.3.3 Soportes físicos en tránsito.	APLICA	El personal utiliza medios físicos en tránsito que tiene información de la Entidad, por esta razón se debe dar los niveles de seguridad apropiados para protegerlos contra accesos no autorizados, uso inadecuado durante el transporte o envío.
9. CONTROL DE ACCESOS.	9.1 Requisitos de negocio para el control de accesos.	9.1.1 Política de control de accesos.	APLICA	La Entidad cuenta con activos de información que son administrados por el personal, en ese sentido, es trascendental establecer controles de seguridad que permitan asegurar que el personal responsable de activos de información, o la misma entidad a través de algún otro personal, controlan el acceso a la información y a las instalaciones donde esta es procesada la información, para esto se debe crear, documentar y revisar una política de control de acceso en base a los requisitos de negocio y de seguridad de la información.
		9.1.2 Control de acceso a las redes y servicios asociados.	APLICA	Es importante el control de acceso a las redes y servicios asociados, para mantener los riesgos generados por acceso no autorizado, manipulación de la información o difusión de amenazas dentro de los niveles aceptables. La Entidad para su operación cuenta con una red LAN e internet, la cual aguenta las actividades de los diferentes usuarios, por tanto, es fundamental establecer controles de seguridad para asegurar que los usuarios solo puedan tener acceso a los servicios para los cuales están acreditados.
	9.2 Gestión de acceso de usuario.	9.2.1 Gestión de altas/bajas en el registro de usuarios.	APLICA	El personal de la Entidad usa o administra distintos tipos de información de acuerdo al área en la cual trabaja, por esta circunstancia, es muy importante establecer un procedimiento que permita gestionar de forma apropiada el acceso de los usuarios a los sistemas y servicios de la Entidad.
		9.2.2 Gestión de los derechos de acceso asignados a usuarios.	APLICA	Se debe establecer un procedimiento formal de asignación de acceso de usuario para diferentes sistemas y servicio que se tiene en la Entidad, para que se permita identificar el registro e inhabilitación de los usuarios o revocación de accesos.
		9.2.3 Gestión de los derechos de acceso con privilegios especiales.	APLICA	La concesión y uso de derechos de acceso con privilegios específicos, debe ser restringido y controlado.
		9.2.4 Gestión de información confidencial de autenticación de usuarios.	APLICA	Se debe establecer un procedimiento de gestión formal para tener control en la asignación de información de autenticación confidencial de usuarios.
		9.2.5 Revisión de los derechos de acceso de los usuarios.	NO APLICA	No se aplica en la Entidad Pública, no existe derechos de acceso de los usuarios comunes.
		9.2.6 Retirada o adaptación de los derechos de acceso	APLICA	Se debe establecer un procedimiento para retirada de los derechos de acceso a la información y a los ambientes de generación de la información de la Entidad, para todo el personal y usuarios externos, a la conclusión de su relación laboral, contrato, acuerdo, o bien cuando se realice cambio área.
	9.3 Responsabilidades del usuario.	9.3.1 Uso de información confidencial para la autenticación.	APLICA	La información de validación a los diferentes sistemas se debe conservar en secreto, por tal motivo, se debe exigir al personal el cumplimiento de las prácticas de la Entidad en la utilización de la información de autenticación secreta.
	9.4 Control de acceso a sistemas y aplicaciones.	9.4.1 Restricción del acceso a la información.	APLICA	Para impedir el acceso no autorizado a los sistemas y aplicaciones de la Entidad Pública se debe restringir dicho acceso de acuerdo a la política de control de acceso.

		9.4.2 Procedimientos seguros de inicio de sesión.	APLICA	El acceso a los sistemas y aplicaciones de la Entidad debe ser fiscalizado a través de un procedimiento de inicio de sesión seguro.
		9.4.3 Gestión de contraseñas de usuario.	APLICA	Debe establecerse un sistema para la administración de contraseñas que sea interactivo y se asegure que cumplan con los criterios de contraseñas dinámicos establecidas en la Entidad.
		9.4.4 Uso de herramientas de administración de sistemas.	APLICA	En la Entidad, se debe restringir y controlar el uso de los programas utilitarios que tengan la capacidad de exceder los controles del sistema y de la aplicación, esto, para impedir la anulación de los controles de las aplicaciones de la Entidad Pública,
		9.4.5 Control de acceso al código fuente de los programas	APLICA	Se crear un procedimiento de acceso al código fuente del programa (análisis, diseños, especificaciones, casos de uso y los planes de validación), para ser controlados estrictamente, con el fin de evitar la inserción de funcionalidades no autorizadas y para evitar cambios no deliberados, de esta manera para mantener confidencialmente la propiedad intelectual valiosa.
10. CIFRADO.	10.1 Controles criptográficos.	10.1.1 Política de uso de los controles criptográficos.	APLICA	Se debe elaborar una política, que se establezca el uso de controles criptográficos, así como el cifrado de contraseñas y la utilización de llaves criptográficas ya que es indispensable para proteger autenticidad, la confidencialidad y la integridad de la información.
		10.1.2 Gestión de claves.	APLICA	La Entidad Pública debe administrar componentes criptográficos para algunos activos de información, de esta manera se hace hincapié a la gestión de llaves por medio de una política.
11. SEGURIDAD FÍSICA Y AMBIENTAL.	11.1 Áreas seguras.	11.1.1 Perímetro de seguridad física.	APLICA	Para impedir el acceso no autorizado a los ambientes que contengan información confidencial, crítica o a instalaciones de manejo de información, se deben crea dentro de las instalaciones perímetros de seguridad.
		11.1.2 Controles físicos de entrada.	APLICA	Para asegurarse el acceso únicamente del personal autorizado a las áreas para las cuales se crearon perímetros de seguridad, se deben elaborar procedimientos de controles de seguridad física.
		11.1.3 Seguridad de oficinas, despachos y recursos.	APLICA	Se deben instaurar los controles de seguridad necesarios para evitar el acceso físico no autorizado y el daño a las oficinas o a las instalaciones del Entidad.
		11.1.4 Protección contra las amenazas externas y ambientales.	APLICA	La Entidad debe poseer protección contra daños generados por ataques maliciosos (revuelta civil, explosión, entre otros), daños ambientales producidos por desastre natural (terremoto, inundación, tsunami, tormenta eléctrica, entre otros), incidentes u otras formas de desastres generados por humanos.
		11.1.5 El trabajo en áreas seguras.	APLICA	La Entidad debe establecer y aplicar procedimientos para desarrollar trabajos en áreas seguras.
		11.1.6 Áreas de acceso público, carga y descarga.	NO APLICA	En la Entidad Pública de estudio, no se aplica, en caso de aplicarse se deben elaborar controles para el área de carga, que, por su importancia, deben ajustarse los protocolos para garantizar la seguridad de la información.
	11.2 Seguridad de los equipos.	11.2.1 Emplazamiento y protección de equipos.	APLICA	La Entidad utiliza equipos tales como computadores de escritorio, portátiles, servidores, impresoras, fotocopadoras, escáneres, entre otros, en estos equipos se

				procesa la información de los diferentes trabajos o proyectos de la Entidad Pública, de tal forma, es necesario crear controles que permitan evitar sucesos como daño, pérdida, robo, interrupción de los equipos o poner en riesgo los activos de información.
		11.2.2 Instalaciones de suministro.	APLICA	Los equipos de la entidad, debe estar protegido contra problemas en el suministro de energía y otras interrupciones producidas por fallas en los elementos de soporte, para prevenir las dificultades en las operaciones de la entidad pública.
		11.2.3 Seguridad del cableado.	APLICA	Es importante poner en conocimiento al personal para proteger contra interceptación, interferencia o daños al cableado usado para energía, red y telecomunicaciones de la Entidad Pública.
		11.2.4 Mantenimiento de los equipos.	APLICA	Es importante poner en conocimiento al personal los procedimientos, para asegurar que se haga adecuadamente el mantenimiento de los equipos de cómputo de la Entidad.
		11.2.5 Salida de activos fuera de las dependencias de la empresa.	APLICA	Se debe elaborar un procedimiento que establezca los pasos a seguir para la autorización formal previamente al retiro de los equipos tecnológicos, software o cualquier activo de información selecto.
		11.2.6 Seguridad de los equipos y activos fuera de las instalaciones.	APLICA	Es fundamental emplear medidas de seguridad a los equipos y activos fuera de las instalaciones de la Entidad para protegerlos.
		11.2.7 Reutilización o retirada segura de dispositivos de almacenamiento.	APLICA	Se deben establecer procedimientos para verificar o revisar todos los equipos de la Entidad para evidenciar si contiene o no medios de almacenamiento antes de su eliminación o reutilización. Los dispositivos de almacenamiento que contengan información importante o con derecho de autor, se deberían destruir físicamente o la se debe destruir, eliminar o sobrescribir la información a través de técnicas para que la información original no se pueda rescatar en vez de utilizar la función de eliminación o formateo corriente.
		11.2.8 Equipo informático de usuario desatendido.	APLICA	Es importante crear conciencia en los usuarios sobre los requisitos de seguridad y los procedimientos para proteger los equipos desatendidos, así por como la buena práctica de bloquear la sesión para conservar segura la información almacenada en estos equipos.
		11.2.9 Política de puesto de trabajo despejado y bloqueo de pantalla.	APLICA	Para optimizar la seguridad de los activos, es importante establecer una política de escritorio limpio para medios de almacenamiento removibles y papeles; y otra política de "pantalla limpia" para las instalaciones donde se genere información en la Entidad Pública.
12. SEGURIDAD EN LA OPERATIVA.	12.1 Responsabilidades y procedimientos de operación.	12.1.1 Documentación de procedimientos de operación.	APLICA	Se deben establecer procedimientos documentados para las actividades operacionales agrupadas con las instalaciones de procesamiento y comunicación de información, de inicio y cierre de sesión de equipos, respaldo, mantenimiento de equipos de cómputo, manejo de medios, salas de computación y administración y seguridad de manejo de e-mail. Estos procedimientos deben estar actualizados y puestos al alcance de todos los usuarios que los requieran.
		12.1.2 Gestión de cambios.	APLICA	Se deben elaborar procedimientos de control de operación de cambios que se lleven a cabo en la Entidad, respecto a procesos de negocio, sistemas que afecten la seguridad de la

			información y las instalaciones de proceso de la información
	12.1.3 Gestión de capacidades.	APLICA	Es necesario controlar y adecuar la utilización de los recursos de la Entidad Pública, de la misma forma, realizar proyecciones de los futuros requisitos de capacidades para asegurar el correcto desarrollo de las operaciones.
	12.1.4 Separación de entornos de desarrollo, prueba y producción.	APLICA	Es necesario garantizar que los cambios no concentren nuevos riesgos en los ambientes donde se generan información, y que estos se identifiquen y para efectuar oportunamente los tratamientos.
12.2 Protección contra código malicioso.	12.2.1 Controles contra el código malicioso.	APLICA	Para el desarrollo de las actividades de la Entidad se dan uso a los servicios como Internet, otros medios extraíbles, estos pueden afectar el correcto funcionamiento de activos de información; tales como equipos, software, entre otros, por tanto, es importante generar controles de seguridad que permitan detección y prevención de la acción de códigos maliciosos y la concientización de los usuarios.
12.3 Copias de seguridad.	12.3.1 Copias de seguridad de la información.	APLICA	Se deben establecer esquemas o procedimientos de respaldo de información con la finalidad de proteger el extravío de datos y cumplir con las exigencias de disponibilidad para ciertos activos.
12.4 Registro de actividad y supervisión.	12.4.1 Registro y gestión de eventos de actividad.	APLICA	Es importante considerar auditorías que permitan hacer trazabilidad de actividad, máquina, usuario y hora con la finalidad de registrar eventos y generar evidencia.
	12.4.2 Protección de los registros de información.	APLICA	Se deben establecer procedimientos para proteger registros de información, para mantener integro los registros en caso de requiera una investigación para solucionar un fallo en sistemas o un incidente de seguridad
	12.4.3 Registros de actividad del administrador y operador del sistema.	APLICA	Se deben establecer procedimientos de control a las actividades de los administradores y operadores de los distintos sistemas de la Entidad, a través de revisiones regulares a los registros y estos deben protegerse apropiadamente.
	12.4.4 Sincronización de relojes.	APLICA	En función con lo establecido en la normativa vigente, el Instituto Nacional de Metrología, mantiene, coordina y difunde la hora legal de Bolivia y todos los equipos de computación deben estar sincronizados con la hora legal.
12.5 Control del software en explotación.	12.5.1 Instalación del software en sistemas en producción.	APLICA	Es importante controlar la instalación de software en los equipos de computación de la Entidad Pública para asegurar la integridad de los sistemas operacionales
12.6 Gestión de la vulnerabilidad técnica.	12.6.1 Gestión de las vulnerabilidades técnicas.	APLICA	Es importante instaurar controles que permitan obtener información acerca de vulnerabilidades técnicas para ser evaluadas y garantizar la disminución de los riesgos. La Entidad posee activos de información tecnológicos, estos están expuestos a vulnerabilidades de tipo técnico.
	12.6.2 Restricciones en la instalación de software.	APLICA	Es importante establecer normas para la instalación de software por los usuarios o personal de la Entidad, para asegurar la integridad de los sistemas operativos.
12.7 Consideraciones de las auditorías de los sistemas de información.	12.7.1 Controles de auditoría de los sistemas de información.	APLICA	Para reducir el impacto de las tareas de control de los sistemas operativos de los equipos de la Entidad, es fundamental planificar y acordar con cuidado el desarrollo de estas tareas.

13. SEGURIDAD EN LAS TELECOMUNICACIONES.	13.1 Gestión de la seguridad en las redes.	13.1.1 Controles de red.	APLICA	Es importante controlar los riesgos a redes, segregándolas y limitando la revisión en red, para proteger la información en las redes de comunicaciones de la Entidad.
		13.1.2 Mecanismos de seguridad asociados a servicios en red.	APLICA	Es importante establecer en todo acuerdo de servicios de redes (interno y como externo), los mecanismos de seguridad, los niveles de servicio y las necesidades de gestión.
		13.1.3 Segregación de redes.	APLICA	Es importante segregar las redes para la protección de su información, fundamentalmente para separar la red de ítems por su criticidad.
	13.2 Intercambio de información con partes externas.	13.2.1 Políticas y procedimientos de intercambio de información.	APLICA	En el desarrollo normal de las actividades de la Entidad Pública se presentan actividades de intercambio de información entre usuarios, áreas, direcciones, otras instituciones, entre otros. Por tanto, es necesario establecer políticas y procedimientos que normen dichas transferencias, para mantener segura la información transferida.
		13.2.2 Acuerdos de intercambio.	APLICA	Es necesario generar acuerdos para la transferencia de información entre la Entidad Pública y terceros, con el fin de garantizar que no se presente uso cuando la información sale externamente de las instalaciones.
		13.2.3 Mensajería electrónica.	APLICA	La entidad, utiliza recurrentemente la transferencia de información por mensajería electrónica, para lo cual se debe crear procedimientos de protección al intercambio de la información.
		13.2.4 Acuerdos de confidencialidad y secreto.	APLICA	Por su importancia de la información que negocia la Entidad Pública, es preciso documentar los requisitos específicos para los acuerdos de confidencialidad para resguardar dicha información. Por tanto, estos acuerdos deben ser revisados y ajustados periódicamente para que cumplan con las necesidades de la Entidad.
14. ADQUISICIÓN, DESARROLLO Y MANTENIMIENTO DE LOS SISTEMAS DE INFORMACIÓN.	14.1 Requisitos de seguridad de los sistemas de información.	14.1.1 Análisis y especificación de los requisitos de seguridad.	APLICA	Es importante establecer controles para garantizar la seguridad de la información generada producto de sus actividades por medio de herramientas ofimáticas, tecnológicas y desarrollos de sistemas de información internamente, para el análisis de especificaciones de los requerimientos de seguridad en la Entidad.
		14.1.2 Seguridad de las comunicaciones en servicios accesibles por redes públicas.	APLICA	Es importante implementar controles de seguridad que apoyen a proteger la información de la Entidad Pública de las aplicaciones que se transmiten sobre redes públicas.
		14.1.3 Protección de las transacciones por redes telemáticas.	APLICA	Se deben efectuar controles para proteger la información implicada en las transacciones de las aplicaciones desarrolladas y utilizadas por la Entidad.
	14.2 Seguridad en los procesos de desarrollo y soporte.	14.2.1 Política de desarrollo seguro de software.	APLICA	La entidad dentro del desarrollo de sus actividades como proyectos, desarrolla sistemas o software de información, y para estos se deben establecer controles de seguridad para su desarrollo seguro, que garanticen que se cumplan con todos los detalles técnicos y de seguridad que se requiere.
		14.2.2 Procedimientos de control de cambios en los sistemas.	APLICA	Se deben implantar procedimientos de control de cambios en los sistemas para garantizar que estos no incorporen nuevos riesgos en los ambientes de la Entidad, y a pesar de estos controles se identifiquen

				vulneraciones, se puedan realizarse su tratamiento oportuno.
		14.2.3 Revisión técnica de las aplicaciones tras efectuar cambios en el sistema operativo.	APLICA	Por los constantes cambio que se realizan en las plataformas de operación, se deben efectuar pruebas y revisiones a las aplicaciones críticas de la Entidad Pública con la finalidad de asegurar que no exista impactos adversos en la seguridad.
		14.2.4 Restricciones a los cambios en los paquetes de software.	APLICA	Es importante crear controles de seguridad que garanticen que todos los cambios efectuados a los paquetes de software se revisan, controlan y someten a pruebas para no comprometer la seguridad del sistema, tanto en el entorno operativo y como también de esta manera evitar la fuga de información.
		14.2.5 Uso de principios de ingeniería en protección de sistemas.	APLICA	Como la Entidad Pública implementa constantemente distintos sistemas de información o aplicaciones, es necesario establecer procedimientos para la construcción de sistemas seguros y demandar que sean cumplidos.
		14.2.6 Seguridad en entornos de desarrollo.	APLICA	Por el desarrolla constante de sistemas de información o aplicaciones, la Entidad Pública debe establecer ambientes de desarrollo adecuados para brindar los niveles de seguridad apropiados.
		14.2.7 Externalización del desarrollo de software.	NO APLICA	La Entidad Pública de estudio no aplica, pero algunas organizaciones demandan para algunas de las tareas el desarrollo de software contratado externamente, por lo tanto, es ese caso se deben crear controles de seguridad para custodiar el acceso al código fuente de las aplicaciones, para evitar su alteración.
		14.2.8 Pruebas de funcionalidad durante el desarrollo de los sistemas.	APLICA	Es importante establecer controles para asegurar que los sistemas desarrollados cumplan con las funcionalidades de seguridad apropiada.
		14.2.9 Pruebas de aceptación.	APLICA	Es importante establecer criterios de aceptación y establecer datos de pruebas para los sistemas, para que se implementen nuevos sistemas de información, actualización de sistemas y nuevas versiones de sistemas.
		14.3.1 Protección de los datos utilizados en pruebas.	APLICA	La Entidad Pública debe generar protección a los datos de pruebas que se utilizan para realizar pruebas de sistemas de información.
	14.3 Datos de prueba.			
15. RELACIONES CON SUMINISTRADO RES.	15.1 Seguridad de la información en las relaciones con suministradores.	15.1.1 Política de seguridad de la información para suministradores.	APLICA	Debido a que los proveedores de la Entidad Pública tienen facilidades de acceso a distintos activos, es importante crear una política que establezca las directrices para debilitar los riesgos asociados al acceso a estos activos.
		15.1.2 Tratamiento del riesgo dentro de acuerdos de suministradores.	APLICA	Es importante generar acuerdos de servicio con los proveedores de la Entidad Pública que contemplen requisitos de seguridad de la información.
		15.1.3 Cadena de suministro tecnologías de la información y comunicaciones.	APLICA	En los acuerdos de servicios generados, es importante que se instauren con los proveedores de la Entidad Pública, incluyendo requisitos de seguridad de la información asociados con la cadena de suministros.
	15.2 Gestión de la prestación del servicio por suministradores.	15.2.1 Supervisión y revisión de los servicios prestados por terceros.	APLICA	Es importante realizar el monitoreo y revisión de los servicios prestados, esto para garantizar el cumplimiento de las condiciones de seguridad exigidos por la Entidad Pública a los proveedores,
		15.2.2 Gestión de cambios en los servicios prestados por terceros.	APLICA	Cuando existan cambios en el suministro de servicios por parte de los proveedores, estos deben ser negociados de acuerdo a la

				importancia de seguridad de la información de sistemas y procesos involucrados en negocios.
16. GESTIÓN DE INCIDENTES EN LA SEGURIDAD DE LA INFORMACIÓN.	16.1 Gestión de incidentes de seguridad de la información y mejoras.	16.1.1 Responsabilidades y procedimientos.	APLICA	Para generar una respuesta oportuno y eficaz a los incidentes de seguridad de la información en la Entidad, es preciso establecer las responsabilidades y forma de trabajo ante estos incidentes.
		16.1.2 Notificación de los eventos de seguridad de la información.	APLICA	Es fundamental generar los canales apropiados para que los eventos de seguridad de la Entidad Pública puedan ser reportados de lo más inmediato posible.
		16.1.3 Notificación de puntos débiles de la seguridad.	APLICA	El personal de la Entidad, deben estar forzados a reportar cualquier debilidad de seguridad de la información evidenciada o sospechada en los sistemas de información para su atención.
		16.1.4 Valoración de eventos de seguridad de la información y toma de decisiones.	APLICA	Para garantizar la correcta atención de los eventos o sucesos de seguridad de la Entidad Pública, los mismos deben ser atendidos y valorados por el personal de seguridad de la información.
		16.1.5 Respuesta a los incidentes de seguridad.	APLICA	Es importante contar con un esquema de respuestas y correcciones a los incidentes de seguridad en función a los procedimientos documentados en la Entidad Pública.
		16.1.6 Aprendizaje de los incidentes de seguridad de la información.	APLICA	Es trascendental reducir el impacto de incidentes de seguridad de la información en la Entidad Pública utilizando el conocimiento adquirido sobre la gestión de incidentes.
		16.1.7 Recopilación de evidencias.	NO APLICA	En la Entidad de estudio no se aplica, en caso de implementar, es importante construir esquemas de recopilación de evidencia y en caso de que un incidente requiera para su tratamiento forense.
17. ASPECTOS DE SEGURIDAD DE LA INFORMACIÓN EN LA GESTIÓN DE LA CONTINUIDAD DEL NEGOCIO.	17.1 Continuidad de la seguridad de la información.	17.1.1 Planificación de la continuidad de la seguridad de la información.	APLICA	La Entidad Pública a través de protocolos establecidos, debe garantizar la continuidad de la gestión de la seguridad de la información, aunque estos fuesen en situaciones adversas.
		17.1.2 Implantación de la continuidad de la seguridad de la información.	APLICA	La Entidad Pública debe crear, documentar, implementar, conservar procesos y procedimientos; para dar continuidad adecuada a la administración de la seguridad de la información en situaciones adversas.
		17.1.3 Verificación, revisión y evaluación de la continuidad de la seguridad de la información.	APLICA	Para evidenciar y verificar que los procedimientos de controles de continuidad de seguridad de la información implementados en la Entidad Pública, son legítimos, se deben efectuar revisiones en intervalos de tiempos regulares.
	17.2 Redundancias.	17.2.1 Disponibilidad de instalaciones para el procesamiento de la información.	APLICA	Para definir la disponibilidad de las instalaciones para el procesamiento de información de la Entidad Pública estas deben contar con redundancia.
18. CUMPLIMIENTO.	18.1 Cumplimiento de los requisitos legales y contractuales.	18.1.1 Identificación de la legislación aplicable.	APLICA	Es una exigencia normativa para que la Entidad Pública tenga un cronograma actualizado que cumpla la normativa vigente.
		18.1.2 Derechos de propiedad intelectual (DPI).	APLICA	Para garantizar el cumplimiento normativo relacionado con derechos de autor, se deben implementarse procedimientos adecuados de propiedad intelectual y utilización de software patentado.
		18.1.3 Protección de los registros de la organización.	APLICA	En la Entidad, se debe implementarse, por administrar registros públicos y debiera ser protegido por el Estado.
		18.1.4 Protección de datos y privacidad de la información personal.	APLICA	La Entidad Pública, está obligada a dar cumplimiento con la normativa de Protección de Datos Personales.

		18.1.5 Regulación de los controles criptográficos.	APLICA	La utilización de los procedimientos de control criptográfico como cifrado de contraseñas de información importante en bases de datos o activos de información confidenciales, es preciso para mantener el riesgo operacional en los niveles aceptables.
	18.2 Revisiones de la seguridad de la información.	18.2.1 Revisión independiente de la seguridad de la información.	APLICA	Para confirmar que la seguridad de la información se opera e implementa debidamente en Entidad Pública, se deben efectuar revisiones al SGSI en periodos planificados o cuando broten cambios importantes.
		18.2.2 Cumplimiento de las políticas y normas	APLICA	Se deben establecer procedimientos adecuados para que los directores deban revisar el cumplimiento de los protocolos de seguridad de sus áreas, para asegurar que la información se maneje de acuerdo a los lineamientos establecidos.
		18.2.3 Comprobación del cumplimiento	APLICA	A través de una planificación adecuada, periódicamente, se deben revisar el cumplimiento de los lineamientos de seguridad de sistemas de información de la Entidad Pública, para asegurar que la información se opere de acuerdo a los lineamientos establecidos.

Fuente: ISO 27001 & ISO 27002

La justificación para cada uno de los controles, se establece de acuerdo a la normativa existente, referidos a la seguridad de la información.

4.1.2.2.2 CLAUSULAS, OBJETIVOS DE CONTROL Y CONTROLES PARA EVALUACIÓN

De acuerdo a los resultados de análisis obtenidos en la tabla 3.1, las cláusulas, objetivos de control y controles aplicables se convierten en insumos para la evaluación de riesgo y para la implementación del Modelo de Seguridad de la Información. Por tanto, a continuación, se identifica las 14 cláusulas, 35 objetivos de Control y 110 controles o atributos con sus respectivos códigos de acuerdo al siguiente detalle:

1. Políticas de Seguridad.
2. Organización de la Seguridad de la Información.
3. Seguridad de los Recursos Humanos.
4. Gestión de Activos.
5. Control de Accesos.
6. Cifrado.
7. Seguridad Física y del Entorno.
8. Seguridad de las Operaciones.

9. Seguridad de la Comunicaciones.
10. Adquisición, Desarrollo y Mantenimiento de los Sistemas de Información.
11. Relaciones con los Proveedores.
12. Gestión de Incidentes de Seguridad de la Información.
13. Aspectos de Seguridad de la Información en la Gestión de la Continuidad del Negocio.
14. Cumplimiento.

4.1.2.3 EVALUACIÓN DE RIESGOS DE SEGURIDAD DE LA INFORMACIÓN

Inicialmente se debe establecer el criterio de riesgo elemental, los tipos de criterios y considerar diferentes niveles de riesgo, funciones, valores y rangos críticos para determinar el indicador de riesgo para cada control o atributo cuantificable para realizar el proceso de medición del nivel de riesgo de cada clausula, objetivo de control y control del Modelo. (Fenton et al, 2007)

Para la evaluación de riesgos se plantea los siguientes pasos a seguir:

1. Identificación de la población o muestra de la entidad pública.
2. Para cada control o atributo cuantificable, se toma un valor real a través de la técnica de cuestionario, a partir de un proceso de análisis de riesgos.
3. Por medio de un criterio elemental, se selecciona el indicador de riesgo adecuado para cada control o atributo evaluado.
4. Se asignan pesos de acuerdo de acuerdo a la importancia y los resultados obtenidos a cada dominio de control.

4.1.2.3.1 CRITERIO DE RIESGO ELEMENTAL

El criterio de riesgo elemental se define como un "riesgo básico" que forma parte de un riesgo principal, es decir que el nivel de análisis de complejidad de un criterio de riesgo elemental es menor a un criterio de riesgo principal. En ese sentido, para la presente evaluación se identifica el criterio de riesgo elemental para medir todos los dominios, objetivos y controles del Modelo.

Para cada control cuantificable C_i , se debe asociar y determinar una variable X_i que procede a tomar un valor real a partir de un proceso de medición. Además, para cada variable X_i computada, por medio de un criterio elemental, se producirá un indicador de riesgo elemental por cada sección en el diseño del modelo (RE_i), el resultado final obtenido se interpreta como el grado o porcentaje del requerimiento del Responsable Experto satisfecho para el Control C_i .

En cada variable medida X_i , donde $i = 1, \dots, n$, se define una función que representa al criterio elemental. Un criterio elemental está definido como una correspondencia del valor de la variable de uso X_i , con el valor de riesgo elemental RE_i . En términos generales, el valor medido de la variable es un número real (Fenton et al, 2007):

$$X_i \in R_i \subset R$$

Donde:

- C_i : Control o atributo
- X_i : Variable
- R : Representa a los números reales
- RE_i : Riesgo elemental

El valor de riesgo elemental RE_i es también un número real perteneciente al intervalo $I = [0, 1]$ entonces (Fenton et al, 2007):

$$RE_i \in I_i; \quad \text{donde } i = 1, 2, \dots, n$$

Con frecuencia, en vez de usar el intervalo unitario es beneficioso emplear la escala porcentual de 0% a 100%. En este sentido se interpreta al indicador de riesgo como el porcentaje del requerimiento insatisfecho. Desde un punto de vista analítico, el criterio elemental (CrE), se define como la función:

$$F_i: R_i \rightarrow I_i; \quad \text{donde: } RE_i = F_i(x_i); \quad \text{además: } X_{i \min} < X_i < X_{i \max}$$

Entonces, sea X_i el valor que se le asigna a un control o atributo C_i donde, el criterio elemental para dicho atributo es definido como: (Fenton et al, 2007)

$X_{i \min}$: es el menor valor que toma X ;

$X_{i \max}$: es el mayor valor que toma X

Entonces:

$$CrE(X_i) = \begin{cases} Si: X_i \leq X_{i\ min} ==> RE_i = 0 \approx 0\% \\ Si: X_i \geq X_{i\ max} ==> RE_i = 1 \approx 100\% \\ Si: X_{i\ min} \leq X_i \leq X_{i\ max} ==> RE_i = \frac{X_i - X_{i\ max}}{X_{i\ max} - X_{i\ min}} \end{cases}$$

Donde:

CrE: Criterio Elemental

De acuerdo a lo formulado, el criterio declara que el grado de satisfacción del Responsable Experto se encuentra en:

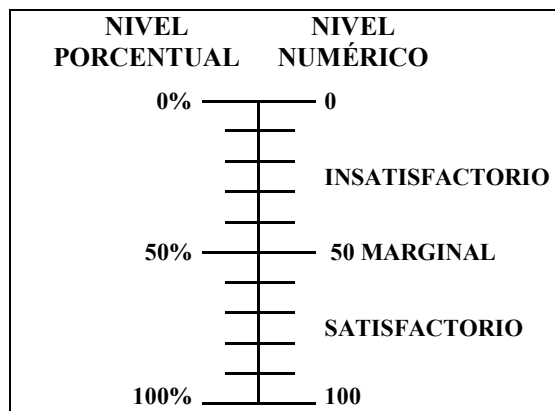
- Un nivel satisfactorio si el control C_i es mayor o igual, al mayor o máximo $X_{i\ max}$, es decir, $RE_i = 100\%$.
- Un nivel insatisfactorio si el control C_i es menor o igual, al menor o mínimo $X_{i\ min}$, es decir, $RE_i = 0\%$.

4.1.2.3.2 REPRESENTACIÓN DE NOTACIÓN DE CRITERIOS

De acuerdo a la información que se genera, la notación de criterios está dada por Notación Escala de Riesgos en la Figura 3.7., en esta se muestran los niveles de riesgo correspondientes y los puntos que se consideran de mayor interés:

$$CrE(X_i) = \begin{cases} Si: X_{i\ min} = 0 ==> RE_i = 0 \approx 0\% \\ Si: X_{i\ max} = 100 ==> RE_i = 100 \approx 100\% \end{cases}$$

Figura 4.7.: Escala de Riesgo Elemental

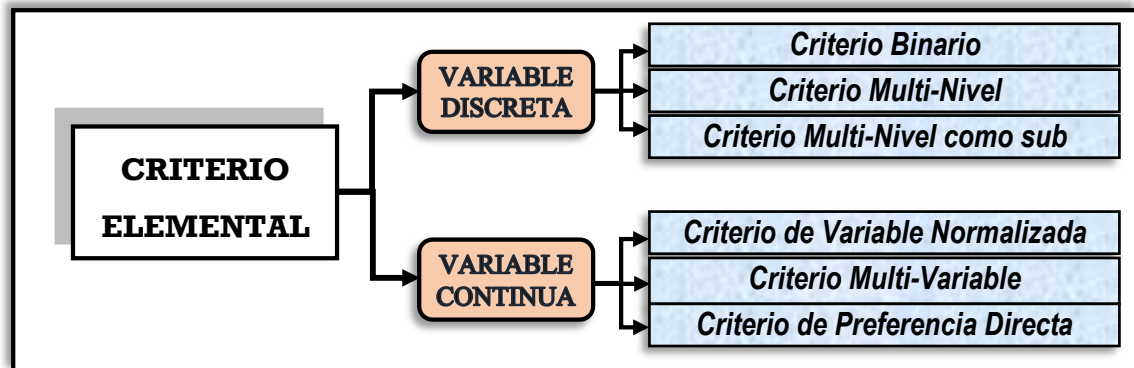


Fuente: Fenton et al, 2007

4.1.2.3.3 TIPOS DE CRITERIO DE RIESGO ELEMENTAL

La selección del tipo de criterio riesgo elemental para evaluación, resulta de mucha importancia en las cláusulas, objetivos de control y controles o atributos de la Gestión y Control integral en Seguridad de la Información. Por tanto, se identifican dos tipos de variables de criterio de riesgo elemental: (Fenton et al, 2007)

Figura 4.8.: Tipos de Criterio de Riesgo Elemental



Fuente: Fenton et al, 2007

4.1.2.3.3.1 CRITERIO ELEMENTAL CON VARIABLE DISCRETA¹

a) Criterio Binario CB

El criterio para mapear el indicador del riesgo elemental de la variable X_i , representada de la siguiente manera: (Fenton et al, 2007)

$$CrE(X_i) = \begin{cases} Si: X_i = 0 \implies RE_i = 0 \approx 0\% \\ Si: X_i = 1 \implies RE_i = 100 \approx 100\% \end{cases}$$

Donde:

$X_i = 0$, se interpreta como ausencia o no disponibilidad del control o atributo.

$X_i = 1$, se interpreta como la presencia o disponibilidad del control o atributo.

¹ Son aquellas que se cuentan, es decir, tienen un número finito de valores posibles, tanto las variables discretas como las continuas se construyen agrupando intervalos.

b) Criterio Multi-Nivel CMN

Es la generalización del criterio Binario, la variable discreta toma tres (3) valores, para ciertos controles o atributos la variable discreta X_i se mapea en distintos valores de riesgos y se representa de la siguiente manera: (Fenton et al, 2007)

$$CrE(X_i) = \begin{cases} Si: X_i = 0 ==> RE_i = 0 \approx 0\% \\ Si: X_i = 1 ==> RE_i = 60 \approx 60\% \\ Si: X_i = 2 ==> RE_i = 100 \approx 100\% \end{cases}$$

Donde:

$X_i = 0$, se interpreta como ausencia o no disponibilidad del control o atributo.

$X_i = 1$, se interpreta como la presencia parcial del control o atributo.

$X_i = 2$, se interpreta como la presencia total del control o atributo.

c) Criterio Multi-Nivel definido por sub conjuntos CMNS

Este criterio se encuentra establecido dentro de un sub conjunto de números naturales. La variable discreta toma tres (3) valores, cada una de las cuales corresponde a un riesgo por una sección en la parte de diseño del modelo. Para ciertos controles o atributos la variable discreta X_i se mapean valores de riesgos y se representa de la siguiente manera: (Fenton et al, 2007)

$$CrE(X_i) = \begin{cases} Si: X_i = 0 ==> RE_i = 0 \approx 0\% \\ Si: X_i = 1 ==> RE_i = 60 \approx 60\% \\ Si: X_i = 2 = 1+n ==> RE_i = 100 \approx 100\% \end{cases}$$

Donde:

$X_i = 0$, se interpreta como ausencia en el mecanismo de seguridad de la Organización.

$X_i = 1$, se interpreta como seguridad mínima de acceso: mecanismos de acceso por autenticación.

$X_i = 2 = 1+n$, con “n” clausulas o dominios particulares extras.

4.1.2.3.3.2 CRITERIO ELEMENTAL CON VARIABLE CONTINUA²

a) Criterio de Variable Normalizada CVN

Se utiliza para evaluar la relación entre “n” controles o atributos que tienen criterios diferentes de un comportamiento equivalente (Figura 3.12.), se utiliza para computar las variables y se representa de la siguiente manera: (Fenton et al, 2007)

$$RE_i = \frac{X_i - X_{i \max}}{X_{i \max} - X_{i \min}}$$

Donde:

X_i = Cantidad de controles o atributos satisfechos

X_i = Cantidad de total de controles o atributos

RE_i = Grado o porcentaje del usuario satisfecho para el Objetivo de control o comportamiento.

b) Criterio de Multi-Variables Continuas CMC

Para este criterio, la variable “X” es resultante de otras variables y constantes Este criterio también sirve para la evaluación elemental “n” controles o atributos de un objetivo de control. (Fenton et al, 2007)

c) Criterio de Riesgo Directo CRD

Este tipo de criterio es subjetivo y basado en la experiencia a criterio de los responsables expertos. Desde el punto de vista de precisión y objetividad en este criterio se introducen errores de valoraciones involuntarias y/o intencionales. Sin embargo, aun con las falencias que posee se hace muy necesario para completar la evaluación global, en caso donde los controles o atributos de alta complejidad y baja prioridad (Fenton et al, 2007).

El criterio para la variable “X” se mapea en un riesgo trivial y cuya representación notarial es:

$$CrE(X_i) = \begin{cases} Si: X_i = 0 \implies RE_i = 0 \approx 0\% \\ Si: X_i = 100 \implies RE_i = 100 \approx 100\% \end{cases}$$

² Son aquellas que asumen cualquier valor dentro de un intervalo, por lo cual tiene un número infinito de valores posibles.

En esta etapa se debe especificar los pesos de acuerdo a los datos obtenidos en la evaluación de riesgos por cada dominio o característica del modelo, sabiendo que la suma total de los pesos debe ser 1 o el 100%.

4.1.2.3.4 ASIGNACIÓN DE PESOS

La asignación de pesos P es de acuerdo a los datos obtenidos en la evaluación de riesgos por cada cláusula o dominio del Modelo de Gestión y Control Integral de Seguridad en la Información. Estos datos obtenidos servirán para la evaluación global de riesgos, se debe considerar siempre que la suma de los pesos sea igual a 1 o al 100%.

Tabla 4.2. Estructura de Asignación de Pesos a Clausulas o Dominios

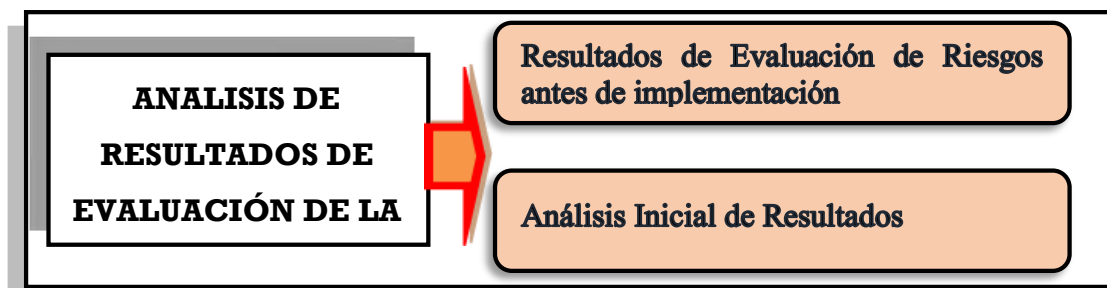
CLAUSULA	PESO (P)	JUSTIFICACIÓN
Clausula 1 ... Clausula N	$0 \leq P \leq 1$	Descripción
Total	1	

Fuente: Elaboración Propia

4.1.3 FASE DE ANÁLISIS INICIAL DE RESULTADOS DE EVALUACIÓN DE LA SITUACIÓN ACTUAL

En esta fase, se evalúan y computan los resultados de los planes, políticas, procesos y procedimientos de la situación actual de la Entidad Pública, es decir antes de ser implementado el Modelo, a fin de comprobar el estado de Seguridad de la información.

Figura 4.9.: Fase de Análisis de Resultados de Evaluación de la situación Actual



Fuente: Elaboración Propia

4.1.3.1 RESULTADOS EVALUACIÓN DE RIESGOS ANTES DE IMPLEMENTACIÓN

Para concretar un plan de riesgos a tratar y seguidamente implementar controles de seguridad, se deben tener una variedad de criterios de evaluación dentro de la Entidad Pública, que acepten delimitar el nivel de riesgo aceptable para Sistema de la Seguridad de la Sistemas de información.

Por tanto, producto de la evaluación y análisis de riesgos, se realizan actividades de análisis y comparación de riesgos de las cláusulas o dominios definidas, consolidando los datos generados por cada clausula con datos obtenidos a través de las técnicas de entrevistas y cuestionarios realizadas a al área de Tecnologías de la Información y Comunicación (TICs) de la Entidad Pública, justificando cada resultado mediante el empleo de tablas, cuadros estadísticos y gráficas.

Para mostrar los resultados o efectos de la evaluación de riesgos de la Organización o Entidad Pública, bajo los criterios ya establecido sobre las Cláusulas o dominios del Modelo de Gestión y Control Integral debe utilizar una Tabla, una bajo el siguiente formato:

Tabla 4.3.: Resultados de la Evaluación de Riesgos

CLAUSULA O DOMINIO	CRITERIO	PARAMETROS Y VALORES	RESULTADO DE EVALUACION DE RIESGO (%)
a. Clausula a.1.Objetivo de Control a.1.1.Control a.1.2. ...n ...	$E_{i,...,n} = RE_n$... $CrE(X_i) = RE_i$	V_1	R_1
b. Clausula b.1.Objetivo de Control b.1.1.Control b.1.2. ...n ...	$E_{i,...,m} = RE_m$... $CrE(X_i) = RE_i$	V_2	R_2

Fuente: Elaboración Propia

4.1.3.2 ANALISIS INICIAL DE RESULTADOS

Para mostrar el Indicador del total del Riesgo Controlado, se establece bajo tres Niveles de Seguridad de Información:

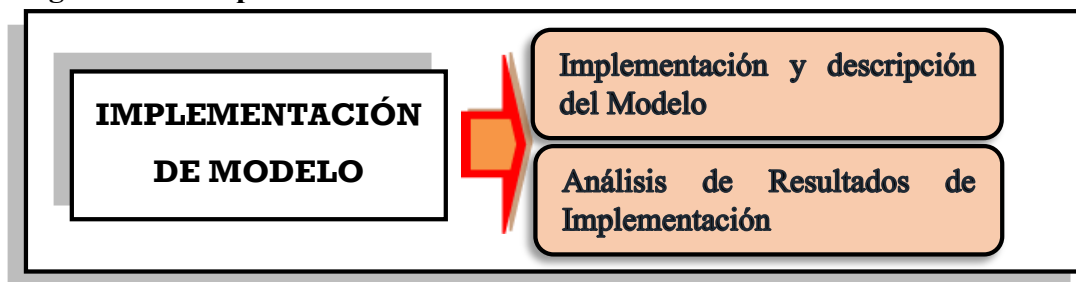
Tabla 4.4.: Niveles de Evaluación de Seguridad de Información

NIVEL (%)	CRITERIO
0 – 40	Insatisfactorio
41- 60	Marginal
61 - 100	Satisfecho

Fuente: Elaboración Propia

4.1.4 FASE DE IMPLEMENTACION

En esta etapa se implementan y aplican las políticas, procesos, procedimientos y controles o atributos del Modelo de Gestión y Control Integral de Seguridad de la Información MOGYCISI, mismos seleccionados e identificados de acuerdo al requerimiento o actividad de la Organización o Entidad Pública. El asunto que nos corresponde en esta fase, se deben implementar las medidas de seguridad que hayan resultado aplicables de acuerdo al análisis de riesgos realizados, bajo los criterios y el comportamiento de la información dentro de la Entidad Pública.

Figura 4.10.: Implementación del Modelo

Fuente: Elaboración Propia

4.1.4.1 IMPLEMENTACION Y DESCRIPCIÓN DEL MODELO

Resultado de análisis de brecha, declaración de aplicabilidad y árbol general de requerimiento, se ha establecido 14 cláusulas o dominios, 35 objetivos de control o comportamientos y 110 controles o atributos, basados en los estándares de la Norma ISO 27001:2013, para su implementación del modelo en la Entidad Pública de estudio. De acuerdo a su alcance, se plantean como aporte, la descripción de Objetivos de Control, controles y los procedimientos adecuados para la seguridad de la información.

Tabla 4.5.: Implementación y Descripción del Modelo en la Entidad Pública

1. POLÍTICAS DE SEGURIDAD.	
1.1 Directrices de la Dirección en seguridad de la información.	
OBJETIVO: <i>Brinda apoyo y orientación a la dirección ejecutiva de la entidad respecto a la seguridad de la información, de acuerdo con los requisitos de la organización y los reglamentos y leyes pertinentes en nuestro país.</i>	
1.1.1 Políticas para la seguridad de la información.	
CONTROL: <i>Define un conjunto de políticas para la seguridad de la información, aprobada por la dirección, publicada y comunicada al personal de la entidad y a las partes externas pertinentes de la entidad.</i>	
PROCEDIMIENTO DE IMPLEMENTACIÓN: El documento de la política de seguridad de la información de la entidad, tiene declaraciones relacionadas con: i) Descripción de la Seguridad de la información, objetivos generales y el alcance de la seguridad como formas que comparta la información. ii) Declaración de la Intención de la organización, que apoye las metas y elementos de la seguridad de la información, en función a los objetivos estratégicos y de gestión de la organización. iii) Estructura que se constituya los objetivos de control, control y estrategia de evaluación de riesgos. iv) Descripción de los requisitos de cumplimiento para la organización, tales como: - Requisitos de educación, capacitación y concientización sobre seguridad de la información. - Acatamiento de los requisitos legales, reglamentarios y pactadas. - Gestión de la continuidad del negocio. - Resultados de las violaciones de la política de seguridad. v) Definición de las responsabilidades usuales y específicas para la gestión de la seguridad de la información, a todos los empleados involucrados en la organización de manera permanente.	
1.1.2 Revisión de las políticas para la seguridad de la información.	
CONTROL: <i>La política de la seguridad de la información se revisa cada vez que se producen cambios significativos, de esta manera la entidad garantiza que la política de seguridad siga siendo adecuada y eficaz.</i>	
PROCEDIMIENTO DE IMPLEMENTACIÓN: El temario para la revisión por parte de la dirección ejecutiva de la entidad incluye información sobre: - Los resultados de las revisiones previas por parte de la dirección ejecutiva y cumplimiento de la política de seguridad de la información. - Las tendencias relacionadas con las amenazas y vulnerabilidades interna y externas que afecten el intercambio y la generación de la información. - Los incidentes de seguridad de la información reportados.	
2. ORGANIZACIÓN DE LA SEGURIDAD DE LA INFORMACIÓN	
2.1 Organización interna.	
OBJETIVO: <i>Gestionar la seguridad de la información, estableciendo una estructura de gestión para iniciar y controlar la implementación de la seguridad de la información dentro de la entidad.</i>	
2.1.1 Roles y responsabilidades para la seguridad de la información	
CONTROL: <i>Se establecen y asignan todas las responsabilidades de la seguridad de la información en la entidad.</i>	
PROCEDIMIENTO DE IMPLEMENTACIÓN: Las responsabilidades de la seguridad de la información se asignan alineada a la política de seguridad de la información. De igual forma, el comité de seguridad de la información plantea a la autoridad que corresponda para su aprobación, la definición y asignación de las responsabilidades que emerjan de los procesos de seguridad que se puntualizan a continuación, indicando en cada caso el o los responsables del cumplimiento de los aspectos de este dominio aplicables a cada caso: a) Seguridad del Personal b) Seguridad Física y Ambiental	

- c) Seguridad en las Comunicaciones y las Operaciones
- d) Controles de Acceso
- e) Seguridad en el Desarrollo y Mantenimiento de Sistemas
- f) Planificación de la Continuidad Operativa

De la misma forma, el Comité de Seguridad de la Información plantea a la autoridad correspondiente para su aprobación, la definición y asignación de las responsabilidades a los dueños de la información que se definan.

Importante señalar que, si bien los dueños de información pueden delegar la gestión de sus funciones a personal apto a su cargo, deben conservar la responsabilidad del cumplimiento de las mismas. Esta delegación debe ser documentada por los mismos y entregada al Oficial de Seguridad de información.

2.1.2 Separación de deberes

CONTROL:

Las obligaciones y áreas de responsabilidad en conflicto, se separan para minimizar las posibilidades de alteración no autorizada o no intencional, o por la utilización indebida de los activos de la organización.

PROCEDIMIENTO DE IMPLEMENTACIÓN:

El comité de Seguridad de la Información debe presentar una clara delimitación de actividades entre las partes que estén bajo su dependencia. Las incompatibilidades existentes entre las funciones de una parte específica, con respecto a las actividades desempeñadas por otros sectores o áreas. La Entidad debe tomar medidas en la segregación de tareas, para evitar su concentración. Por tanto, para la implementación se debe realizar:

- El Análisis de la descripción de los cargos, con el fin de identificar actividades que no cuenten con control cruzado, para que se implementen.
- La Tipificación de actividades de revisión, aprobación, ejecución y auditoría en un mismo cargo para efectuar su separación.
- La Formalización de la asignación de nuevas actividades al personal correspondiente.

2.1.3 Contacto con las autoridades.

CONTROL:

Se conservan contactos adecuados con las autoridades pertinentes.

PROCEDIMIENTO DE IMPLEMENTACIÓN:

- Se generar una base de datos de entes o los grupos de interés actualizado que puedan apoyar a gestionar algún problema que llegase a presentar respecto a la seguridad de la información.
- Se recomienda establecer un procedimiento que especifique qué entidades y autoridades deben ser contactadas (Centro Cibernético Policial, bomberos, ATT, Data Center, proveedor de Internet, entre otros), cuándo y cómo o a través de que medio.
- Se establece protocolos que cada Entidad tienen determinados para el reporte de los incidentes de seguridad de la información.
- Se mantiene una agenda actualizada con el personal responsable de atender los requerimientos en cada uno de los organismos gubernamentales.

2.1.4 Contacto con grupos de interés especial.

CONTROL:

Se conservan contactos apropiados con grupos de interés especial de grupos y asociaciones profesionales especializadas en seguridad.

PROCEDIMIENTO DE IMPLEMENTACIÓN:

El Responsable de Seguridad de la Información debe exponer sus conocimientos y las experiencias relacionados en la Entidad a fin de brindar apoyo en la toma de decisiones en materia de seguridad. El cual puede obtener apoyo de otras Instituciones con el objeto de mejorar su gestión, así mismo debe habilitar al Responsable de Seguridad de la Información el contacto con otras Instituciones del sector privado como público de diferentes áreas de la Entidad.

Es importante considerar que ser miembro de grupos de interés especial es para:

- a) Obtener nuevos conocimientos actualizados y acerca de las mejores prácticas.
- b) Recibir alertas tempranas, advertencias y recomendaciones ante vulnerabilidades y ataques.
- c) Hacer que la concientización sobre la seguridad de la información esté completa y actualizada.
- d) Suministrar vínculos adecuados en transcurso de tratamiento de los incidentes de seguridad de la información.

2.1.5 Seguridad de la información en la gestión de proyectos.

CONTROL:

Se contemplan la seguridad de la información en la gestión de proyectos, independientemente del tipo de proyecto a desarrollar por la Entidad.

PROCEDIMIENTO DE IMPLEMENTACIÓN:

La seguridad de la información en la gestión de proyectos de tecnología de información establece parte del compromiso de la ética con los datos de las personas e instituciones, así como la responsabilidad digital de la organización, que entiende que los sistemas de información son puentes que habilitan nuevas oportunidades de negocio y al tiempo se convierten en garantes de los derechos individuales y exigencias jurídicas que confirman la autodeterminación informática de sus usuarios o participantes, para lo cual se debe:

- Identificar de los activos digitales y de información clave que estará involucrados en el desarrollo de la solución.
- Determinar las responsabilidades legales que tiene la Entidad con la información que se modela y fluye en la solución de negocio (incluidos los grupos de interés afectados).
- Establecer el nivel de sensibilidad de la información que la aplicación utilizará y las medidas de seguridad y control requeridas para asegurarla de acuerdo con dicho nivel.
- Consultar los informes de auditorías previas que afectan el proceso que se interviene con el proyecto de aplicación de software, con el fin de atender y asegurar los hallazgos que sean pertinentes su alcance.
- Configurar el estándar de debido cuidado necesario y suficiente para atender los retos propios del desarrollo de aplicaciones, que atienda las exigencias de los entes de control, el perfil de riesgo del negocio y las expectativas de la gerencia frente a sus objetivos estratégicos.

2.2 Dispositivos Móviles y teletrabajo.

OBJETIVO:

Garantizar el trabajo a distancia y el uso de dispositivos móviles de manera segura y responsablemente los servicios y equipos proporcionados.

2.2.1 Política para dispositivos móviles

CONTROL:

Se adoptan una política y medidas de seguridad de soporte, para gestionar los riesgos incrustados por el uso de dispositivos móviles.

PROCEDIMIENTO DE IMPLEMENTACIÓN:

Se debe crear una política para dispositivos móviles y adoptar medidas de apoyo a la seguridad adecuadas para gestionar los riesgos que se exhiben al usar aparatos móviles.

Se deben incluirse todos los dispositivos móviles que pudieran contener información propia de la Entidad y, que sean susceptibles a sufrir un incidente en el que se comprometa la seguridad del mismo.

Para esto se debe considerar dispositivo móvil y/o removible, como: Laptop, Notebooks, Teléfonos Celulares y sus tarjetas de memoria, dispositivos de almacenamiento removibles, como CDs, DVDs, Flash memory y dispositivo de almacenamiento de conexión USB, Tarjetas de identificación personal (control de acceso), dispositivos criptográficos, cámaras digitales y otros relacionados.

La política debe crear lineamientos para las conexiones a las redes inalámbricas de internet por parte de los dispositivos móviles y aparatos de terceros.

La política de dispositivos móviles, debe considerar los riesgos para la seguridad de la información del negocio al desarrollar trabajos con dispositivos móviles en lugares desprotegidos, y deberá tomar en cuenta entre otros para los dispositivos que la Entidad entrega a su personal:

- El registro de las características de los dispositivos móviles;
- Exigencias de protección física;
- Limitación a la instalación de software;
- Restricción a la conexión de servicios de información;
- Protección para el uso de servicios web y aplicaciones web.

Capacitar al personal sobre el manejo y aplicación de la política de dispositivos móviles.

2.2.2 Teletrabajo.

CONTROL:

Se implementan políticas y medidas de seguridad de soporte, para custodiar la información a la que se tiene acceso, que es procesada en los ambientes en los que se ejecuta teletrabajo.

	PROCEDIMIENTO DE IMPLEMENTACIÓN: Se construye una política y las medidas de seguridad para la información a la que se tienen accesos remotos para desarrollo de las actividades de la Entidad. Se desarrolla una política y medidas de seguridad para custodiar la información procesada o almacenada en los sitios de trabajo remoto. Esta política debe definir ciertas condiciones y restricciones para adherirse a la modalidad de trabajo remoto, como: - la presencia de seguridad física en el sitio de trabajo remoto; - la provisión insumos de acceso a escritorio remoto que prevenga el procesamiento y/o almacenamiento de información procesada en equipamiento de propiedad privada; - los requerimientos de seguridad en las telecomunicaciones; - protección o resguardo contra código malicioso y requerimientos de firewall; - un procedimiento de trabajo permitido, sistemas y servicios que el usuario remoto está autorizado a acceder, el horario y periodo de trabajo, la categorización de la información. Además, debe contemplar, la capacitación al personal en la política de teletrabajo. Detalle de no cumplimiento a la política de teletrabajo.
3. SEGURIDAD DE LOS RECURSOS HUMANOS.	
	3.1 Antes de Asumir el Trabajo
	OBJETIVO: <i>Asegurar que el personal, contratistas y terceros entiendan sus responsabilidades, y sean aptos para los roles para los cuales fueron considerados; y minimizar el riesgo de robo, fraude y mal uso de los medios.</i>
	3.1.1 Selección
	CONTROL: <i>Las revisiones de los antecedentes de todos los candidatos a un trabajo se llevan a cabo de acuerdo con las normativas vigentes y deben ser ajustadas a los requisitos de negocio, a los riesgos percibidos y a la clasificación de la información a la que tiene accesos.</i>
	PROCEDIMIENTO DE IMPLEMENTACIÓN: En esta revisión o verificación se debe tener en cuenta toda la privacidad selecta, la protección de la información de datos personales, la aplicación de la normativa laboral vigente, el manual de contratación, y debe, incluir lo siguiente: - Una revisión de la hoja de vida del solicitante o grupo de trabajo de encargado de contratar. - Una revisión de antecedentes penales. Asignar el cargo de responsable de seguridad a quien tenga mayor experiencia en gestión de seguridad de la información. Constituir como requisito para el ingreso a la Entidad, el conocimiento en el manejo de los conceptos de seguridad de la información requeridos por el SGSI y aplicaciones requeridas para el cargo.
	3.1.2 Términos y condiciones de Trabajo.
	CONTROL: <i>Los acuerdos contractuales con los funcionarios y la entidad, se establecen sus responsabilidades y las de la entidad en cuanto a la seguridad de la información.</i>
	PROCEDIMIENTO DE IMPLEMENTACIÓN: El personal de la entidad, cualquiera sea su situación de cargo, como parte de sus términos y condiciones iniciales de empleo, deben firmar un Compromiso de Confidencialidad o de no divulgación, referente al tratamiento de la información de la Entidad. Y una copia firmada del Compromiso debe ser documentada en forma segura por la Unidad de Recursos Humanos. De la misma forma, a través del Compromiso de Confidencialidad el funcionario declarará conocer y aceptar la existencia de ciertas actividades que pueden ser objeto de control y monitoreo. Dichas actividades deben ser registradas a fin de no violar el derecho a la privacidad del personal de la Entidad. Se debe establecer un procedimiento para la suscripción del Compromiso de Confidencialidad donde se debe incluir aspectos sobre: - Suscripción inicial del documento de Compromiso por parte de la totalidad del personal. - Modalidad de re suscripción en caso de ajustes en el texto del Compromiso. - Revisión del contenido del Compromiso anualmente.

	Las condiciones y términos de cargo establecerán la responsabilidad del uncionario en materia de seguridad de la información. Cuando se pueda, las condiciones y términos de cargo establecerán que estas responsabilidades se extienden más allá de los límites de la Entidad y del horario habitual de trabajo. Los derechos y obligaciones del funcionario respecto a la seguridad de la información, con relación a las normativas de Propiedad Intelectual o protección de datos, se deben encontrar aclarados e incluidos en los condiciones y términos de empleo.
	3.2 Durante la ejecución del Trabajo.
	OBJETIVO: <i>Asegurarse de que los funcionarios y contratistas tienen conocimiento y cumplen con sus responsabilidades en seguridad de la información.</i>
	3.2.1 Responsabilidades de la Dirección.
	CONTROL: <i>La dirección exige a todos los funcionarios la ejecución de la seguridad de la información de acuerdo con las políticas y procedimientos establecidos por la Entidad.</i>
	PROCEDIMIENTO DE IMPLEMENTACIÓN: La dirección deberá solicitar al personal, contratistas y usuarios terceros que empleen la seguridad en concordancia con las políticas y procedimientos determinados por la organización, dando cumplimiento con lo siguiente: - antes de que se le conceda el acceso a información sensible o a los sistemas de información debe estar debidamente informados de sus roles y responsabilidades de seguridad de la información; - ser dotados de guías para tener conocimiento sobre las expectativas de seguridad de su rol dentro de la Entidad; - estar motivados para dar cumplimiento con las políticas de seguridad de la Entidad; - plasmar con las condiciones y términos del cargo, donde incluyen las políticas de seguridad de la información de la Entidad y métodos apropiados de trabajo; - logren un nivel de conciencia respecto a la seguridad conforme con sus roles y responsabilidades dentro de la Entidad; - conservarse con las habilidades y calificaciones apropiadas. Si los funcionarios, contratistas y terceros no son conscientes de sus responsabilidades de seguridad, estos pueden producir daños considerables a la entidad. Una persona motivada, tiene más probabilidades de ser más confiable y producir menos incidentes de seguridad de la información.
	3.2.2 Toma de conciencia, educación y formación en la seguridad de la información.
	CONTROL: <i>Todos los funcionarios de la entidad, y en donde sea oportuno, reciben capacitación en toma de conciencia apropiada, y ajustes regulares sobre las políticas y procedimientos de la organización referidos a su cargo.</i>
	PROCEDIMIENTO DE IMPLEMENTACIÓN: - Todos los funcionarios de la Entidad cuando sea oportuno, los usuarios externos y los terceros que desarrollen funciones en la entidad, deben recibir una adecuada capacitación y actualización constante en el tema de la política, normas y procedimientos de la Entidad. Esto contempla los requerimientos de seguridad y las responsabilidades legales, así como la capacitación referente al uso correcto de las instalaciones de manipulación de información y el uso correcto de los recursos a su alcance. - El jefe de Recursos Humanos es el encargado de coordinar las tareas de capacitación de los funcionarios. - Periódicamente se debe revisar el material concerniente a la capacitación, con el fin de valorar la pertinencia o no de su actualización. - El personal que se incorpore a la Entidad debe recibir el material, instruyéndole el comportamiento esperado respecto a la seguridad de la información, antes de ser otorgados los privilegios de acceso a los sistemas de la Entidad que corresponden. - En otro sentido, se mediarán los medios técnicos precisos para notificar a todo el personal, las modificaciones o novedades en materia de seguridad, que deban ser considerados o tomados con un orden preferencial. Los esquemas de concientización: - El programa de sensibilización debe planificarse teniendo en cuenta los roles de los empleados en la

	organización, y en caso de ser relevante, las expectativas de la organización acerca de la sensibilización de seguridad de la información. - Habiendo en cuenta la información de la organización que se debe custodiar y los controles que se han implementado, para este fin, se deben establecerse de acuerdo con las políticas de seguridad de la información de la entidad y los procedimientos pertinentes. - Capacitación a los funcionarios en los procedimientos y tecnologías requeridas por el SGSI - Crear reuniones de sensibilización sobre el SGSI.
	3.2.3 Proceso disciplinario.
	CONTROL:
	<i>Se cuenta con un proceso formal, el cual es ser difundido para iniciar acciones contra funcionarios que hayan cometido infracción a la seguridad de la información.</i>
	PROCEDIMIENTO DE IMPLEMENTACIÓN:
	- Se sigue el proceso disciplinario formal examinado en las normativas reglamentarias dispuestas que rigen para los funcionarios que infrinjan las Políticas, Normas y Procedimientos de Seguridad de la Entidad. - Se pueden utilizar también el proceso disciplinario, como un aparato disuasivo para evitar que los funcionarios, contratistas y terceros que violen la políticas y procedimientos de la seguridad de la Entidad y cualquiera otra infracción de la seguridad. - Se incorporan premisas que permitan a la entidad saber de qué forma actuar en caso de que los colegas de trabajo y ex-colegas cometan alguna contravención en la seguridad, en caso de presentar mayor número de infracciones por parte de los colegas de la dirección, se les debe pedir el cumplimiento estricto de las políticas, procedimientos y demás lineamientos establecidos de seguridad de la información. - Se establecer el proceso de registro de infracciones de la política de seguridad.
	3.3 Terminación o cambio de puesto de trabajo.
	OBJETIVO:
	<i>Asegurar que los empleados, contratistas y terceros salgan de la entidad o cambien de trabajo de forma ordenada y se deben crear las responsabilidades para asegurar que la salida de la entidad sea manejada y se consuma la devolución de todo el equipo y se eliminen todos los derechos de acceso.</i>
	3.3.1 Terminación o cambio de responsabilidades de trabajo.
	CONTROL:
	<i>Las responsabilidades para ejecutar la terminación trabajo y el cambio de área son claramente definidas, comunicadas al funcionario y asignadas naturalmente.</i>
	PROCEDIMIENTO DE IMPLEMENTACIÓN:
	- Son claramente establecidas y asignadas las responsabilidades para realizar la desvinculación o cambio de puesto, así como también, se deben establecer los requerimientos de seguridad y responsabilidades legales a posteriori y, cuando sea adecuado, las responsabilidades comprendidas dentro de cualquier acuerdo de confidencialidad, y así como los términos y condiciones de trabajo con continuidad por un periodo definido de tiempo luego de la terminación del trabajo del funcionario, contratista o tercero. - Es fundamental informar a los funcionarios, contratistas y terceros de los cambios en el personal y los pactos de operación. - Al terminar un contrato con la institución, para los empleados de planta y el área de reclutamiento para contratistas, el área de recursos humanos es responsable de evidenciar que todos los activos de la organización que estén en posesión de funcionarios, contratistas y terceros sean devueltos. - La Entidad se asegura que se difunda sobre las responsabilidades en la finalización o cambio de empleo y esta contenga requisitos vigentes de seguridad de la información y responsabilidades legales y, donde corresponda, las responsabilidades contenidas en cualquier compromiso de confidencialidad que continúan por un período definido posterior al fin del trabajo del funcionario o del contratista. - Los ajustes en las responsabilidades o en el trabajo se operan como en la terminación de la responsabilidad actual o el trabajo en combinación con el inicio de la nuevo trabajo o responsabilidad asumida en la entidad.
	4. GESTIÓN DE ACTIVOS.
	4.1 Responsabilidad sobre los activos.
	OBJETIVO:
	<i>Asegurar que todos los activos de información de la organización, posean un responsable y/o custodio, que garanticen la preservación de la confidencialidad, integridad y disponibilidad de la información, en cada uno de los ambientes de la Entidad.</i>

4.1.1 Inventario de activos.

CONTROL:

Están claramente identificados todos los activos de la entidad, registrados en un inventario con los más importantes.

PROCEDIMIENTO DE IMPLEMENTACIÓN:

Se identifican todos los activos de información de la Institución.

Existen varios tipos de activos, que contienen:

- activos de software: software de sistemas, software de aplicaciones, materiales de desarrollo, y utilitarios;
- información: archivos de datos, bases de datos, convenios, documentación;
- activos intangibles, tales como la reputación y la imagen de la Entidad.
- activos físicos: equipos de computación, equipos de comunicaciones, dispositivos removibles y otros equipamientos;
- instalaciones: edificaciones, sitios físicos, instalación eléctrica, red de agua y gas;
- servicios: servicios de comunicaciones y cómputo y servicios generales.
- individuos y sus evaluaciones, destrezas y experiencia;

El inventario de ser ajustado ante cualquier alteración de la información es registrada y revisada por lo menos periódicamente.

La persona responsable de consolidar el inventario y mantenerlo actualizado, es a la que se lo asignó los activos fijos de la Entidad.

4.1.2 Propiedad de los activos.

CONTROL:

Los registros de activos fijos tienen a funcionarios como responsable o propiedad para su uso y custodio.

PROCEDIMIENTO DE IMPLEMENTACIÓN:

Todos los activos y la información juntamente a sus medios tecnológicos de procesamiento de información son de propiedad de un responsable determinado en la Entidad.

Se nombrarán los propietarios de los activos registrados, los cuales deben cumplir sus funciones de propietario, para:

- clasificar los activos en según su valor
- reportar sobre los cambios que afecten el inventario de activos
- establecer los requisitos de seguridad de los activos
- estar al pendiente y ver por el mantenimiento e implementación de los controles de seguridad necesarios en los activos.

Se conserva la responsabilidad del cumplimiento de las funciones como propietarios de activos, si bien estas funciones se pueden delegar a los funcionarios idóneos de la Entidad. Esta delegación por parte de los propietarios de los activos y documentada por los mismos.

4.1.3 Uso aceptable de los activos.

CONTROL:

Se identifica, documenta e implementa reglas para el uso aceptable de la información y de los activos asociados a recursos o herramientas de tratamiento de información.

PROCEDIMIENTO DE IMPLEMENTACIÓN:

Se identifican, documentan e implementan reglas para el uso aceptable de la información y los activos asociados a recursos o herramientas de tratamiento de la información.

Definitivamente sin restricción los funcionarios, contratistas y terceras partes, deben conocer las reglas para el uso aceptable de la información y los activos asociados con los ambientes de generación de la información, incluyendo:

- correo electrónico institucional,
- puntos de trabajo,
- sistemas de gestión,
- aparatos móviles,
- herramientas y equipos de comunicación de contenidos.

	4.1.4 Devolución de activos. CONTROL: <i>Todos los funcionarios y usuarios de terceras partes devuelven todos los activos de la entidad que se encuentren en su posición o cargo, al terminar contrato o acuerdo de prestación de servicios.</i> PROCEDIMIENTO DE IMPLEMENTACIÓN: Están insertados en proceso que, a la finalización del contrato, los activos de la organización deberán ser devueltos por los funcionarios, vale decir que, al finalizar su relación contractual, que incluya la devolución de todos los activos físicos y tecnológicos entregados previamente de propiedad de la entidad. - En casos donde un empleado, contratista o tercero, utilice sus equipos personales propios, se deberán cumplir con los procedimientos para garantizar que la información generada se transfiera a la entidad y que de manera segura se elimine del equipo. - En trascurso del período de aviso de alejamiento de la entidad, esta se deberá controlar las copias no autorizadas de la información pertinente de los funcionarios y contratistas despedidos. - En caso de el funcionario o el usuario externo cuente con conocimiento significativo para las operaciones continuas, por su importancia, esta información se debería documentar y transferir a la organización Separación de la cuenta de usuario perteneciente al personal que se está alejando de la entidad. Establecer en el procedimiento de desvinculación de un personal o cambio de puesto, la entrega formal de los activos que sean de su propiedad. 4.2 Clasificación de la información. OBJETIVO: <i>Asegurar que la información recibe el nivel de clasificación adecuado de protección, de acuerdo a su importancia para la entidad.</i> 4.2.1 Clasificación de la Información. CONTROL: <i>La información se clasifica en relación de los requisitos legales, valor, criticidad y susceptibilidad a divulgación o modificación no autorizada para la entidad.</i> PROCEDIMIENTO DE IMPLEMENTACIÓN: Se evalúan los elementos de la seguridad de la información para clasificar los activos de Información, basadas en: confidencialidad, integridad y disponibilidad. En ese sentido, seguidamente, se describe la metodología de clasificación de la información propuesta en función a cada uno de los elementos o características establecidas: • Confidencialidad: - Información que puede ser conocida y utilizada por todo el personal de la Entidad y algunas organizaciones externas debidamente autorizadas, y una divulgación o uso no autorizados podría generar riesgos o pérdidas leves para la entidad, el Sector Público nacional o terceros, RESERVADA - USO INTERNO - Información que puede ser utilizada y conocida sin previa autorización, por cualquier persona, mismo sea funcionario de la Entidad o no. PUBLICO. - Información que sólo puede ser utilizada y conocida por un grupo de funcionarios, que la requieran para realizar su trabajo, y uso no autorizados o divulgación, podría generar pérdidas importantes a la Entidad, al Sector Público nacional o a terceros. RESERVADA – CONFIDENCIAL - Información que sólo puede ser utilizada y conocida por un grupo muy reducido de funcionarios, generalmente de la alta dirección de la Entidad, y cuyo uso no autorizados o divulgación podría generar pérdidas graves al mismo, al Sector Público nacional o a terceros. RESERVADA SECRETA • Integridad: - Información con modificación no autorizada puede remediarse de manera fácil, o no afecta las operaciones de la institución. - Información cuya modificación no autorizada puede remediarse, aunque podría causar pérdidas leves para la institución, el Sector Público Nacional o terceros. - Información con modificación no autorizada es de difícil reparación y podría causar pérdidas significativas para la institución, el Sector Público Nacional o terceros. - Información con modificación no autorizada no podría repararse, ocasionando pérdidas graves la institución, al Sector Público Nacional o a terceros.
--	--

• **Disponibilidad:**

- Información no accesible, no afecta las operaciones de la Entidad.
- Información no accesible permanente en transcurso de un periodo no menor a una semana, podría causar pérdidas significativas para la entidad, el Sector Público Nacional o terceros.
- Información no accesible permanente en transcurso de un periodo no menor a un día, podría causar pérdidas significativas a la entidad, al Sector Público Nacional o a terceros.
- Información no accesible permanente en transcurso de un periodo no menor a una hora, podría causar pérdidas significativas a la entidad, al Sector Público Nacional o a terceros.

Por tanto, es importante asignar a la información un valor por cada uno de estos criterios. Para posteriormente clasificar la información en una de las siguientes condiciones:

- CRITICIDAD BAJA: ninguno de los valores asignados supera el 1.
- CRITICIDAD MEDIA: alguno de los valores asignados es 2
- CRITICIDAD ALTA: alguno de los valores asignados es 3

Puede asignar o cambiar el nivel de clasificación, solo el propietario de la información, dando cumplimiento con los siguientes requisitos previos:

- Establecer una fecha de efectividad.
- Notificar al custodio del recurso.
- Realizar los cambios precisos para que los usuarios tengan conocimiento la nueva clasificación.

Posterior a la clasificación de la información, el propietario identificará los recursos agrupados (equipamiento, sistemas, servicios y otros relacionados).

De ahí en adelante se identifican como información o datos clasificados, a aquellas que se enmarquen en los tres niveles de confidencialidad.

4.2.2 Etiquetado y manejo de la información.

CONTROL:

Se desarrolla e implanta un conjunto adecuado de procedimientos para el etiquetado y tratamiento de la información, de acuerdo con el esquema de clasificación de información adoptado por la organización.

PROCEDIMIENTO DE IMPLEMENTACIÓN:

Se crean procedimientos para el etiquetado y manejo de la información, de acuerdo al esquema de clasificación de información definidos en la entidad. Estos incorporarán los recursos adecuados de información tanto en formatos electrónicos como físicos. Por tanto, para el procesamiento de la información, se concentrarán las siguientes actividades:

- Almacenamiento;
- Copia;
- Transferencia por correo, fax, E-mail;
- Transferencia oral (correo de voz, telefonía fija y móvil y contestadores automáticos).
- Transferencia a través de mecanismos de intercambio de archivos, como almacenamiento masivo remoto

Se establecen los procedimientos de manejo seguro, para cada uno de los niveles de clasificación, incluyendo las actividades de almacenamiento, procesamiento, transmisión y destrucción.

4.2.3 Manejo de activos.

CONTROL:

Se desarrolla e implementa procedimientos para la manipulación de activos, de acuerdo con el esquema de clasificación de información adoptado por la organización.

PROCEDIMIENTO DE IMPLEMENTACIÓN:

Para dar a la información de la entidad el nivel apropiado de protección, etiquetado y manejo en base a la clasificación de información que se maneje, se deben crear controles y procedimientos adecuados.

Así mismo, están establecidos los procesos para el manejo, procesamiento, almacenamiento y comunicación de la información acorde a su clasificación, considerando los siguientes elementos:

- Limitaciones de acceso que apoyen los requisitos de protección para cada nivel de clasificación;
- Protección de copias permanentes y temporales de información a un nivel congruente con la protección de la información original;
- Actualización de un registro formal de los que tienen a su cargo los activos autorizados;
- Almacenamiento de los activos de Tecnologías de Información, acorde con las especificaciones del fabricante o proveedor;
- Señalización de todas las copias de medios para la atención del recipiente autorizado.

Capacitar al personal de la entidad con privilegios de acceso al activo de información en las tecnologías, procedimientos, políticas que el SGSI establezca. Establecer los diferentes mecanismos de protección conforme con la clasificación de los activos de información y el resultado del estudio de riesgos.
4.3 Manejo de Medios.
OBJETIVO: <i>El personal de la entidad, usuarios externos y partes interesadas, que requieran utilizar periféricos o medio de almacenamiento para el cumplimiento de sus funciones, deben efectuar cumpliendo con los lineamientos de seguridad de la entidad.</i>
4.3.1 Gestión de Medios extraíbles.
CONTROL: <i>Se establecen procedimientos para la gestión de los medios informáticos removibles, de acuerdo con el esquema de clasificación adoptado por la entidad.</i>
PROCEDIMIENTO DE IMPLEMENTACIÓN: Se establecen procedimientos para la gestión de medios informáticos removibles, como discos, pendrives e informes impresos, mismo debe ser controlado e implementado por la autoridad del área informática, con la asistencia del responsable de Seguridad de la Información. Se deben tomar en cuenta las siguientes pautas para la gestión de medios extraíbles: - Todos los medios extraíbles se deben almacenar o custodiar en un ambiente seguro y protegido, de acuerdo con las especificaciones del proveedor o fabricante. - Cuando se requiera retirar, se debería requerir una autorización para los medios extraíbles de la entidad y se debe mantener un registro en detalle de tales retiros para poder mantener un seguimiento de auditoría. - Si la confidencialidad o la integridad de los datos son consideraciones importantes, se deberán utilizar técnicas criptográficas para proteger los datos de los medios extraíbles; - Se deben guardar muchas copias de datos importantes en medios apartados para minimizar aún más el riesgo accidental de pérdidas de datos o daños. - Se debe establecer un registro de medios extraíbles para evitar las pérdidas de datos. - Solo corresponde habilitar si existe una razón justificada, las unidades de medios extraíbles. - En donde haya la necesidad de utilizar medios extraíbles, se debe vigilar la transferencia de información a estos medios. - Se debe establecer la documentación de los procedimientos y los niveles de autorización. Reportar de inmediato las incoherencias o infracciones en el procedimiento de la gestión de medios extraíbles. Capacitar al personal y terceros relacionados, sobre los procedimientos de gestión de medios extraíbles del SGSI.
4.3.2 Disposición de Medios.
CONTROL: <i>Se disponen de forma segura los medios y sin riesgo cuando ya no se requieran, utilizando procedimientos formales.</i>
PROCEDIMIENTO DE IMPLEMENTACIÓN: La autoridad del área Informática conjuntamente con el responsable de la Seguridad de la Información, establecen procedimientos para la eliminación segura de los medios de soportes de la información, mismos respetando la normativa legal vigente. Los procedimientos de disposición de medios deben tomar en cuenta para el almacenamiento y eliminación segura de los siguientes elementos: - Audios grabados. - Documentación en papel. - Reportes de salida. - Discos u otros dispositivos extraíbles. - Cintas magnéticas. - Medios de almacenamiento óptico. - Registro de programas. - Datos de prueba.

	- Documentación o manual del sistema. La valoración de los mecanismos de eliminación de medios debe considerar el tipo de dispositivo y la criticidad de la información comprendida. 4.3.3 Transferencia de medios físicos. CONTROL: <i>Los medios físicos que contienen información se protegen contra acceso no autorizado, uso indebido o sustracción durante el transporte.</i> PROCEDIMIENTO DE IMPLEMENTACIÓN: Los procedimientos de transferencia establecidos de medios informáticos entre diferentes sitios, incorporan: a) El reconocimiento de controles especiales, cuando esto resulte necesario, a fin de proteger la información importante contra divulgación o modificaciones no autorizadas. b) El uso de medios de transferencia o servicios de mensajería confiables. El dueño de la Información a transportar debe determinar cuál de los servicios de mensajería a utilizar conforme la criticidad de la información a transferir. c) Suficiente protección para envío de medios a través de servicios de mensajería, siguiendo las especificaciones de los proveedores.
	5. CONTROL DE ACCESOS.
	5.1 Requisitos de negocio para el control de accesos. OBJETIVO: <i>Controla el acceso a la información de los servicios de procesamiento de información en base a los requisitos de seguridad establecidos en la entidad.</i>
	5.1.1 Política de control de accesos. CONTROL: <i>El documento de la política de control de acceso tiene establecido con claridad las reglas y los derechos para el control del acceso de cada funcionario a los sistemas que procesan información confidencial de la entidad.</i> PROCEDIMIENTO DE IMPLEMENTACIÓN: En la aplicación de las políticas de controles de acceso, se deben tomar los siguientes aspectos: - Selecciona toda la información relacionada con las aplicaciones. - Evidencia los requerimientos de seguridad de cada una de las aplicaciones. - Establece los perfiles de acceso de usuarios comunes, a cada nivel de puestos de trabajo. - Define criterios acordes entre Política de Control de Acceso y la Política de Clasificación de Información de los distintos sistemas y redes. - Establece la normativa aplicable y las obligaciones contractuales referente a la protección del acceso a datos y servicios. - Gestiona los derechos de acceso en un ambiente compartido y de red, que se muestren todos los tipos de conexiones disponibles.
	5.1.2 Acceso a redes y a servicios en red CONTROL: <i>Los funcionarios solo tienen acceso a redes y a servicios de red para su utilización están específicamente autorizados.</i> PROCEDIMIENTO DE IMPLEMENTACIÓN: Se establecen procedimientos para el control de acceso a los servicios de red tanto internos como externos, las conexiones no seguras de red pueden generar problemas a la entidad. Por tanto, se consideran las siguientes directrices: - El monitoreo a los funcionarios, protege el acceso a las conexiones de red y los servicios de red a las que tienen acceso. - La política sobre el uso de los servicios de red está acorde con la política de control de acceso. El desarrollo de procedimientos para acceso a red y a servicios de red, deben comprender: - La identificación de las redes y servicios de red a los cuales se admite el acceso. - La elaboración de normas y procedimientos de autorización para seleccionar funcionarios, redes y servicios de red a los cuales se les otorgará el acceso. - El Establecimiento de controles y procedimientos de administración para resguardar el acceso a las conexiones y servicios de red.

5.2 Gestión de acceso de usuario.
OBJETIVO: <i>Asegura el acceso de funcionarios autorizados a los sistemas de información de la entidad estableciendo procedimientos para controlar la asignación de los derechos de acceso a los sistemas y servicios de información.</i>
5.2.1 Registro y eliminación del registro de usuarios
CONTROL: <i>Se controla el registro y eliminación de funcionarios con el fin de verificar y revocar el acceso a los sistemas y servicios de información de la entidad.</i>
PROCEDIMIENTO DE IMPLEMENTACIÓN: La autoridad de Seguridad Informática definirá un procedimiento formal de registro de usuarios para otorgar y revocar el acceso a todos los sistemas, bases de datos y sistemas de información. El procedimiento de control de acceso para registro y eliminación de usuarios incluye: - La aplicación de una identificación única para que los funcionarios queden vinculados y sean responsables de las acciones que realizan. - La verificación de que el funcionario tenga autorización del área responsable del sistema para el uso del sistema o servicios de información. - Brinda a los funcionarios una declaración escrita de los derechos de acceso a los sistemas de información de la institución. - El mantenimiento formal de los funcionarios registrados para utilizar un sistema de información. - El retiro y bloqueo inmediato de los derechos de acceso de los funcionarios de han cambiado de función de trabajo o que haya dejado la institución.
5.2.2 Suministro de acceso de usuarios
CONTROL: <i>Se implementa un proceso de suministro de acceso formal de usuarios para asignar y revocar derechos de acceso a todos los sistemas y servicios de la entidad.</i>
PROCEDIMIENTO DE IMPLEMENTACIÓN: - Se establecen los procedimientos de control de la Gestión de los derechos de acceso asignados a los usuarios a través de entrenamiento y sensibilización en la aplicación del procedimiento de registro y cancelación de cuentas de usuario. - Se registra reportes de anomalías sobre el incumplimiento al procedimiento de registro y cancelación de cuentas de usuario.
5.2.3 Gestión de derechos de acceso privilegiado
CONTROL: <i>Se restringe y controla la asignación y el uso de privilegios de los sistemas y servicios de información de la entidad.</i>
PROCEDIMIENTO DE IMPLEMENTACIÓN: Se toman las siguientes consideraciones: - Se identifican a los funcionarios y privilegios de acceso asociados con cada producto del sistema; sistemas operativos, sistemas de gestión de bases de datos y aplicaciones. - Se asignan los privilegios a los funcionarios sobre los principios de necesidad de uso acorde con la política de control de acceso. - Se conserva un proceso de autorización y un registro de todos los privilegios asignados y se aplica el desarrollo y empleo de rutinas del sistema para evitar la necesidad de otorgar privilegios a los funcionarios. - Se limita y controla la asignación y uso de privilegios a los funcionarios, debido a que el uso inadecuado de los privilegios del sistema resulta frecuentemente un factor muy importante que contribuye a la falla de los sistemas a los que se ha accedido ilegalmente.
5.2.4 Gestión de información de autenticación secreta de usuarios
CONTROL: <i>La asignación de autenticación secreta se controla a través de un proceso formal de gestión.</i>
PROCEDIMIENTO DE IMPLEMENTACIÓN: Importante identificar aquellos servicios y aplicaciones que manejan una contraseña cifrada en la Entidad, para proteger la confidencialidad.

	Por tanto, considerar los siguientes requisitos: - Se exige a los funcionarios la firma de una declaración para mantener confidencialidad de las contraseñas personales. - Se suministra una contraseña temporal a los funcionarios para que se cambie por una contraseña propia del usuario cuando se ingresa por primera vez a un sistema de información de la entidad. - Se verifica la identidad del funcionario antes de proporcionarle una contraseña temporal.
	5.2.5 Retiro o ajuste de los derechos de acceso.
	CONTROL: <i>Se retiran los derechos de accesos a los sistemas vinculados a los funcionarios de la entidad, cuando estos son desvinculados o cuando finalizan sus contratos y se asignan nuevos usuarios de accesos a los funcionarios que cambian de área o funciones.</i>
	PROCEDIMIENTO DE IMPLEMENTACIÓN: Posterior a la desvinculación de los funcionarios, los derechos de acceso a la información y a los activos asociados con instalaciones y servicios de procesamiento de información son removidos o suspendidos. Para lo cual, se toman las siguientes consideraciones: - Se reportan funcionarios desvinculados de la institución, para que los mismos sean retirados los accesos a los sistemas de información asignados. - En caso de que los funcionarios son removidos o cambiados de área o unidad, se le asignan nuevos accesos de acuerdo a su nuevo cargo o función. - Se revisan los logs de acceso a las aplicaciones para detectar anomalías sobre la política de control de acceso.
	5.3 Responsabilidades del usuario.
	OBJETIVO: <i>Evita el acceso de los funcionarios no autorizados, el robo o la puesta en peligro la información y de los servicios de procesamiento de información de la entidad.</i>
	5.3.1 Uso de información confidencial para la autenticación.
	CONTROL: <i>Se exige a los funcionarios, el cumplimiento de buenas prácticas de seguridad en la selección y el uso de las contraseñas.</i>
	PROCEDIMIENTO DE IMPLEMENTACIÓN: Los funcionarios de la entidad: - Mantienen la confidencialidad de las contraseñas asignadas. - Seleccionan contraseñas con una combinación de caracteres, números y combinación de letras mayúsculas y minúsculas. - Cambian las contraseñas temporales en el primer registro de inicio y no incluyen contraseñas con en ningún registro de proceso automatizado. - No comparten contraseñas con otros funcionarios de la entidad.
	5.4 Control de acceso a sistemas y aplicaciones.
	OBJETIVO: <i>Evita el acceso no autorizado a los sistemas y aplicaciones de la entidad, utilizando medios de seguridad para restringir el acceso de usuarios no autorizados.</i>
	5.4.1 Restricción del acceso a la información.
	CONTROL: <i>Se restringe el acceso a los usuarios de la información y a los funcionarios que realizan mantenimientos a la información y funciones a las aplicaciones acuerdo con la política de control de acceso.</i>
	PROCEDIMIENTO DE IMPLEMENTACIÓN: Los usuarios de sistemas de aplicación y los funcionarios de soporte, tienen acceso a la información y a las funciones de los sistemas de aplicación de conformidad con la Política de Control de Acceso definida. Para brindar el sustento a los requerimientos de limitación de accesos, e aplican los siguientes controles: - Se crean esquemas de interfaz para control a las funciones de sistemas de aplicaciones. - Se restringe el acceso, cuando se realizan mantenimientos a los equipos de tecnología de información hasta que se concluya.

	5.4.2 Procedimiento de ingreso seguro. CONTROL: <i>El acceso a los sistemas y aplicaciones se controla a través de una verificación y aplicación de un registro de ingreso seguros.</i> PROCEDIMIENTO DE IMPLEMENTACIÓN: El procedimiento de un registro de acceso seguro a sistemas y aplicaciones, está diseñado para minimizar la oportunidad de acceso no autorizado y se cumplen los siguientes requerimientos: - No se muestran identificadores de aplicación ni de sistema hasta que el proceso de registro de inicio seguro se complete exitosamente. - Se muestra una advertencia de notificación general indicando que solo tienen acceso al equipo de computación los funcionarios autorizados. - No se muestran mensajes de ayuda durante el procesamiento de registro de inicio que ayude a un funcionario no autorizado a ingresar a un sistema de información de la entidad. - Se limita cierta cantidad de los intentos permitidos de registro de inicio, posteriormente se requiere apoyo técnico para su habilitación de registro de inicios
	5.4.3 Gestión de contraseñas de usuario. CONTROL: <i>El sistema para la gestión de contraseñas es interactivo y asegura la calidad y confiabilidad de todos los funcionarios de la entidad.</i> PROCEDIMIENTO DE IMPLEMENTACIÓN: El sistema de asignación de contraseñas se controla: - Hacer cumplir el uso de identificadores de usuarios ID individual y contraseñas para conservar la confidencialidad. - Permite a los usuarios la selección y el cambio de contraseñas y tiene incluido un reporte de confirmación para tomar en cuenta los errores de los ingresos. - Conserva un registro de las contraseñas de funcionarios previas para evitar la reutilización de contraseñas caducas. - Almacena los archivos de contraseñas en forma separada de los datos del sistema de aplicación.
	5.4.4 Uso de programas utilitarios privilegiados CONTROL: <i>Se restringen y controlan estrictamente el uso de herramientas de sistemas o programas utilitarios que tienen la capacidad de anular el sistema y los controles de las aplicaciones de la entidad.</i> PROCEDIMIENTO DE IMPLEMENTACIÓN: Se consideran los siguientes aspectos para este proceso: - Se establece un procedimiento de identificación, autorización y autenticación para los programas utilitarios. - Se limita el uso de programas utilitarios a un número mínimo para los funcionarios autorizados. - Se limita la disponibilidad de los programas utilitario y continuar con la política de que ningún funcionario pueda instalar y ejecutar archivos o aplicaciones por voluntad propia. - Se verifica que los logs de eventos del uso de los programas utilitarios sean examinados por auditoría. - Se establece que los programas utilitarios considerados privilegiados únicamente puedan ser utilizados con roles de administrador.
	5.4.5 Control de acceso al código fuente de los programas. CONTROL: <i>Se restringe el acceso a los códigos fuente de los programas.</i> PROCEDIMIENTO DE IMPLEMENTACIÓN: Se establece un procedimiento para restringir acceso a los códigos fuente de los sistemas y se cumplen los siguientes requisitos: - El responsable de seguridad de Información, conjuntamente con la autoridad de DNTICs, prueban la función de <i>administrador de programas fuentes</i> al personal del área de desarrollo de sistemas. - El jefe de Desarrollo de Sistemas, es la que controla al personal de su dependencia el uso adecuado de código fuente de sistemas o aplicaciones de la entidad. - Los programas fuentes solicitados por el personal de desarrollo, para su modificación, manteniendo en todo momento la correlación programa fuente/ejecutable, son facilitados a través de un registro.

	- Se establece que todo programa objeto o ejecutable en producción tenga un único programa fuente asociado que garantice su origen. - Se establece un procedimiento que garantiza la migración a producción el módulo fuente, se cree el código ejecutable correspondiente en forma automática. - Se realizan copias de respaldo automatizado de los programas fuentes cumpliendo los requisitos de seguridad establecidos por la entidad en los procedimientos que surgen de la presente política.
6. CIFRADO.	
	6.1 Controles criptográficos.
	OBJETIVO: <i>Asegurar el uso apropiado de la criptografía para proteger la autenticidad, confidencialidad y la integridad de la información, que todos los sistemas de información, posean un certificado digital, permitiendo, de esta manera, que toda la información que viaja de origen a destino, lo haga de manera cifrada.</i>
	6.1.1 Política sobre el uso de controles criptográficos
	CONTROL: <i>Por medio de la política implementada para el uso de controles criptográficos se protege adecuadamente la información de la entidad.</i>
	PROCEDIMIENTO DE IMPLEMENTACIÓN: Se utilizan controles criptográficos para los siguientes aspectos: - Para la protección de claves o usuarios de acceso a sistemas, datos y servicios por el personal no autorizado. - Para la transmisión de información a través de red o cualquier otro medio fuera del ámbito de la Entidad. - Para el resguardo de información, cuando se realizan de evaluación de riesgo a los sistemas o información por los funcionarios dispuestos.
	6.1.2 Gestión de Claves.
	CONTROL: <i>Existe una política sobre el uso, protección y el ciclo vida de las claves criptográficas, a través de todo su ciclo de vida.</i>
	PROCEDIMIENTO DE IMPLEMENTACIÓN: Se establecen en la entidad procedimientos para la administración de claves criptográficos necesarios, y cumplen los siguientes aspectos: - Crear claves para diferentes aplicaciones y sistemas criptográficos de manera segura. - Entregar claves de forma segura a los usuarios y como activar. - Almacenamiento o archivo de claves de criptografía. - Cambiar o actualizar, revocar o desactivar claves, incluyendo reglas sobre cómo y cuándo. - Recuperación de claves pérdidas o alteradas como parte de la gestión de la continuidad de las operaciones de la entidad. Con el propósito de minimizar la probabilidad de riesgo, las claves tienen fechas de inicio y caducidad de vigencia, establecidas de manera que sólo puedan ser utilizadas por el lapso de tiempo determinado.
7. SEGURIDAD FÍSICA Y DEL ENTORNO.	
	7.1 Áreas seguras.
	OBJETIVO: <i>Previene el acceso físico no autorizado y el daño a la información y el edificio de la entidad, los servicios de procesamiento de la información esta ubicadas en áreas seguras.</i>
	7.1.1 Perímetro de seguridad física.
	CONTROL: <i>La puerta de acceso de la entidad cuenta con un estricto control a personal que visitan la institución, y se utilizan puertas de acceso con biométrico a los ambientes en los cuales se encuentran el procesamiento de la información.</i>
	PROCEDIMIENTO DE IMPLEMENTACIÓN: Se consideran los siguientes lineamientos para la seguridad física en la entidad: - El inmueble donde se encuentra el equipamiento tecnológico de la entidad, se encuentra protegido con una construcción sólida y los accesos se encuentran instalados aparatos biométricos.

	- Se efectúan controles estrictos inicialmente en la puerta de ingreso a la infraestructura de la entidad, para personas ajenas de la institución se les exige obligatoriamente su cedula de identidad, a cargo del personal de seguridad. - El personal de seguridad registra todos los ingresos al edificio.
	7.1.2 Controles físicos de acceso.
	CONTROL:
	<i>Las áreas de procesamiento de información esta protegidas a través de registro biométrico, que garantiza el ingreso solo al personal autorizado.</i>
	PROCEDIMIENTO DE IMPLEMENTACIÓN:
	Par operaciones de acceso se toman en cuenta las siguientes reglas:
	- En la puerta principal el personal de seguridad registra fecha y hora de acceso de personas ajenas o visitantes a la entidad. - Se encuentra normado que los funcionarios de la entidad porten credenciales en lugar visible para el acceso al edificio de la entidad para desarrollar sus labores. - Los ambientes físicos donde se generan y almacenan información sensible, se restringe el acceso únicamente al personal autorizado, por medio de huellas dactilares para autorizar y su validación de acceso.
	7.1.3 Seguridad de oficinas, recintos e instalaciones.
	CONTROL:
	<i>Se tiene definida la seguridad física para oficinas, recintos y todas las instalaciones de la entidad.</i>
	PROCEDIMIENTO DE IMPLEMENTACIÓN:
	Se establecen las siguientes medidas de protección para áreas protegidas:
	- Las instalaciones que manejan información confidencial en la entidad son discretas y no tienen señalizaciones sobre el propósito principal, si señales ovias fuera y dentro de los ambientes, que identifican la presencia de actividades de procesamiento de información. - Los directorios y listado de números telefónicos internos que describen ubicaciones de servicios de procesamiento de información, son estrictamente resguardadas y no son proporcionadas a personas externas.
	7.1.4 Protección contra las amenazas externas y ambientales.
	CONTROL:
	<i>Se tiene diseñadas protecciones físicas contra daños de incendios, corte de energía eléctrica, terremoto e inundaciones en la entidad.</i>
	PROCEDIMIENTO DE IMPLEMENTACIÓN:
	- Los combustibles o peligrosos se encuentran aislados del edificio de la entidad, y en caso de un incendio se tienen instalados alertas contra incendios y extintores en cada área para que sean utilizados por los funcionarios en caso de alguna contingencia al respecto. - Se capacitan a los funcionarios representantes de cada área, sobre primeros auxilios, contingencias por incendio o inundación. - Los equipos tecnológicos y sus accesorios se encuentran adecuadamente ubicados para evitar daño en caso de un desastre ambiental que afecte al edificio de la entidad.
	7.1.5 El trabajo en áreas seguras.
	CONTROL:
	<i>Son diseñados y aplicados procedimientos para trabajo en áreas seguras</i>
	PROCEDIMIENTO DE IMPLEMENTACIÓN:
	Por su importancia se consideran los siguientes aspectos:
	- Existen ambientes específicos y adecuado para el desarrollo laboral de los funcionarios de la entidad. - Se limitan el acceso a los funcionarios que no son del área o a personas ajenas hasta cierto lugar y contacto con ciertos funcionarios autorizados. - Existe una normativa interna para la prohibición de ingreso de equipos de computación móvil, fotográficos, de vídeo, audio o cualquier otro tipo de equipamiento personal, a los ambientes donde se procesan información. - Existe instructivos y normativas internas que prohíbe comer, beber y fumar dentro de las instalaciones de procesamiento de la información.

7.2 Seguridad de los equipos.
OBJETIVO: <i>Evitar pérdida, daño o rodo de los equipos tecnológicos y la interrupción de las actividades de la entidad, los equipos se encuentran protegidos contra cualquier amenaza física o ambientales.</i>
7.2.1 Ubicación y protección de los equipos.
CONTROL: <i>Los equipos están ubicados y protegidos sobre escritorios adecuados para reducir los riesgos de amenazas y peligros del entorno, y las posibilidades de accesos no autorizado.</i>
PROCEDIMIENTO DE IMPLEMENTACIÓN: Las directrices que se consideran para la protección de los equipos son: - Los equipos se encuentran en lugares estratégicos de cada ambiente, de modo que se minimice el acceso a personas no autorizadas a la extracción de la información generada. - Los servicios de procesamiento de información que manejan los datos sensibles, se encuentran en sitios específicos y exclusivos para este fin, de manera que reduce el riesgo de visualización de la información por personas no autorizadas durante la ejecución de la operación. - Se tienen instalados áreas de tecnologías de procesamiento y almacenamiento de información, aires acondicionados y se monitorean diariamente las condiciones ambientales como la temperatura y humedad. - Existe instalación de para rayos para su protección de equipos tecnológicos de la entidad y se tienen filtros protectores para las fuentes de energía entrantes y las líneas de comunicación.
7.2.2 Servicios de suministro.
CONTROL: <i>Los equipos tecnológicos se encuentran protegidos contra fallas de energía y otras interrupciones causadas por los servicios de suministro.</i>
PROCEDIMIENTO DE IMPLEMENTACIÓN: - El equipamiento tecnológico se encuentra protegido con respecto a las posibles fallas en el suministro de energía u otras anomalías eléctricas. - Para el suministro de energía se han instalado maquinas generadores de energía en caso de un corte o falla de suministro. - Se tiene instalado UPS para asegurar el apagado regulado y sistemático o la ejecución continua del equipamiento de la entidad.
7.2.3 Seguridad en el cableado.
CONTROL: <i>El cableado de energía eléctrica y de telecomunicaciones de la entidad que transporta datos a los servicios de información están protegidos contra interceptaciones y daños internos externos.</i>
PROCEDIMIENTO DE IMPLEMENTACIÓN: Se consideran los siguientes lineamientos para la seguridad del cableado: - El cableado de red está protegido con ductos contra la interceptación de personas que quieran extraer información de la entidad. - Los cables de energía eléctrica están identificados y separados de los cables de comunicaciones para evitar interferencia de la señal. - Los cables están claramente identificados para reducir los errores en el manejo, tales como conexiones accidentales de cables erróneos de red y energía eléctrica.
7.2.4 Mantenimiento de los equipos.
CONTROL: <i>Los equipos tecnológicos reciben mantenimiento adecuado para asegurar la continua disponibilidad e integridad.</i>
PROCEDIMIENTO DE IMPLEMENTACIÓN: Se consideran los siguientes lineamientos para el mantenimiento de los equipos tecnológicos: - Se da cumplimiento a las especificaciones e intervalos de servicios provistos por los proveedores el mantenimiento de los equipos. - Solo el personal de soporte técnico autorizado realiza las reparaciones y cambios de partes en equipos. - Se elaboran registro de fallas reales o sospechosas de todo el mantenimiento preventivo y correctivo realizados.

- Se tienen establecidos los periodos de mantenimiento de todos los equipos de tecnológicos de la entidad que se encuentran con garantía para que sea realizado el proveedor externo.
7.2.5 Salida de activos fuera de las dependencias de la Entidad.
CONTROL: <i>Los equipos, la información o el software no se pueden retirar de su sitio sin autorización previa.</i>
PROCEDIMIENTO DE IMPLEMENTACIÓN: Se tiene implementados los siguientes lineamientos: - Queda terminantemente prohibido sacar o retirar los activos fuera de la entidad sin previa autorización del personal de encargado de todos los activos. - No se puede sacar activos fijos para fines personales, sino es para fines institucionales. - Se debe registrar un formulario de autorización de salida de activos fijos fuera de la entidad. - El personal de seguridad registra todo retiro de activos fuera de las instalaciones de la Entidad.
7.2.6 Seguridad de los equipos y activos fuera de las instalaciones.
CONTROL: <i>Se aplican medidas de seguridad a los activos que se encuentran fuera de las instalaciones de la organización, teniendo considerando diferentes riesgos fuera instalaciones.</i>
PROCEDIMIENTO DE IMPLEMENTACIÓN: Se establecen las siguientes consideraciones: - El equipo de procesamiento de información fuera de la entidad, debe ser justificado debidamente y con autorizaciones correspondiente. - Existen instrucciones y procedimientos para el cuidado del equipo o activo fuera de la entidad. - Para su procesamiento de información por medio de equipo de computación fuera de la entidad, existe instrucción de trabajo en un sitio seguro.
7.2.7 Disposición segura o reutilización de equipos.
CONTROL: <i>Se verifican todos los elementos de equipos que contengan medios de almacenamiento para asegurar que cualquier dato confidencial o software se haya sido retirado o sobrescrito en forma segura antes de su disposición o reúso.</i>
PROCEDIMIENTO DE IMPLEMENTACIÓN: Se consideran los siguientes aspectos: - Todos los equipos expuestos para su disposición, previamente son revisados detalladamente la información almacenada para su clasificación, y posteriormente como política se formatea o borra toda esta información almacenada. - Los equipos rescatados para su reutilización, son adecuados el hardware y software, de acuerdo al área en función, para su desarrollo de actividades de los funcionarios.
7.2.8 Equipos de usuario desatendido.
CONTROL: <i>Los usuarios se aseguran de que los equipos desatendidos o no supervisados, tengan protección apropiada en el tiempo.</i>
PROCEDIMIENTO DE IMPLEMENTACIÓN: Se siguen los siguientes requisitos: - El personal de la entidad, recibe capacitaciones antes de ser asignado un equipo, para mantener adecuadamente funcionando para el desarrollo de sus actividades. - Los funcionarios una vez asignados los equipos para su procesamiento de información, según normativa interna no deben instalar o manipular aplicaciones propias del equipo. - Los equipos son bloqueados sus periféricos de ingreso de información, para evitar riesgo de daño interno y externo de estos equipos.
7.2.9 Política de escritorio limpio y pantalla limpia.
CONTROL: <i>Se debe adoptar una política de escritorio limpio para los papeles y medios de almacenamiento removibles, y una política de pantalla limpia en las instalaciones de procesamiento de información.</i>
PROCEDIMIENTO DE IMPLEMENTACIÓN: - Se capacita a todos los funcionarios en la política de escritorio limpio y pantalla limpia a fin de reducir riesgos de acceso no autorizado y daño de la información.

- Deben reportar los funcionarios las anomalías al cumplimiento de la política de escritorio limpio y pantalla limpia.

8. SEGURIDAD DE LAS OPERACIONES.

8.1 Procedimientos operacionales y responsabilidades.

OBJETIVO:

Asegurar la operación segura y correcta de los medios de procesamiento de la información, estableciendo las responsabilidades y procedimientos para la gestión y operación.

8.1.1 Procedimientos de operación documentados

CONTROL:

Los procedimientos de operación están documentados y puestos a disposición de todos los usuarios que los necesitan.

PROCEDIMIENTO DE IMPLEMENTACIÓN:

Esta documentación debe estar actualizados.

Se consideran los siguientes aspectos sobre los procedimientos operaciones y responsabilidad en la entidad:

- Existen documentados los procedimientos de manejo de la información
- A través de un documento se describen las operaciones a realizar por los funcionarios sobre las aplicaciones de sistemas.
- Cuando se desarrollan nuevas aplicaciones de procesamiento de información, estos son documentados para el conocimiento de los funcionarios designación para su manejo.
- Se ha diseñado una plataforma o acceso sistematizado para la obtención de los manuales de operación de aplicaciones de procesamiento de información.

8.1.2 Gestión de cambios.

CONTROL:

Se controlan los cambios en la entidad, en los procesos de las actividades, en las instalaciones y en los sistemas de procesamiento de información que afectan la seguridad de la información.

PROCEDIMIENTO DE IMPLEMENTACIÓN:

Se consideran los siguientes aspectos para la administración de cambios:

- Existen procedimientos establecidos para el control de los cambios en el ambiente operativo y de comunicaciones.
- Los cambios operativos son registrados, controlados y supervisado por el personal autorizado.
- Se verifican que los cambios sean adecuados y oportunos, con el fin de no perjudicar las operaciones de la institución.
- Se dan seguimientos a los cambios operacionales ejecutadas en la entidad.

8.1.3 Gestión de capacidad.

CONTROL:

Se realizan seguimiento y ajustes al uso de recursos conjuntamente a las proyecciones necesarias de los requisitos de capacidad futura, para asegurar el desempeño requerido del sistema.

PROCEDIMIENTO DE IMPLEMENTACIÓN:

- Se realizan monitoreos constantes sobre las necesidades de capacidad de los sistemas en operación y proyectar las futuras demandas
- Se documentan necesidades detectadas para evitar potenciales cuellos de botella para su acción correctiva inmediata.
- Las proyecciones sobre los requerimientos futuros de capacidad son registradas para mediar con la implementación de nuevas herramientas para su continuidad de desempeño de los sistemas o equipos de computación.

8.1.4 Separación de los ambientes de desarrollo, pruebas y operación.

CONTROL:

Los ambientes de desarrollo, pruebas y operacionales, son separados para reducir los riesgos de acceso o cambios no autorizados al ambiente de operación.

PROCEDIMIENTO DE IMPLEMENTACIÓN:

- Los ambientes físicos en la entidad se encuentran separados para desarrollo, prueba y operaciones
- Los funcionarios pertenecientes a cada unidad, tiene acceso a través de biométrico, para evitar acceso de personas no autorizadas.

	- Están definidas para cada área las funciones o actividades a desarrollar. - Para poner en marcha los sistemas operaciones, los encargados de cada ambiente previamente realizan reuniones de explicación de las propuestas y funcionalidad de los sistemas.
	8.2 Protección contra código malicioso.
	OBJETIVO: <i>Asegurar de que la información y las instalaciones de procesamiento de información se encuentren protegidas contra códigos maliciosos que pongan en riesgo la preservación de la confidencialidad, integridad y disponibilidad de la información en la entidad.</i>
	8.2.1 Controles contra los códigos maliciosos.
	CONTROL: <i>Se detecta, previene y protege la integridad del software y la información contra códigos maliciosos.</i>
	PROCEDIMIENTO DE IMPLEMENTACIÓN: - Se llevan a cabo revisiones regulares del software y del contenido de datos de los sistemas que dan soporte a los procesos importantes de la entidad. - Se han definido controles de detección y prevención contra software malicioso. - Existen documentos para concientización adecuada de usuarios en materia de seguridad, controles de acceso al sistema y administración de cambios. - Se cuenta con licencias de software corporativos y actualizaciones para detección del virus - Existe instructivas administrar adecuadamente para la protección y habilitación o no de puertos de conexión de dispositivos extraíbles y sus derechos de acceso - Se recolecta información con regularidad se sitios web que contienen información de virus.
	8.3 Copias de seguridad.
	OBJETIVO: <i>Mantienen la integridad y sensibilidad de la información de los servicios de procesamiento de información de la entidad realizando copias de seguridad de los datos y probando tiempos de restauración.</i>
	8.3.1 Copias de respaldo de la información.
	CONTROL: <i>Se realizan copias o backup de respaldo de la información, software e imágenes de los sistemas generadas y se pone a las pruebas regularmente de acuerdo con una política de copias de respaldo acordadas.</i>
	PROCEDIMIENTO DE IMPLEMENTACIÓN: - Existen documentados esquemas de resguardo de información de determinados requerimientos para resguardar cada software o dato en función de su criticidad. - Se realizan registros exactos y completos de las copias de respaldo y se generan documentos detallados del proceso de restauración y recuperación de la información. - Se cuenta con infraestructura tecnológica y física para copias de seguridad automatizada en la entidad. - Se tiene un protocolo de copia de seguridad de información, de acuerdo a su importancia y confidencialidad. - La verificación y prueba se realizan periódicamente con las tareas de restauración, garantizando su eficacia y cumplimiento del tiempo asignado a la recuperación en actividades operativos.
	8.4 Registro de Eventos y Monitoreo de los Recursos Tecnológicos y los Sistemas de Información.
	OBJETIVO: <i>Asegurar que todos los sistemas de información y recursos tecnológicos, tengan un sistema de monitoreo periódico, de los registros de eventos creados y almacenados.</i>
	8.4.1 Registro de eventos.
	CONTROL: <i>Se elaboran, conservan y revisan regularmente los registros acerca de actividades del usuario, así como las excepciones, fallas y eventos de seguridad de la información</i>
	PROCEDIMIENTO DE IMPLEMENTACIÓN: En el procedimiento de registro de eventos se consideran los siguientes aspectos: - Se registran, tiempos de inicio y cierre del sistema. - Se documentan errores del sistema y medidas correctivas aplicadas. - Se registran los intentos de acceso a sistemas, aplicaciones, recursos o información crítica.

	- Se contrasta los registros de actividades del personal operativo con relación a los procedimientos operativos existentes.
	8.4.2 Protección de la información de registro.
	CONTROL: <i>Existen medios para la protección de las instalaciones y la información de registro para proteger contra alteración y acceso no autorizado.</i>
	PROCEDIMIENTO DE IMPLEMENTACIÓN: - Existen controles para la protección de los registros contra cambios no autorizados y problemas operacionales. - Se tiene el control de la capacidad de almacenamiento de los archivos de registro en los dispositivos de almacenamientos. - Existe un procedimiento de firma digital para los archivos de logs de transmisiones de las aplicaciones.
	8.4.3 Registros del administrador y del operador.
	CONTROL: <i>Se registran las actividades del administrador y del operador del sistema y los registros se protegen y revisan con regularidad.</i>
	PROCEDIMIENTO DE IMPLEMENTACIÓN: Se consideran los siguientes aspectos para el registro de las operaciones del administrador y operador: - Se tiene identificado la cuenta de administrador - Se tiene identificado claramente las cuentas de los operadores del sistema - Se tiene registrado todas operaciones del sistema - Se registran los eventos, fallas y situaciones imprevistas ocurridos, así como las acciones implantadas.
	8.4.4 Sincronización de relojes.
	CONTROL: <i>Los relojes de todos los sistemas de procesamiento de información pertinentes dentro de una organización o ámbito de seguridad están sincronizar con una única fuente de referencia de tiempo que se tiene.</i>
	PROCEDIMIENTO DE IMPLEMENTACIÓN: - Se dispone de un procedimiento de ajuste de relojes, el cual también incluye la comparación con relojes de fuentes externas. - Se encuentran sincronizados a través de un servidor, todos los relojes de equipos tecnológicos de la entidad.
	8.5 Control del software en explotación.
	OBJETIVO: <i>Asegurar que todo el software operacional, que está instalado en la plataforma tecnológica de la entidad, se encuentre operando en los niveles óptimos de seguridad.</i>
	8.5.1 Instalación de software en sistemas operativos
	CONTROL: <i>Se deben implementar procedimientos para controlar la instalación de software en sistemas operativos.</i>
	PROCEDIMIENTO DE IMPLEMENTACIÓN: - Existe un procedimiento establecido para la instalación de sistemas operativos. - Se ejecutan protocolos establecidos para poner en marcha la aplicación de sistemas operativos. - La actualización de sistemas operacionales, aplicaciones, y bibliotecas de programas son realizadas por la unidad de implementación de la entidad. - Antes de puesta en marcha se capacitan a los funcionarios operativos que operan este tipo de sistemas.
	8.6 Gestión de la vulnerabilidad técnica.
	OBJETIVO: <i>Asegurar que las vulnerabilidades técnicas identificadas a través de la aplicación de una metodología de pruebas de efectividad, puedan recibir un tratamiento óptimo para lograr mitigarlas.</i>
	8.6.1 Gestión de las vulnerabilidades técnicas.
	CONTROL: <i>Se identifican de manera oportuna la información acerca de las vulnerabilidades técnicas de los sistemas de información que se utilizan; para evaluar la exposición de la entidad ante estas vulnerabilidades, y tomar las acciones inmediatas y apropiadas para tratar el riesgo asociado.</i>

	PROCEDIMIENTO DE IMPLEMENTACIÓN: Para la administración de vulnerabilidades técnicas, se toman los siguientes aspectos: - Se cuenta con procedimiento de identificación de vulnerabilidades técnicas. - Existen definidos los roles y responsabilidades asociados con la administración de vulnerabilidades técnicas. - Se dispone de una aplicación que registra información de versiones del mismo, así como datos del proveedor y responsable interno. - Se cuenta con protocolos definidos para reaccionar y ejecutar acciones inmediatas y adecuados para tratar el riesgo asociado.
	8.6.2 Restricciones sobre la instalación de software.
	CONTROL: <i>Se establecen reglas para la instalación de software por parte de los usuarios.</i>
	PROCEDIMIENTO DE IMPLEMENTACIÓN: - Se encuentran establecidos a través de procedimientos los controles de seguridad para garantizar la protección y correcta operación de los sistemas operativos. - Para conocimiento, se capacitan a todos los funcionarios sobre estos procedimientos para autorización de instalación de software.
	8.7 Consideraciones sobre auditorías de los sistemas de información.
	OBJETIVO: <i>Garantizar la reducción del impacto de las actividades sobre los sistemas operativos de la entidad.</i>
	8.7.1 Controles de auditoría de los sistemas de información.
	CONTROL: <i>Se planifican y se ponen de acuerdo sobre los requisitos y actividades de auditoría que involucran la verificación de los sistemas operativos para minimizar las interrupciones en los procesos de la entidad.</i>
	PROCEDIMIENTO DE IMPLEMENTACIÓN: - Existen documentos planificados actividades de auditoría interna para verificaciones de los sistemas operativos de la entidad. - Se tienen procedimientos que involucran ponerse de acuerdo con la unidad de auditoría para establecer requerimientos a auditar los sistemas operacionales de la entidad. - Se tienen registros según su aplicación de todos los sistemas disponibles y en ejecución para su examen por parte de auditoría. - Se tiene registro de trazabilidades de accesos y operación de información en los sistemas de información.
	9. SEGURIDAD DE LAS COMUNICACIONES.
	9.1 Gestión de la seguridad en las redes.
	OBJETIVO: <i>Garantizar la protección de la información en las redes, y sus instalaciones de procesamiento de información de soporte, la cual puede abarcar los límites de la entidad, considerando cuidadosamente el flujo de datos, consecuencias legales, monitoreo y protección.</i>
	9.1.1 Controles de red.
	CONTROL: <i>La entidad administra y controla las redes de manera adecuada para proteger la información en sistemas y aplicaciones.</i>
	PROCEDIMIENTO DE IMPLEMENTACIÓN: - La entidad cuenta con protocolos de control de redes sobre las que se desarrollan todas las aplicaciones ejecutadas por los usuarios. - Se tiene establecido y definido el registro de las direcciones IP origen y destino, puertos para el tráfico autorizado. - Se encuentran establecidos el control de acceso por puerto en los switches. - Están establecidos los controles especiales para salvaguardar la confidencialidad e integridad del procesamiento de los datos que se transmiten a través de redes públicas, y para proteger los sistemas conectados. - Están establecidos los procedimientos de supervisión, para evidenciar que los controles se aplican adecuadamente en toda la infraestructura de procesamiento de información.

	9.1.2 Seguridad de los servicios de red. CONTROL: <i>En cualquier acuerdo sobre los servicios de red se tienen identificados características de seguridad, niveles de servicios y los requisitos de gestión de todos los servicios de la red de la entidad.</i> PROCEDIMIENTO DE IMPLEMENTACIÓN: Se deben considerar las siguientes directrices: - El proveedor del servicio gestiona y brinda los servicios de red de manera segura y confiable cumpliendo los acuerdos estipulados con la entidad. - Están definidos los modelos para garantizar la seguridad de los servicios de red de la institución, tanto públicos como privados. - Solo se tiene instalados y habilitados aquellos servicios que son utilizados. - Existen procedimientos para configuración cada servicio de manera segura, para evitar las vulnerabilidades que se pudieran presentar. - Para asegurarse la correcta configuración e instalación de redes, es revisada periódicamente toda la infraestructura de red de la entidad 9.1.3 Separación en las redes. CONTROL: <i>Están separados las redes según su criticidad de servicios, usuarios sistemas de información para la adecuada protección de su contenido.</i> PROCEDIMIENTO DE IMPLEMENTACIÓN: Se encuentran segregados las conexiones de redes, según los grupos de servicios de información, usuarios y sistemas de información de la entidad. 9.2 Transferencias de Información. OBJETIVO: <i>Asegurar que la información de la entidad sea transferida, de manera interna y externa según requieran, en el marco de una serie de procedimientos y controles, para garantizar la conservación de la confidencialidad e integridad de la información de la entidad.</i> 9.2.1 Políticas y procedimientos de transferencias de información. CONTROL: <i>Se cuenta con políticas, procedimientos y controles formales de transferencia información para proteger la transmisión de información a través de uso de todo tipo de medios de comunicaciones.</i> PROCEDIMIENTO DE IMPLEMENTACIÓN: Para transferencia de información por medio de redes de comunicación, se considera lo siguiente: - La política sobre el uso de la red se encuentra acorde con las políticas de acceso. - Esta establecida la protección de la información para transferencia de la información sin que se genere vulneraciones. - Existe aplicaciones para la detección y protección contra los códigos malicioso que puede ser transmitido a través del uso de red. - Existen protocolos de criptográficas para proteger la integridad, confidencialidad y la autenticidad de la información - Se capacitan al personal para transferencia de información con las medidas adecuadas. 9.2.2 Acuerdos sobre transferencias de información. CONTROL: <i>Están establecidos adecuadamente los acuerdos a tratar sobre la transferencia segura de la información entre la entidad y las partes externas.</i> PROCEDIMIENTO DE IMPLEMENTACIÓN: Se establecen los siguientes aspectos: - Están establecidas el intercambio de información y/o software, entre los involucrados con las consideraciones de seguridad sobre la misma. - Se notifican oportunamente cualquier transferencia de información. - Se tiene establecido procedimientos para evidenciar la trazabilidad de transferencia de información.
--	---

	9.2.3 Mensajería electrónica. CONTROL: <i>Se encuentran adecuadamente los lineamientos de protección de la información incluida la mensajería electrónica.</i> PROCEDIMIENTO DE IMPLEMENTACIÓN: - Los correos electrónicos de los funcionarios de la entidad están establecidos con los datos de los mismos para su identificación. - La información de ciertos funcionarios seleccionados, por mensajería a través de correos electrónicos, quedan almacenados en la nube, para el acceso a la información en cualquier momento. - No todos los funcionarios tienen acceso a mensajerías privados o universales.
	9.2.4 Acuerdos de confidencialidad y secreto. CONTROL: <i>Se identifican, revisan regularmente y se documentan los requisitos para los acuerdos de confidencialidad o no divulgación que se reflejen las necesidades de la entidad para la protección de la información.</i> PROCEDIMIENTO DE IMPLEMENTACIÓN: En la entidad se establecen los siguientes aspectos: - La confidencialidad se encuentra descrito en la normativa principal de la entidad. - Los funcionarios están obligados de firmar un documento de la no divulgación de información institucional a su cargo para intereses particulares. - Existen acuerdo de confidencialidad debidamente documentadas por los funcionarios de la entidad. - Existe normativa interna que contempla sanciones en caso de divulgación de acuerdos confidenciales.
	10. ADQUISICIÓN, DESARROLLO Y MANTENIMIENTO DE LOS SISTEMAS DE INFORMACIÓN.
	10.1 Requisitos de seguridad de los sistemas de información.
	OBJETIVO: <i>Garantiza que la seguridad es parte integral ante y durante el desarrollo de un sistema de información, así como en la implementación del producto final en el ambiente de producción de la entidad.</i>
	10.1.1 Análisis y especificación de requisitos de seguridad de la información.
	CONTROL: <i>Las declaraciones sobre los requisitos de la entidad para nuevos sistemas de información o mantenimientos a los sistemas existentes tienen especificados los requisitos para los controles de la seguridad.</i>
	PROCEDIMIENTO DE IMPLEMENTACIÓN: - En las especificaciones para los requisitos de control se consideran los controles automatizados para que se incorporen en el sistema de información. - Los requisitos del sistema para la seguridad de la información y los procesos para implementarla se integran en las fases iniciales de los proyectos del sistema de información. - Se identifican que los controles de seguridad interpuestos en la etapa de diseño, no son tan costosos de implementar y mantener, que aquellos controles incluidos durante o después de la implementación.
	10.1.2 Seguridad de servicios de las aplicaciones en redes públicas.
	CONTROL: <i>La información de los servicios de aplicación que se transfieren por medio de redes públicas está protegida por los niveles de servicios prestan los proveedores.</i>
	PROCEDIMIENTO DE IMPLEMENTACIÓN: - Se tienen identificados disposiciones de seguridad necesarias para las características de seguridad, los niveles de servicios y los requisitos de administración de la entidad. - Existen lineamientos de la capacidad de conexión de los usuarios. - Existen restricciones implementadas a través de puertas de enlace (gateway) de red pública que filtren el tráfico por medio de reglas redefinidas.
	10.1.3 Protección de transacciones de los servicios de las aplicaciones.
	CONTROL: <i>La información implicada en las transacciones de los servicios de aplicación se encuentra protegidos para evitar la transmisión fragmentada, el enrutamiento incorrecto, la alteración no autorizada de mensajes, la divulgación no autorizada, y la duplicación o reproducción de mensajes no autorizadas.</i>

	PROCEDIMIENTO DE IMPLEMENTACIÓN: - Están definidos los controles para desarrollar transacciones a través de diferentes aplicaciones transaccionales. - Existen procedimientos de protección sobre la información implicada en las transacciones para evitar transmisión incompleta, omisión de envío, divulgaciones, duplicaciones y repeticiones no autorizadas.
	10.2 Seguridad en los procesos de desarrollo y soporte.
	OBJETIVO: <i>Garantizar que la seguridad de la información esté adecuadamente diseñada e implementada dentro del ciclo de vida de desarrollo de los sistemas, así mismo, se cumplan con los lineamientos de seguridad y soporte que garanticen la conservación de la confidencialidad, integridad y disponibilidad de los datos de la entidad, soportados en los aplicativos.</i>
	10.2.1 Política de desarrollo seguro de software.
	CONTROL: <i>Están establecidos y aplicados reglas para el desarrollo de software y al desarrollo seguros dentro de la entidad.</i>
	PROCEDIMIENTO DE IMPLEMENTACIÓN: - Se encuentran establecidos las políticas de control de desarrollo seguro de sistemas o software. - Están definidos los procedimientos de desarrollo de sistemas en la entidad. - Existe recursos humanos capacitados para cumplir con el desarrollo de sistemas requeridos por la entidad. - Las reglas para el desarrollo de software y de sistemas deben ser establecidas y aplicadas a los desarrollos dentro de la organización.
	10.2.2 Procedimientos de control de cambios en los sistemas.
	CONTROL: <i>Los cambios a los sistemas dentro del ciclo de vida de desarrollo se deben controlar mediante el uso de procedimientos formales de control de cambios.</i>
	PROCEDIMIENTO DE IMPLEMENTACIÓN: Los procedimientos formales de control de cambios de documentan y hacen cumplir para minimizar la corrupción de sistemas de información, el desarrollo de nuevos sistemas y de cambios importantes en los sistemas existentes. Los procedimientos de control de cambios incluyen: - El mantenimiento de un registro de los niveles acordados de autorización y la garantía de que los cambios son realizados por los funcionarios autorizados. - La garantía de que los funcionarios autorizados acepten los cambios antes de la implementación. - La garantía de que la documentación del sistema este actualizada al finalizar cada cambio y que la documentación antigua se archiva o se destruye. - El mantenimiento de un rastro para auditoría de todos los cambios solicitados y la garantía de que la implementación de los cambios tiene lugar en el momento oportuno y no perturbe los procesos de la entidad involucrados.
	10.2.3 Revisión técnica de las aplicaciones después de cambios en la plataforma de operación.
	CONTROL: <i>Cuando se cambian los sistemas operativos, las aplicaciones críticas para el negocio, se revisan y someten a prueba para asegurar que no hay impacto advero en las operaciones ni en la seguridad de la información de la entidad.</i>
	PROCEDIMIENTO DE IMPLEMENTACIÓN: Este proceso comprende los siguientes aspectos: - Revisión de la integridad y control de la aplicación para que se asegure de que no se han puesto en peligro debido a los cambios en el sistema operativo. - Garantía de que el plan y el presupuesto de soporte actual cubra las revisiones y pruebas del sistema que resulten de cambios en el sistema operativo. - Garantía de la notificación oportuna sobre los cambios en el sistema operativo para que permita la realización de las pruebas y las revisiones apropiadas antes de la implementación del sistema en producción. - Garantía que los cambios en el sistema operativo sean informados con antelación a la implementación.

	10.2.4 Restricciones en los cambios a los paquetes de software. CONTROL: <i>Se restringen las modificaciones a los paquetes de software, los cuales están limitados a los cambios necesarios, y todos los cambios se implementan controles estrictos.</i> PROCEDIMIENTO DE IMPLEMENTACIÓN: Para este proceso se consideran los siguientes aspectos: - Se analizan los términos y condiciones de la licencia para determinar si las modificaciones se encuentran autorizadas. - Se tiene conocimiento en caso de que la entidad se haga cargo del mantenimiento, por la capacidad que tienen los funcionarios del área. 10.2.5 Principio de Construcción de los Sistemas Seguros. CONTROL: <i>Están establecidos, documentados, mantenidos y aplicados los principios para la construcción de sistemas seguros, para la actividad de implementación de sistemas de información.</i> PROCEDIMIENTO DE IMPLEMENTACIÓN: - Existen diseñados la seguridad de información en todos los niveles necesarios para la construcción de sistemas. - Se analizan todas las tecnologías nuevas con el objeto de conocer los riesgos de seguridad y e diseño se evaluación contra los patrones de ataque. 10.2.6 Ambientes de desarrollo seguro. CONTROL: <i>Se encuentran adecuadamente protegidos los ambientes de desarrollo seguros en la entidad, mismos para las actividades de desarrollo e integración de sistemas que alcancen todo el ciclo de vida de sistemas.</i> PROCEDIMIENTO DE IMPLEMENTACIÓN: - Los ambientes de desarrollo e integración de sistemas, se encuentran adecuadamente protegidos y equipados. - Se encuentran documentados las evaluaciones de riesgos asociados a la protección de ambientes para los trabajos de desarrollo seguros de sistemas. 10.2.7 Pruebas de seguridad de sistemas. CONTROL: <i>Los conjuntos de datos de pruebas se establecen para la prueba durante desarrollo de sistemas adecuados.</i> PROCEDIMIENTO DE IMPLEMENTACIÓN: - Existen procedimientos establecidos para las pruebas de sistemas nuevos y actualizados durante los procesos de desarrollo. - Están controlados el alcance de las pruebas en proporción a la importancia y naturaleza de los sistemas de información. 10.2.8 Pruebas de aceptación de sistemas. CONTROL: <i>El establecimiento de programas oficiales de prueba y criterios relacionados son para la aceptación de nuevos sistemas de información, actualizaciones y nuevas versiones.</i> PROCEDIMIENTO DE IMPLEMENTACIÓN: - Están establecido la política de desarrollo de sistemas de información, criterios y pruebas de aceptación para los nuevos sistemas de información propios o adquiridas por la entidad. - Existen protocolos de pruebas de aceptación de sistemas de información definidos por los funcionarios responsables y proveedores de sistemas. 10.3 Datos de prueba. OBJETIVO: <i>Garantizar la protección de los datos utilizados y suministrados para pruebas a los administradores y/o desarrolladores de los sistemas de información.</i> 10.3.1 Protección de datos de pruebas. CONTROL: <i>Los datos de prueba seleccionados, protegidos y controlados cuidadosamente en la entidad.</i>
--	---

	PROCEDIMIENTO DE IMPLEMENTACIÓN: - Están establecidos que las pruebas de los nuevos sistemas se efectúen con datos recolectados del ambiente operativos. - Existen protocolos de protección de datos de prueba para sistemas de información desarrollados o actualizados. - Estos procedimientos y protocolos, son puestos en conocimientos a los funcionarios desarrolladores.
11. RELACIONES CON LOS PROVEEDORES.	
	11.1 Seguridad de la información en las relaciones con los proveedores.
	OBJETIVO: <i>Garantizar la protección de activos de la entidad, mismos que sean accesibles a los proveedores en la prestación de servicios contratados, en cumplimiento de los lineamientos de seguridad de la información establecidos, para esta manera, preservar la confidencialidad, integridad y disponibilidad de los datos institucionales.</i>
	11.1.1 Política de seguridad de la información para las relaciones con proveedores.
	CONTROL: <i>La documentación establece los requisitos de seguridad de la información para mitigar los riesgos asociados con el acceso de los proveedores a los activos de la organización se encuentra seguros.</i>
	PROCEDIMIENTO DE IMPLEMENTACIÓN: - Están establecidos documentar los acuerdos con los proveedores para asegurar que no haya malentendidos entre la entidad y el proveedor. - Se encuentran definidos los escenarios de conexión adecuada, para los dispositivos móviles y equipos de tecnológicos de los proveedores, en la red de datos de la institución.
	11.1.2 Tratamiento de la seguridad dentro de los acuerdos con proveedores.
	CONTROL: <i>La entidad tiene establecido y acordado todos los requisitos de seguridad de la información oportunos con cada proveedor que pueda acceder, procesar, almacenar, comunicar y suministrar componentes de infraestructura de Tecnologías de Información para dar soporte a la información de la entidad.</i>
	PROCEDIMIENTO DE IMPLEMENTACIÓN: - Se tiene normativa que obliga a los proveedores y a la entidad incluir en los acuerdos el soporte de seguridad de la información. - Para el acceso la información por parte de los proveedores, se rigen en las políticas de protección establecidas por la entidad.
	11.1.3 Cadena de suministro de tecnología de información y comunicación.
	CONTROL: <i>En acuerdos con proveedores y la entidad obligan incluir requisitos para tratar los riesgos de seguridad de la información asociados con la cadena de suministro de bienes y servicios de tecnología de comunicación e información.</i>
	PROCEDIMIENTO DE IMPLEMENTACIÓN: - Todos acuerdos establecidos con los proveedores son documentados debidamente para suministro de tecnologías y comunicación. - Existen políticas de implementación de proceso de monitoreo y técnicas aceptables para validar que los bienes y/o servicios de tecnología de información y comunicación cumplan con las especificaciones de seguridad determinados; - La política de la entidad establece obtener garantía e fábrica de manera obligatoria por el tiempo prudente sobre los equipos tecnológicos y de comunicación proveídos.
	11.2 Gestión de la prestación de servicios de proveedores.
	OBJETIVO: <i>Garantizar que toda prestación de servicios, por los proveedores, cumplan con los lineamientos de seguridad, para mantener la confidencialidad, integridad y disponibilidad de la información de la entidad.</i>
	11.2.1 Seguimiento y revisión de los servicios de los proveedores.
	CONTROL: <i>Productos de la acción de seguimiento, revisión de manera regular a la prestación de servicios de los proveedores se mantiene intacto la información de la entidad.</i>

	PROCEDIMIENTO DE IMPLEMENTACIÓN: El seguimiento a la prestación de servicios de parte de los proveedores incluye: - Documentar la acción de seguimiento realizado a los servicios de los proveedores periódicamente. - Exigir a los proveedores de servicio, informes sobre la provisión de servicios de manera detallada. 11.2.2 Gestión del cambio en los servicios de los proveedores. CONTROL: <i>Se administran cambios de suministro de servicios por parte de los proveedores, incorporado el mantenimiento y las mejoras de las políticas, procedimientos y controles de seguridad de la información existentes, teniendo en cuenta lo crítico de la información, sistemas y procesos implicados y la reevaluación de los riesgos.</i> PROCEDIMIENTO DE IMPLEMENTACIÓN: - La entidad requiere constantemente mejora de servicios por los proveedores por exigencias de la sociedad. - Existe un registro de control de niveles de mejora de servicios ofrecidos por los proveedores.
12. GESTIÓN DE INCIDENTES DE SEGURIDAD DE LA INFORMACIÓN.	
	12.1 Gestión de incidentes y mejoras en la seguridad de la información. OBJETIVO: <i>Asegurar una orientación coherente y eficaz para la administración de incidentes de seguridad de la información, incluida la comunicación sobre eventos de seguridad y puntos débiles.</i>
	12.1.1 Responsabilidades y procedimientos. CONTROL: <i>Se establecen responsabilidades y procedimientos de administración para asegurar una respuesta rápida, eficaz y ordenada frente a los incidentes de seguridad de la información de la entidad.</i> PROCEDIMIENTO DE IMPLEMENTACIÓN: Para este control se considera lo siguiente: - Definición de los probables incidentes relativos a la seguridad. - La comunicación inmediatamente de manera formal a las autoridades de la entidad sobre los incidentes suscitados. - La documentación de planes de contingencias es periódicamente ajustada. - En caso de incidentes de alto riesgo de seguridad de la información que involucre seguridad de la información, se establece pertinente incluir al área legal para tomar acciones.
	12.1.2 Reporte de eventos de seguridad de la información. CONTROL: <i>Los registros de eventos de seguridad de la información son informados a través de los canales de gestión apropiados, tan pronto como sea posible.</i> PROCEDIMIENTO DE IMPLEMENTACIÓN: - Existen canales establecidos para reportes de eventos de seguridad de información, - La entidad considera la omisión en el reporte de eventos de seguridad como incidente. - Se concientiza a los funcionarios de la entidad reportar cualquier incidente relacionado con seguridad de la información.
	12.1.3 Reporte de debilidades de seguridad de la información. CONTROL: <i>Se exige a todos los funcionarios y contratistas que utilizan los sistemas de información de la entidad, que reportar cualquier debilidad de seguridad de la información sospechada en los sistemas o servicios.</i> PROCEDIMIENTO DE IMPLEMENTACIÓN: - Los funcionarios están conminados de reportar las debilidades encontradas en la seguridad de la información. - Todas las debilidades identificadas en la entidad deben ser registradas y documentadas para su tratamiento.
	12.1.4 Evaluación de eventos de seguridad de la información y decisiones sobre ellos. CONTROL: <i>Los funcionarios designados tienen la capacidad de evaluar los eventos de seguridad y para poder decidir como incidentes o no sobre la seguridad de la información.</i>

	PROCEDIMIENTO DE IMPLEMENTACIÓN: - Existen funcionarios con capacidad de evaluación de eventos de seguridad de la información como incidentes o no. - Para evaluar estos eventos la entidad cuenta con una escala de clasificación de eventos o incidentes de la seguridad de la información. - Todos los eventos considerados como incidentes o propensos a ser incidentes son registrados y documentados para su tratamiento.
	12.1.5 Respuesta a los incidentes de seguridad.
	CONTROL: <i>La respuesta a los incidentes de seguridad de la información es efectuada en atención a los procedimientos documentados.</i>
	PROCEDIMIENTO DE IMPLEMENTACIÓN: Para la respuesta a los incidentes se deben considerar los siguientes aspectos: - La recopilación de evidencia válida después de la ocurrencia. - Las actividades de respuesta se registran detalladamente en documento para su análisis posterior. - Se realizan análisis detallado posterior al incidente con el propósito de identificar el origen del incidente.
	12.1.6 Aprendizaje obtenido de los incidentes de seguridad de la información.
	CONTROL: <i>El conocimiento adquirido del análisis de los incidentes suscitados en seguridad de la información de la entidad, se utilizan para minimizar los posibles incidentes futuros.</i>
	PROCEDIMIENTO DE IMPLEMENTACIÓN: - Están definidos los procedimientos para documentar, cuantificar y monitorear volúmenes, tipos y costos de los incidentes. - La información documentada sobre incidentes recurrentes es analizada para minimizar y mejorar controles de seguridad de la información.
	13. ASPECTOS DE SEGURIDAD DE LA INFORMACION EN LA GESTIÓN DE LA CONTINUIDAD DEL NEGOCIO.
	13.1 Continuidad de seguridad de la información.
	OBJETIVO: <i>Resistir las paralizaciones de las operaciones de la Entidad y resguardar los procesos críticos producto de fallas o desastres significativos en los sistemas de información para asegurar su reanudación y continuidad oportuna.</i>
	13.1.1 Planificación de la continuidad de seguridad de la información.
	CONTROL: <i>La entidad planifica requisitos y la continuidad de administración de seguridad de la información, aun en situaciones adversas, como una crisis o desastre.</i>
	PROCEDIMIENTO DE IMPLEMENTACIÓN: - La entidad tiene definido el proceso de gestión de continuidad y recuperación de desastres. - La documentación con objetivos y prioridades acordados, es una estrategia para la continuidad de las operaciones de la institución.
	13.1.2 Implantación de la continuidad de la seguridad de la información.
	CONTROL: <i>La entidad establece, documenta, implementa y mantiene procesos, procedimientos y controles en situación adversa, para asegurar el nivel de continuidad requeridos para la seguridad de la información.</i>
	PROCEDIMIENTO DE IMPLEMENTACIÓN: - La documentación de planes de contingencia necesarios es para garantizar la continuidad de las operaciones de la Entidad. - Se analizan controles de los posibles sucesos de contingencia para definir trabajos correctivos a implementar para la continuidad de la seguridad de la información - Los planes de continuidad de seguridad de información, están orientadas a alcanzar objetivos de las actividades de la institución.

	13.1.3 Verificación, revisión y evaluación de la continuidad de la seguridad de la información. CONTROL: <i>La entidad verifica, revisa y evalúa a intervalos regulares los controles de continuidad de la seguridad de la información señalados e implementados, para confirmar que son válidos y eficaces en situaciones adversas</i> PROCEDIMIENTO DE IMPLEMENTACIÓN: Se consideran los siguientes aspectos para continuación de la seguridad de la información: - Las evaluaciones de controles de continuidad son documentados para evidenciar la validez y eficaz en situaciones adversas. - Se aplican procedimientos de continuidad de seguridad de información en caso de contingencia para mantener los requerimientos de integridad y confidencialidad para los activos implicados en el suceso de una contingencia.
	13.2 Redundancias. OBJETIVO: <i>Asegurar que los sistemas de información, equipos tecnológicos de la institución y servicios identificados como críticos, para favorecer la conservación de la disponibilidad en su funcionamiento cuentan con una solución redundante en su operación.</i>
	13.2.1 Disponibilidad de instalaciones de procesamiento de información. CONTROL: <i>Para cumplir los requisitos de disponibilidad en la entidad se implementan con redundancia suficiente las instalaciones de procesamiento de información.</i> PROCEDIMIENTO DE IMPLEMENTACIÓN: - Los equipos de respaldo son dispuestos para aquellos servicios críticos de la entidad, para avalar la existencia para procesamiento de información. - Se ejecutan pruebas para evidenciar el cumplimiento del tiempo de recuperación requerido por los servicios de la institución.
14. CUMPLIMIENTO.	
	14.1 Cumplimiento de los requisitos legales y contractuales. OBJETIVO: <i>Garantizar el cumplimiento de las normativas legales vigentes y contractuales vinculados con la seguridad de la información y/o con cualquier otro requisito de seguridad de la entidad.</i>
	14.1.1 Identificación de la legislación aplicable a los requisitos contractuales. CONTROL: <i>Para la entidad y cada sistema de información, la normativa vigente, los requisitos estatuarios y contractuales, así como el enfoque de la organización, deben ser identificados, documentados explícitamente y actualizados.</i> PROCEDIMIENTO DE IMPLEMENTACIÓN: Son documentados las normativas legales vigentes que tienen relación con los requisitos contractuales, del sistema de seguridad de la información.
	14.1.2 Derechos de Propiedad Intelectual (DPI). CONTROL: <i>La entidad implementa procedimientos apropiados para garantizar el cumplimiento con los requisitos legales, normativos específicos y contractuales relacionados con los derechos de propiedad intelectual y se utiliza productos de software original.</i> PROCEDIMIENTO DE IMPLEMENTACIÓN: - Son documentados todos los sistemas desarrollados como propiedad intelectual de la entidad, en marcados en la normativa legal vigente - La entidad dispone el uso de los sistemas desarrollados únicamente a los funcionarios internos como herramienta para desarrollo de sus actividades. - Se difunde para el conocimiento de los funcionarios de la entidad, los sistemas desarrollados por los profesionales dependientes de la institución.

	14.1.3 Protección de los registros de la Organización. CONTROL: <i>Los registros son protegidos contra pérdidas, destrucción, falsificación, accesos y publicaciones no autorizados de acuerdo con los requisitos legislativos, normativos, contractuales y comerciales de la entidad y del país.</i> PROCEDIMIENTO DE IMPLEMENTACIÓN: - Al momento de incorporar un personal nuevo a la entidad, la unidad de recursos humanos hace firmar un documento de acta de confidencialidad y no divulgación de información de la institución. - La información generada a través de medios tecnológicos de la entidad, están registrados y documentados como propio de la institución. - Existen normativas internas disciplinarias para aquellos funcionarios que realizan mal manejo de los registros de información de la entidad. - Se pueden evidenciar en la unidad de archivo que los registros se encuentren clasificados dentro del inventario de activos de la institución. 14.1.4 Protección de datos y privacidad de la información personal. CONTROL: <i>Se protege en privacidad de manera íntegra la información de datos personales en el marco de la normativa legal vigente de la entidad y del país.</i> PROCEDIMIENTO DE IMPLEMENTACIÓN: - Se tiene establecido procedimientos para la protección de datos personales en la entidad. - Se pone en conocimiento a todos los funcionarios las normativas referentes a la protección de datos y privacidad de la información personal. 14.1.5 Reglamentación de controles criptográficos. CONTROL: <i>Se protege con controles criptográficos la información, en cumplimiento de todos los contratos, normativa legal y reglamentación pertinente de la entidad y del país.</i> PROCEDIMIENTO DE IMPLEMENTACIÓN: - Se generan documentos con códigos criptográficos para proteger información de la entidad. - Se tiene reglamentación específico aprobada, para uso de controles criptográficos para seguridad de la información en la entidad. 14.2 Revisiones de la seguridad de la información. OBJETIVO: <i>Garantizar que la seguridad de la información para su implementación y se aplique adecuadamente de acuerdo con las políticas, estándares de seguridad y procedimientos organizacionales debe ser revisada.</i> 14.2.1 Revisión independiente de la seguridad de la información. CONTROL: <i>El enfoque de la entidad para la administración de la seguridad de la información y su implementación, se deben revisar independientemente a intervalos planeados o cuando haya cambios significativos.</i> PROCEDIMIENTO DE IMPLEMENTACIÓN: - Están establecidos la revisión independiente de seguridad de la información. - La revisión independiente, se realiza para asegurar la capacidad, ajuste y efectividad continua de la misión de la entidad y para la gestión de la seguridad de la información. - Se documentan los resultados de la revisión independiente de la seguridad de la información. 14.2.2 Cumplimiento con las políticas y normas de seguridad. CONTROL: <i>Los directores revisan con regularidad el cumplimiento del proceso y procedimientos de información dentro de su área de responsabilidad en la entidad, con las normas y políticas de seguridad adecuadas, y cualquier otro requisito de seguridad.</i> PROCEDIMIENTO DE IMPLEMENTACIÓN: - Existen procedimientos establecidos y documentados para el cumplimiento de normativa legal vigente y el apropiado procesamiento de seguridad definidos, dentro de su área de responsabilidad. - Se brinda apoyo a la revisión programada de cumplimiento de la política, normas y procedimientos aplicables de seguridad de la información en la entidad.
--	---

14.2.3 Revisión del cumplimiento técnico.
CONTROL: <i>Los sistemas de información se revisan regularmente por periodos planificados para determinar el cumplimiento con las políticas y normas de seguridad de información en la entidad.</i>
PROCEDIMIENTO DE IMPLEMENTACIÓN: ✓ Se registra la revisión de conformidad técnica a través de herramientas dispuesta que generan datos técnicos para su posterior interpretación. ✓ Es documentado la revisión regular realizado para determinar el cumplimiento de normas vigentes y políticas de seguridad de la información en la entidad.

Fuente: Elaboración Propia & Anexo ISO 27001

4.1.4.2 ANÁLISIS DE RESULTADOS DE IMPLEMENTACIÓN

Para el análisis final de los resultados posterior a la implementación del Modelo de Gestión y Control de Seguridad de la Información, se deben aplicar nuevamente las técnicas de entrevista y cuestionario al personal de la Entidad Pública, considerado el área de Tecnologías de la Información y Comunicación TICs, justificando cada resultado mediante el empleo de tablas, cuadros estadísticos y gráficas.

Para mostrar los resultados de la evaluación de riesgos de la Organización o Entidad Pública, después de realizar la implementación del modelo, se debe mostrar los resultados finales en una Tabla, bajo el siguiente formato:

Tabla 4.6.: Resultados Finales de la Evaluación de Riesgos

CLAUSULA	CRITERIO	PARAMETROS Y VALORES	RESULTADO FINAL DE EVALUACION DE RIESGO (%)
a. Clausula a.1.Objetivo de Control a.1.1. Control a.1.2. ...n ...	$E_{i,...,n} = RE_n$... $CrE(X_i) = RE_i$	V_1	R_1
b. Clausula b.1.Objetivo de Control b.1.1. Control b.1.2. ...n ...	$E_{i,...,m} = RE_m$... $CrE(X_i) = RE_i$	V_2	R_2

Fuente: Elaboración Propia

4.1.4.2.1 DETERMINACIÓN DEL NIVEL FINAL DE LA SEGURIDAD DE INFORMACIÓN

Producto de la implementación del Modelo, se debe determinar la situación del nivel de Seguridad de la Información final en la Entidad Pública, resultado del Indicador Global de Riesgo Controlado, bajo los criterios establecidos en la Tabla 3.4.:

- Insatisfactorio
- Marginal
- Satisfecho

4.1.4.2.2 ANÁLISIS COMPARATIVO DE SEGURIDAD DE INFORMACIÓN ANTES Y DESPUÉS DE LA IMPLEMENTACION DEL MODELO

Para la conclusión de los resultados obtenidos producto de la aplicación del modelo, se debe comparar los resultados obtenidos de seguridad de la Información en la entidad Pública, antes y después de la implementación del modelo, por tanto, los resultados se deben expresar en la siguiente tabla:

Tabla 4.7.: Resultados de Seguridad de la Información antes y después

CLAUSULA	INDICE GLOBAL DE RIESGO CONTROLADO (%)	
	ANTES DE LA IMPLEMENTACIÓN	DESPUES DE LA IMPLEMENTACIÓN
1. Clausula	RA1	RD1
2. Clausula	RA2	RD2
3. Clausula	RA3	RD3
...	...	...
n	RAn	RDn

Fuente: Elaboración Propia

4.1.5 FASE DE AUDITORIA DE CUMPLIMIENTO

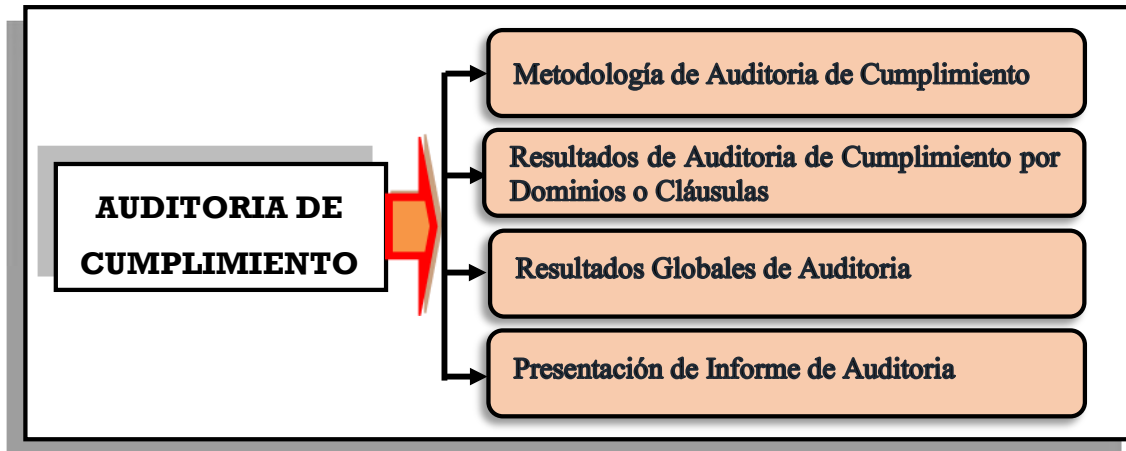
Una vez implementado el modelo de Gestión y Control Integral de riesgos de Seguridad de la Información en las Organizaciones de la Administración Pública, que sirviese para ir progresando en las diferentes áreas que plantea la norma ISO 27002.

El propósito de esta etapa es evaluar la madurez y el cumplimiento de la seguridad de la Información respecto a los 14 dominios o cláusulas de control y los 110 controles trazados e implementados.

A través de auditoría de cumplimiento se analiza la progreso y estado de la gestión de la seguridad de la información en la Entidad. Desde el nivel inicial hasta el nivel de madurez una vez implementado el modelo, mismo que obliga a un progreso y revisión continua que seguirán optimizando el nivel de madurez de la Seguridad de la Información de las Organizaciones de la Administración Pública en el transcurso del tiempo.

Es importante subrayar la importancia de estas auditorías como instrumento de análisis y revisión de la gestión de la seguridad de la información, como forma de conseguir conocimiento de la situación real en un determinado tiempo o periodo y por tanto de las posibles acciones a establecer o mejorar el nivel de seguridad.

Figura 4.11.: Auditoria de Cumplimiento



Fuente: Elaboración Propia

4.1.5.1 METODOLOGÍA DE AUDITORIA DE CUMPLIMIENTO

Para ejecutar la auditoria de cumplimiento se debe realizar al Modelo de Gestión y control de Seguridad de información implementado en la Entidad Pública, basado en el estándar ISO/IEC 27001:2013, agrupa un total de 110 controles o salvaguardas sobre buenas prácticas para la Gestión de la Seguridad de la Información organizado en 14 dominios y 35 objetivos

de control. Esta norma es internacionalmente reconocida y es perfectamente válido para distintas organizaciones.

Existen distintos aspectos en los cuales las salvaguardas proceden reduciendo el riesgo, así como los controles ISO/IEC 27002:2013 o de cualquiera otra nomenclatura, estos actúan en general instaurando:

- La formalización de las prácticas mediante documentos escritos o aprobados.
- La política de personal.
- Solicitudes técnicas (hardware, software o comunicaciones).
- Seguridad física.

La protección general frente a las posibles amenazas, se requiere de una composición de salvaguardas sobre cada uno de estos puntos.

Para esta etapa de forma concisa, los dominios o cláusulas que se deben examinar son las siguientes:

1. Políticas de Seguridad.
2. Organización de la Seguridad de la Información.
3. Seguridad de los Recursos Humanos.
4. Gestión de Activos.
5. Control de Accesos.
6. Cifrado.
7. Seguridad Física y del Entorno.
8. Seguridad de las Operaciones.
9. Seguridad de la Comunicaciones.
10. Adquisición, Desarrollo y Mantenimiento de los Sistemas de Información.
11. Relaciones con los Proveedores.
12. Gestión de Incidentes de Seguridad de la Información.
13. Aspectos de Seguridad de la Información en la Gestión de la Continuidad del Negocio.
14. Cumplimiento.

Para estudiar el escenario actual de cumplimiento en la Entidad Publica frente a la Seguridad de la Información sobre las normas ISO 27001 e ISO 27002 se efectúa un análisis de madurez o cumplimiento, dicho resultado de cada dominio se identifica la situación actual.

En el Modelo Capacidad de Procesos de COBIT 5, hay 6 niveles de capacidades que se pueden lograr alcanzar por un proceso, incluida la designación de *proceso incompleto*, si las prácticas determinadas en el proceso, no alcanzan el propósito prevista:

- **0. Proceso incompleto:** Se revela que el proceso no está implementado o no logra su propósito. A este nivel, hay muy escasa o casi ninguna evidencia de ningún logro consecuente del propósito del proceso.
- **1. Proceso ejecutado (un atributo):** Corresponde al proceso implementado que alcanza su propósito.
- **2. Proceso gestionado (dos atributos):** El proceso ejecutado descrito precedentemente ya está implementado de forma planificado, supervisado y ajustado y los resultados de su ejecución están determinados, controlados y mantenidos adecuadamente.
- **3. Proceso establecido (dos atributos):** El proceso descrito anteriormente, está actualmente implementado, utilizando un proceso definido que es capaz de lograr sus resultados de proceso.
- **4. Proceso predecible (dos atributos):** El proceso establecido descrito precedentemente actualmente se ejecuta entre los límites definidos para alcanzar sus resultados de proceso.
- **5. Proceso optimizado (dos atributos):** El proceso predecible descrito anteriormente es mejorado de forma continua para cumplir con las metas empresariales actuales y futuros.

La auditoría de cumplimiento se debe realizar a los 110 controles planteados en el modelo implementado, para dar cumplimientos con los diferentes objetivos de control, la cifra de los cuales se muestra entre paréntesis, para cada uno de los 14 dominios o clausulas. Esta evaluación se realiza de acuerdo a la tabla del Modelo de Madurez de la Capacidad (CMM) con la valoración correspondiente descritos en la siguiente tabla:

Tabla 4.8.: Modelo de Madurez de la Capacidad CMM - Cumplimiento

NIVEL	CMM	DESCRIPCIÓN DE CUMPLIMIENTO
0% Inexistente	C0	<i>Existe Ausencia total de procesos identificables. La organización no ha reconocido que tiene una dificultad por gestionar.</i>
20% Inicial	C1	<i>Hay prueba de que la organización reconoce que hay el problema. Sin embargo, no hay procesos formales, en su lugar hay aproximaciones que tienden a ser utilizados de forma desordenada sin ningún tipo de administración.</i>
40% Repetible	C2	<i>Se diseñan procesos dependientes de los individuos y otras le siguen. No hay una comunicación ni preparación formal y la responsabilidad recae sobre las personas. Excesiva confianza en el conocimiento de los individuos, por tanto, los errores son comunes. No hay formación ni comunicación formal sobre los procedimientos y estándares. Hay un alto grado de confianza en los conocimientos de cada individuo, por eso hay probabilidad de errores.</i>
60% Definido	C3	<i>Los procesos se definen, documentan y se comunican a través de ejercicio formal. Es preciso el cumplimiento de los procesos y por tanto la posibilidad de descubrir desviaciones es alta. Los procedimientos por si mismos no son sofisticados, pero se formalizan las prácticas existentes.</i>
80% Gestionado y Medible	C4	<i>Existen controles y supervisiones sobre el cumplimiento de los procedimientos y es posible tomar medidas de acción donde los procesos no estén desempeñando eficientemente. Los procedimientos están bajo constante mejoramiento y aportan a la calidad y producción. Regularmente se requiere de herramientas automatizadas para la medición.</i>
100% Optimizado	C5	<i>Los procesos se han optimizado hasta un nivel de mejor práctica, se basan en los resultados de mejoras continuas y en un modelo de madurez con otros entes. Las tecnologías de la información se utilizan de forma integrada para automatizar el flujo de trabajo, brindando herramientas para mejorar la calidad y la efectividad, haciendo que la organización se adapte de manera rápida y cumpla los requerimientos legales.</i>

Fuente: COBIT 5

4.1.5.2 RESULTADOS DE AUDITORIA DE CUMPLIMIENTO POR DOMINIOS O CLÁUSULAS

Se describe el análisis del nivel de madurez por cada uno de los dominios o cláusulas. Por lo tanto, se podrá valorar la evolución de la madurez de los 14 dominios o cláusulas y 110 controles implementados por medio del Modelo de Gestión y Control Integral de Seguridad de la Información, basados en norma ISO 27001:2013.

En una auditoría interna, se examinan el cumplimiento normativo de la Entidad relacionados con seguridad de la información, donde se pueden obtener diferentes tipos de desviaciones:

- **No conformidad Mayor:** Refleja el incumplimiento de un apartado completo de la norma.
- **No conformidad Menor:** Describe el incumplimiento de un punto de un apartado.

- **Observación:** No incumple nada, es sólo una recomendación, en caso de que, si no se trata, en la siguiente auditoría, esto se puede convertir en *No conformidad*.

Es decir, en función a estos principios se deben realizar los análisis de adecuación a la norma de distintos controles que conforman los dominios o cláusulas que establece el modelo.

4.1.5.3 RESULTADOS GLOBALES DE AUDITORIA

De una forma más sintetizada se presenta un diagrama donde se puede apreciar el grado porcentual de madurez en base a los 110 controles del modelo implementado y de los niveles de madurez basados en CMM. De esta forma podemos, de una manera rápida y global, evaluar el estado de la seguridad en su conjunto.

De manera general podemos determinar que el Modelo de Gestión y Control Integral de Seguridad de la Información implementado ha elevado, mantenido o disminuido el nivel de grado de seguridad, aunque el objetivo siempre es de mejorar o de evolucionar hasta llegar a los niveles óptimos.

4.1.5.4 PRESENTACION DE INFORME DE AUDITORIA

Este documento debe englobar la parte esencial del trabajo desarrollado, considerando todas las fases realizadas: definición, análisis y estudio. De esto, se debe nutrir y haberse nutrido al resto de documentos y cálculos que forman en cada etapa.

Así mismo deberá incluirse, por ejemplo:

1. *Informe ejecutivo* que contiene un breve desarrollo sobre la estimulación, enfoque y principales conclusiones abstraídas del trabajo.
2. *Documentación y/o presentaciones* que deben mostrar la imagen de la entidad pública, la motivación hacia la seguridad de la información y la importancia del SGSI. Asimismo, se debe mostrar el estado actual de la seguridad de información con respecto al cumplimiento y grado de madurez de los controles que forma la norma.

De este análisis surgirán las distintas mejoras a acometer dentro de un plan de acción a realizar en un periodo de tiempo determinado.

Finalmente se deben presentar los resultados obtenidos tras el desarrollo e implementación, así como el proceso de auditoría de cumplimiento. Con ello obtendremos el nivel de adecuación a la norma y los puntos pendientes a resolver para adecuarse completamente, estableciendo los objetivos alcanzados y aquellas tareas que quedan pendientes de realizar.

4.2 PRÁCTICO Y APLICATIVO DE MODELO

Para el desarrollo de aplicación del Modelo de Gestión y Control de Seguridad de la Información, se establece claramente a la Entidad Pública, es decir a la Administración Pública, dependencias de los mismos para su estudio y análisis.

La Administración Pública del Estado Plurinacional de Bolivia, en cumplimiento a la Ley 1178 en las Normas Básicas del Sistema de Organización Administrativa y la Ley de Organización del Poder Ejecutivo N° 3351 y sus Decretos Reglamentarios, establecen la Conformación de sus Estructuras, Niveles Jerárquicos, Áreas y Unidades Organizacionales claramente.

4.2.1 DEFINICIÓN DE LA ORGANIZACIÓN E IDENTIFICACIÓN DEL DOMINIO

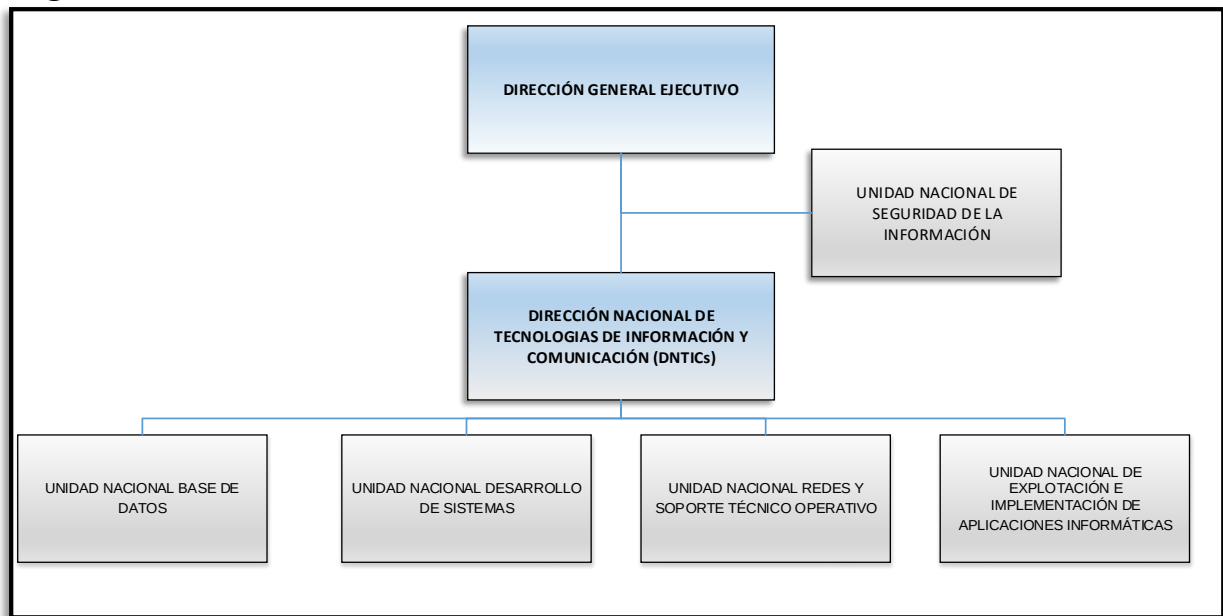
Se ha identificado para la aplicación del modelo de Gestión y Control Integral de Seguridad de la Información, como dominio al Servicio General de Identificación Personal - SEGIP una entidad pública descentralizada.

El Servicio General de Identificación Personal - SEGIP, fue creado a través de la Ley 0145 el 27 de junio de 2011, como institución pública descentralizada, con personalidad jurídica y patrimonio propio, con capacidad administrativa, financiera, legal, técnica y operativa, bajo tuición del Ministerio de Gobierno, con jurisdicción y competencia en todo el territorio del Estado Plurinacional de Bolivia. (Ley 0145, 2011)

SEGIP, única entidad pública autorizada para otorgar la Cédula de Identidad C.I., dentro y fuera del territorio nacional, crear, administrar, controlar, mantener y precautelar el Registro Único de Identificación RUI, de las personas naturales a efecto de su identificación y ejercicio de sus derechos, en el marco de la presente Ley y la Constitución Política del Estado. Así como también a través del Servicio General de Licencias de Conducir, es la entidad delegada de otorgar, registrar, renovar y ejecutar la revocatoria de las Licencias para conducir vehículos terrestres en todo el territorio del Estado Plurinacional de Bolivia, además de las licencias internacionales. (Ley 0145, 2011)

En ese sentido, para nuestro estudio, se estable como entidad a la Dirección Nacional de Tecnología y Comunicaciones DNTICs del Servicio General de Identificación Personal SEGIP.

Figura 4.12.: Estructura de la DNTICs del SEGIP



Fuente: SEGIP, 2011

El objetivo del presente es: Elaborar un Modelo de Gestión y Control Integral en Seguridad de la Información que constituya en la adecuación de todos los componentes, técnicas, controles y procedimientos de seguridad necesarios para convertirse como herramienta para la minimización del nivel de riesgo en la Administración Pública.

4.2.2 PLANIFICACION DE PROGRAMA DE ACCIÓN

Se planifica el cronograma correspondiente, aplicando las fases o etapas del Modelo para alcanzar los propósitos en el Dominio, Entidad Publica a ser evaluado, referidas especialmente a la definición y diagnóstico de la situación actual, evaluación de riesgos, implementación, análisis de resultados y examen de cumplimiento.

Tabla 4.9.: Programa o Cronograma de Acción

Nº	FASE	CONDICIÓN (Fase)	TIEMPO APROX.	DOMINIO, OBJETO DE APLICACIÓN
1	PLANIFICACIÓN Y PROGRAMACIÓN DE EVALUACIÓN	NINGUNA	2 semanas	DNTICs - SEGIP
2	DIAGNÓSTICO DE LA SITUACIÓN ACTUAL Y EVALUACIÓN DE RIESGO	1	2 semanas	DNTICs - SEGIP
3	IMPLEMENTACIÓN	1,2	Según disposición de la MAE	DNTICs - SEGIP
4	ANALISIS DE RESULTADOS	1,2,3	1 semana	DNTICs - SEGIP
5	AUDITORIA DE CUMPLIMIENTO	1,2,3,4	2 semanas	DNTICs - SEGIP

Fuente: Elaboración Propia

4.2.3 DEFINICIÓN DE REQUERIMIENTOS ESPECIFICOS DE EVALUACIÓN

4.2.3.1 MUESTRA Y PROCEDIMIENTO

La muestra obtenida se adquiere mediante la colaboración de la de los directores o autoridades de la Entidad Pública. Mientras los funcionarios o servidores y servidoras públicos eran sometidos a los tests de análisis o diagnóstico para la recolección de información, se les entregaban los cuestionarios para que los rellenaran individualmente. Por tanto, se reúne a todos los servidores y servidoras públicos en función y con disponibilidad dentro de la Dirección Nacional de Tecnologías de la Información DNTICs, de acuerdo a la estructura utilizando el instrumento de la encuesta y cuestionario, de esta manera se estableció un muestreo sistemático para la recolección de información.

4.2.3.1.1 DESCRIPCIÓN DE LA MUESTRA SELECCIONADA

La muestra es establecida de acuerdo al alcance, disposición y colaboración existente por parte de los servidores y servidoras públicos pertenecientes a la Dirección Nacional de Tecnologías de la Información DNTICs del Servicio General de Identificación Personal (SEGIP), a un total de 44 (cuarenta y cuatro) servidores y servidoras públicos pertenecientes a diferentes unidades nacionales de dicha Dirección.

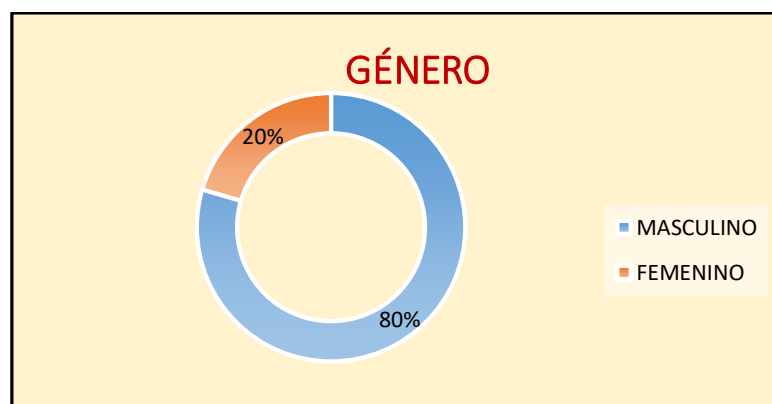
✓ Descripción de la Muestra

- Género

La Figura 4.13 muestra los porcentajes de ocurrencia de los dos sexos en la muestra.

Un 20% de la muestra son mujeres, mientras la mayoría, un 80% son varones.

Figura 4.13. Muestra de encuestados, según Género



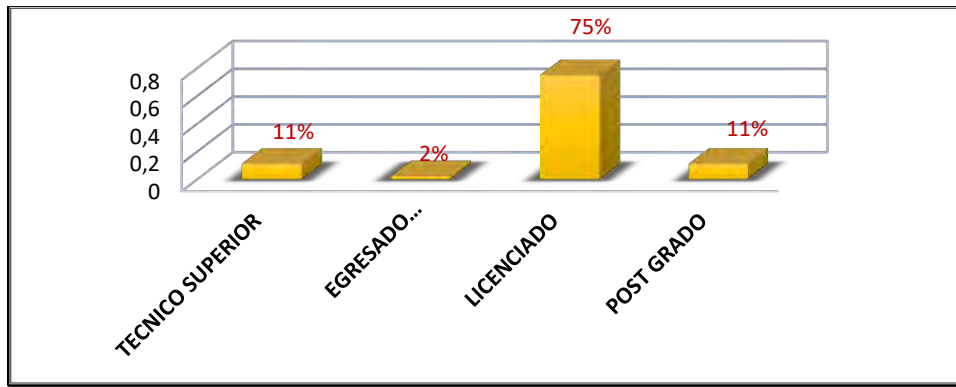
Fuente: Elaboración Propia

- Estudios

En cuanto al nivel de estudios de los servidores y servidoras públicos de la muestra, se han planteado 4 niveles de estudio para identificar a los trabajadores encuestados, de los cuales una gran mayoría poseen estudios de licenciatura, así respectivamente. Los resultados se han trasladado al diagrama de barras, tal como se muestra en la figura 4.14., donde se detalla de acuerdo al nivel de formación planteada y los porcentajes obtenidos por cada nivel.

La importancia del grado de formación que tienen los funcionarios, da a conocer la relación directa de la cultura y clima que pueda producirse o generarse en las instituciones públicas.

Figura 4.14. Muestra, Según nivel de formación

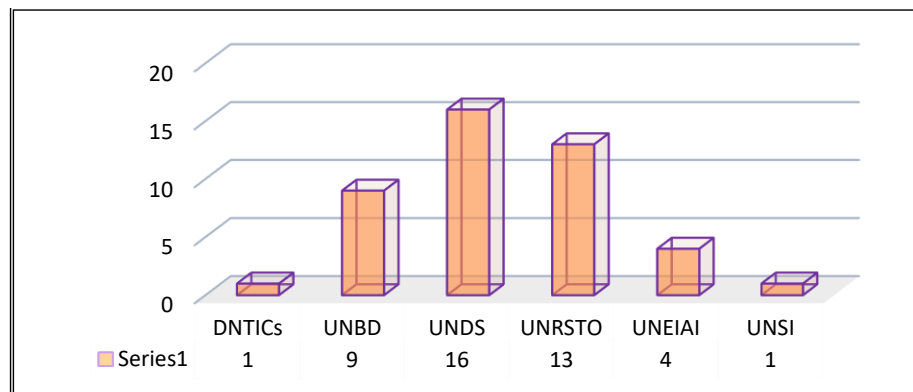


Fuente: Elaboración Propia

- Área de trabajo

En relación con el área de trabajo, en la figura 4.15., se puede evidenciar trabajadores o funcionarios públicos de las unidades nacionales pertenecientes a la DNTICs y al personal de la Unidad Nacional de Seguridad de la Información.

Figura 4.15. Muestra, según Unidad de Trabajo.



Fuente: Elaboración Propia

4.2.3.2 RESPONSABLE DE SEGURIDAD DE LA INFORMACIÓN

Una vez identificado el dominio y las muestras correspondientes, se tomó al Administrador experto de acuerdo al perfil y cargo dentro de la entidad pública, que el mismo tiene una relación estrecha con el manejo y conocimiento de estándares, políticas, técnicas y procedimientos de seguridad de la información para la implementación y seguimiento del Modelo de Gestión y Control Integral como Herramienta para la Minimización del Nivel de Riesgo en la Entidad Pública.

Por tanto, el mismo recae a la jefatura de la Unidad Nacional de Seguridad de la Información UNSI del SEGIP.

4.2.4 REPRESENTACIÓN DE CLAUSULAS, OBJETIVOS Y CONTROLES PARA EVALUACIÓN

De acuerdo al diagnóstico realizada de la situación actual en la Entidad Publica frente a la Seguridad de la Información a través de la norma ISO 27001 e ISO 27002, se ha identificado de acuerdo al comportamiento de las actividades y desarrollo de las funciones, las siguientes clausulas, objetivos y controles para su evaluación:

Tabla 4.10.: Representación de cláusulas, objetivos y controles

CLAUSULAS (CARACTERÍSTICAS)	OBJETIVO DE CONTROL (PROCEDIMIENTO)	CONTROL (ATRIBUTO)
1. POLÍTICAS DE SEGURIDAD.	1.1 Directrices de la Dirección en seguridad de la información.	1.1.1 Conjunto de políticas para la seguridad de la información.
		1.1.2 Revisión de las políticas para la seguridad de la información.
2. ASPECTOS ORGANIZATIVOS DE LA SEGURIDAD DE LA INFORMACIÓN	2.1 Organización interna.	2.1.1 Asignación de responsabilidades para la segur. de la información.
		2.1.2 Segregación de tareas.
		2.1.3 Contacto con las autoridades.
		2.1.4 Contacto con grupos de interés especial.
		2.1.5 Seguridad de la información en la gestión de proyectos.
	2.2 Dispositivos para movilidad y teletrabajo.	2.2.1 Política de uso de dispositivos para movilidad.
3. SEGURIDAD LIGADA A LOS RECURSOS HUMANOS.	3.1 Antes de la contratación.	2.2.2 Teletrabajo.
		3.1.1 Investigación de antecedentes.
	3.2 Durante la contratación.	3.1.2 Términos y condiciones de contratación.
		3.2.1 Responsabilidades de gestión.
		3.2.2 Concienciación, educación y capacitación en segur. de la información.
		3.2.3 Proceso disciplinario.

	3.3 Cese o cambio de puesto de trabajo.	3.3.1 Cese o cambio de puesto de trabajo.
4. GESTIÓN DE ACTIVOS.	4.1 Responsabilidad sobre los activos.	4.1.1 Inventario de activos.
		4.1.2 Propiedad de los activos.
		4.1.3 Uso aceptable de los activos.
		4.1.4 Devolución de activos.
	4.2 Clasificación de la información.	4.2.1 Directrices de clasificación.
		4.2.2 Etiquetado y manipulado de la información.
		4.2.3 Manipulación de activos.
	4.3 Manejo de los soportes de almacenamiento.	4.3.1 Gestión de soportes extraíbles.
		4.3.2 Eliminación de soportes.
		4.3.3 Soportes físicos en tránsito.
5. CONTROL DE ACCESOS.	5.1 Requisitos de negocio para el control de accesos.	5.1.1 Política de control de accesos.
	5.2 Gestión de acceso de usuario.	5.1.2 Control de acceso a las redes y servicios asociados.
		5.2.1 Gestión de altas/bajas en el registro de usuarios.
		5.2.2 Gestión de los derechos de acceso asignados a usuarios.
		5.2.3 Gestión de los derechos de acceso con privilegios especiales.
		5.2.4 Gestión de información confidencial de autenticación de usuarios.
		5.2.5 Retirada o adaptación de los derechos de acceso
	5.3 Responsabilidades del usuario.	5.3.1 Uso de información confidencial para la autenticación.
	5.4 Control de acceso a sistemas y aplicaciones.	5.4.1 Restricción del acceso a la información.
		5.4.2 Procedimientos seguros de inicio de sesión.
		5.4.3 Gestión de contraseñas de usuario.
		5.4.4 Uso de herramientas de administración de sistemas.
		5.4.5 Control de acceso al código fuente de los
6. CIFRADO.	6.1 Controles criptográficos.	6.1.1 Política de uso de los controles criptográficos.
		6.1.2 Gestión de claves.
7. SEGURIDAD FÍSICA Y AMBIENTAL.	7.1 Áreas seguras.	7.1.1 Perímetro de seguridad física.
		7.1.2 Controles físicos de entrada.
		7.1.3 Seguridad de oficinas, despachos y recursos.
		7.1.4 Protección contra las amenazas externas y ambientales.
		7.1.5 El trabajo en áreas seguras.
	7.2 Seguridad de los equipos.	7.2.1 Emplazamiento y protección de equipos.
		7.2.2 Instalaciones de suministro.
		7.2.3 Seguridad del cableado.
		7.2.4 Mantenimiento de los equipos.
		7.2.5 Salida de activos fuera de las dependencias de la empresa.
		7.2.6 Seguridad de los equipos y activos fuera de las instalaciones.
		7.2.7 Reutilización o retirada segura de dispositivos de almacenamiento.
		7.2.8 Equipo informático de usuario desatendido.

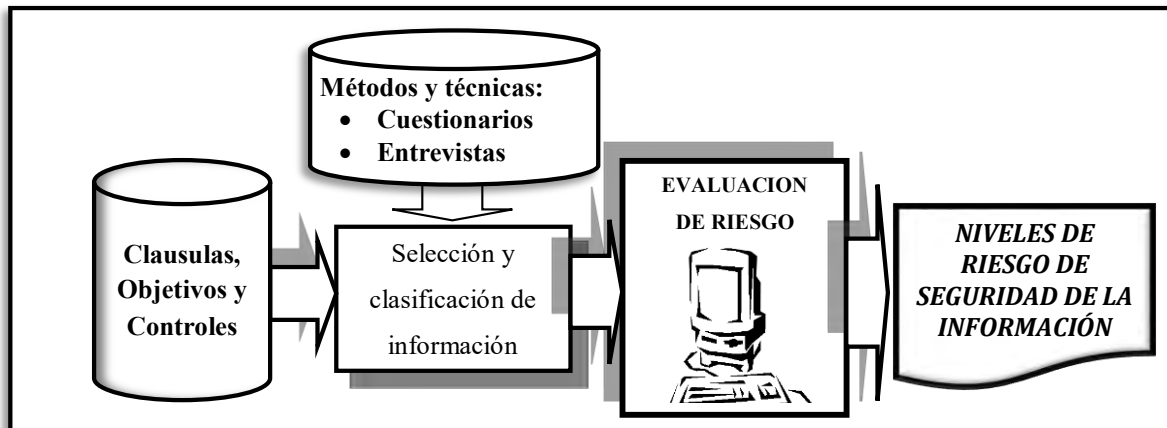
		7.2.9 Política de puesto de trabajo despejado y bloqueo de pantalla.
8. SEGURIDAD EN LA OPERATIVA.	8.1 Responsabilidades y procedimientos de operación.	8.1.1 Documentación de procedimientos de operación.
		8.1.2 Gestión de cambios.
		8.1.3 Gestión de capacidades.
		8.1.4 Separación de entornos de desarrollo, prueba y producción.
	8.2 Protección contra código malicioso.	8.2.1 Controles contra el código malicioso.
	8.3 Copias de seguridad.	8.3.1 Copias de seguridad de la información.
	8.4 Registro de actividad y supervisión.	8.4.1 Registro y gestión de eventos de actividad.
		8.4.2 Protección de los registros de información.
		8.4.3 Registros de actividad del administrador y operador del sistema.
		8.4.4 Sincronización de relojes.
	8.5 Control del software en explotación.	8.5.1 Instalación del software en sistemas en producción.
	8.6 Gestión de la vulnerabilidad técnica.	8.6.1 Gestión de las vulnerabilidades técnicas. 8.6.2 Restricciones en la instalación de software.
	8.7 Consideraciones de las auditorías de los sistemas de información.	8.7.1 Controles de auditoría de los sistemas de información.
9. SEGURIDAD EN LAS TELECOMUNICACIONES.	9.1 Gestión de la seguridad en las redes.	9.1.1 Controles de red.
		9.1.2 Mecanismos de seguridad asociados a servicios en red.
		9.1.3 Segregación de redes.
	9.2 Intercambio de información con partes externas.	9.2.1 Políticas y procedimientos de intercambio de información.
		9.2.2 Acuerdos de intercambio.
		9.2.3 Mensajería electrónica. 9.2.4 Acuerdos de confidencialidad y secreto.
10. ADQUISICIÓN, DESARROLLO Y MANTENIMIENTO DE LOS SISTEMAS DE INFORMACIÓN.	10.1 Requisitos de seguridad de los sistemas de información.	10.1.1 Análisis y especificación de los requisitos de seguridad.
		10.1.2 Seguridad de las comunicaciones en servicios accesibles por redes públicas.
		10.1.3 Protección de las transacciones por redes telemáticas.
	10.2 Seguridad en los procesos de desarrollo y soporte.	10.2.1 Política de desarrollo seguro de software.
		10.2.2 Procedimientos de control de cambios en los sistemas.
		10.2.3 Revisión técnica de las aplicaciones tras efectuar cambios en el sistema operativo.
		10.2.4 Restricciones a los cambios en los paquetes de software.
		10.2.5 Uso de principios de ingeniería en protección de sistemas.
		10.2.6 Seguridad en entornos de desarrollo.
		10.2.7 Pruebas de funcionalidad durante el desarrollo de los sistemas.
		10.2.8 Pruebas de aceptación.
	10.3 Datos de prueba.	10.3.1 Protección de los datos utilizados en pruebas.
		11.1.1 Política de seguridad de la información para suministradores.

11. RELACIONES CON SUMINISTRADORES.	11.1 Seguridad de la información en las relaciones con suministradores.	11.1.2 Tratamiento del riesgo dentro de acuerdos de suministradores.
		11.1.3 Cadena de suministro en tecnologías de la información y comunicaciones.
	11.2 Gestión de la prestación del servicio por suministradores.	11.2.1 Supervisión y revisión de los servicios prestados por terceros.
		11.2.2 Gestión de cambios en los servicios prestados por terceros.
12. GESTIÓN DE INCIDENTES EN LA SEGURIDAD DE LA INFORMACIÓN.	12.1 Gestión de incidentes de seguridad de la información y mejoras.	12.1.1 Responsabilidades y procedimientos.
		12.1.2 Notificación de los eventos de seguridad de la información.
		12.1.3 Notificación de puntos débiles de la seguridad.
		12.1.4 Valoración de eventos de seguridad de la información y toma de decisiones.
		12.1.5 Respuesta a los incidentes de seguridad.
		12.1.6 Aprendizaje de los incidentes de seguridad de la información.
13. ASPECTOS DE LA SEGURIDAD DE LA INFORMACIÓN EN LA GESTIÓN DE LA CONTINUIDAD DEL NEGOCIO.	13.1 Continuidad de la seguridad de la información.	13.1.1 Planificación de la continuidad de la seguridad de la información.
		13.1.2 Implantación de la continuidad de la seguridad de la información.
		13.1.3 Verificación, revisión y evaluación de la continuidad de la seguridad de la información.
	13.2 Redundancias.	13.2.1 Disponibilidad de instalaciones para el procesamiento de la información.
14. CUMPLIMIENTO.	14.1 Cumplimiento de los requisitos legales y contractuales.	14.1.1 Identificación de la legislación aplicable.
		14.1.2 Derechos de Propiedad Intelectual (DPI)
		14.1.3 Protección de los Registros de la Organización.
		14.1.4 Protección de datos y privacidad de la información personal.
		14.1.5 Regulación de los controles criptográficos.
	14.2 Revisiones de la seguridad de la información.	14.2.1 Revisión independiente de la seguridad de la información.
		14.2.2 Cumplimiento de las políticas y normas
		14.2.3 Comprobación del cumplimiento

Fuente: Elaboración Propia

4.2.5 PROCESO DE EVALUACIÓN Y ANÁLISIS DE RIESGOS DE SEGURIDAD DE LA INFORMACIÓN

Para el proceso de evaluación y análisis de riesgos de seguridad de información en la entidad pública, se dispone los procesos que se deben seguir para obtener la información requerida y esperada para el diagnóstico, como se puede observar en la figura 4.16.

Figura 4.16.: Proceso de Evaluación y Análisis de Riesgo

Fuente: Elaboración Propia

Para la aplicación de las técnicas de cuestionarios y entrevistas, se ha seleccionado muestra en la figura 4.16., quedando de la siguiente manera:

Tabla 4.11.: Muestra por área para obtención de información

Nº	DIRECCIÓN/UNIDAD	CANT. PERSONAS
1	Dirección Nacional de Tecnologías de la Información y Comunicaciones (DNTICs)	1
2	Unidad Nacional de Base de Datos (UNBD)	9
3	Unidad nacional de Desarrollo de Sistemas (UNDS)	16
4	Unidad Nacional de Redes y Soporte Técnico Operativo (UNSTO)	13
5	Unidad Nacional de Explotación e Implementación de Aplicaciones Informáticas (UNEIAI)	4
6	Unidad Nacional de Seguridad de la Información	1
TOTAL		44

Fuente: Elaboración Propia

4.2.5.1 CRITERIOS DE EVALUACIÓN DE RIESGOS

La información de la evaluación de riesgos de los controles de Seguridad de Información del modelo propuesto, es producto de la aplicación de técnicas cuestionarios y entrevistas, de acuerdo a los siguientes criterios de evaluación de riesgos:

- a) **Criterio Binario CB**, este criterio es aplicada para evaluar controles a través de entrevistas o cuestionarios con preguntas cerradas y el resultado es evaluada:

$$\text{SÍ: } C_i \neg \exists \Rightarrow RE = 0$$

$$\text{SÍ: } C_i \exists \Rightarrow RE = 1 = 100$$

- b) **Criterio de Riesgo Directo CRD**, este criterio esta aplicada para cuestionarios o entrevistas con preguntas de tipo abierta, donde:

C_i está sujeta a la objetividad del usuario entrevistado.

- c) **Criterio Multi-nivel CMN**, este criterio esta aplicada para evaluar controles a través de cuestionarios y entrevistas con respuestas de selección de tres alternativas y está dada por:

$$\text{SÍ: } C_i \neg \exists \Rightarrow RE = 0$$

$$\text{SÍ: } C_i \exists \text{ parcial o intermedio} \Rightarrow RE = 1 = 60$$

$$\text{SÍ: } C_i \exists \Rightarrow RE = 2 = 100$$

- d) **Criterio de Variable Normalizada CVN**, este criterio es aplicada para la consolidación de la evaluación de riesgos en las cláusulas o características y está dado por:

$$Y = \Sigma \text{ Máximo Puntaje}$$

$$X = \Sigma \text{ Puntaje Obtenido}$$

Por lo tanto:

$$RE = \left(\frac{X}{Y} \right) * 100$$

4.2.5.2 EVALUACIÓN INICIAL DE RIESGOS DE LA SITUACIÓN ACTUAL

Para la evaluación inicial de riesgos del contexto actual de la entidad pública respecto a la Seguridad de la información, se aplica la técnica de encuestas y entrevistas a la muestra seleccionada en la Figura 4.16., para evaluar cada clausula o dominio, objetivos de control y controles o atributos seleccionados y descritos en la Tabla 4.12.

Tabla 4.12.: Evaluación Inicial de Riesgos de Seguridad de la Información

CLAUSULAS (CARACTERÍSTICAS)	NRC (%)	OBJETIVO DE CONTROL (PROCEDIMIENTO)	EVROC (%)	CONTROL (ATRIBUTO)	EVRC (%)
1. POLÍTICAS DE SEGURIDAD.	85.91	1.1 Directrices de la Dirección en seguridad de la información.	85.91	1.1.1 Conjunto de políticas para la seguridad de la información.	100.00
				1.1.2 Revisión de las políticas para la seguridad de la información.	71.82
2. ASPECTOS ORGANIZATIVOS DE LA SEGURIDAD DE LA INFORMACIÓN	68.75	2.1 Organización interna.	82.27	2.1.1 Asignación de responsabilidades para la segur. de la información.	69.09
				2.1.2 Segregación de tareas.	71.82
				2.1.3 Contacto con las autoridades.	70.45
				2.1.4 Contacto con grupos de interés especial.	100.00
				2.1.5 Seguridad de la información en la gestión de proyectos.	100.00
		2.2 Dispositivos para movilidad y teletrabajo.	55.23	2.2.1 Política de uso de dispositivos para movilidad.	38.64
				2.2.2 Teletrabajo.	71.82
3. SEGURIDAD LIGADA A LOS RECURSOS HUMANOS.	89.62	3.1 Antes de la contratación.	92.05	3.1.1 Investigación de antecedentes.	84.09
				3.1.2 Términos y condiciones de Contratación.	100.00
		3.2 Durante la contratación.	76.82	3.2.1 Responsabilidades de gestión.	100.00
				3.2.2 Concienciación, educación y capacitación en segur. de la información.	62.27
				3.2.3 Proceso disciplinario.	68.18
		3.3 Cese o cambio de puesto de trabajo.	100.00	3.3.1 Cese o cambio de puesto de trabajo.	100.00
4. GESTIÓN DE ACTIVOS.	87.32	4.1 Responsabilidad sobre los activos.	92.27	4.1.1 Inventario de activos.	100.00
				4.1.2 Propiedad de los activos.	100.00
				4.1.3 Uso aceptable de los activos.	69.09
				4.1.4 Devolución de activos.	100.00
		4.2 Clasificación de la información.	84.85	4.2.1 Directrices de clasificación.	100.00
				4.2.2 Etiquetado y manipulado de la información.	54.55
				4.2.3 Manipulación de activos.	100.00
		4.3 Manejo de los soportes de almacenamiento.	84.85	4.3.1 Gestión de soportes extraíbles.	84.09
				4.3.2 Eliminación de soportes.	100.00
				4.3.3 Soportes físicos en tránsito.	70.45
5. CONTROL DE ACCESOS.	94.45	5.1 Requisitos de negocio para el control de accesos.	100.00	5.1.1 Política de control de accesos.	100.00
				5.1.2 Control de acceso a las redes y servicios asociados.	100.00

		5.2 Gestión de acceso de usuario.	88.64	5.2.1 Gestión de altas/bajas en el registro de usuarios.	61.36
				5.2.2 Gestión de los derechos de acceso asignados a usuarios.	100.00
				5.2.3 Gestión de los derechos de acceso con privilegios especiales.	100.00
				5.2.4 Gestión de información confidencial de autenticación de usuarios.	100.00
				5.2.5 Retirada o adaptación de los derechos de acceso	81.82
		5.3 Responsabilidades del usuario.	100.00	5.3.1 Uso de información confidencial para la autenticación.	100.00
		5.4 Control de acceso a sistemas y aplicaciones.	89.18	5.4.1 Restricción del acceso a la información.	70.45
				5.4.2 Procedimientos seguros de inicio de sesión.	93.64
				5.4.3 Gestión de contraseñas de usuario.	100.00
				5.4.4 Uso de herramientas de administración de sistemas.	81.82
				5.4.5 Control de acceso al código fuente de los progr.	100.00
6. CIFRADO.	88.64	6.1 Controles criptográficos.	88.64	6.1.1 Política de uso de los controles criptográficos.	77.27
				6.1.2 Gestión de claves.	100.00
7. SEGURIDAD FÍSICA Y AMBIENTAL.	91.22	7.1 Áreas seguras.	94.36	7.1.1 Perímetro de seguridad física.	71.82
				7.1.2 Controles físicos de entrada.	100.00
				7.1.3 Seguridad de oficinas, despachos y recursos.	100.00
				7.1.4 Protección contra las amenazas externas y ambientales.	100.00
				7.1.5 El trabajo en áreas seguras.	100.00
		7.2 Seguridad de los equipos.	88.08	7.2.1 Emplazamiento y protección de equipos.	100.00
				7.2.2 Instalaciones de suministro.	100.00
				7.2.3 Seguridad del cableado.	60.00
				7.2.4 Mantenimiento de los equipos.	100.00
				7.2.5 Salida de activos fuera de las dependencias de la empresa.	100.00
				7.2.6 Seguridad de los equipos y activos fuera de las instalaciones.	100.00
				7.2.7 Reutilización o retirada segura de dispositivos de almacenamiento.	100.00

				7.2.8 Equipo informático de usuario desatendido.	69.09
				7.2.9 Política de puesto de trabajo despejado y bloqueo de pantalla.	63.64
8. SEGURIDAD EN LA OPERATIVA.	86.30	8.1 Responsabilidades y procedimientos de operación.	88.41	8.1.1 Documentación de procedimientos de operación.	72.73
				8.1.2 Gestión de cambios.	80.91
				8.1.3 Gestión de capacidades.	100.00
				8.1.4 Separación de entornos de desarrollo, prueba y producción.	100.00
		8.2 Protección contra código malicioso.	100.00	8.2.1 Controles contra el código malicioso.	100.00
		8.3 Copias de seguridad.	100.00	8.3.1 Copias de seguridad de la información.	100.00
		8.4 Registro de actividad y supervisión.	92.95	8.4.1 Registro y gestión de eventos de actividad.	71.82
				8.4.2 Protección de los registros de información.	100.00
				8.4.3 Registros de actividad del administrador y operador del sistema.	100.00
				8.4.4 Sincronización de relojes.	100.00
		8.5 Control del software en explotación.	100.00	8.5.1 Instalación del software en sistemas en producción.	100.00
		8.6 Gestión de la vulnerabilidad técnica.	100.00	8.6.1 Gestión de las vulnerabilidades técnicas.	100.00
				8.6.2 Restricciones en la instalación de software.	100.00
		8.7 Consideraciones de las auditorías de los sistemas de información.	22.73	8.7.1 Controles de auditoría de los sistemas de información.	22.73
9. SEGURIDAD EN LAS TELECOMUNICACIONES.	96.14	9.1 Gestión de la seguridad en las redes.	100.00	9.1.1 Controles de red.	100.00
				9.1.2 Mecanismos de seguridad asociados a servicios en red.	100.00
				9.1.3 Segregación de redes.	100.00
		9.2 Intercambio de información con partes externas.	92.27	9.2.1 Políticas y procedimientos de intercambio de información.	100.00
				9.2.2 Acuerdos de intercambio.	69.09
				9.2.3 Mensajería electrónica.	100.00
10. ADQUISICIÓN, DESARROLLO Y MANTENIMIENTO DE LOS SISTEMAS DE INFORMACIÓN.	96.09	10.1 Requisitos de seguridad de los sistemas de información.	96.97	9.2.4 Acuerdos de confidencialidad y secreto.	100.00
				10.1.1 Análisis y especificación de los requisitos de seguridad.	100.00
				10.1.2 Seguridad de las comunicaciones en servicios accesibles por redes públicas.	100.00
				10.1.3 Protección de las transacciones por redes telemáticas.	90.91

		10.2 Seguridad en los procesos de desarrollo y soporte.	91.31	10.2.1 Política de desarrollo seguro de software.	100.00
				10.2.2 Procedimientos de control de cambios en los sistemas.	100.00
				10.2.3 Revisión técnica de las aplicaciones tras efectuar cambios en el sistema operativo.	100.00
				10.2.4 Restricciones a los cambios en los paquetes de software.	100.00
				10.2.5 Uso de principios de ingeniería en protección de sistemas.	100.00
				10.2.6 Seguridad en entornos de desarrollo.	69.09
				10.2.7 Pruebas de funcionalidad durante el desarrollo de los sistemas.	100.00
				10.2.8 Pruebas de aceptación.	61.36
		10.3 Datos de prueba.	100.00	10.3.1 Protección de los datos utilizados en pruebas.	100.00
11. RELACIONES CON SUMINISTRADORES.	89.47	11.1 Seguridad de la información en las relaciones con suministradores.	82.12	11.1.1 Política de seguridad de la información para suministradores.	77.27
				11.1.2 Tratamiento del riesgo dentro de acuerdos de suministradores.	100.00
				11.1.3 Cadena de suministro en tecnologías de la información y comunicaciones.	69.09
		11.2 Gestión de la prestación del servicio por suministradores.	96.82	11.2.1 Supervisión y revisión de los servicios prestados por terceros.	93.64
				11.2.2 Gestión de cambios en los servicios prestados por terceros.	100.00
12. GESTIÓN DE INCIDENTES EN LA SEGURIDAD DE LA INFORMACIÓN.	92.27	12.1 Gestión de incidentes de seguridad de la información y mejoras.	92.27	12.1.1 Responsabilidades y procedimientos.	93.64
				12.1.2 Notificación de los eventos de seguridad de la información.	100.00
				12.1.3 Notificación de puntos débiles de la seguridad.	100.00
				12.1.4 Valoración de eventos de seguridad de la información y toma de decisiones.	60.00
				12.1.5 Respuesta a los incidentes de seguridad.	100.00
				12.1.6 Aprendizaje de los incidentes de seguridad de la información.	100.00
13. ASPECTOS DE SEGURIDAD DE LA	60.98		76.52	13.1.1 Planificación de la continuidad de la seguridad de la información.	100.00

INFORMACION EN LA GESTIÓN DE LA CONTINUIDAD DEL NEGOCIO.		13.1 Continuidad de la seguridad de la información.		13.1.2 Implantación de la continuidad de la seguridad de la información.	29.55
				13.1.3 Verificación, revisión y evaluación de la continuidad de la seguridad de la información.	100.00
		13.2 Redundancias.	45.45	13.2.1 Disponibilidad de instalaciones para el procesamiento de la información.	45.45
14. CUMPLIMIENTO.	71.82	14.1 Cumplimiento de los requisitos legales y contractuales.	86.36	14.1.1 Identificación de la legislación aplicable.	60.00
				14.1.2 Derechos de Propiedad Intelectual (DPI)	100.00
				14.1.3 Protección de los Registros de la Organización.	71.82
				14.1.4 Protección de datos y privacidad de la información personal.	100.00
				14.1.5 Regulación de los controles criptográficos.	100.00
		14.2 Revisiones de la seguridad de la información.	57.27	14.2.1 Revisión independiente de la seguridad de la información.	0.00
				14.2.2 Cumplimiento de las políticas y normas	71.82
				14.2.3 Comprobación del cumplimiento	100.00

Fuente: Elaboración Propia

Donde:

NRC: Nivel de Riesgo Controlado

EVROC: Evaluación de Riesgo de Objetivo Controlado

EVRC: Evaluación de Riesgo de Controle o Atributo Controlado

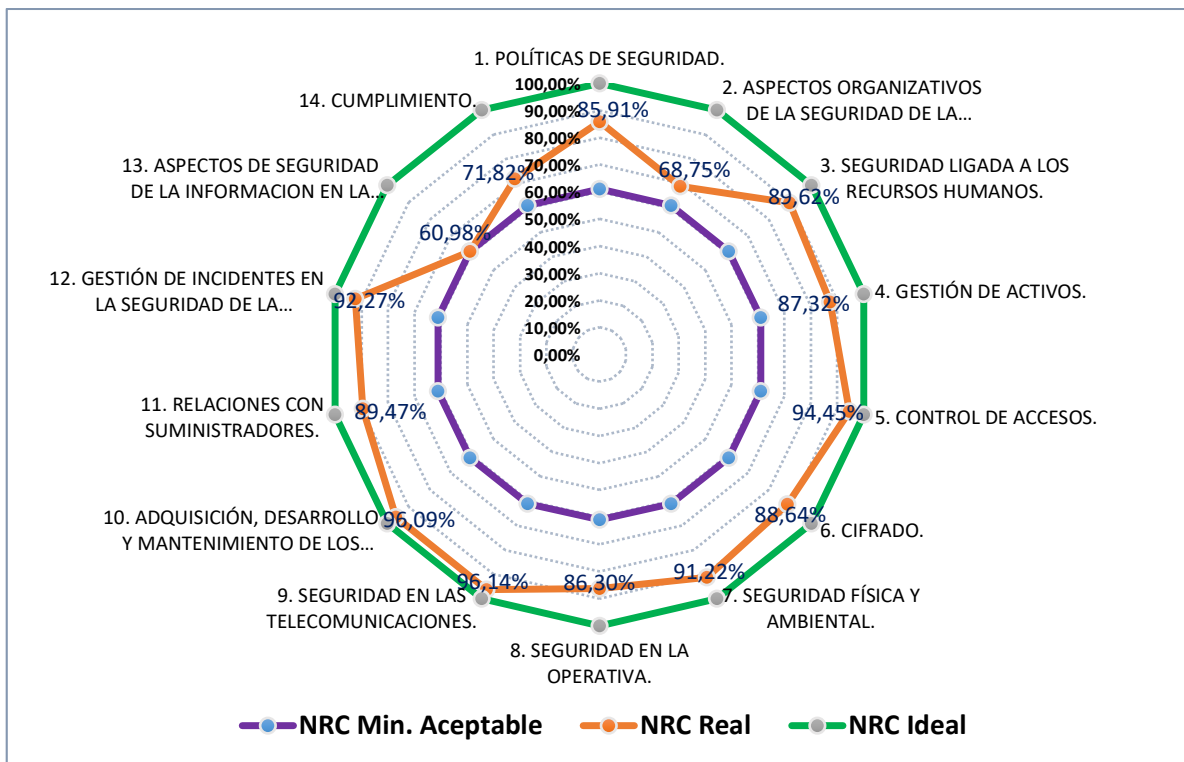
4.2.6 ANÁLISIS DE RESULTADOS DE EVALUACION DE RIESGOS DE LA SITUACIÓN ACTUAL

Para el diagnostico o evaluación de riesgos de la contexto actual o inicial de la Entidad Publica respecto a la Seguridad de la Información, se ha desarrollado el trabajo juntamente con el personal determinado en la muestra, es decir funcionarios de la Dirección Nacional de Tecnologías de la Información DNTICs del Servicio General de Identificación Personal SEGIP.

El proceso de evaluación se la realiza a través de una representación basada sobre métodos estadísticos, cuestionarios y entrevistas, que facilitan el almacenamiento, recolección de datos, cuantificación y clasificación, que de gran manera ayudan a obtener los resultados respecto a la Seguridad de la Información para interpretación.

Resultado de la evaluación de riesgos de la situación actual o inicial de la Seguridad de la Información en la Entidad Pública, se ha obtenido información cuantificada, tal como se muestra en la figura 4.17.

Figura 4.17.: Evaluación de Riesgo de la Situación Actual



Fuente: Elaboración Propia

En esta figura se muestra la medición cuantitativa inicial o de situación actual de la evaluación de riesgos de la Seguridad de la Información de la Entidad Pública, específicamente del Servicio General de Identificación Personal (SEGIP), donde los resultados muestran que en su gran mayoría de las cláusulas o características del modelo propuesto son satisfactorios, es decir por encima del mínimo aceptable.

Para determinar claramente este proceso, se establece dos aspectos muy importantes para su análisis global de las cláusulas del modelo propuesto:

- a) **Nivel Riesgo Controlado (NRC)**, resultado producto de la evaluación de riesgo, a través de técnicas de entrevistas y cuestionarios a las cláusulas, objetivos de control y controles propuestos.
- b) **Nivel de Riesgo No Controlado NRNC**, se determina de la siguiente manera:

$$\text{NRNC} = 100\% - \text{NRC}$$

Por tanto, a partir del nivel de riesgo controlado (NRC) se determina el nivel de riesgo no controlado (NRNC), el mismo se describe en la Tabla 4.13, de la siguiente manera:

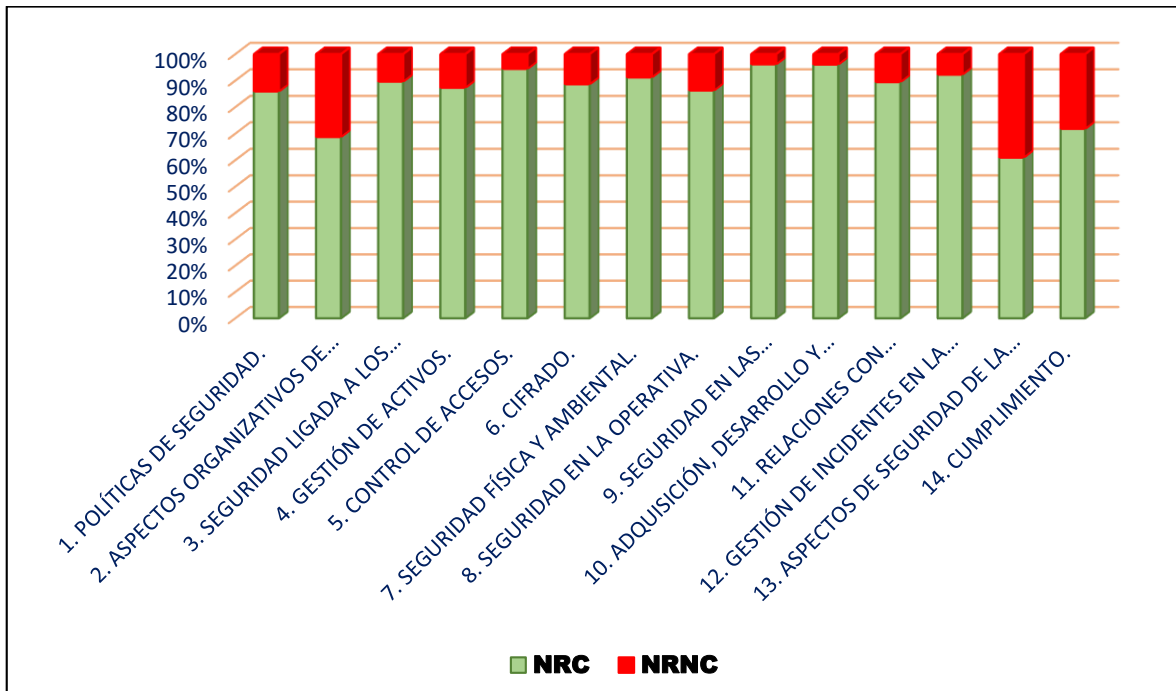
Tabla 4.13.: Niveles de Riesgos Controlados y No Controlados

CLAUSULA O DOMINIO	NRC (%)	NRNC (%)
1. POLÍTICAS DE SEGURIDAD.	85.91	14.09
2. ASPECTOS ORGANIZATIVOS DE LA SEGURIDAD DE LA INFORMACIÓN	68.75	31.25
3. SEGURIDAD LIGADA A LOS RECURSOS HUMANOS.	89.62	10.38
4. GESTIÓN DE ACTIVOS.	87.32	12.68
5. CONTROL DE ACCESOS.	94.45	5.55
6. CIFRADO.	88.64	11.36
7. SEGURIDAD FÍSICA Y AMBIENTAL.	91.22	8.78
8. SEGURIDAD EN LA OPERATIVA.	86.30	13.70
9. SEGURIDAD EN LAS TELECOMUNICACIONES.	96.14	3.86
10. ADQUISICIÓN, DESARROLLO Y MANTENIMIENTO DE LOS SISTEMAS DE INFORMACIÓN.	96.09	3.91
11. RELACIONES CON SUMINISTRADORES.	89.47	10.53
12. GESTIÓN DE INCIDENTES EN LA SEGURIDAD DE LA INFORMACIÓN.	92.27	7.73
13. ASPECTOS DE SEGURIDAD DE LA INFORMACION EN LA GESTIÓN DE LA CONTINUIDAD DEL NEGOCIO.	60.98	39.02
14. CUMPLIMIENTO.	71.82	28.18

Fuente: Elaboración Propia

El resultado del proceso de evaluación de riesgo inicialmente realizada, se han determinado el Nivel de Riesgo Controlado NRC y Nivel de Riesgo No Controlado NRNC, en el cual se describe claramente la necesidad de mejorar en algunas cláusulas o características de los controles propuestos para determinar y mejorar al nivel de riesgos controlados en la Entidad Pública respecto al Control de Riesgo de Seguridad de la Información, en ese sentido el comportamiento de la información se describe en la figura 4.18.

Figura 4.18.: Niveles de Riesgos Controlados y No Controlados



Fuente: Elaboración Propia

Determinación de los pesos de acuerdo a la importancia a las cláusulas, dominio o características determinados para la evaluación de los riesgos de seguridad de la información en la entidad pública.

Tabla 4.14.: Determinación de pesos para evaluación de riesgos

CLAUSULA O DOMINIO	PESOS
1. POLÍTICAS DE SEGURIDAD.	0.06
2. ASPECTOS ORGANIZATIVOS DE LA SEGURIDAD DE LA INFORMACIÓN	0.06

3. SEGURIDAD LIGADA A LOS RECURSOS HUMANOS.	0.06
4. GESTIÓN DE ACTIVOS.	0.07
5. CONTROL DE ACCESOS.	0.09
6. CIFRADO.	0.07
7. SEGURIDAD FÍSICA Y AMBIENTAL.	0.09
8. SEGURIDAD EN LA OPERATIVA.	0.07
9. SEGURIDAD EN LAS TELECOMUNICACIONES.	0.09
10. ADQUISICIÓN, DESARROLLO Y MANTENIMIENTO DE LOS SISTEMAS DE INFORMACIÓN.	0.09
11. RELACIONES CON SUMINISTRADORES.	0.05
12. GESTIÓN DE INCIDENTES EN LA SEGURIDAD DE LA INFORMACIÓN.	0.07
13. ASPECTOS DE SEGURIDAD DE LA INFORMACION EN LA GESTIÓN DE LA CONTINUIDAD DEL NEGOCIO.	0.06
14. CUMPLIMIENTO.	0.07
TOTAL	1.00

Fuente: Elaboración Propia

La determinación de pesos para cada clausula, dominio o característica en el proceso de evaluación de riesgos, sirve para obtener el Indicador del Nivel de Riesgo Controlado (INRC), realizando los cálculos de la siguiente manera:

$$\text{INRC} = \text{NRC} * \text{PESOS}$$

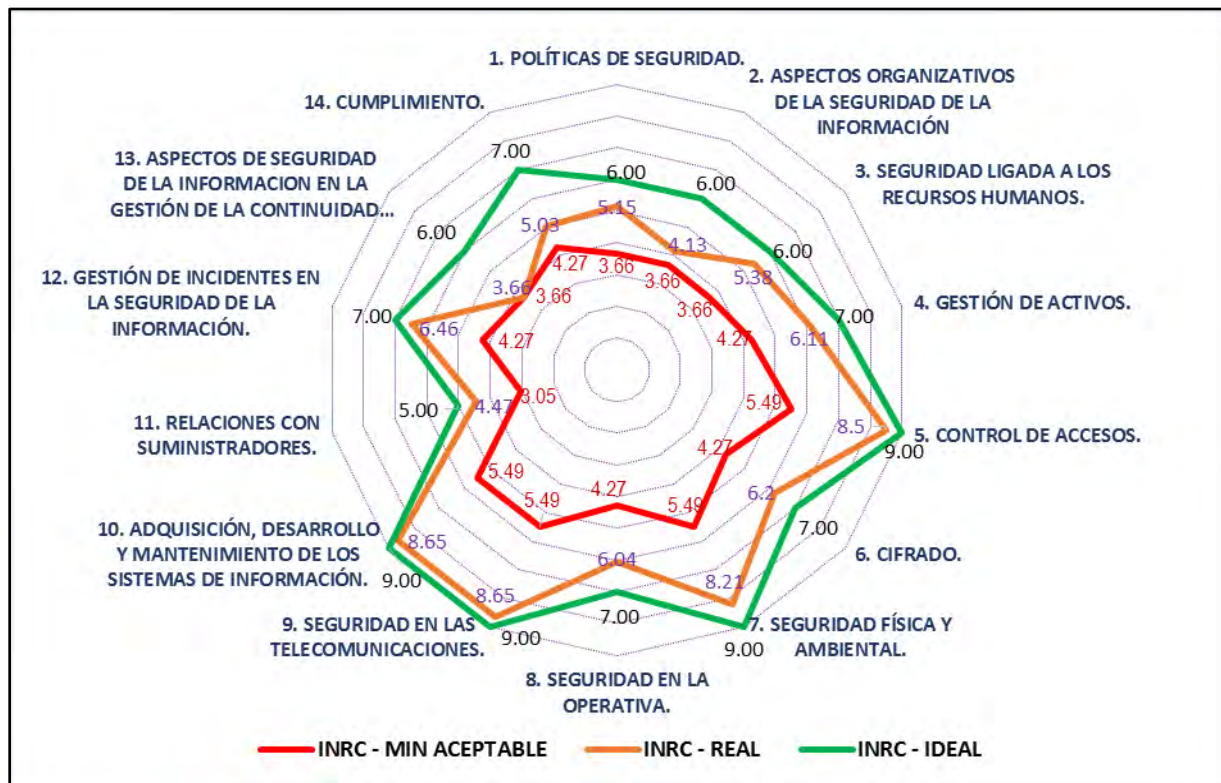
Tabla 4.15.: Determinación del Indicador del Nivel de Riesgo Controlado

CLAUSULA O DOMINIO	NRC (%)	PESOS	INRC (%)
1. POLÍTICAS DE SEGURIDAD.	85.91	0.06	5.15
2. ASPECTOS ORGANIZATIVOS DE LA SEGURIDAD DE LA INFORMACIÓN	68.75	0.06	4.13
3. SEGURIDAD LIGADA A LOS RECURSOS HUMANOS.	89.62	0.06	5.38
4. GESTIÓN DE ACTIVOS.	87.32	0.07	6.11
5. CONTROL DE ACCESOS.	94.45	0.09	8.50
6. CIFRADO.	88.64	0.07	6.20
7. SEGURIDAD FÍSICA Y AMBIENTAL.	91.22	0.09	8.21

8. SEGURIDAD EN LA OPERATIVA.	86.30	0.07	6.04
9. SEGURIDAD EN LAS TELECOMUNICACIONES.	96.14	0.09	8.65
10. ADQUISICIÓN, DESARROLLO Y MANTENIMIENTO DE LOS SISTEMAS DE INFORMACIÓN.	96.09	0.09	8.65
11. RELACIONES CON SUMINISTRADORES.	89.47	0.05	4.47
12. GESTIÓN DE INCIDENTES EN LA SEGURIDAD DE LA INFORMACIÓN.	92.27	0.07	6.46
13. ASPECTOS DE SEGURIDAD DE LA INFORMACION EN LA GESTIÓN DE LA CONTINUIDAD DEL NEGOCIO.	60.98	0.06	3.66
14. CUMPLIMIENTO.	71.82	0.07	5.03
INDICADOR GLOBAL DE NIVEL DE RIESGO CONTROLADO (IGNRC)	1.00	0.07	86.64

Fuente: Elaboración Propia

Figura 4.19.: Indicador del Nivel de Riesgo Controlado INRC



Fuente: Elaboración Propia

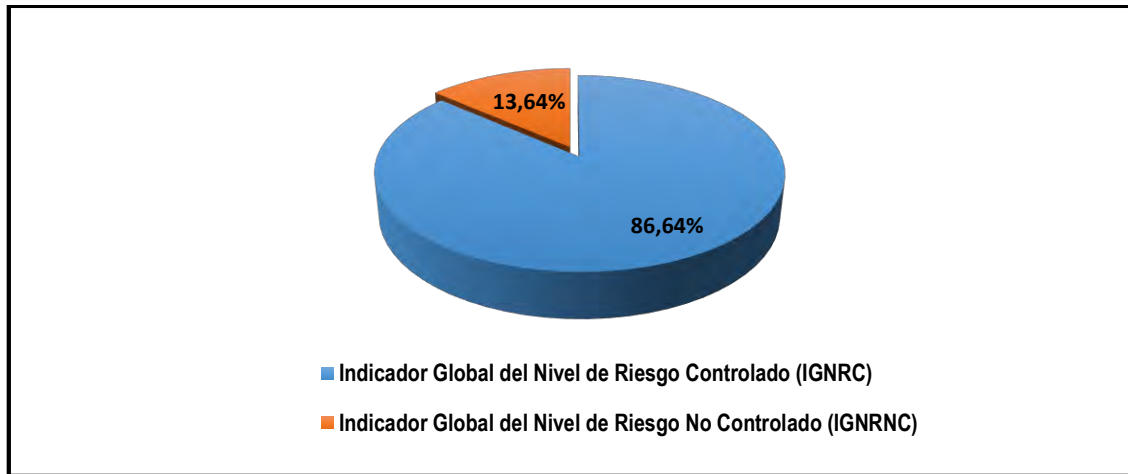
En ese sentido, a partir de la determinación del Indicador Global de Nivel de Riesgo Controlado IGNRC también se puede determinar el Indicador del Global del Nivel de Riesgo No Controlado **IGNRNC**, de la siguiente manera:

$$\text{IGNRNC} = 100\% - \text{IGNRC}$$

$$\text{IGNRNC} = 100\% - 86.64\%$$

$$\text{IGNRNC} = 13.36\%$$

Figura 4.20.: Indicador Global del Nivel de Riesgo Controlado IGNRC e Indicador Global del Nivel de Riesgo No controlado IGNRNC



Fuente: Elaboración Propia

A partir de los resultados obtenidos se puede determinar en el Servicio General de Identificación Personal SEGIP:

a) Nivel Inicial de Seguridad de la Información

Tabla 4.16.: Nivel de la Situación Inicial de Seguridad de la Información

ENTIDAD EVALUADA	Indicador Global del Nivel de Riesgo Controlado (IGNRC) (%)	NIVEL DE SEGURIDAD DE LA INFORMACIÓN (%)		
		INSATISFACTORIO (0 - 40)	MARGINAL (41 - 60)	SATISFACTORIO (61 - 100)
SEGIP	86.64			X

Fuente: Elaboración Propia

Según la tabla 4.16, nos muestra el resultado de la situación actual respecto al Nivel de Seguridad de la Información del Servicio General de Identificación Personal SEGIP, es del 86.64%, lo cual se considera de manera global como **SATISFACTORIO**.

b) Nivel Inicial de Riesgo de Seguridad de la Información

Tabla 4.17.: Nivel de la Situación Inicial del Nivel de Riesgo de Seguridad de la Información

ENTIDAD EVALUADA	Indicador Global del Nivel de Riesgo No Controlado (IGNRNC) (%)	NIVEL DE RIESGO DE SEGURIDAD DE LA INFORMACIÓN (%)		
		BAJO (0 - 40)	MODERADO (41 - 60)	ALTO (61 - 100)
SEGIP	13.36	X		

Fuente: Elaboración Propia

De acuerdo a los parámetros establecidos, el diagnóstico inicial respecto al Nivel de Riesgo de Seguridad de la Información se evidencia como BAJO, lo cual, una vez implementado el modelo el propósito es minimizar esta situación.

4.2.7 IMPLEMENTACIÓN Y EVALUACIÓN DE RIESGO DE SEGURIDAD DE LA INFORMACIÓN

Para la implementación del Modelo de Gestión y Control Integral de Riesgos de Seguridad de la Información, se considera la misma Entidad Pública, Servicio General de Identificación Personal - SEGIP, Dirección Nacional de Tecnologías y Comunicación TICs. Así mismo para recopilación de información de la misma manera se aplica las técnicas de Entrevistas y Cuestionarios.

En ese sentido, en el marco de las normas ISO 27001:2013, se implementa las cláusulas o características, objetivos de control y controles seleccionadas de acuerdo al desarrollo de las actividades de la Entidad Pública.

Para esta fase, se aplican los mismos criterios de evaluación de riesgos descritos y seleccionados para el tratamiento de los resultados de la información producto de entrevistas y cuestionarios.

Tabla 4.18. Resultado de la Evaluación de Riesgos de Seguridad de la Información posterior a la implementación

CLAUSULAS (CARACTERÍSTICAS)	NRC (%)	OBJETIVO DE CONTROL (PROCEDIMIENTO)	EVROC (%)	CONTROL (ATRIBUTO)	EVRC (%)
1. POLÍTICAS DE SEGURIDAD.	95.45	1.1 Directrices de la Dirección en seguridad de la información.	95.45	1.1.1 Conjunto de políticas para la seguridad de la información.	100.00
				1.1.2 Revisión de las políticas para la seguridad de la información.	90.91
2. ASPECTOS ORGANIZATIVOS DE LA SEGURIDAD DE LA INFORMACIÓN	92.61	2.1 Organización interna.	100.00	2.1.1 Asignación de responsabilidades para la segur. de la información.	100.00
				2.1.2 Segregación de tareas.	100.00
				2.1.3 Contacto con las autoridades.	100.00
				2.1.4 Contacto con grupos de interés especial.	100.00
				2.1.5 Seguridad de la información en la gestión de proyectos.	100.00
		2.2 Dispositivos para movilidad y teletrabajo.	85.23	2.2.1 Política de uso de dispositivos para movilidad.	70.45
				2.2.2 Teletrabajo.	100.00
3. SEGURIDAD LIGADA A LOS RECURSOS HUMANOS.	96.34	3.1 Antes de la contratación.	92.05	3.1.1 Investigación de antecedentes.	84.09
				3.1.2 Términos y condiciones de Contratación.	100.00
		3.2 Durante la contratación.	96.97	3.2.1 Responsabilidades de gestión.	100.00
				3.2.2 Conciliación, educación y capacitación en segur. de la información.	90.91
				3.2.3 Proceso disciplinario.	100.00
		3.3 Cese o cambio de puesto de trabajo.	100.00	3.3.1 Cese o cambio de puesto de trabajo.	100.00
4. GESTIÓN DE ACTIVOS.	95.73	4.1 Responsabilidad sobre los activos.	97.05	4.1.1 Inventario de activos.	100.00
				4.1.2 Propiedad de los activos.	100.00
				4.1.3 Uso aceptable de los activos.	88.18
				4.1.4 Devolución de activos.	100.00
		4.2 Clasificación de la información.	100.00	4.2.1 Directrices de clasificación.	100.00
				4.2.2 Etiquetado y manipulado de la información.	100.00
				4.2.3 Manipulación de activos.	100.00
			90.15	4.3.1 Gestión de soportes extraíbles.	100.00
				4.3.2 Eliminación de soportes.	100.00

		4.3 Manejo de los soportes de almacenamiento.		4.3.3 Soportes físicos en tránsito.	70.45
5. CONTROL DE ACCESOS.	97.34	5.1 Requisitos de negocio para el control de accesos.	100.00	5.1.1 Política de control de accesos.	100.00
				5.1.2 Control de acceso a las redes y servicios asociados.	100.00
		5.2 Gestión de acceso de usuario.	97.64	5.2.1 Gestión de altas/bajas en el registro de usuarios.	100.00
				5.2.2 Gestión de los derechos de acceso asignados a usuarios.	100.00
				5.2.3 Gestión de los derechos de acceso con privilegios especiales.	100.00
				5.2.4 Gestión de información confidencial de autenticación de usuarios.	100.00
				5.2.5 Retirada o adaptación de los derechos de acceso	88.18
		5.3 Responsabilidades del usuario.	100.00	5.3.1 Uso de información confidencial para la autenticación.	100.00
		5.4 Control de acceso a sistemas y aplicaciones.	91.73	5.4.1 Restricción del acceso a la información.	70.45
				5.4.2 Procedimientos seguros de inicio de sesión.	100.00
				5.4.3 Gestión de contraseñas de usuario.	100.00
				5.4.4 Uso de herramientas de administración de sistemas.	88.18
				5.4.5 Control de acceso al código fuente de los	100.00
6. CIFRADO.	88.64	6.1 Controles criptográficos.	88.64	6.1.1 Política de uso de los controles criptográficos.	77.27
				6.1.2 Gestión de claves.	100.00
7. SEGURIDAD FÍSICA Y AMBIENTAL.	97.31	7.1 Áreas seguras.	97.45	7.1.1 Perímetro de seguridad física.	87.27
				7.1.2 Controles físicos de entrada.	100.00
				7.1.3 Seguridad de oficinas, despachos y recursos.	100.00
				7.1.4 Protección contra las amenazas externas y ambientales.	100.00
				7.1.5 El trabajo en áreas seguras.	100.00
		7.2 Seguridad de los equipos.	97.17	7.2.1 Emplazamiento y protección de equipos.	100.00
				7.2.2 Instalaciones de suministro.	100.00
				7.2.3 Seguridad del cableado.	87.27

				7.2.4 Mantenimiento de los equipos.	100.00
				7.2.5 Salida de activos fuera de las dependencias de la empresa.	100.00
				7.2.6 Seguridad de los equipos y activos fuera de las instalaciones.	100.00
				7.2.7 Reutilización o retirada segura de dispositivos de almacenamiento.	100.00
				7.2.8 Equipo informático de usuario desatendido.	87.27
				7.2.9 Política de puesto de trabajo despejado y bloqueo de pantalla.	100.00
8. SEGURIDAD EN LA OPERATIVA.	94.90	8.1 Responsabilidades y procedimientos de operación.	97.05	8.1.1 Documentación de procedimientos de operación.	88.18
				8.1.2 Gestión de cambios.	100.00
				8.1.3 Gestión de capacidades.	100.00
				8.1.4 Separación de entornos de desarrollo, prueba y producción.	100.00
		8.2 Protección contra código malicioso.	100.00	8.2.1 Controles contra el código malicioso.	100.00
		8.3 Copias de seguridad.	100.00	8.3.1 Copias de seguridad de la información.	100.00
		8.4 Registro de actividad y supervisión.	96.82	8.4.1 Registro y gestión de eventos de actividad.	87.27
				8.4.2 Protección de los registros de información.	100.00
				8.4.3 Registros de actividad del administrador y operador del sistema.	100.00
				8.4.4 Sincronización de relojes.	100.00
		8.5 Control del software en explotación.	100.00	8.5.1 Instalación del software en sistemas en producción.	100.00
		8.6 Gestión de la vulnerabilidad técnica.	100.00	8.6.1 Gestión de las vulnerabilidades técnicas.	100.00
				8.6.2 Restricciones en la instalación de software.	100.00
		8.7 Consideraciones de las auditorías de los sistemas de información.	70.45	8.7.1 Controles de auditoría de los sistemas de información.	70.45
9. SEGURIDAD EN LAS TELECOMUNICACIONES.	98.52	9.1 Gestión de la seguridad en las redes.	100.00	9.1.1 Controles de red.	100.00
				9.1.2 Mecanismos de seguridad asociados a servicios en red.	100.00
				9.1.3 Segregación de redes.	100.00

		9.2 Intercambio de información con partes externas.	97.05	9.2.1 Políticas y procedimientos de intercambio de información.	100.00
				9.2.2 Acuerdos de intercambio.	88.18
				9.2.3 Mensajería electrónica.	100.00
				9.2.4 Acuerdos de confidencialidad y secreto.	100.00
10. ADQUISICIÓN, DESARROLLO Y MANTENIMIENTO DE LOS SISTEMAS DE INFORMACIÓN.	99.34	10.1 Requisitos de seguridad de los sistemas de información.	100.00	10.1.1 Análisis y especificación de los requisitos de seguridad.	100.00
				10.1.2 Seguridad de las comunicaciones en servicios accesibles por redes públicas.	100.00
				10.1.3 Protección de las transacciones por redes telemáticas.	100.00
		10.2 Seguridad en los procesos de desarrollo y soporte.	98.01	10.2.1 Política de desarrollo seguro de software.	100.00
				10.2.2 Procedimientos de control de cambios en los sistemas.	100.00
				10.2.3 Revisión técnica de las aplicaciones tras efectuar cambios en el sistema operativo.	100.00
				10.2.4 Restricciones a los cambios en los paquetes de software.	100.00
				10.2.5 Uso de principios de ingeniería en protección de sistemas.	100.00
				10.2.6 Seguridad en entornos de desarrollo.	100.00
				10.2.7 Pruebas de funcionalidad durante el desarrollo de los sistemas.	100.00
				10.2.8 Pruebas de aceptación.	84.09
		10.3 Datos de prueba.	100.00	10.3.1 Protección de los datos utilizados en pruebas.	100.00
11. RELACIONES CON SUMINISTRADORES.	92.65	11.1 Seguridad de la información en las relaciones con suministradores.	88.48	11.1.1 Política de seguridad de la información para suministradores.	77.27
				11.1.2 Tratamiento del riesgo dentro de acuerdos de suministradores.	100.00
				11.1.3 Cadena de suministro en tecnologías de la información y comunicaciones.	88.18
		11.2 Gestión de la prestación del	96.82	11.2.1 Supervisión y revisión de los servicios prestados por terceros.	93.64

		servicio por suministradores.		11.2.2 Gestión de cambios en los servicios prestados por terceros.	100.00
12. GESTIÓN DE INCIDENTES EN LA SEGURIDAD DE LA INFORMACIÓN.	98.94	12.1 Gestión de incidentes de seguridad de la información y mejoras.	98.94	12.1.1 Responsabilidades y procedimientos.	93.64
				12.1.2 Notificación de los eventos de seguridad de la información.	100.00
				12.1.3 Notificación de puntos débiles de la seguridad.	100.00
				12.1.4 Valoración de eventos de seguridad de la información y toma de decisiones.	100.00
				12.1.5 Respuesta a los incidentes de seguridad.	100.00
				12.1.6 Aprendizaje de los incidentes de seguridad de la información.	100.00
13. ASPECTOS DE SEGURIDAD DE LA INFORMACION EN LA GESTIÓN DE LA CONTINUIDAD DEL NEGOCIO.	88.64	13.1 Continuidad de la seguridad de la información.	100.00	13.1.1 Planificación de la continuidad de la seguridad de la información.	100.00
				13.1.2 Implantación de la continuidad de la seguridad de la información.	100.00
				13.1.3 Verificación, revisión y evaluación de la continuidad de la seguridad de la información.	100.00
		13.2 Redundancias.	77.27	13.2.1 Disponibilidad de instalaciones para el procesamiento de la información.	77.27
14. CUMPLIMIENTO.	95.48	14.1 Cumplimiento de los requisitos legales y contractuales.	94.00	14.1.1 Identificación de la legislación aplicable.	79.09
				14.1.2 Derechos de Propiedad Intelectual (DPI)	100.00
				14.1.3 Protección de los Registros de la Organización.	90.91
				14.1.4 Protección de datos y privacidad de la información personal.	100.00
				14.1.5 Regulación de los controles criptográficos.	100.00
		14.2 Revisiones de la seguridad de la información.	96.97	14.2.1 Revisión independiente de la seguridad de la información.	100.00
				14.2.2 Cumplimiento de las políticas y normas	90.91
				14.2.3 Comprobación del cumplimiento	100.00

Fuente: Elaboración Propia

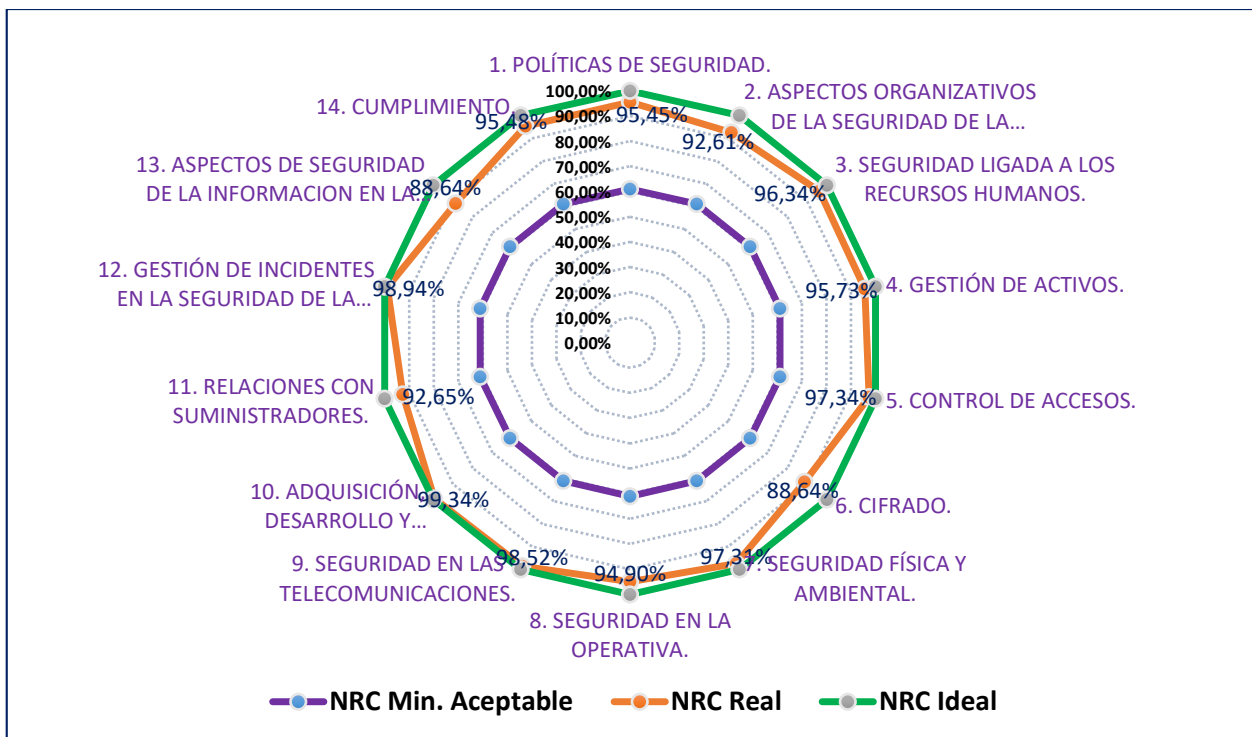
4.2.8 ANÁLISIS DE RESULTADOS

Posterior a la implementación del modelo, se requiere el análisis de resultados del diagnóstico o evaluación de riesgos de la Entidad Publica respecto a la Seguridad de la Información, de la misma manera se ha desarrollado el trabajo juntamente con el personal determinado en la muestra, es decir funcionarios de la Dirección Nacional de Tecnologías de la Información (DNTICs) del SEGIP.

El proceso de análisis de resultados es producto de una representación basada en métodos estadísticos, cuestionarios y entrevistas, que facilitan el almacenamiento y recolección de datos, que de gran manera ayudan a encontrar los resultados, para su interpretación.

Los resultados de la evaluación de riesgos de la situación posterior a la implementación del Modelo de Gestión y Control Integral de Riesgos de Seguridad de la Información en la Administración Pública, se obtiene información cuantificada y evolutiva o creciente notoriamente, tal como se muestra en la figura 4.21.

Figura 4.21.: Resultado de Evaluación de Riesgo de la Seguridad en la Información



Fuente: Elaboración Propia

En esta figura se muestra la medición cuantitativa posterior a la implementación del modelo, donde se eleva cuantitativamente el Nivel de Seguridad de la Información del Servicio General de Identificación Personal (SEGIP), donde los resultados muestran que en su totalidad de las cláusulas o dominios del modelo propuesto se elevan, es decir aproximándose al Nivel de Seguridad de la Información Ideal.

En ese sentido, manteniendo la misma metodología de evaluación para análisis de resultados, se establece dos aspectos muy importantes para su análisis global de las cláusulas del modelo propuesto:

- a) Nivel Riesgo Controlado (NRC).
- b) Nivel de Riesgo No Controlado (NRNC)

$$\text{NRNC} = 100\% - \text{NRC}$$

A partir del nivel de riesgo controlado (NRC) se determina el nivel de riesgo no controlado (NRNC), el mismo se describe en la Tabla 4.19:

Tabla 4.19.: Niveles de Riesgos Controlados y No Controlados

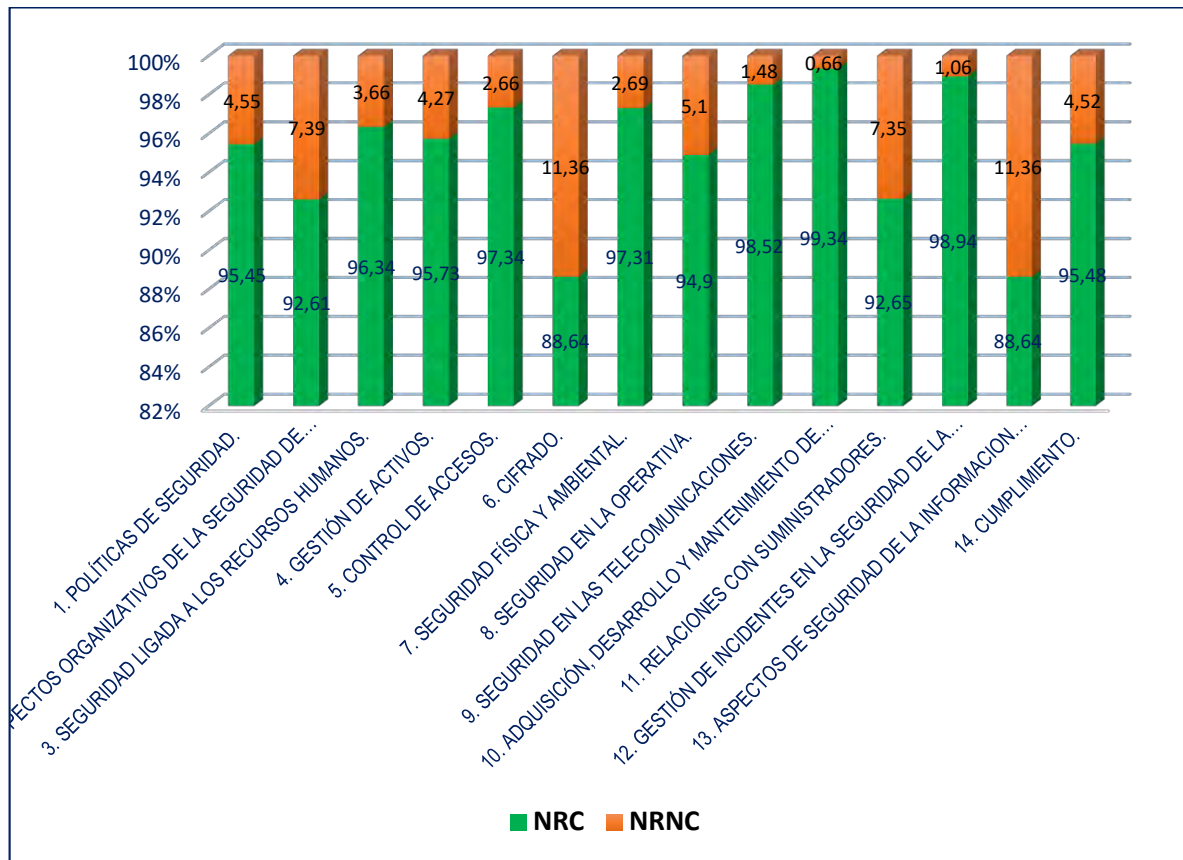
CLAUSULA O DOMINIO	NRC (%)	NRNC (%)
1. POLÍTICAS DE SEGURIDAD.	95.45	4.55
2. ASPECTOS ORGANIZATIVOS DE LA SEGURIDAD DE LA INFORMACIÓN	92.61	7.39
3. SEGURIDAD LIGADA A LOS RECURSOS HUMANOS.	96.34	3.66
4. GESTIÓN DE ACTIVOS.	95.73	4.27
5. CONTROL DE ACCESOS.	97.34	2.66
6. CIFRADO.	88.64	11.36
7. SEGURIDAD FÍSICA Y AMBIENTAL.	97.31	2.69
8. SEGURIDAD EN LA OPERATIVA.	94.90	5.10
9. SEGURIDAD EN LAS TELECOMUNICACIONES.	98.52	1.48
10. ADQUISICIÓN, DESARROLLO Y MANTENIMIENTO DE LOS SISTEMAS DE INFORMACIÓN.	99.34	0.66
11. RELACIONES CON SUMINISTRADORES.	92.65	7.35
12. GESTIÓN DE INCIDENTES EN LA SEGURIDAD DE LA INFORMACIÓN.	98.94	1.06
13. ASPECTOS DE SEGURIDAD DE LA INFORMACION EN LA GESTIÓN DE LA CONTINUIDAD DEL NEGOCIO.	88.64	11.36
14. CUMPLIMIENTO.	95.48	4.52

Fuente: Elaboración Propia

El Resultado del proceso de evaluación posterior a la implementación del Modelo, se ha determinado el Nivel de Riesgo Controlado NRC y Nivel de Riesgo No Controlado NRC.

De acuerdo a nuestro análisis, se muestra claramente que el Nivel de Riesgo Controlado NRC se ha incrementado con relación a la evaluación inicial, así mismo el Nivel de Riesgo No controlado NRNC ha disminuido de manera general en todas las cláusulas o características de los controles implementados o seleccionados para la evaluación de Seguridad de la Información en la Entidad Pública, en ese sentido se puede evidenciar gráficamente la situación de Nivel de Riesgo Controlado y Nivel de Riesgo No Controlado en la figura 4.22.

Figura 4.22.: Niveles de Riesgos Controlados y No Controlados



Fuente: Elaboración Propia

A partir de la aplicación del producto entre el Nivel de Riesgo Controlado NRC y los pesos determinados para la evaluación, se obtiene el Indicador Total de Nivel de Riesgo Controlado ITNRC, realizando los cálculos de la siguiente manera:

$$\text{ITNRC} = \text{NRC} * \text{PESOS}$$

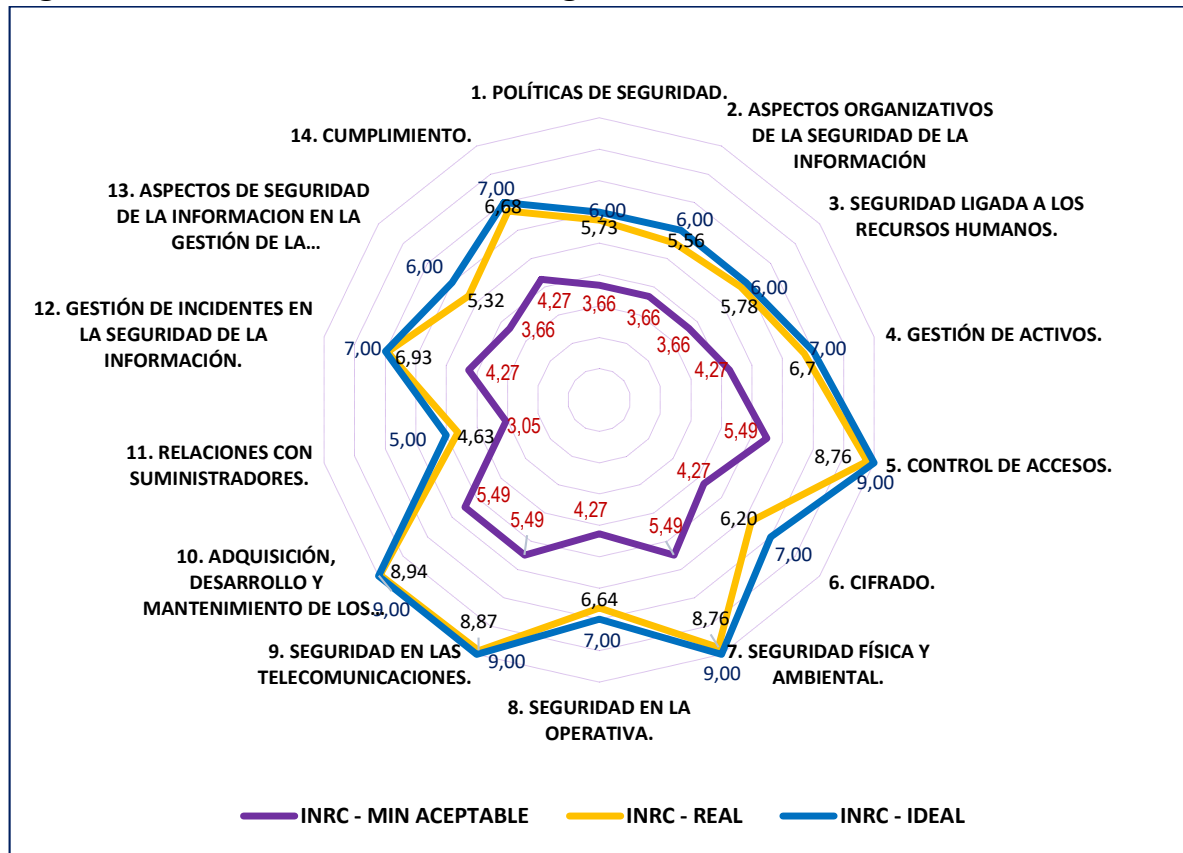
Tabla 4.20: Determinación del Indicador Total del Nivel de Riesgo Controlado

CLAUSULA O DOMINIO	NRC (%)	PESOS	ITNRC (%)
1. POLÍTICAS DE SEGURIDAD.	95.45	0.06	5.73
2. ASPECTOS ORGANIZATIVOS DE LA SEGURIDAD DE LA INFORMACIÓN	92.61	0.06	5.56
3. SEGURIDAD LIGADA A LOS RECURSOS HUMANOS.	96.34	0.06	5.78
4. GESTIÓN DE ACTIVOS.	95.73	0.07	6.70
5. CONTROL DE ACCESOS.	97.34	0.09	8.76
6. CIFRADO.	88.64	0.07	6.20
7. SEGURIDAD FÍSICA Y AMBIENTAL.	97.31	0.09	8.76
8. SEGURIDAD EN LA OPERATIVA.	94.90	0.07	6.64
9. SEGURIDAD EN LAS TELECOMUNICACIONES.	98.52	0.09	8.87
10. ADQUISICIÓN, DESARROLLO Y MANTENIMIENTO DE LOS SISTEMAS DE INFORMACIÓN.	99.34	0.09	8.94
11. RELACIONES CON SUMINISTRADORES.	92.65	0.05	4.63
12. GESTIÓN DE INCIDENTES EN LA SEGURIDAD DE LA INFORMACIÓN.	98.94	0.07	6.93
13. ASPECTOS DE SEGURIDAD DE LA INFORMACION EN LA GESTIÓN DE LA CONTINUIDAD DEL NEGOCIO.	88.64	0.06	5.32
14. CUMPLIMIENTO.	95.48	0.07	6.68
INDICADOR GLOBAL DE NIVEL DE RIESGO TOTAL CONTROLADO (IGNRTC)		1.00	95.50

Fuente: Elaboración Propia

El comportamiento del Indicador Total del Nivel de Riesgo Controlado ITNRC posterior a la implementación del Modelo de Gestión y Control Integral de Riesgos de Seguridad de la Información, se puede observar en la siguiente figura.

Figura 4.23.: Indicador del Nivel de Riesgo Controlado ITNRC



Fuente: Elaboración Propia

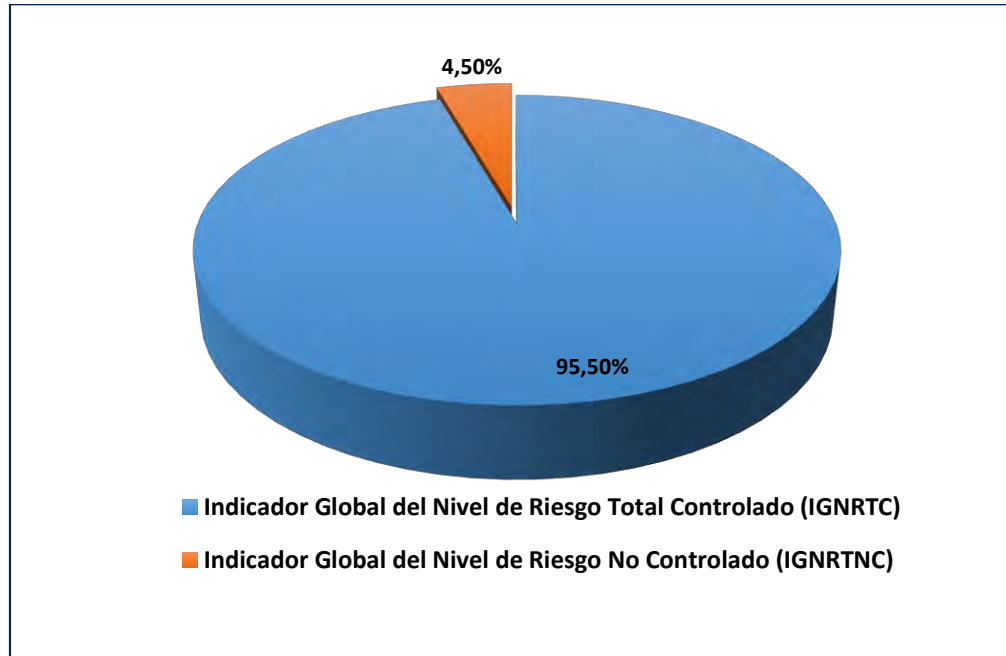
Por tanto, a partir de la determinación del Indicador Global de Nivel de Riesgo Total Controlado (IGNRTC) también se puede determinar el Indicador del Global del Nivel de Riesgo Total No Controlado **IGNRTNC**, de la siguiente manera:

$$\text{IGNRTNC} = 100\% - \text{IGNRTC}$$

$$\text{IGNRTNC} = 100\% - 95.50\%$$

$$\text{IGNRTNC} = 4.50\%$$

Figura 4.24.: Indicador Global del Nivel de Riesgo Total Controlado IGNRTC e Indicador Global del Nivel de Riesgo Total No controlado IGNRTNC



Fuente: Elaboración Propia

Después de la implementación del Modelo de Gestión y Control Integral de Riesgos de Seguridad de la Información en la Administración Pública los resultados obtenidos en el Servicio General de Identificación Personal SEGIP respecto a la seguridad de la información, son los siguientes:

i) Nivel Inicial de Seguridad de la Información

Tabla 4.21: Nivel de la Situación de Seguridad de la Información

ENTIDAD EVALUADA	Indicador Global del Nivel de Riesgo Total Controlado (IGNRTC) (%)	NIVEL DE SEGURIDAD DE LA INFORMACIÓN (%)		
		INSATISFACTORIO (0 - 40)	MARGINAL (41 - 60)	SATISFACTORIO (61 - 100)
SEGIP	95.50			X

Fuente: Elaboración Propia

Según la tabla 4.21, nos muestra el resultado de la situación actual, es decir posterior a la implementación del modelo, respecto al Nivel de Seguridad de la Información en el Servicio General de Identificación Personal SEGIP, es del 91.00%, lo cual se considera de manera global como **SATISFACTORIO**.

ii) Nivel Inicial de Riesgo de Seguridad de la Información

Tabla 4.22: Nivel de la Situación del Riesgo de Seguridad de la Información

ENTIDAD EVALUAD A	Indicador Global del Nivel de Riesgo Total No Controlado (IGNRTNC) (%)	NIVEL DE RIESGO DE SEGURIDAD DE LA INFORMACIÓN (%)		
		BAJO (0 - 40)	MODERADO (41 - 60)	ALTO (61 - 100)
SEGIP	4.50	X		

Fuente: Elaboración Propia

De acuerdo a los parámetros establecidos, el diagnóstico respecto al Nivel de Riesgo de Seguridad de la Información se evidencia como **BAJO**, lo cual, nos demuestra que se ha minimizado posterior a la Implementación del modelo con relación al nivel inicial.

4.2.8.1 ANÁLISIS COMPARATIVO DE EVALUACIÓN DE RIESGO DE SEGURIDAD DE INFORMACIÓN

Posterior a los resultados obtenidos producto de la evaluación de riesgo de seguridad de la información en el Servicio General de Identificación Personal (SEGIP), se puede evidenciar variaciones entre el antes de la implementación del modelo y después de la implementación del mismo, tal como se muestra en la siguiente tabla.

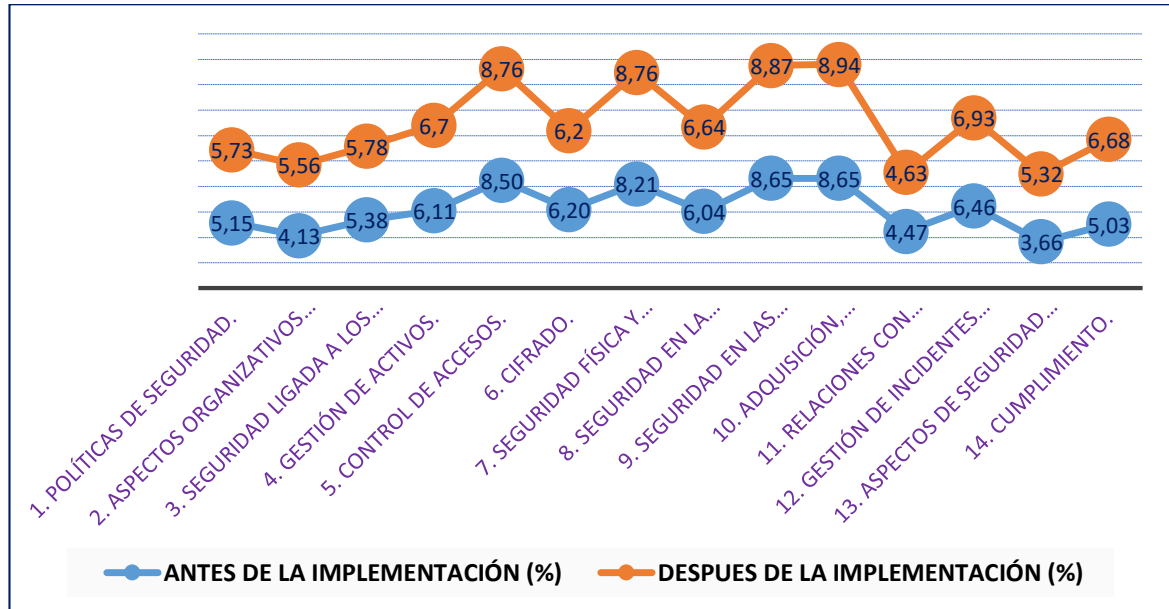
Tabla 4.23: cuadro comparativo final de seguridad de la Información antes y después de la Implementación del Modelo.

CLAUSULA O DOMINIO	Antes de la Implementación (%)	Después de la Implementación (%)
1. POLÍTICAS DE SEGURIDAD.	5.15	5.73
2. ASPECTOS ORGANIZATIVOS DE LA SEGURIDAD DE LA INFORMACIÓN	4.13	5.56
3. SEGURIDAD LIGADA A LOS RECURSOS HUMANOS.	5.38	5.78
4. GESTIÓN DE ACTIVOS.	6.11	6.70
5. CONTROL DE ACCESOS.	8.50	8.76
6. CIFRADO.	6.20	6.20
7. SEGURIDAD FÍSICA Y AMBIENTAL.	8.21	8.76
8. SEGURIDAD EN LA OPERATIVA.	6.04	6.64
9. SEGURIDAD EN LAS TELECOMUNICACIONES.	8.65	8.87
10. ADQUISICIÓN, DESARROLLO Y MANTENIMIENTO DE LOS SISTEMAS DE INFORMACIÓN.	8.65	8.94
11. RELACIONES CON SUMINISTRADORES.	4.47	4.63
12. GESTIÓN DE INCIDENTES EN LA SEGURIDAD DE LA INFORMACIÓN.	6.46	6.93
13. ASPECTOS DE SEGURIDAD DE LA INFORMACION EN LA GESTIÓN DE LA CONTINUIDAD DEL NEGOCIO.	3.66	5.32
14. CUMPLIMIENTO.	5.03	6.68

Fuente: Elaboración Propia

Se puede evidenciar en esta tabla 4.25 las variaciones correspondientes entre antes y después de la implementación del modelo, en todos los dominios o clausulas se incrementan y gráficamente se puede mostrar en la siguiente figura.

Figura 4.25: Seguridad de la Información antes y después de la implementación del Modelo



Fuente: Elaboración Propia

4.2.8.2 INDICADOR DE MINIMIZACIÓN DE RIESGO

Para determinar el Indicador de Minimización de Riesgo IMR de Seguridad de la Información en el Servicio General de Identificación Personal SEGIP, se obtendrá a partir del resultado Global de la evaluación realizada antes de la Implementación del Modelo y el resultado Global después de la Implementación del Modelo, de la siguiente manera:

$$\text{IMR} = \text{IGNRTC (después de la implementación)} - \text{IGNRC (antes de la implementación)}$$

Realizando los cálculos correspondientes:

$$\text{IMR} = 95.50\% - 86.64\%$$

$$\text{IMR} = 8.86\%$$

En ese sentido, se puede afirmar que producto de la implementación del “Modelo de Gestión y Control Integral de Seguridad de la Información como Herramienta Para la Minimización del Nivel de Riesgo en la Administración Pública” en el Servicio General de Identificación Personal SEGIP, se minimizó el **8.86%** del Nivel de Riesgo de Seguridad de la Información.

4.2.9 AUDITORIA DE CUMPLIMIENTO

En base a los análisis realizados en los que se han identificado las amenazas y riesgos en los que SEGIP se puede ver expuesto, es importante determinar en este punto cual el grado de cumplimiento de los controles de seguridad acorde con la ISO/IEC 27001:2013, con el objeto de establecer la madurez del sistema de gestión en la institución pública establecida anualmente.

4.2.9.1 METODOLOGIA DE AUDITORIA

De distintas formas las salvaguardas actúan minimizando los riesgos, solo con mencionar como los controles ISO/IEC 27002:2013 u otros con las mismas características. Estos son:

- El establecimiento de las prácticas a través de documentos escritos o admitidos.
- La política de personal.
- Las solicitudes técnicas (hardware, software o comunicaciones).
- La seguridad física.

La protección integral frente a las posibles amenazas, requiere de una combinación de salvaguardas sobre cada uno de estos aspectos.

Por tanto, es importante que este tipo de evaluaciones una vez implantado el modelo, se deban realizar anualmente en el SEGIP auditorias de cumplimiento, con el propósito de mejorar, actualizar los controles correspondientes referentes a la seguridad de la información.

Como base del nivel de madurez de los controles, se hará uso del Modelo de Madurez de la Capacidad (CMM), con la siguiente escala de valoración:

<u>NIVEL</u>	<u>CMM</u>
0% INEXISTENTE	C1
20% INICIAL	C2
40% REPETIBLE	C3
60% GESTIONADO Y MEDIBLE	C4
100% OPTIMIZADO	C5

Así mismo, indicar que en un proceso de auditoría interna se lleva a cabo el examen del cumplimiento de la normativa de la entidad pública, donde se pueden evidenciar distintas tipologías de desviaciones, para el caso:

- **No conformidad Mayor:** para el que incumple un apartado completo de la norma.
- **No conformidad Menor (o solamente no conformidad):** para el que incumple un punto de un apartado o es una no conformidad detectada, que por sus características no llega a la gravedad de la anterior.
- **Observación:** para el que no incumple nada, se describe sólo una recomendación, en caso de no ser tratado el mismo, esto se puede convertir en la siguiente auditoría en *No conformidad*.

4.2.9.2 EVALUACIÓN Y ANÁLISIS DE RESULTADOS DE MADUREZ

Para tal propósito, como base del nivel de madurez de los controles, se hará uso del Modelo de Madurez de la Capacidad (CMM) con sus respectivas valoraciones a las Dominios o clausulas, sus objetivos y controles correspondientes. El cual comprende 110 controles y 14 dominios o cláusulas de seguridad los cuales fueron evaluados su cumplimiento, con los siguientes resultados.

Tabla 4.24.: Resultado de la Capacidad de Madurez - Cumplimiento

CLAUSULA O DOMINIO	CUMPLIMIENTO DOMINIO	CMM
1. POLÍTICAS DE SEGURIDAD.	95.45	C4
2. ASPECTOS ORGANIZATIVOS DE LA SEGURIDAD DE LA INFORMACIÓN	96.27	C4
3. SEGURIDAD LIGADA A LOS RECURSOS HUMANOS.	95.71	C4
4. GESTIÓN DE ACTIVOS.	94.97	C4
5. CONTROL DE ACCESOS.	98.82	C4
6. CIFRADO.	95.45	C4
7. SEGURIDAD FÍSICA Y AMBIENTAL.	93.69	C4
8. SEGURIDAD EN LA OPERATIVA.	95.58	C4
9. SEGURIDAD EN LAS TELECOMUNICACIONES.	98.52	C4
10. ADQUISICIÓN, DESARROLLO Y MANTENIMIENTO DE LOS SISTEMAS DE INFORMACIÓN.	99.73	C4
11. RELACIONES CON SUMINISTRADORES.	85.61	C4

12. GESTIÓN DE INCIDENTES EN LA SEGURIDAD DE LA INFORMACIÓN.	94.70	C4
13. ASPECTOS DE SEGURIDAD DE LA INFORMACION EN LA GESTIÓN DE LA CONTINUIDAD DEL NEGOCIO.	95.45	C4
14. CUMPLIMIENTO.	94.42	C4

Fuente: Elaboración Propia

a) Análisis de Resultados por Dominio o Clausula

A continuación, se realizan análisis de las auditorías de cumplimiento realizadas a los dominios o clausulas seleccionadas:

- 1) Dominio: **POLÍTICA DE SEGURIDAD**, de manera general muestra un progreso de madurez óptima, por tanto, logro un nivel acorde a la norma. La entidad Publica dispone con un documento de *Política de Seguridad de la Información* al alcance de los involucrados y se tiene un plan periódico de revisión.

Resultado de la auditoría de cumplimiento respecto a este dominio, no presenta no conformidad ni observación.

- 2) Dominio: **ASPECTOS ORGANIZATIVOS DE LA SEGURIDAD DE LA INFORMACIÓN** evidencias tres **Observaciones** concretas:

En el Objetivo de Control 2.1 sobre la *Organización interna*. Se recomiendan aspectos referentes a:

- Control 2.1.1 *Asignación de Responsabilidades para la Seguridad de Información*. Deberán los Responsables o el Director del Área oportunamente asignar responsabilidades.
- Control 2.1.3 *Contacto con las autoridades*. Deben conservar los contactos fluidos y apropiados con las autoridades pertinentes.
- Control 2.1.4 *Contactos con grupos de especial interés*. Mantener contactos pertinentes con grupos de interés especial, foros y con organizaciones profesionales en materia de seguridad.

- 3) Dominio: **SEGURIDAD LIGADA A LOS RECURSOS HUMANOS** presenta una **Observación** evidenciada en:

En el Objetivos de Control 3.1 *Antes de la contratación* se deben mejorar aspectos concernientes a:

- Control 3.1.1 *Investigación de antecedentes*. La revisión de los antecedentes de los postulantes a un cargo de trabajo de los contratistas o de los terceros, procede de acuerdo a las normativas legales vigentes y códigos de éticas.

En el Objetivo de Control 3.2 *Durante la contratación* se deben optimizar aspectos concernientes a:

- Control 3.2.3 *Proceso disciplinario*. Debe existir un proceso disciplinario formal para los funcionarios que hayan incurrido a alguna infracción de la seguridad.

4) Dominio: **GESTIÓN DE ACTIVOS** presenta una **Observación**:

En el Objetivo de Control 4.1 *Responsabilidad sobre los Activos*, se recomienda mejorar el aspecto referido a:

- Control 4.1.3 *Uso Aceptable de los Activos*, Establecer la mejora en el uso aceptable de los funcionarios de la entidad.

En el Objetivo de Control 4.3 *Manejo de soportes de almacenamiento*. Se recomienda perfeccionar aspectos relativos a:

- Control 4.3.1 *Gestión de soportes extraíbles*. Establecer procedimientos para la gestión de los soportes extraíbles.

Como No Conformidad Menor, se ha determinado a:

- Control 4.3.3 *Soportes físicos en tránsito*. Los soportes físicos en tránsito deben ser controlados estrictamente para evitar daño.

5) Dominio: **CONTROL DE ACCESO** presenta dos **observaciones** que se exponen de la siguiente manera:

En el Objetivo de Control 5.2 *Gestión de acceso de usuario* se recomienda mejorar aspectos relativos a:

- Control 5.2.2 *Gestión de los derechos de acceso asignados a usuarios*. Establecer procedimiento formal de registro y de anulación de derechos de

acceso asignados a usuarios para otorgar y anular el acceso a todos los sistemas y servicios de información.

En el Objetivo de Control 5.4 *Gestión de acceso de usuario* se recomienda mejorar aspectos relativos:

- Control 5.4.2 *Procedimientos seguros de inicio de sesión*. Asegurar el cumplimiento al inicio de sesión de los equipos.

6) Dominio: *CIFRADO* presenta una **Observación:**

En el Objetivo de Control 6.1 *Controles criptográficos* se recomienda mejorar aspectos relativos a:

- Control 6.1.1 *Política de uso de los controles criptográficos*. Perfeccionar e implementar una política para el uso de los controles criptográficos de protección de la información.

7) Dominio: *SEGURIDAD FÍSICA Y AMBIENTAL* presenta dos **observaciones que se muestran a continuación:**

En el Objetivo de Control 7.2 *Gestión de acceso de usuario* se recomienda mejorar aspectos relativos a:

- Control 7.2.5 *Salida de activos fuera de las dependencias de la empresa*. Tomar mayor precaución en la salida de equipos en especial para trabajos en áreas rurales.
- Control 7.2.7 *Reutilización o retirada Segura de dispositivos de almacenamiento*. Comprobar que todos los soportes de almacenamiento de datos sensibles y todas las licencias de software se hayan eliminado manera segura, antes de su retirada o reutilizada.

8) Dominio: *SEGURIDAD EN LA OPERATIVA* presenta solo una **No conformidad Menor:**

En el Objetivo de Control 8.7 *Controles de auditoría de los sistemas de información* se deben mejorar aspectos relativos a:

- Control 8.7.1 *Controles de auditoría de los sistemas de información*. Se deben obtener la información adecuada acerca de las vulnerabilidades

técnicas de los sistemas de información que están siendo utilizados, evaluar la exposición de la organización a dichas vulnerabilidades y adoptar las medidas adecuadas para afrontar el riesgo asociado, así mismo se recomienda realizar auditorías anualmente.

- 9) Dominio: ***SEGURIDAD EN LAS TELECOMUNICACIONES*** presenta solo una **Observación:**

En el Objetivo de Control 9.2 *Intercambio de información con partes externas* se recomienda mejorar aspecto relativos a:

- Control 9.2.2 *Acuerdos de intercambio*. Establecer acuerdos adecuados para el intercambio de la información y software entre la Entidad y terceros.

- 10) Dominio: ***ADQUISICIÓN, DESARROLLO Y MANTENIMIENTO DE LOS SISTEMAS DE INFORMACIÓN*** presenta una **Observación** focalizadas en:

En el Objetivo de Control 10.2 *Seguridad en los procesos de desarrollo y soporte*, se recomienda mejorar aspectos relativos a:

- Control 10.2.8 *Pruebas de Aceptación*. Es importante mejor que las pruebas de aceptación también sean documentadas por todos los involucrados.

- 11) Dominio: ***RELACIONES CON SUMINISTRADORES*** presenta cuatro **observaciones** y una **no conformidad menor** por incumplimiento algunos de sus controles:

No conformidad Menor:

En el Objetivo de Control 11.1 *Seguridad de la información en las relaciones con suministradores*, se deben mejorar aspectos relativos a:

- Control 11.1.1 *Política de seguridad de la información para suministradores*, es importante que los suministradores consideren también las políticas establecidas en la entidad pública, para que se coordinen y concilien los mismos.

Observaciones:

En el Objetivo de Control 11.1 *Seguridad de la información en las relaciones con suministradores*, se recomienda mejorar aspectos relativos a:

- Control 11.1.2 *Tratamiento del riesgo dentro de acuerdos de suministradores*. Deberían tratarse todos los requisitos de seguridad identificados, antes de otorgar acceso a los clientes a los activos o a la información de la organización.
- Control 11.1.3 *Cadena de suministro en Tecnologías de la Información y Comunicaciones*, se recomienda planificar con un cierto tiempo de anticipación y cumplir en su totalidad.

En el Objetivo de Control 11.2 *Gestión de la prestación del servicio por suministradores*, se recomienda mejorar aspectos relativos a:

- Control 11.2.1 *Supervisión y Revisión de los servicios prestados por terceros*. Establecer controles estrictos para el cumplimiento de la planificación de supervisión para evitar cualquier riesgo.
- Control 11.2.2 *Gestión de cambios en los servicios prestados por terceros*. Establecer procedimientos claros para gestionar los cambios en la provisión de los servicios y mantenimientos prestados por terceros, así mismo, mejorar las políticas, procedimientos y controles de seguridad de la información existentes, considerando la criticidad de los procesos y sistemas del negocio, como también la reevaluación de los riesgos.

12) Dominio: *GESTIÓN DE INCIDENTES EN LA SEGURIDAD DE LA INFORMACIÓN* presenta dos **observaciones** en:

En el Objetivo de Control 12.1 *Gestión de Incidentes de seguridad de la información y mejoras*, se recomienda optimizar aspectos relativos a:

- Control 12.1.1 *Responsabilidades y procedimientos*. Establecer el control de cumplimiento estricto a los procedimientos dispuestos.
- Control 12.1.3 *Notificaciones de Puntos Débiles de la Seguridad*. Establecer que todos los funcionarios estar comprometido con la seguridad de la información e inmediatamente alertar sobre los puntos débiles encontrados durante el desarrollo de trabajo o no.

13) Dominio: **ASPECTOS DE SEGURIDAD DE LA INFORMACIÓN EN LA GESTIÓN DE LA CONTINUIDAD DE NEGOCIO**, se evidencia una evolución de madurez óptima, alcanzando un nivel conforme a la normativa vigente. De la misma manera, se muestra implementación eficaz de todos controles que determina el Objetivo de Control de *continuidad de la Seguridad de la Información y Redundancias*.

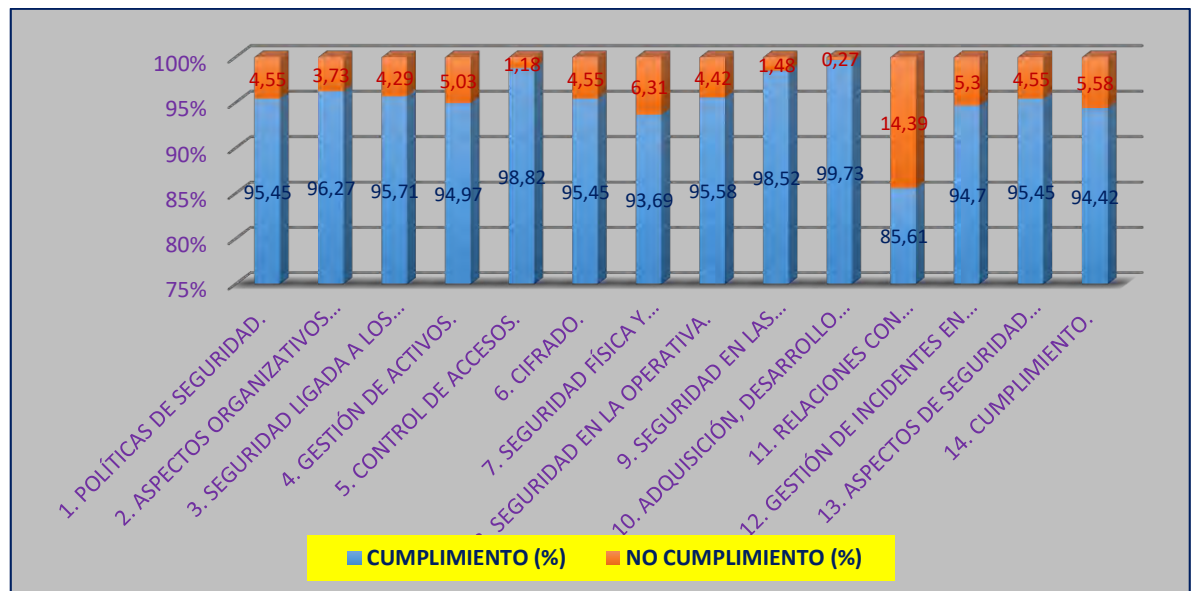
El resultado la auditoría interna sobre este dominio o clausula no muestra ninguna no conformidad y ninguna observación.

14) Dominio: **CUMPLIMIENTO** presenta una **observación** referido a:
En el Objetivo de Control 14.2 Revisiones de la seguridad de la información, se recomienda mejorar aspectos relativos a:

- Control 14.2.3 *Comprobación del cumplimiento*. Establecer protocolos para la comprobación periódica de cumplimiento o no de la normativa vigente de aplicación para la implantación.

b) Representación gráfica de madurez medida en la auditoria de cumplimiento

Figura 4.26.: Madurez medida en la auditoria de cumplimiento



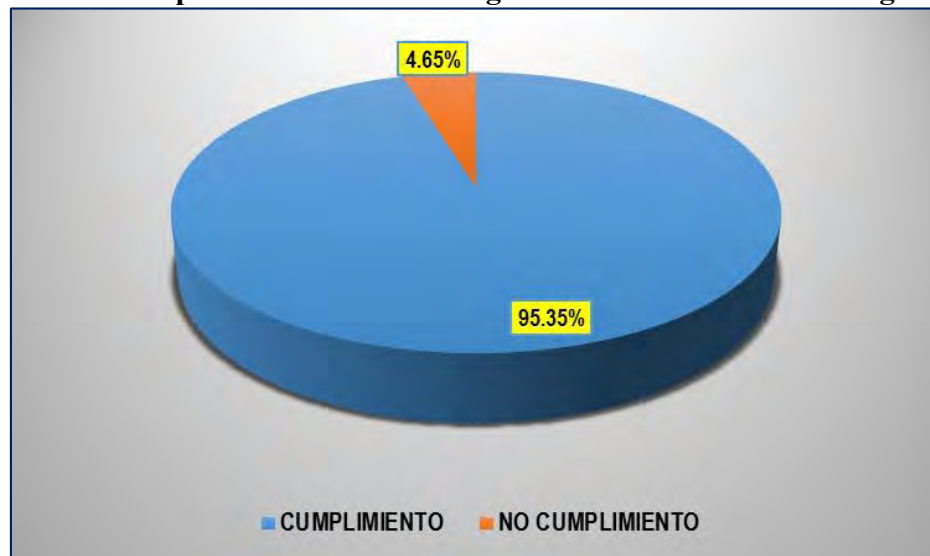
Fuente: Elaboración Propia

4.2.9.3 RESULTADOS GLOBALES

En líneas generales se puede evidenciar que la implementación del modelo implementado ha desarrollado un nivel bastante aceptable referente al grado de seguridad, con la esperanza de que pueda alcanzar los niveles óptimos.

Es decir, los 14 dominios implementados en el modelo, de acuerdo a la auditoria de cumplimiento realizado han alcanzado en promedio **el 95.35% de CUMPLIMIENTO** en la aplicación de las políticas y documentos de seguridad de la información en la entidad pública, como resultado el nivel **GESTIONADO Y MEDIBLE** de acuerdo al Modelo de Madurez de la Capacidad (CMM).

Figura 4.27.: Cumplimiento Global de Seguridad de la Información según CMM



Fuente: Elaboración Propia

4.2.9.4 PRESENTACIÓN DE RESULTADOS Y ENTREGA DE INFORME EJECUTIVO

1. Introducción

Se selecciona información selecta del Modelo de Gestión y Control Integral de Riesgos de Seguridad de la Información en la Administración Pública, el mismo puesto en práctica en el SEGIP.

2. Objetivos

El objetivo general de esta etapa es la elaborar el documento, donde debe contemplar mínimamente los siguientes puntos:

- ✓ *Resumen ejecutivo:* breve descripción que contenga la motivación, enfoque del modelo y conclusiones extraídas.
- ✓ *Memoria descriptiva:* donde contiene un detalle del proceso, incluye la descripción del objeto de estudio, el análisis de riesgos efectuado, el nivel de cumplimiento de la empresa, un plan de acción para optimizar la seguridad, el parámetro de la mejora que presumirá el plan y los algunos aspectos importantes que se requiere puntualizar para hacer viable el modelo.
- ✓ *Presentación:* en este apartado, que se muestren los principales resultados del trabajo, se plantee el plan de acción y los aspectos organizativos selectos.

3. Entregable

En este apartado el documento que se entrega básicamente, son los siguientes:

- Resumen ejecutivo, con las significativas conclusiones de la implementación y resultados de auditoria
- Memorias del modelo,
- Resultados de análisis de Riesgos
- Nivel de cumplimiento de la norma ISO 27001.
- Modelo planteado, detallando su planificación temporal, costo y el impacto sobre el cumplimiento normativo de la ISO/IEC 27002:2013 en sus diferentes dominios.

4. Análisis

Las fases y la implementación del modelo han sido desarrolladas dando seguimiento las directrices de la norma ISO/IEC 2700:2013 y las metodologías seleccionadas. Es importante señalar, que durante el desarrollo se visualiza la importancia clara de la definición del alcance del SGSI, los cuales han sido primordial para todo el proceso. Como también, la identificación de la metodología de análisis de riesgo, desde nuestro punto de vista es la correcta, que facilita la toma de decisiones de la Dirección.

La desarrollar todas las fases de implementación del Modelo se estableció el estado de cumplimiento de los controles a través de una auditoría de cumplimiento, que fue ejecutado por personal interno de la Entidad Pública. Es importante señalar que el equipo de auditoría no forma parte del proceso de Implementación del Modelo de Gestión de Seguridad de la Información.

Producto del proceso de auditoría interna, los resultados obtenidos son presentados a la dirección de la Entidad Pública, para toma las decisiones así consideren pertinente.

Por todo lo descrito, se señala a continuación las desviaciones identificadas en base a un conjunto de pruebas realizadas a través de técnicas de encuestas, entrevistas y análisis de documentación tanto interna y externa:

a) No conformidad mayor (incumple completamente con la norma)

- Ninguno

b) No conformidad menor

Producto de la evaluación o examen de auditoría, se ha evidenciado dos controles específicos considerados como desviaciones **No Conformidad Menor**:

- **En el Objetivo de Control 8.7** *Controles de auditoría de los sistemas de información* se deben mejorar aspectos relativos a:
 - Control 8.7.1 *Controles de auditoría de los sistemas de información*. Se deben obtener la información adecuada acerca de las vulnerabilidades técnicas de los sistemas de información que están siendo utilizados, evaluar la exposición de la organización a dichas vulnerabilidades y adoptar las medidas adecuadas para afrontar el riesgo asociado, así mismo se recomienda realizar auditorías anualmente.
- **En el Objetivo de Control 11.1** *Seguridad de la información en las relaciones con suministradores*, se deben mejorar aspectos relativos a:
 - Control 11.1.1 *Política de seguridad de la información para suministradores*, es importante que los suministradores consideren también las políticas establecidas en la entidad pública, para que se coordinen y concilien los mismos.

c) Observaciones

Un buen número de controles se han determinado como observación, en el sentido **No incumple Nada**, caso de no realizar su tratamiento, es probable que en futuras auditorías se pueda convertirse en *No conformidad*.

5. Conclusiones

Para concluir se determina que todo su tratamiento del proceso fue realizado cuidadosamente enmarcados en la misión y visión, planificación estratégica y la normativa legal vigente de la Entidad Pública. La implementación del Modelo de Gestión y Control Integral de Riesgos de Seguridad de la Información en la Administración Pública alimentó a la Dirección una visión fundamental sobre la seguridad en la información. También se considera que se encuentran implementadas iniciativas a nivel de direcciones nacionales y departamentales, inclusive al no estar involucrados con una política de seguridad, se obtuvieron resultados aunque no esperados y en algunos momentos se generaban resultados adversos al deseado. Se debe rescatar el compromiso de los funcionarios involucrados en la implementación y cumplimiento de los mismos, en muchas unidades y/o áreas resaltan la importancia de la seguridad de la información.

CAPITULO V

CONCLUSIONES Y RECOMENDACIONES

5.1 CONCLUSIONES

Partiendo del análisis de las teorías y términos sobre Seguridad e Información, se concluye que ambos conceptos son de vital importancia y práctica para todas las instituciones públicas. Pues de esto depende la eficacia y eficiencia de la administración de las mismas.

A lo largo de este estudio se presentaron diferentes conceptos relacionados a la gestión, control, riesgo y seguridad de la información, para poder finalmente identificar las variables de análisis entorno a estas situaciones.

Esta labor debe comenzar con el compromiso demostrable de la alta directiva hacia la seguridad de la información, labor que no es nada fácil cuando no se tiene concebida la seguridad de la información dentro de los objetivos estratégicos de la organización.

La hipótesis establecida en el capítulo 1 del presente trabajo, se analiza considerando los siguientes aspectos:

- Se establecen cinco fases principales del modelo que son: planificación y programación de evaluación, diagnóstico de la situación actual y evaluación de riesgos, análisis de resultados de la situación actual, implementación del modelo y auditoria de cumplimiento, descritos en el punto 4.1.
- Se determina el análisis de declaración de aplicabilidad y árbol general de requerimientos, basados en el estándar ISO 27001, que está compuesto por: Dominios o Clausulas, Objetivos de Control y Controles, descrito en el punto 4.1.2.2.1.
- En la fase de implementación del modelo, definidos en controles y procedimientos que apoyan a que la seguridad de la información en una organización sea confiable y este resguardada de forma seguro. Su aplicación se evidencia en un caso de estudio real en el Capítulo 4, a partir del punto 4.2. del presente trabajo.

- Finalmente, en el capítulo 4, el punto 4.2.6, se encuentra el Indicador de Minimizador de Riesgo (IMR) que se evidencia que la implementación del modelo, minimiza el riesgo en la organización o entidad pública.

Por tanto, es posible afirmar el valor tautológico de la hipótesis, ya que el Modelo de Gestión de Seguridad de la Información, se constituye en la adecuación de componentes, fases, estándares, controles y procedimientos para la minimización del nivel riesgo de seguridad de la información en la Administración Pública, a través de un análisis de un caso de estudio real.

De la misma manera, se ha dado cumplimiento al objetivo general planteado en el presente trabajo, a través del Capítulo 4, donde se constituye el Modelo de Gestión y Control Integral en Seguridad de la Información en cinco fases principales, en cada una de ellas se aplican métodos, criterios y herramientas y se adecuan controles y procedimientos para que minimicen el nivel de riesgo de seguridad de la información y para que se apliquen en un caso de análisis y estudio real.

En relación a los objetivos específicos, su cumplimiento se fundamenta para cada uno de los incisos, de la siguiente forma:

- Para el inciso a) aspecto que se cumple en el capítulo 2, en los puntos 2.1.3, 2.1.4, 2.1.5, 2.1.11 y 2.1.12,
- Para el inciso b) se cumple a través del capítulo 4, en el punto 4.1.2.2.1,
- Para el inciso c) se cumple a través del capítulo 4, en los puntos 4.1.2.3 y 4.1.4, y
- Finalmente, para el inciso d) donde plantea implementar el modelo, aspecto que se cumple en el capítulo 4, en el punto 4.1.4 y a partir del punto 4.2.

Por tanto, de manera general y específicos, se dio cumplimiento a los objetivos planteados de manera clara y específica, basados en buenas prácticas y directrices de seguridad, como es la norma ISO/IEC 27001:2013, considerado como una herramientas importante que permite establecer los diferentes aspectos que se deben tomar en cuenta para llegar a crear en el tiempo un apropiado y sostenible Modelo de Sistema de Gestión de Seguridad de la Información, aunque dicho trabajo depende de la naturaleza y tamaño de la entidad y de la cultura de la misma sobre la seguridad de la información.

Siendo el diagnóstico, como origen de partida en un proceso de retroalimentación en el que los funcionarios del Servicio General de Identificación Personal SEGIP son actores principales, si bien la entidad define su situación ideal, son los funcionarios quienes muestran lo que aún falta por realizar y de quien la entidad se alimenta y aprende para conseguir un adecuado seguridad de la información. No se trata de algo teórico, sino que se puede aplicar una metodología de auditoría para detectar si existe una mejora o no, y en qué nivel o porcentaje y, en su caso, aplicar una mecánica de transformación de estas variables y controles

Al lograr aplicar los distintos requerimientos de la norma ISO 27001:2013, se obtuvo una serie de diagnósticos que ayudaron establecer el nivel de madurez de la entidad pública frente a la administración de la seguridad de la información.

Seguidamente se describen algunas las conclusiones importantes para dar respuesta a los objetivos planteados:

- Inicialmente se dio cumplimiento con la identificación de directrices en las entidades públicas, para la correcta, valoración y análisis de los riesgos de seguridad asociados a información, donde fueron identificados las características o dominios, así como los criterios, objetivos de control y controles iniciales para el diagnóstico inicial de la entidad pública.
- De igual manera, se han analizado el contexto de la entidad pública identificando requerimientos, amenazas, características de la información y tipos de ataque de seguridad, donde se ha identificado que en el SEGIP trabajan con cierta falta de estrategias de mayor seguridad de la información para dar servicio a la sociedad y que existen factores que la pueden llevar a la decadencia y de poca importancia sino se les presta la atención debida, tales como los dominios o clausulas y objetivos de control de seguridad de la información.
- Debido a la complejidad de la infraestructura tecnología y a la capacidad de DNTICs, la entidad pública inicialmente se encuentra catalogada en un nivel SATISFACTORIO, que involucra un esfuerzo inmenso para la implementación del Modelo de Gestión y Control Integral de Riesgos de Seguridad de la Información en la Administración Pública, lo cual, se ve reflejado en los diferentes planes de acción que se crearon a lo largo del trabajo que están encaminado a dar cumplimiento a los requerimientos de la norma ISO/IEC 27001:2013.
- El nivel de cumplimiento de acuerdo a la evaluación de auditoría interna de la entidad

pública, frente de los requerimientos de la norma ISO/IEC 27001:2013, es del **95.34%**, lo que representa que la implementación del Modelo de Gestión y Control Integral de Riesgos de Seguridad de la Información en la Administración Pública lo cual implica que la entidad ha realizado un refuerzo considerable para ajustar y adecuar las políticas de controles para el alto grado de cumplimiento de muchos de ellos.

- En algunos sectores, áreas o dominios de la entidad pública, se pudo evidenciar la falta de controles adecuados encaminados a proteger la seguridad de la información que se intercambia con terceros, esto puede producir consecuencias de riesgo para la institución y afectar de forma negativa su imagen ante sus partes interesadas, por tal razón, es preciso que la entidad implemente mecanismos de protección con el objetivo de garantizar confidencialidad, autenticidad e integridad de la información.

En ese sentido, se concluye que la situación en seguridad de la información posterior de la implementación del Modelo de Gestión y Control Integral de Riesgos de Seguridad de la Información en la Administración Pública, mejora considerablemente encontrándose en producto de la evaluación en el nivel SATISFACTORIO y el mismo se ha confirmado con la auditoria de cumplimiento y madurez realizado a la seguridad de la información en la Entidad Pública.

5.2 RECOMENDACIONES

Las siguientes recomendaciones son establecidas en base a los resultados del análisis, de igual forma, están basadas en políticas de mejora que la Máxima Autoridad Ejecutiva MAE y personal de la Entidad Pública y los usuarios propusieron para mejorar la Seguridad de la Información, los mismos son:

- Establecer un sistema de entrevistas y encuestas al personal de la Entidad Pública, para evaluar el nivel de cumplimiento sobre los controles y políticas implementados.
- Contabilizar antes el proceso de tratamiento de incidentes de seguridad, para proveer un mecanismo para el reporte, evaluación y respuesta a los sucesos e incidencias de seguridad de la información
- Establecer políticas de seguridad de la información aprobadas por la Dirección, para garantizar la correcta implementación, actualización y cumplimiento.
- Importante verificar y actualizar permanentemente los compromisos de seguridad, los

reconocimientos de responsabilidades de seguridad de la información con el fin de generar concientización sobre la protección de la información y así alcanzar los objetivos de gestión y estratégicos de la Entidad Pública.

- Es importante que las autoridades de la Entidad Publica tomen en cuenta a su personal para su capacitación constante respecto a la seguridad de la información, ya que es gracias a ellos, y por ellos, son a quien se deben como Institución.
- Las Entidades Públicas deben afinar y replantear en algunos casos los controles razonables, estructura y burocracia de la Entidad Pública, y mejorar la comunicación interna. Dichos factores pueden ser mejorados en el ánimo de buscar la excelencia operacional y seguridad de la información, de esta manera garantizando así su alta competitividad y trabajo como Entidad Pública en la sociedad del país.
- La Administración Pública en su conjunto, deben mejorar la atención en beneficio de la sociedad, ya que este no cumple su cometido, es claro que las políticas y procedimientos no son formulados por los directores y jefes, quienes únicamente sirven para llevar adelante la administración y operación de la institución, no obstante, ellos pueden compensar u optimizar el trabajo de los servidores y servidoras públicos, partiendo de las deficiencias de la institución, es decir, pueden optar por trabajar en equipo, en la integración y en la búsqueda de la excelencia de su centro de trabajo, poniendo especial énfasis en la participación de su gente, detectar, e implementar medios eficientes para las oportunidades de su personal.

Por último, no hay que perder de vista que:

“La mejor institución no es aquella que mejor paga si no la que respeta, da oportunidad de superación, administra óptimamente su información y estimula el desarrollo personal y profesional de su gente”.

BIBLIOGRAFIA:

VILLALÓN, H. A, (2002). Seguridad en Unix y Redes, Libro público en PDF accesible desde la página de seguridad de la Red Iris.

EAFIT, U. (2007). Modelo para Auditoria y Control de Sistemas de información - Boletín 54. *AUDINET*, 1.

Ley 0145. (27 de 06 de 2011). Ley 0145. *Ley 0145*. La Paz, Murillo, Bolivia: Gaceta Oficial.

CANO, J., (2007). Administrando la confidencialidad de la información: Algunas consideraciones sobre el saneamiento de medios de almacenamiento. AR: Revista de Derecho Informático.

LOPEZ P. & SEBASTIAN L., (2008). Los Nuevos retos de Seguridad en un Entorno Global, McGraw Hill/Interamericana, España.

DEL CARPIO, J., (2009). Análisis del riesgo en la Administración de Proyectos de Tecnología de Información, 2da. Edición, Prentice-Hall, México.

J. BURGOS, (2008). Modelo para el Control de Riesgos de Seguridad de la Información en Áreas de Tecnologías de la Información y Comunicaciones (TIC), Universidad del Bío-Bío, Concepción, Chile.

LÁZARO J. BLANCO ENCINOSA, (2001). Auditoria y Sistemas Informáticos, 1ra. Edición, Edit. Latina Editores, Oruro - Bolivia.

COBIT, (2008). Objetivos de Control para la Información y Tecnologías Aplicadas, 2da. Edición.

MUÑOZ F. (2007). Metodología para la incorporación de medidas de Seguridad en Sistemas de Información, Escuela de Ingeniería de Sistemas Telemático, Universidad Politécnica Madrid, Madrid España.

HORTON, M. y MUGGE, C., (2003). Network Security Portable Reference, McGraw Hill.

LACEY, D. (2009): Managing the human factor in information security. John Wiley&Sons.

WILBANKS, L. (2008). Need to share vs. need to assure. IEEE IT Professional.

WESTNEY, E. (2008). Three perspectives on organizational change. Leading Change in Complex Organization. MIT Sloan School of Management. Executive Program. June.

FENTON C. (1997). Software Metrics, A. Rigorous And Practical Approach. PWS Publishing Company, Eda. Edition.

GACETA OFICIAL (2011). LEY N° 164, 8 de agosto de 2011, Ley general de Telecomunicaciones, Tecnologías de Información y Comunicación, Bolivia.

GACETA OFICIAL (2013). DECRETO SUPREMO 1793 (13/11/2013), Reglamento para el Desarrollo de Tecnologías de Información y Comunicación, Bolivia.

7GAUS. (16 de 02 de 2017). *Significados.com.* Obtenido de <https://www.significados.com/informacion/>

BLANCO, J. P. (2015). *Estándar para el buen gobierno de los sistemas de la Información.* Madrid - España.

DUARTE, G. (10 de 12 de 2008). *Definición ABC.* Obtenido de <https://www.definicionabc.com/social/seguridad.php>

RAFFINO, M. E. (06 de 12 de 2019). *Concepto.de.* Obtenido de <https://concepto.de/que-es-norma/>

RAFFINO, M. E. (11 de 12 de 2019). *Sistemaa.* Obtenido de <https://concepto.de/sistema/>

BORGHELLO C., (2010): *Seguridad de la Informática – Implicancias e implantación,* disponible en: <http://www.segu-info.com.ar/tesis>

CAO AVELLANEDA, J., (29 de 08 de 2016): *Apuntes de Seguridad de Información,* <http://seguridad-de-la-informacion.blogspot.com/>.

SEGU.INFOR, (20 de 12 de 2017). *Seguridad de la Información.* Obtenido de <https://www.segu-info.com.ar/>

SEGURIDAD INFORMATICA, (10 de 05 de 2018), *Dominios de ISO 27001 e ISO 27002.* Obtenido de <https://seguinfo.wordpress.com/2010/06/28/dominios-de-iso-27001-e-iso-27002/>

ISO/IEC 27001, (29 de 06 de 2018). *Seguridad de la Información:* <http://www.bsigroup.com/es-ES/Seguridad-de-la-Informacion-ISOIEC-27001/>

ANEXOS

CUESTIONARIO DE CONTROLES DE SISTEMAS DE GESTIÓN DE SEGURIDAD DE LA INFORMACION APLICADOS EN EL SEGIP

La técnica que es utilizada para conocer el grado de implantación de seguridad de la información en la Entidad Pública, para análisis y evaluación de riesgos y posteriormente como insumos para el Modelo de Gestión y control de Seguridad en la Información.

A.1 POLÍTICAS DE SEGURIDAD

1.1.1. ¿Existen políticas publicadas, aprobadas por la dirección, para apoyar la seguridad de la información?

SI o NO

La dirección definirá las políticas de seguridad de la información dentro del alcance del SGSI. Las políticas deben ser apropiadas para apoyar la seguridad de la información y los requerimientos del negocio.

1.1.2. ¿Las políticas de seguridad de la información son revisadas y actualizadas?

Nunca Casi Nunca A veces Casi siempre Siempre

Las políticas de seguridad de información deben revisarse a intervalos planificados para asegurar la idoneidad, adecuación y eficacia.

A.2 ORGANIZACIÓN DE LA SEGURIDAD

2.1.1. ¿Están definidas todas las responsabilidades de seguridad de la información?

Nunca Casi Nunca A veces Casi siempre Siempre

Se asignará la responsabilidad de organizar las tareas relacionadas con la seguridad de la información, para asegurar que se llevan a cabo las actividades de implantación y operación del SGSI.

2.1.2. ¿Los deberes y las responsabilidades son correctamente segregadas teniendo en cuenta las situaciones de conflicto de intereses?

Nunca Casi Nunca A veces Casi siempre Siempre

Separar las actividades críticas en dos o más pasos o entre dos o más personas, puede minimizar la probabilidad de que un incidente ocurra.

2.1.3. ¿Existen definidos contactos con las autoridades competentes?

SI o NO

Los contactos con las autoridades deben ser claramente definidas.

2.1.4. ¿Existen definidos contactos con grupos de interés especial o asociaciones profesionales?

SI o NO

Deben ser claramente definidos los contactos con las autoridades.

2.1.5. ¿Los proyectos consideran aspectos relacionados con la seguridad de la información?

SI o NO

Deben ser definidas reglas de seguridad de la información para proteger la información

2.2.1. ¿Existen definidas reglas para el manejo seguro de los dispositivos móviles?

SI o NO

La dirección deberá definir políticas para dispositivos móviles dentro del alcance del SGSI. Las políticas deben ser apropiadas para el soporte de la seguridad de la información y los requerimientos del negocio.

2.2.2. ¿Existen reglas que definen cómo está protegida la información de la organización teniendo en cuenta el teletrabajo?

Nunca Casi Nunca A veces Casi siempre Siempre

La dirección deberá definir políticas para teletrabajo dentro del alcance del SGSI. Las políticas deben ser apropiadas para el soporte de la seguridad de la información y los requerimientos del negocio.

A.3 SEGURIDAD RELATIVA A LOS RECURSOS HUMANOS

3.1.1. ¿La organización realiza verificaciones de antecedentes de los candidatos para el empleo o para los contratistas?

SI o NO

Se realizarán revisiones de antecedentes, según las leyes nacionales que apliquen y los requerimientos del negocio, para evitar la exposición de la información a riesgos innecesarios.

3.1.2. ¿Existen acuerdos con los empleados y contratistas donde se especifiquen las responsabilidades de seguridad de información?

SI o NO

Antes de acceder a la información, los empleados y contratistas deberán ser conscientes de sus responsabilidades relacionadas con la seguridad de información y de su compromiso de cumplimiento.

3.2.1. ¿La dirección requiere activamente que todos los empleados y contratistas cumplan con las reglas de seguridad de la información?

SI o NO

La dirección debe publicar la política de seguridad de la información, definir responsabilidades, autoridades y roles y promover el conocimiento de seguridad de información a empleados y contratistas.

3.2.2. ¿Los empleados y contratistas asisten a entrenamientos para realizar mejor sus tareas de seguridad, y existen programas de sensibilización?

Nunca Casi Nunca A veces Casi siempre Siempre

Los empleados y contratistas deben ser entrenados en las competencias requeridas para cumplir sus deberes de seguridad y estar al tanto de las cuestiones de seguridad pertinentes a la organización.

3.2.3. ¿La organización tiene un proceso disciplinario?

SI o NO

Se debe establecer un proceso disciplinario, para asegurar una sistemática de penalizaciones contra empleados y contratistas que hayan cometido un fallo o un incumplimiento relacionado con la seguridad.

3.3.1. ¿Existen acuerdos que cubren las responsabilidades de seguridad de información que siguen siendo válidas después de la terminación del empleo?

SI o NO

La organización debe definir las obligaciones de seguridad de la información que deben ser cumplidos después de la terminación del empleo y concienciar a los empleados y contratistas de estas responsabilidades.

A.4 GESTIÓN DE ACTIVOS

4.1.1. ¿Existe un inventario de activos?

SI o NO

Existe un inventario de activos para identificar y organizar los activos de información.

4.1.2. ¿Todos los activos en el inventario de activos tienen un dueño designado?

SI o NO

Para asegurar el adecuado manejo y protección de un activo, se le debe asignar un propietario.

4.1.3. ¿Existen definidas reglas para el manejo de activos y de información?

Nunca Casi Nunca A veces Casi siempre Siempre

Para asegurar el manejo adecuado y la protección de un activo, deben ser definidas un grupo de reglas.

4.1.4. ¿Los activos de la organización son devueltos cuando los empleados y contratistas finalizan su contrato?

SI o NO

Para asegurar el manejo adecuado y la protección de un activo, deben ser definidas un conjunto de reglas.

4.2.1. ¿Están definidos los criterios para clasificar la información?

SI o NO

La existencia de criterios de clasificación asegura que toda la información deberá recibir un nivel de protección según el valor que posee para la organización.

4.2.2. ¿Existen procedimientos que definen cómo etiquetar y manejar información clasificada?

SI o NO

La existencia de etiquetado y manejo asegura que toda la información clasificada deberá recibir un tratamiento de acuerdo a su nivel de clasificación.

4.2.3. ¿Existen procedimientos que definen cómo manejar activos?

SI o NO

Con la existencia de procedimientos de manejo de activos se asegura que todos los activos deberán recibir un tratamiento de acuerdo a la información clasificada que manejan.

4.3.1. ¿Existen procedimientos que definen cómo manejar medios extraíbles en consonancia con las reglas de clasificación?

SI o NO

La existencia de procedimientos de manejo de medios extraíbles asegura que todos los medios extraíbles deberán recibir un tratamiento de acuerdo a la información clasificada que manejan.

4.3.2. ¿Existen procedimientos formales para la eliminación de medios?

SI o NO

Debe haber procedimientos formales para asegurar que los medios que ya no se necesitaban, no pueden ser reutilizados y que las informaciones contenidas en él serán destruidas o hecha inaccesible.

4.3.3. ¿Son protegidos los medios que contienen información sensible durante el transporte?

SI o NO

La existencia de procedimientos de manejo de medios extraíbles asegura que todos los medios extraíbles deberán recibir un tratamiento de acuerdo a la información clasificada que manejan.

A.5 CONTROL DE ACCESO

5.1.1. ¿Existe una política de control de acceso?

SI o NO

La dirección deberá definir una política de Control de acceso dentro del alcance del SGSI. La política necesita ser apropiada para apoyar la seguridad de la información y los requerimientos del negocio.

5.1.2. ¿Los usuarios tienen acceso sólo a los recursos que se les permite?

SI o NO

El usuario tendrá acceso sólo a las redes y los servicios para los que está autorizado específicamente.

5.2.1. ¿Los derechos de acceso son proporcionados mediante un proceso de registro formal?

SI o NO

Debe existir un proceso formal para la creación / exclusión de cuentas de usuario y la asignación de derechos de acceso.

5.2.2. ¿Existe un sistema de control de acceso formal para el inicio de sesión en sistemas de información?

SI o NO

Debe existir un proceso formal para conceder o denegar el acceso de usuario para todos los tipos de usuarios para todos los sistemas y servicios.

5.2.3. ¿Los derechos de acceso privilegiado son manejados con especial cuidado?

SI o NO

Debe existir un proceso formal para conceder o denegar el acceso de usuario con derechos de privilegios especiales.

5.2.4. ¿Las contraseñas, y otra información de autenticación secreta, es proporcionada de forma segura?

SI o NO

Toda información relacionada con la autenticación de usuarios dispondrá de una manera que sólo el usuario conocerá la información de autenticación.

5.2.5. ¿Los derechos de acceso son actualizados cuando hay un cambio en la situación del usuario (por ejemplo: cambio organizacional o terminación)?

Nunca Casi Nunca A veces Siempre Casi siempre

Debe existir un proceso formal para cambiar o revocar el acceso de los usuarios para todos los tipos de usuarios para todos los sistemas y servicios cuando hay un cambio en su situación.

5.3.1. ¿Existen reglas para los usuarios sobre cómo proteger las contraseñas y otra información de autenticación?

SI o NO

Toda información relacionada con la autenticación de usuario deberá ser protegida (por ejemplo: contraseñas.)

5.4.1. ¿El acceso a la información en los sistemas es restringido según la política de control de acceso?

SI o NO

El acceso a las funciones de bases de datos y aplicaciones se limitará según la política de control de acceso.

5.4.2. ¿Es requerido un sistema de login en los sistemas según la política de control de acceso?

Nunca Casi Nunca A veces Casi siempre Siempre

Los sistemas desarrollados o adquiridos por la organización deberán considerar sistemas de login como uno de sus requisitos de seguridad según la política de control de acceso.

5.4.3. ¿Los sistemas de gestión de contraseñas utilizados por los usuarios de la organización les ayuda a manejar de forma segura su información de autenticación?

SI o NO

Los sistemas de gestión de contraseñas adoptados por la organización deberán ser interactivos y garantizar la creación de contraseñas seguras.

5.4.4. ¿El uso de herramientas de utilidad es controlado y limitado a empleados específicos?

Nunca Casi Nunca A veces Casi siempre Siempre

Algunas herramientas de utilidad pueden anular los controles de seguridad de aplicaciones y sistemas y deberán ser estrictamente controladas, incluyendo limitar su acceso a un estrecho círculo de los empleados.

5.4.5. ¿El acceso al código fuente es restringido a personas autorizadas?

SI o NO

El acceso a códigos fuente puede tener un impacto enorme a los sistemas de negocio si son comprometidos, por lo que deben de gestionarse con cuidado y debe restringirse el acceso a ellos.

A.6 CRIPTOGRAFÍA

6.1.1. ¿Existe una política para regular la encriptación y existen otros controles criptográficos?

SI o NO

La dirección deberá definir una política de Control criptográfica dentro del alcance del SGSI. La política necesita ser apropiado para apoyar la seguridad de la información y los requerimientos del negocio.

6.1.2. ¿Están debidamente protegidas las claves criptográficas?

SI o NO

Los controles criptográficos son fuertes y sus llaves se guardan y mantienen de forma segura, por tanto, el manejo de claves criptográficas debe ser gestionado adecuadamente.

A.7 SEGURIDAD FÍSICA Y DEL ENTORNO

7.1.1. ¿Son efectivas las zonas seguras que protegen la información sensible?

Inefectivas Casi Inefectivas Casi efectivas Efectivas Siempre efectivas

Las zonas seguras deberán ofrecer una capa adicional de seguridad para ayudar a proteger la información sensible.

7.1.2. ¿Es protegida la entrada a las zonas seguras?

SI o NO

La entrada para garantizar las zonas seguras debe estar protegida con controles que permitan solamente a las personas autorizadas entrar.

7.1.3. ¿Las zonas seguras están ubicadas en un lugar protegido?

SI o NO

Las zonas seguras deben estar ubicadas de tal manera que no sean visibles a los forasteros y no sean fácilmente accesibles desde el exterior.

7.1.4. ¿Existen instaladas alarmas, sistemas de protección contra incendios y otros sistemas?

SI o NO

Existe protección física para así minimizar el riesgo relacionado con las amenazas externas y ambientales.

7.1.5. ¿Existen definidos procedimientos para las zonas seguras?

SI o NO

Deben existir procedimientos de trabajo específicos proporcionales a la sensibilidad de las zonas seguras para minimizar incidentes relacionados con acciones inapropiadas.

7.2.1. ¿Los equipos son debidamente protegidos?

SI o NO

Los equipos deben estar ubicados de tal manera que estén protegidos contra accesos no autorizados y amenazas ambientales.

7.2.2. ¿Los equipos están protegidos contra las variaciones de energía?

SI o NO

Se considerarán protecciones como la fuente de alimentación ininterrumpida (SAI) para evitar que los niveles de energía más altos o más bajos más allá de las especificaciones del fabricante pueden dañar los equipos.

7.2.3. ¿Son adecuadamente protegidos los cables de energía y telecomunicaciones?

Totalmente Inadecuada Inadecuadas Casi Adecuadas Adecuadas
Totalmente adecuadas

Los cables de alimentación y las telecomunicaciones pueden ser un punto de entrada a un ataque, por tanto, los recursos del sistema deben ser protegidos.

7.2.4. ¿Existe mantenimiento de los equipos?

SI o NO

Para asegurar la confiabilidad de los sistemas, los equipos deberán someterse a los procedimientos de mantenimiento según las especificaciones del fabricante y las buenas prácticas.

7.2.5. ¿La retirada de información y equipos fuera de la organización está controlada?

SI o NO

Cada vez que sea necesario la organización debe de proporcionar permisos de autorización para la eliminación de información y otros activos.

7.2.6. ¿Los activos de la organización son debidamente protegidos cuando no están en las instalaciones de la organización?

SI o NO

Los activos fuera de los locales de la organización están expuestos a más riesgos y deberán considerarse la aplicación de controles más fuertes.

7.2.7. ¿Es correctamente eliminada la información de los equipos que se van a eliminar?

SI o NO

Toda la información y software con licencia se eliminarán de los equipos o medios cuando estos se destruyan.

7.2.8. ¿Las reglas son efectivas para proteger los equipos cuando estos no estén siendo usados por los usuarios?

Totalmente Inefectivas

Casi Inefectivas

A veces efectivas

Efectivas

Totalmente efectivas

Los equipos no deben dejarse sin supervisión, pero si no hay ninguna alternativa, deberá proporcionarse recomendaciones para guiar sobre su uso a los usuarios.

7.2.9. ¿Hay orientaciones a los usuarios sobre qué hacer cuando estos no están presentes en sus estaciones de trabajo?

SI o NO

Debe existir una política para que los usuarios eliminen papeles y cualquier dato de su escritorio, y bloqueen sus equipos de trabajo cuando no estén delante del ordenador.

A.8 SEGURIDAD DE LAS OPERACIONES

8.1.1. ¿Están documentados los procedimientos de TI?

Ninguno **algunos**

Todos

La documentación disponible debe ayudar a asegurar la correcta operación y seguridad de los recursos de procesamiento de información.

8.1.2. ¿Los cambios que podrían afectar a la seguridad de la información son estrictamente controlados?

No son controlados, Casi Controlados, Parcialmente Controlados, Son controlados, Totalmente controlados

Todos los cambios a los sistemas y a otros procesos que puedan afectar la seguridad de la información serán estrictamente controlados.

8.1.3. ¿Los recursos son monitoreados y se realizan planes para asegurar su capacidad para cumplir con la demanda de los usuarios?

SI o NO

Alguien debe supervisar el uso de los recursos y la capacidad para garantizar el mantenimiento de las prestaciones acordadas del proyecto.

8.1.4. ¿Se separan los entornos de desarrollo, pruebas y producción?

SI o NO

Existen diferentes entornos para minimizar los riesgos relacionados con el acceso no autorizado o modificación de información o recursos.

8.2.1. ¿El software antivirus y otros programas para la protección de malware se instalan y utilizan correctamente?

SI o NO

Deberá existir software antivirus y otros programas para la protección de malware, y estar correctamente configurados y actualizados.

8.3.1. ¿Existe una política de backup definida y se lleva a cabo correctamente?

SI o NO

Debe existir una política de backup.

8.4.1. ¿Los eventos relevantes de los sistemas son verificados periódicamente?

Nunca Casi Nunca A veces Casi siempre Siempre

Los logs de los usuarios, fallos y otros mensajes importantes de los sistemas TI deberán chequearse periódicamente.

8.4.2. ¿Los registros están protegidos adecuadamente?

SI o NO

Los logs estarán protegidos contra el acceso y modificaciones no autorizadas.

8.4.3. ¿Están adecuadamente protegidos los logs de los administradores?

SI o NO

Los logs de los administradores deben estar protegidos contra el acceso y modificación no autorizada y deben comprobarse regularmente.

8.4.4. ¿Esta la hora de todos los sistemas de TI sincronizada?

SI o NO

La hora de los sistemas TI deberá sincronizarse con una sola fuente de tiempo para asegurar con precisión el registro de los eventos.

8.5.1. ¿La instalación de software es estrictamente controlada?

SI o NO

Deberán existir reglas definidas y procedimientos para asegurar la instalación del software, y se llevarán a cabo de manera adecuada y controlada.

8.6.1. ¿La información de análisis de vulnerabilidades es correctamente gestionada?

SI o NO

Existe una persona que se encarga de obtener información sobre vulnerabilidades.

8.6.2. ¿Existen reglas para definir restricciones de instalación de software a los usuarios?

SI o NO

Deben definirse normas y procedimientos para asegurar que la instalación de software realizada por los usuarios se realiza de una manera adecuada y controlada.

8.7.1. ¿Están las auditorías de sistemas de producción planeadas y se ejecutan correctamente?

Nunca Casi Nunca A veces Casi siempre Siempre

Las auditorías de sistemas de producción serán planeadas y ejecutadas de forma que no aumente el riesgo de interrupción de esos sistemas.

A.9 SEGURIDAD DE LAS COMUNICACIONES

9.1.1. ¿Las redes son gestionadas para proteger la información de sistemas y aplicaciones?

Nunca Casi Nunca A veces Casi siempre Siempre

Las redes deben ser controladas para evitar compromisos y fugas de información.

9.1.2. ¿Los requisitos de seguridad para servicios de red están incluídas en los acuerdos?

SI o NO

Deben existir reglas claras para los servicios de red internos y externos, para de esta manera proteger la información y los sistemas, y estas reglas serán definidas e incluídas en los acuerdos.

9.1.3. ¿Existen redes segregadas considerando los riesgos y la clasificación de los activos?

SI o NO

Los usuarios, servicios y sistemas deben estar separados en diferentes redes para minimizar los riesgos.

9.2.1. ¿Las transferencias de información están debidamente protegidas?

SI o NO

Deben existir procedimientos y políticas formales para la protección de transferencia de información.

9.2.2. ¿Los acuerdos con terceras partes consideran la seguridad durante la transferencia de información?

Nunca Casi Nunca A veces Casi siempre Siempre

En los acuerdos deben existir definidos cláusulas específicas para asegurar el uso de políticas y procedimientos para la protección de la información en las transferencias con terceras partes.

9.2.3. ¿Los mensajes que se intercambian sobre las redes están protegidos correctamente?

SI o NO

Los mensajes que se intercambian a través de las redes deben estar protegidos contra el acceso y modificación no autorizada.

9.2.4. ¿La organización posee una lista con todas las cláusulas de confidencialidad que deben ser incluídos en los acuerdos con terceros?

SI o NO

La organización debe garantizar que todas las cláusulas de confidencialidad pertinentes tienen que ser incluídos en los acuerdos con terceros, revisadas y documentadas.

A.10 ADQUISICIÓN, DESARROLLO Y MANTENIMIENTO DE SISTEMAS DE INFORMACIÓN

10.1.1. ¿Se definen requisitos de seguridad para nuevos sistemas de información, o para cualquier cambio sobre ellos?

SI o NO

Los requisitos de seguridad deben formar parte de la evaluación de nuevos sistemas de información, así como cualquier cambio planeado en los sistemas que ya existen.

10.1.2. ¿La información de aplicaciones transferida a través de redes públicas es adecuadamente protegida?

SI o NO

Las redes públicas deben ser consideradas inseguras y deben establecerse controles adecuados para proteger la información cuando se transfiere a través de dichas redes públicas.

10.1.3. ¿Las transacciones de información a través de redes públicas considera que es adecuada la protección?

Totalmente Inadecuada Inadecuadas Casi Adecuadas Adecuadas Totalmente adecuadas
Las redes públicas deben ser consideradas inseguras y deben existir controles adecuados para proteger la información cuando se transfiere información a través de ellas.

10.2.1. ¿Existen definidas reglas para el desarrollo seguro de software y de los sistemas?

SI o NO

El software y los sistemas deben incorporar seguridad desde etapas tempranas del desarrollo, orientado por las reglas que consideren los riesgos de los sistemas.

10.2.2. ¿Se controlan los cambios en los sistemas nuevos o existentes?

SI o NO

Deben existir procedimientos de control de cambio para reducir al mínimo los riesgos de seguridad de la información durante los cambios en los sistemas nuevos o existentes.

10.2.3. ¿Las aplicaciones críticas son debidamente probadas después de los cambios realizados en los sistemas operativos?

SI o NO

Las aplicaciones críticas del negocio podrían verse afectadas negativamente por los cambios realizados en los sistemas operativos en producción, así que deberán someterse a pruebas para asegurar que siguen funcionando como se esperaba.

10.2.4. ¿Se realizan sólo los cambios necesarios a los sistemas de información?

SI o NO

Sólo cambios relevantes y críticos podrán hacerse en sistemas de información para minimizar los riesgos de transacción de sistemas.

10.2.5. ¿Los principios de ingeniería de sistemas seguros son aplicados al proceso de desarrollo de sistemas de la organización?

SI o NO

Los sistemas deberán incorporar seguridad desde etapas tempranas del desarrollo, impulsado por principios de ingeniería de seguridad en sus componentes y funciones.

10.2.6. ¿Es seguro el entorno de desarrollo?

Totalmente Inseguro Inseguro Casi Seguro Seguro Totalmente seguro
Entorno de desarrollo deberá protegerse de cambios y de accesos no autorizados.

10.2.7. ¿Los requisitos de implementación de seguridad son probada durante el desarrollo del sistema?

SI o NO

La prueba de implementación de los requisitos de seguridad es crítica y deben ser realizadas para asegurar que un sistema puede alcanzar los objetivos de negocio y de seguridad.

10.2.8. ¿Existe definido un criterio para aceptar los sistemas?

SI o NO

Se definirán criterios para la aceptación de los sistemas para asegurar una manera de comprobar si todas las necesidades de seguridad y negocio se cumplen.

10.3.1. ¿Los datos de prueba son cuidadosamente seleccionados y protegidos?

SI o NO

Los datos de prueba deben ser seleccionados de forma que no se permita identificar datos sensibles de negocio.

A.11 RELACIÓN CON PROVEEDORES

11.1.1. ¿Existe una política para el tratamiento de los riesgos relacionados con proveedores y socios?

SI o NO

Se debe de documentar una política para el tratamiento de los riesgos relacionados con proveedores y socios.

11.1.2. ¿Los requisitos de seguridad son incluidos en los acuerdos con los proveedores y socios?

SI o NO

Todos los requisitos de seguridad más importantes se incluirán en los acuerdos con los proveedores y socios para asegurar que están comprometidos con el mismo nivel de seguridad definido por la organización.

11.1.3. ¿Los acuerdos con los proveedores incluyen requisitos de seguridad?

Nunca Casi Nunca A veces Casi siempre Siempre

Los acuerdos con los proveedores deberán incluir los requisitos de seguridad para garantizar el suministro seguro de servicios.

11.2.1. ¿Son supervisados regularmente los proveedores?

Nunca Casi Nunca A veces Casi siempre Siempre

Los proveedores deberán controlarse regularmente y ser auditados en su caso, para cumplir con los requisitos de seguridad.

11.2.2. ¿Los cambios relacionados con los acuerdos y contratos con proveedores y socios tienen en cuenta los riesgos existentes?

SI o NO

Cualquier cambio en la provisión de los servicios proporcionados por un proveedor será administrado e incluirá la evaluación de riesgos.

A.12 GESTIÓN DE INCIDENTES DE SEGURIDAD DE LA INFORMACIÓN

12.1.1. ¿Los incidentes son gestionados adecuadamente?

Nunca Casi Nunca A veces Casi siempre Siempre

Existen procedimientos y responsabilidades para la gestión de incidentes, para asegurar una respuesta adecuada y rápida.

12.1.2. ¿Los eventos de seguridad son reportados adecuadamente?

SI o NO

Los eventos de seguridad de la información deben ser reportados a tiempo para minimizar los daños a sistemas de información y al negocio.

12.1.3. ¿Los empleados y contratistas informan sobre las debilidades de seguridad?

SI o NO

La divulgación de las debilidades de seguridad es una de las principales fuentes para minimizar los riesgos, por tanto, deben ser reportados para proporcionar información útil.

12.1.4. ¿Cómo usted cree que los eventos de seguridad, son evaluados y clasificados correctamente?

Nunca Casi Nunca A veces Casi siempre Siempre

Los eventos de seguridad serán evaluados y clasificados adecuadamente. Se asignarán recursos disponibles para asegurar una pronta respuesta.

12.1.5. ¿Están documentados los procedimientos para dar respuesta a los incidentes?

SI o NO

Los procedimientos para respuesta a incidentes deberán documentarse para asegurar una respuesta estandarizada para los eventos de seguridad.

12.1.6. ¿Se analizan los incidentes de seguridad correctamente?

SI o NO

Los incidentes de seguridad deberán ser analizados para obtener conocimiento sobre cómo evitar que vuelva a producirse.

A.13.ASPECTOS DE SEGURIDAD DE LA INFORMACIÓN PARA LA GESTIÓN DE LA CONTINUIDAD DEL NEGOCIO

13.1.1. ¿Existen definidos requisitos para la continuidad de la seguridad de la información?

SI o NO

Se definirán los requisitos para la continuidad de la seguridad de la información para asegurar que están apoyando el negocio incluso durante un evento de interrupción.

13.1.2. ¿Existen procedimientos que aseguren la continuidad de la seguridad de la información durante una crisis o un desastre?

SI o NO

Deben existir procedimientos que aseguren la continuidad de la seguridad de la información durante una crisis o desastre. Estarán disponibles para ayudar a acelerar la recuperación de las operaciones normales del negocio y para apoyar la protección de la información durante el reinicio de las operaciones.

13.1.3. ¿Se realizan tests y pruebas de continuidad?

SI o NO

Se deben de realizar tests y pruebas con el fin de garantizar una respuesta eficaz en un caso real.

13.2.1. ¿La infraestructura IT está redundada, incluyendo su planeamiento y operación?

SI o NO

La infraestructura IT debe estar redundada para ayudar a conseguir las expectativas de recuperación ante un escenario de desastre.

A.14 CUMPLIMIENTO

14.1.1. ¿Son conocidos los requisitos legislativos, regulatorios, contractuales y cualquier otro requisito relativo a seguridad?

Nunca Raramente Ocasionalmente Frecuentemente Muy frecuentemente

Todos los requisitos legales, reglamentarios, contractuales y otros requisitos relativos a seguridad deben ser enumerados y documentados para asegurar las actividades de cumplimiento.

14.1.2. ¿Existen procedimientos para proteger los derechos de propiedad intelectual?

SI o NO

Deben existir procedimientos para asegurar la aplicación de los derechos de propiedad intelectual, en particular, el uso de software con licencia.

14.1.3. ¿La protección de los registros, están de acuerdo a requerimientos normativos?

Totalmente en desacuerdo, En desacuerdo, Ni acuerdo ni desacuerdo, De acuerdo, Totalmente de acuerdo

Todos los registros deberán estar protegidos según los requerimientos reglamentarios, contractuales y otros.

14.1.4. ¿La información personal está protegida adecuadamente?

SI o NO

La información personal debe ser protegida según lo estipulado en las leyes y reglamentos locales de cada país.

14.1.5. ¿Se utilizan controles criptográficos correctamente?

SI o NO

Los controles criptográficos se utilizarán según lo estipulado en las leyes y reglamentos legales de cada país.

14.2.1. ¿La seguridad de la información es revisada regularmente por un auditor independiente?

SI o NO

La seguridad de la información deberá ser periódicamente revisada por un auditor independiente para garantizar la idoneidad del sistema de gestión, adecuación y eficacia y para evaluar las oportunidades de mejora.

14.2.2. ¿Los gerentes revisan regularmente si las políticas de seguridad y procedimientos son llevadas a cabo adecuadamente en sus áreas de responsabilidad?

Nunca Casi Nunca A veces Casi siempre Siempre

Los gerentes deberán examinar regularmente si las políticas de seguridad y los procedimientos se realizan correctamente en sus áreas de responsabilidad para garantizar la idoneidad de los controles, la adecuación y eficacia y para evaluar oportunidades de mejoras.

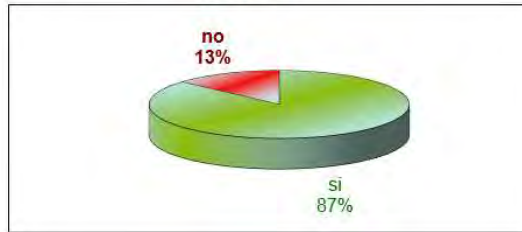
14.2.3. ¿Los sistemas de información son revisados regularmente para comprobar su cumplimiento con los estándares y las políticas de seguridad de la información?

SI o NO

Los sistemas de información deberán ser revisados periódicamente para comprobar su cumplimiento con las políticas de seguridad de la información y las normas para garantizar su idoneidad, adecuación y eficacia y para evaluar las oportunidades de mejora.

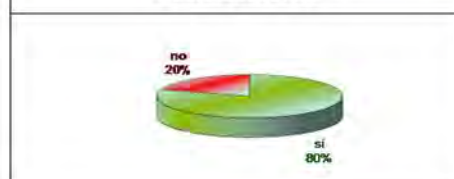
RESULTADOS DE DIAGNOSTICO INICIAL

RESULTADOS AUTODIAGNÓSTICO GENERAL

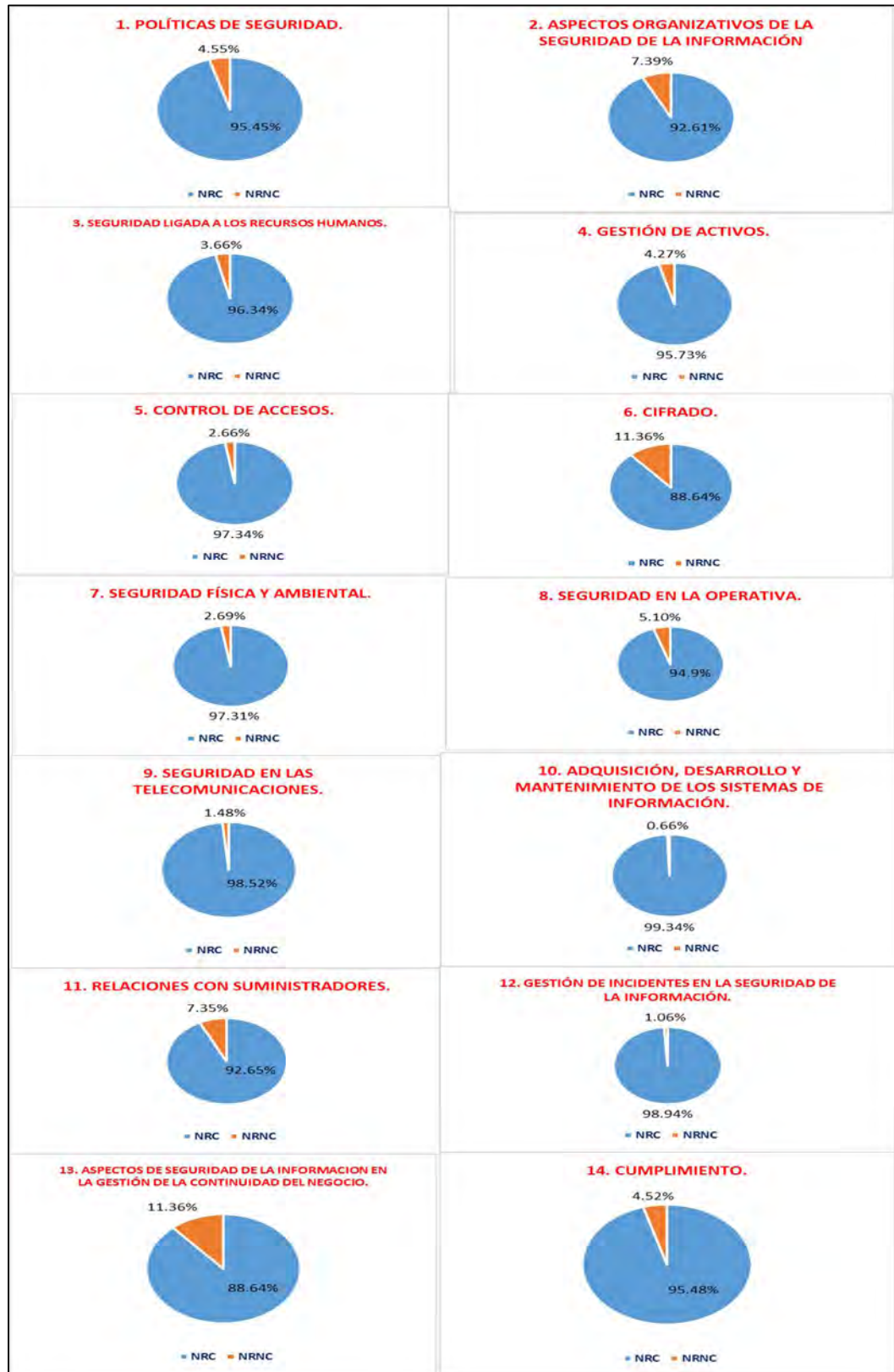


POR ÁREAS													
POLÍTICAS DE SEGURIDAD	ORGANIZACIÓN DE LA SEGURIDAD												
<table border="1"> <thead> <tr> <th>Respuesta</th><th>Porcentaje</th></tr> </thead> <tbody> <tr> <td>Si</td><td>83%</td></tr> <tr> <td>no</td><td>17%</td></tr> </tbody> </table>	Respuesta	Porcentaje	Si	83%	no	17%	<table border="1"> <thead> <tr> <th>Respuesta</th><th>Porcentaje</th></tr> </thead> <tbody> <tr> <td>Si</td><td>87%</td></tr> <tr> <td>no</td><td>13%</td></tr> </tbody> </table>	Respuesta	Porcentaje	Si	87%	no	13%
Respuesta	Porcentaje												
Si	83%												
no	17%												
Respuesta	Porcentaje												
Si	87%												
no	13%												
CLASIFICACIÓN Y CONTROL DE ACTIVOS	SEGURIDAD DEL PERSONAL												
<table border="1"> <thead> <tr> <th>Respuesta</th><th>Porcentaje</th></tr> </thead> <tbody> <tr> <td>Si</td><td>83%</td></tr> <tr> <td>no</td><td>17%</td></tr> </tbody> </table>	Respuesta	Porcentaje	Si	83%	no	17%	<table border="1"> <thead> <tr> <th>Respuesta</th><th>Porcentaje</th></tr> </thead> <tbody> <tr> <td>Si</td><td>89%</td></tr> <tr> <td>no</td><td>11%</td></tr> </tbody> </table>	Respuesta	Porcentaje	Si	89%	no	11%
Respuesta	Porcentaje												
Si	83%												
no	17%												
Respuesta	Porcentaje												
Si	89%												
no	11%												
SEGURIDAD FÍSICA Y DEL ENTORNO	GESTIÓN DE COMUNICACIONES Y OPERACIONES												
<table border="1"> <thead> <tr> <th>Respuesta</th><th>Porcentaje</th></tr> </thead> <tbody> <tr> <td>Si</td><td>91%</td></tr> <tr> <td>no</td><td>9%</td></tr> </tbody> </table>	Respuesta	Porcentaje	Si	91%	no	9%	<table border="1"> <thead> <tr> <th>Respuesta</th><th>Porcentaje</th></tr> </thead> <tbody> <tr> <td>Si</td><td>83%</td></tr> <tr> <td>no</td><td>17%</td></tr> </tbody> </table>	Respuesta	Porcentaje	Si	83%	no	17%
Respuesta	Porcentaje												
Si	91%												
no	9%												
Respuesta	Porcentaje												
Si	83%												
no	17%												
CONTROL DE ACCESOS	DESARROLLO Y MANTENIMIENTO DE SISTEMAS												
<table border="1"> <thead> <tr> <th>Respuesta</th><th>Porcentaje</th></tr> </thead> <tbody> <tr> <td>Si</td><td>94%</td></tr> <tr> <td>no</td><td>6%</td></tr> </tbody> </table>	Respuesta	Porcentaje	Si	94%	no	6%	<table border="1"> <thead> <tr> <th>Respuesta</th><th>Porcentaje</th></tr> </thead> <tbody> <tr> <td>Si</td><td>80%</td></tr> <tr> <td>no</td><td>20%</td></tr> </tbody> </table>	Respuesta	Porcentaje	Si	80%	no	20%
Respuesta	Porcentaje												
Si	94%												
no	6%												
Respuesta	Porcentaje												
Si	80%												
no	20%												
ADM. DE INCIDENTES	GESTIÓN DE LA CONTINUIDAD DEL NEGOCIO												
<table border="1"> <thead> <tr> <th>Respuesta</th><th>Porcentaje</th></tr> </thead> <tbody> <tr> <td>Si</td><td>80%</td></tr> <tr> <td>no</td><td>20%</td></tr> </tbody> </table>	Respuesta	Porcentaje	Si	80%	no	20%	<table border="1"> <thead> <tr> <th>Respuesta</th><th>Porcentaje</th></tr> </thead> <tbody> <tr> <td>Si</td><td>80%</td></tr> <tr> <td>no</td><td>20%</td></tr> </tbody> </table>	Respuesta	Porcentaje	Si	80%	no	20%
Respuesta	Porcentaje												
Si	80%												
no	20%												
Respuesta	Porcentaje												
Si	80%												
no	20%												

CUMPLIMIENTO



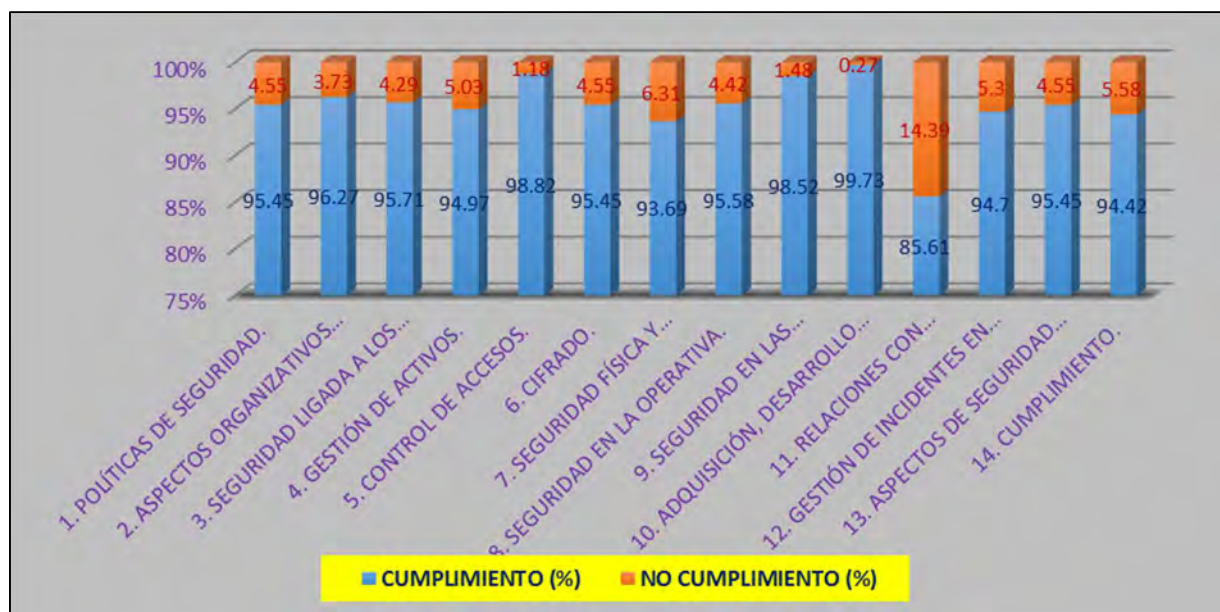
A) RESULTADOS POSTERIOR A LA IMPLEMENTACION DEL MODELO



RESULTADO GENERAL



RESULTADO DE AUDITORIA DE CUMPLIMIENTO



DOCUMENTACIÓN DE POLITICAS DE SEGURIDAD

[logo de la organización]

[nombre de la organización]

Comment [DK1]: Se deben completar todos los campos de este documento que estén marcados con corchetes [].

POLÍTICA DE CLASIFICACIÓN DE LA INFORMACIÓN

Código	
Versión:	
Fecha de la versión:	
Creado por:	
Aprobado por:	
Nivel de confidencialidad:	

Comment [DK2]: El sistema de codificación del documento debe coincidir con el sistema actual de codificación de documentos de la organización. En el caso que no exista ese sistema, se puede eliminar esta línea.

Historial de modificaciones

Fecha	Versión	Creado por	Descripción de la modificación
20/10/2018	0.1	Bernabe Huanca	Descripción básica del documento

Tabla de contenido

1. OBJETIVO, ALCANCE Y USUARIOS	3
2. DOCUMENTOS DE REFERENCIA.....	3
3. INFORMACIÓN CLASIFICADA	3
3.1. PASOS Y RESPONSABILIDADES.....	3
3.2. CLASIFICACIÓN DE LA INFORMACIÓN.....	4
3.2.1. Criterios de clasificación.....	4
3.2.2. Niveles de confidencialidad.....	4
3.2.3. Lista de personas autorizadas.....	4
3.2.4. Reclasificación.....	5
3.3. ETIQUETADO DE LA INFORMACIÓN	5
3.4. MANEJO DE INFORMACIÓN CLASIFICADA	5
4. GESTIÓN DE REGISTROS GUARDADOS EN BASE A ESTE DOCUMENTO	8
5. VALIDEZ Y GESTIÓN DE DOCUMENTOS	8

1. Objetivo, alcance y usuarios

El objetivo del presente documento es garantizar que se proteja la información en un nivel adecuado.

Este documento se aplica a todo el alcance del Sistema de gestión de seguridad de la información (SGSI); es decir, a todos los tipos de información, independientemente del formato, ya sean documentos en papel o electrónicos, aplicaciones y bases de datos, conocimiento de las personas, etc.

Los usuarios de este documento son todos los empleados de [nombre de la organización].

2. Documentos de referencia

- Norma ISO/IEC 27001, puntos A.8.2.1, A.8.2.2, A.8.2.3, A.8.3.1, A.8.3.3, A.9.4.1, A.13.2.3
- Política de Seguridad de la Información
- Informe de evaluación y tratamiento de riesgos
- Declaración de aplicabilidad
- Inventario de activos
- Lista de obligaciones legales, normativas y contractuales
- Procedimiento para gestión de incidentes
- [Procedimientos operativos para tecnología de la información y de la comunicación] / [Política de eliminación y destrucción]
- Política de Uso aceptable

Comment [DK3]: Si no tiene esta Lista, entonces aquí detalle toda la legislación y obligaciones contractuales relacionadas con clasificación de información.

Comment [DK4]: Escoger el documento que establece el borrado seguro de datos.

3. Información clasificada

3.1. Pasos y responsabilidades

Los pasos y responsabilidades para la gestión de la información son los siguientes:

Nombre del paso	Responsabilidad
1. Ingreso del activo de información de el inventario de activos	[cargo]
2. Clasificación de la información	Propietario del activo
3. Etiquetado de la información	Propietario del activo
4. Manejo de la información	Personas que controlan el acceso de acuerdo con esta Política

Si la información clasificada proviene de afuera de la organización, el [cargo] es el responsable de su clasificación según los reglas establecidas en esta Política, y solo permite su uso dentro de la organización.

3.2. Clasificación de la información

3.2.1. Criterios de clasificación

El nivel de confidencialidad se determina de acuerdo a los siguientes criterios:

- Valor de la información: según los riesgos asociados a la pérdida de riesgos.
- Sensibilidad y grado crítico de la información: según el mayor riesgo asociado a la pérdida de información durante la evaluación de riesgos.
- Obligaciones legales y contractuales: según la [Lista de obligaciones legales, normativas y contractuales].

3.2.2. Niveles de confidencialidad

Toda la información debe ser clasificada en niveles de confidencialidad.

Nivel de confidencialidad	Etiquetado	Criterios de clasificación	Restricción de acceso
Pública	(sin etiquetar)	La información no es sensible y no requiere de ninguna forma	La información está disponible para todo el público
Confidencial	Confidencial	El acceso no autorizado a la información podría ocasionar daños a la organización	La información está restringida a los empleados y terceros autorizados
Restringida	Restringida	El acceso no autorizado a la información podría dañar la reputación de la organización	La información está restringida a los empleados y terceros autorizados
Confidencial	Confidencial	El acceso no autorizado a la información podría dañar de forma catastrófica (irreparable) el negocio de la organización	La información está restringida a los empleados y terceros autorizados

Comment [DK5]: Los niveles de confidencialidad y el etiquetado pueden adaptarse al sistema vigente en la organización, al sistema habitual en el ambiente local o al sistema determinado por la legislación correspondiente.

La regla básica es utilizar el nivel de confidencialidad más alto que garantice la confidencialidad de la información sin crear gastos de protección innecesarios.

3.2.3. Lista de personas autorizadas

La información clasificada como "Confidencial" y "Restringida" debe estar controlada por una Lista de personas autorizadas en base al principio de la confidencialidad de la información.

La misma regla aplica para el nivel de confidencialidad "Uso interno" si las personas externas a la organización tendrán acceso a esos documentos.

3.2.4. Reclasificación

Los propietarios de activos **deben revisar la nivel de confidencialidad de sus activos de información cada [dos años]** y deben evaluar si se puede cambiar dicho nivel. Si es posible, deberían bajarlo.

Comment [D6]: Esto es sólo una recomendación; ajustar la frecuencia según sea necesario.

3.3. Etiquetado de la información

Los niveles de confidencialidad son etiquetados de la siguiente forma:

- **Documentos en papel:** se indica el nivel de confidencialidad en la esquina superior derecha de cada página del documento, también se indica en la esquina superior izquierda de cada documento, como también en la esquina superior izquierda de cada página de documentos.
- **Documentos electrónicos:** se indica el nivel de confidencialidad en la esquina superior derecha de cada página del documento.
- **Sistemas de información:** el nivel de confidencialidad en aplicaciones y bases de datos debe ser indicado en la esquina superior derecha de cada documento de la aplicación superior derecha de cada pantalla o pantalla que muestra información confidencial.
- **Correo electrónico:** se indica el nivel de confidencialidad en la esquina superior izquierda del correo electrónico.
- **Soporte de almacenamiento electrónico** (discos, tarjetas de memoria, etc.): se debe indicar el nivel de confidencialidad sobre el soporte de cada soporte.
- **Información transmitida oralmente:** el nivel de confidencialidad de la información confidencial que es transmitida y recibida de una conversación cara a cara, por teléfono o por alguna forma de comunicación debe ser comunicado antes que la información propiamente dicha.

3.4. Manejo de información clasificada

Todas las personas que tienen acceso a información clasificada deben seguir las reglas enumeradas en el siguiente cuadro. En ningún caso deben existir acciones excepcionales que no se ajusten a cumplir las reglas y a la información en documentos o personas no autorizadas. Cada incidente relacionado con el manejo de información clasificada debe ser reportado de acuerdo con el Procedimiento para gestión de incidentes.

Los activos de información **deben ser clasificados de acuerdo con la autorización** de acuerdo a lo establecido en la Política de uso aceptable.

El método para **eliminar, destruir o destruir** **documentos** **[Procedimientos operativos para tecnología de la información y de la comunicación] / [Política de eliminación y destrucción]**.

Comment [D7]: Todas las reglas mencionadas aquí deben ser adaptadas a las necesidades de la organización.

Comment [D8]: Eliminar este párrafo si el control A.11.2.5 está excluido de la Declaración de aplicabilidad.

Comment [DK9]: Escoger el documento que establece el borrado seguro de datos.

	Uso interno	Restringida*	Confidencial*
Documentos en papel	Sólo las personas autorizadas pueden tener acceso.	El documento debe ser almacenado en un lugar seguro.	El documento debe ser almacenado en un lugar seguro.

	• Si es enviado fuera de la organización, el documento debe ser enviado por correo certificado. • Los documentos sólo pueden ser guardados en dispositivos de acceso público. • Los documentos deben ser retirados frecuentemente de impresoras y máquinas de fax.	llave. • Los documentos pueden ser transferidos dentro y fuera de la organización solamente en un sobre cerrado. • Si es enviado fuera de la organización, el documento debe ser enviado en un sobre cerrado. • Los documentos deben ser retirados inmediatamente de impresoras y máquinas de fax. • Solamente el propietario del documento puede copiarlo. • Solamente el propietario del documento puede destruirlo.	• El documento puede ser transferido dentro y fuera de la organización solamente por correo certificado y en un sobre cerrado y sellado. • No está permitido enviar el documento por fax. • Es posible imprimir un documento sólo si la persona autorizada está al lado de la impresora.
Documentos electrónicos	• Sólo las personas autorizadas pueden tener acceso. • Cuando se intercambian archivos a través de correo electrónico, transferencia de archivos, etc., deben estar protegidos con clave. • El acceso a los sistemas de información en los que se almacenan los documentos debe estar protegido con una clave segura. • La pantalla en la que se muestra el documento debe estar protegida.	• Sólo las personas con autorización para este documento pueden acceder a la parte del sistema de información en el que está guardado el documento. • Cuando se intercambian archivos a través de correo electrónico, transferencia de archivos, etc., deben estar encriptados. • Solamente el propietario del documento puede copiarlo.	• El documento debe ser almacenado en formato encriptado. • El documento encriptado puede ser utilizado en cualquier dispositivo de la organización. • El documento no debe ser intercambiado a través de correo electrónico, transferencia de archivos, etc.

Política de clasificación de la información ver. [versión] del [fecha] Página 7 de 9

	con clave. • Si es enviado fuera de la organización, el soporte debe ser enviado por correo certificado. • El soporte solamente puede ser guardado en habitaciones con acceso restringido.	gabinete con llave. • Si es enviado fuera de la organización, el soporte debe ser enviado con acuse de recibo. • Sólo el propietario del soporte puede tener acceso al mismo.	fuera de la organización. El soporte debe ser enviado en un sobre cerrado y sellado.
Información transmitida oralmente	• Sólo las personas autorizadas pueden recibir acceso a la información. • Las personas no autorizadas no deben estar presentes en la habitación cuando se transmite la información.	• La habitación debe estar siempre cerrada. • La conversación no debe ser grabada.	• La conversación realizada a través de radio de comunicación debe ser escuchada. • No se debe permitir ninguna transcripción de la conversación.

*Los controles se implementan acumulativamente; es decir, los controles para cualquier nivel de confidencialidad incluyen los controles de todos los niveles inferiores. Si se establecen controles más estrictos para un nivel de confidencialidad mayor, sólo se implementarán esos controles.

4. Gestión de registros guardados en base a este documento

Nombre del registro	Ubicación de archivo	Persona responsable del archivo	Controles para la protección del registro	Tiempo de retención
[Lista de personas autorizadas con acceso a los documentos]	Junto con la información en la que se indica el nivel de confidencialidad	Propietario del activo de información	El mismo que para la protección de información	Debe existir la lista siempre que exista la información propiamente dicha

5. Validez y gestión de documentos

Este documento es válido desde el [fecha]

El propietario de este documento es el [cargo], que ~~debe verificar la vigencia y actualización~~ el documento por lo menos **una vez al año**.

Al evaluar la efectividad y adecuación de este documento, es necesario tener en cuenta los siguientes criterios:

- Cantidad de incidentes ~~relacionados con el manejo y conservación de la~~ información.
- Cantidad de activos de información ~~clasificados con un nivel de confidencialidad~~ inadecuado.

[cargo]

[nombre]

[firma]

Comment [DK10]: Esto es sólo una recomendación; ajustar la frecuencia según sea necesario.

Comment [DK11]: Sólo es necesario si el Procedimiento para control de documentos y registros establece que los documentos en papel deben ser firmados.

[logo de la organización]

[nombre de la organización]

Comment [DK1]: Se deben completar todos los campos de este documento que estén marcados con corchetes [].

POLÍTICA DE CONTROL DE ACCESO

Código	
Versión:	
Fecha de la versión:	
Creado por:	
Aprobado por:	
Nivel de confidencialidad:	

Comment [DK2]: El sistema de codificación del documento debe coincidir con el sistema actual de codificación de documentos de la organización. En el caso que no exista ese sistema, se puede eliminar esta línea.

Historial de modificaciones

Fecha	Versión	Creado por	Descripción de la modificación
20/10/2018	0.1	Bernabe Huanca	Descripción básica del documento

Tabla de contenido

1.	OBJETIVO, ALCANCE Y USUARIOS	3
2.	DOCUMENTOS DE REFERENCIA	3
3.	CONTROL DE ACCESO	3
3.1.	INTRODUCCIÓN	3
3.2.	PERFIL DE USUARIO A	3
3.3.	PERFIL DE USUARIO B	4
3.4.	GESTIÓN DE PRIVILEGIOS	4
3.5.	REVISIONES PERIÓDICAS DE LOS DERECHOS DE ACCESO	5
3.6.	CAMBIO DE ESTADO O FINALIZACIÓN DE UN CONTRATO	5
3.7.	IMPLEMENTACIÓN TÉCNICA	6
3.8.	GESTIÓN DE LA CLAVE DEL USUARIO	6
4.	GESTIÓN DE REGISTROS GUARDADOS EN BASE A ESTE DOCUMENTO	7
5.	VALIDEZ Y GESTIÓN DE DOCUMENTOS	7

1. Objetivo, alcance y usuarios

El objetivo del presente documento es definir reglas de acceso para diversos sistemas, equipos, instalaciones e información en base a los requerimientos de negocios y de seguridad.

Este documento se aplica a todo el alcance del Sistema de gestión de seguridad de la información (SGSI); es decir, a todos los sistemas, equipos, instalaciones e información utilizados dentro del alcance del SGSI.

Los usuarios de este documento son todos los empleados de [nombre de la organización].

2. Documentos de referencia

- Norma ISO/IEC 27001, capítulos A.9.1.1, A.9.1.2, A.9.2.1, A.9.2.2, A.9.2.3, A.9.2.4, A.9.2.5, A.9.2.6, A.9.3.1, A.9.4.1, A.9.4.3
- Política de Seguridad de la Información
- Declaración de aplicabilidad
- [Política de Clasificación de la Información]
- [Declaración de aceptación de los documentos del SGSI]
- [Lista de requisitos legales, normativos, contractuales y de otra índole]

Comment [DK3]: Si no tiene esta Lista, entonces aquí detalle toda la legislación y contratos que contengan requerimientos de control de acceso.

3. Control de acceso

3.1. Introducción

El principio básico es que el acceso a todos los sistemas, redes, servicios e información está prohibido

salvo que sea expresamente permitido a usuarios autorizados o a grupos de usuarios. Debe existir un procedimiento de registro de acceso para cada usuario o grupo.

Está permitido el acceso a [sistemas, redes, servicios e información] de la organización, excepto a aquellos para los cuales el privilegio debe ser concedido por una persona autorizada (punto "Gestión de privilegios").

[Sistemas, redes, servicios e información] que la Política de clasificación de información define reglas de acceso para documentos y registros individuales.

Comment [D4]: Eliminar este punto si el control A.9.2.1 está marcado como no aplicable en la Declaración de aplicabilidad.

3.2. Perfil de usuario A

El perfil de usuario A tiene los siguientes derechos de acceso:

Nombre del sistema / red / servicio	Derechos de acceso

Comment [D5]: Eliminar si la Política de [documentación] es documentada.

Comment [D6]: Adaptar al sistema de identificación estándar de la organización.

Comment [D7]: Pueden ser [sistemas, redes, servicios e información] para módulos individuales.

Comment [D8]: Especificar si incluyen [sistemas, redes, servicios e información] específicas.

[nombre de la organización]

[nivel de confidencialidad]

Los siguientes cargos tienen derechos de acceso de acuerdo al Perfil de usuario A:

- [cargo 1]
- [cargo 2]

3.3. Perfil de usuario B

El perfil de usuario B tiene los siguientes derechos de acceso:

Nombre del sistema / red / servicio	Derechos de acceso

Los siguientes cargos tienen derechos de acceso de acuerdo al Perfil de usuario B:

- [cargo 1]
- [cargo 2]

3.4. Gestión de privilegios

Los privilegios respecto de los perfiles de usuario representados anteriormente (concesión o eliminación de derechos de acceso) son asignados de la siguiente forma:

Nombre del sistema / red / servicio / sistema físico	Quién está autorizado a conceder o eliminar derechos de acceso	Forma del proceso de autorización

Comment [D9]: Enumerar todos los

empleados al momento de ser contratados.

Comment [D10]: Es posible enumerar en que se detalla en este punto.

Comment [D11]: Pueden ser especificados a nivel de todo el sistema o para módulos individuales.

Comment [D12]: Especificar si incluyen específicas.

Comment [D13]: Eliminar este punto si el control A.9.2.3 está marcado como no aplicable en la Declaración de aplicabilidad.

Comment [DK14]: Es posible respectivos propietarios.

Comment [D15]: Por correo quede un registro.

Al asignar privilegios, la persona responsable debe tener en cuenta los requerimientos de negocio y de seguridad para el acceso (definidos en la evaluación de riesgos), tener presente la clasificación de la información y la que se asocia con esos derechos de acceso, de acuerdo con la Política de clasificación de información.

3.5. Revisiones periódicas de los derechos de acceso

Los propietarios de cada sistema y de las instalaciones para los cuales se requieren derechos de acceso operativos deben seguir los siguientes intervalos para revisar los derechos de acceso operativos se mantienen de acuerdo a los requerimientos de negocios y de seguridad:

Nombre del sistema / red / servicio, servicio	Intervalos para revisión periódica

Cada revisión debe ser registrada [especificar cómo se llevan los registros].

3.6. Cambio de estado o finalización de un contrato

Cuando se produce un cambio o terminación de contrato, extinción del contrato inmediatamente a la persona que autorizó los privilegios del empleado en cuestión.

Cuando se modifican las relaciones contractuales con entidades externas que tienen acceso a datos, servicios e instalaciones, o cuando finaliza el contrato, el propietario del contrato debe terminar inmediatamente a la persona que autorizó los privilegios de la entidad externa en cuestión.

Comment [D16]: Eliminar este punto si el control A.9.2.5 está marcado como no aplicable en la Declaración de aplicabilidad.

Comment [D17]: Adaptar en caso que sea necesario.

Comment [D18]: La frecuencia debe ser la que se establezca en la política de los resultados de la evaluación de riesgos.

Comment [D19]: Se puede utilizar un formulario, un informe formal, notas escritas a mano, etc.

Comment [DK20]: Eliminar este punto si el control A.9.2.6 está marcado como no aplicable en la Declaración de aplicabilidad.

Los derechos de acceso para todas las personas que han modificado su condición de empleo o ~~condición de empleo o han sido eliminados o modificados inmediatamente por las personas responsables~~ de acuerdo a lo que se define en la siguiente sección.

3.7. Implementación técnica

La implementación técnica de la asignación o eliminación de derechos de acceso la realizan las siguientes personas:

Nombre del sistema / red / aplicación	Persona responsable de la implementación

Las personas detalladas en este cuadro no pueden ~~asignar o eliminar derechos de acceso de~~ ~~personas no autorizadas o de los archivos de usuarios definidos en la política~~ Política y a solicitudes de personas autorizadas para asignar privilegios.

3.8. Gestión de la clave del usuario

Cuando se asignan y utilizan claves de usuarios, se deben cumplir las siguientes reglas:

- Al firmar la Declaración de aceptación de los documentos del SGSI, los usuarios también ~~aceptan la obligación de mantener sus claves de acceso confidenciales, como se establece en~~ este documento.
- Cada usuario puede utilizar solamente su ~~propio nombre de usuario asignado de forma~~ exclusiva.
- Cada usuario debe tener la ~~capacidad de cambiar su contraseña, en los casos~~ corresponda.
- Las claves utilizadas para el primer acceso ~~al sistema deben ser nuevas y seguras, según lo~~ informado anteriormente.
- Las claves de primer acceso ~~deben ser generadas de manera de~~ forma segura, y se debe verificar previamente la identidad del usuario.
- El sistema de gestión de claves ~~debe asegurarse que el usuario cambie su clave de primer~~ acceso cuando ingrese al sistema por primera vez.
- El sistema de gestión de claves debe ~~asegurarse que el usuario tenga contraseñas~~ seguras.
- El sistema de gestión de claves debe ~~asegurarse que las contraseñas cambien~~ claves cada tres meses.

Comment [D21]: Eliminar este punto si la Política de claves forma parte de un documento aparte.

Comment [D22]: Adaptar estas reglas según los riesgos evaluados.

Comment [DK23]: Se pueden ~~eliminar las contraseñas de~~

Comment [D24]: Aquí se puede agregar más información.

4. Gestión de registros guardados en base a este documento

Comment [D28]: Modificar según sea necesario

Solamente el [cargo] puede ~~generar o actualizar~~ ~~generar o actualizar~~ de los documentos mencionados precedentemente.

5. Validez y gestión de documentos

Este documento es válido desde el [fecha]

Comment [DK29]: Esto es sólo una recomendación; ajustar la frecuencia según sea necesario.

Al evaluar la efectividad y adecuación de este documento, es necesario tener en cuenta los siguientes criterios:

- Cantidad de incidentes relacionados con el acceso no autorizado a la información.
- Cambio de derechos de acceso relacionados con casos de cambio y finalización de empleo o contratos.
- Cantidad de sistemas no incluidos en el presente documento.
- Nivel de cumplimiento de requisitos y de riesgos asociados para la implementación del presente documento.

[cargo]

[nombre]

[firma]

Comment [DK30]: Sólo es necesario si el Procedimiento para control de documentos y registros establece que los documentos en papel deben ser firmados.

[logo de la organización]

[nombre de la organización]

Comment [DK1]: Se deben completar todos los campos de este documento que estén marcados con corchetes [].

POLÍTICA DE CLAVES

Comment [D2]: No es necesario que esta Política se presente como un documento independiente si las mismas reglas están establecidas en la Política de uso aceptable de los activos y en la Política de control de acceso.

Comment [DK3]: El sistema de codificación del documento debe coincidir con el sistema actual de codificación de documentos de la organización. En el caso que no exista ese sistema, se puede eliminar esta línea.

Código	
Versión:	
Fecha de la versión:	
Creado por:	
Aprobado por:	
Nivel de confidencialidad:	

Historial de modificaciones

Fecha	Versión	Creado por	Descripción de la modificación
20/10/2018	0.1	Bernabe Huanca	Descripción básica del documento

Tabla de contenido

1.	OBJETIVO, ALCANCE Y USUARIOS	3
2.	DOCUMENTOS DE REFERENCIA	3
3.	OBLIGACIONES DE LOS USUARIOS	3
4.	GESTIÓN DE LA CLAVE DEL USUARIO	4
5.	VALIDEZ Y GESTIÓN DE DOCUMENTOS	4

- No se deben utilizar las mismas claves personales para fines privados y para fines comerciales.

4. Gestión de la clave del usuario

Cuando se asignan y utilizan claves de usuarios, se deben seguir las siguientes reglas:

- Al firmar la Declaración de aceptación de los documentos del SGSI, los usuarios también aceptan la obligación de mantener sus claves en forma confidencial, como se establece en este documento.
- Cada usuario puede utilizar solamente su propio método de usuario asignado de forma exclusiva.
- Cada usuario debe tener la capacidad de elegir su propio clave, en la que corresponda.
- Las claves utilizadas para el acceso a los datos deben ser diferentes y seguras, según lo establecido precedentemente.
- Las claves de primer acceso deben ser comunicadas al usuario de forma segura, y se debe verificar previamente la identidad del usuario.
- El sistema de gestión de claves debe requerir que el usuario modifique la clave de primer acceso cuando ingrese al sistema por primera vez.
- El sistema de gestión de claves debe requerir que el usuario modifique su clave regularmente.
- El sistema de gestión de claves debe requerir que los usuarios cambien sus claves cada tres meses.
- Si el usuario solicita una nueva clave, el sistema de gestión de claves debe requerir la identidad del usuario [indicar cómo].
- El usuario debe confirmar la recepción del y clave [indicar cómo].
- La contraseña no debe ser reutilizada durante el resto de la vida.
- Si un usuario ingresa una clave incorrecta tres veces consecutivas, el sistema debe bloquear la cuenta de usuario en cuestión.
- Las claves creadas por el sistema de gestión de claves deben ser comunicadas al usuario de forma segura.
- Los archivos que contienen claves deben ser guardados en forma separada de la base de datos del sistema de la aplicación.

Comment [D6]: Eliminar toda esta sección si las reglas ya están establecidas en la Política de control de acceso.

Comment [D7]: Adaptar estas reglas según los riesgos evaluados y las características del sistema.

Comment [DK8]: Se pueden establecer reglas independientes para claves de administrador y de usuario.

Comment [DK9]: Aquí se puede agregar más información.

Comment [D10]: Por ejemplo,

acción, etc.

Comment [D11]: Por ejemplo,

5. Validez y gestión de documentos

Este documento es válido desde el [fecha]

El propietario de este documento es el [cargo], que debe verificar la vigencia actualizada de documento por lo menos una vez al año.

Al evaluar la efectividad y adecuación de este documento, es necesario tener en cuenta los siguientes criterios:

Comment [DK12]: Esto es sólo una recomendación; ajustar la frecuencia según sea necesario.

[nombre de la organización]

[nivel de confidencialidad]

- Cantidad de incidentes ~~relacionados con el uso indebido de claves por usuarios~~ no autorizadas.
- Cantidad de incidentes ~~relacionados con el manejo inadecuado~~ de claves.

[cargo]

[nombre]

[firma]

Comment [DK13]: Sólo es necesario si el Procedimiento para control de documentos y registros establece que los documentos en papel deben ser firmados.

Declaración de confidencialidad

Por medio de la presente, declaro que a toda la información recibida durante la ejecución de [nombre del contrato] por el cual se genera [nombre de la actividad o información confidencial] del [nombre del contrato] en adelante, "[contrato]" se trata un [documento confidencial] y no la revelaré a terceros, excepto hasta lo establecido en esta Declaración, en documentos de [nombre de la organización] o en las leyes correspondientes.

Utilizaré toda la información ~~recibida durante la ejecución del~~ Contrato solamente con la finalidad especificada en el mismo.

Trataré de forma especialmente confidencial toda la información recibida por escrito u oralmente, ya sea técnica, comercial, legal, organizacional, personal o de cualquier otro tipo, que pudiera resultar en daño a (beneficio de) la organización, a terceros o a personas no autorizadas, sin importar si la información está clasificada como confidencial o no.

Solamente compartiré la información confidencial con personas autorizadas de [nombre de la organización] en el marco del objetivo de por la ejecución del Contrato.

Manejaré la información confidencial de acuerdo con [nombre del documento que establece cómo manejar información clasificada por el, desde su expedición en el momento del Contrato o incluyendo una referencia a la Política para manejo de información clasificada].

Si tuviera que colaborar con terceros en la ejecución del Contrato, no compartiré ningún tipo de información confidencial sin el previo consentimiento escrito de [nombre de la organización].

Si fuera requerido por decisión de alguna corte jurisdiccional por un litigio, o por cualquier otro organismo, entidad, gubernamental o regulatorio competente, o si estuviera legalmente obligado a revelar algún tipo de información confidencial, revelaré en forma voluntaria o por ley a [nombre de la organización].

Si se violara alguna obligación establecida bajo esta Declaración, notificaré a [nombre de la organización] inmediatamente al tomar conocimiento de dicha violación.

[signature] *your name* *your title*, *your address*

Los datos personales de confidencialidad bajo la presente Declaración de confidencialidad seguirán teniendo vigencia aún después del vencimiento del Contrato.

Declaro que indemnizaré a [nombre de la organización] por cualquier daño ocasionado por la divulgación de información confidencial.

Nombre de la organización: _____

Nombre: _____

Fecha: _____

Firma: _____

Comment [DK1]: Esta declaración debe ser firmada por todos los empleados de la organización, como también por todos los empleados de los proveedores o socios que tendrán acceso a información confidencial de acuerdo con un contrato.

Comment [DK2]: La persona responsable de asuntos legales en su organización debe verificar la terminología legal de esta Declaración.

Comment [DK3]: Eliminar si esta

Comment [DK4]: Si esta Declaración de confidencialidad es firmada por los

demás documentos de [nombre de la organización]."

Comment [DK5]: Si esta Declaración de confidencialidad es firmada por los empleados, reemplazar con lo siguiente: "Cargo"

Apéndice 1: Programa anual de auditoría interna

Se redacta este programa anual para el período comprendido desde el [fecha] hasta el [fecha].

Las auditorías internas en el marco de las normas ISO/IEC 27001 e ISO 27002 serán realizadas de la siguiente forma:

Período de la auditoría	Alcance de la auditoría	Criterios de la auditoría	Metodología de la auditoría	Audidores	Registro de

[cargo]

[nombre y apellido]

[firma]

Comment [DK1]: Para aprender a completar este documento consulte:

1) **Tutorial en vídeo** 'Cómo redactar el Procedimiento de auditoría interna y el Programa de auditoría interna según ISO 27001/ISO 22301'
<http://www.iso27001standard.com/video-tutorials>

2) **Webinar** 'Auditoría interna: Cómo realizarla de acuerdo con las normas ISO 27001 y BS 25999-2'
<http://www.iso27001standard.com/webinars>

Comment [DK2]: Borrar si el programa es controlado por software.

Comment [DK3]: Borrar si no se aplican los criterios.

Comment [DK4]: Informar las fechas en las que los informes fueron redactados, etc.

Comment [DK5]: Sólo es necesario si el Procedimiento para control de documentos y registros establece que los documentos en papel deben ser firmados.

GLOSARIO

Acción correctiva: Acción para eliminar la causa de una no conformidad y prevenir que vuelva a ocurrir.

Activo: Son los bienes, derechos y otros recursos económicos que poseen las empresas y que son susceptibles de convertirse en beneficios o aportar un rendimiento económico a la organización. Estos activos están controlados por la empresa como resultado de acciones pasadas.

Alcance de la auditoría: Es el acuerdo mutuo entre auditor y auditado sobre qué se va a realizar en la auditoría.

Amenaza: Causa potencial de un incidente no deseado, el cual puede ocasionar daño a un sistema o a una organización.

Análisis de riesgo intrínseco: Estudio que se realiza sin tener en consideración las medidas de seguridad implantadas en la Organización.

Análisis de riesgo residual: Estudio que se realiza teniendo en consideración las medidas de seguridad implantadas en la Organización.

Análisis de Riesgos: Proceso de identificación de los riesgos, determinando la magnitud y las áreas que requieren las medidas de protección

Análisis Diferencial: Es un análisis de los controles implantados vs controles necesarios según la norma ISO 27001:2013, dando como resultado el análisis de la madurez.

Auditado: Es la Entidad Publica a la que se va a auditar.

Auditor/Equipo auditor: Es el grupo de personas que van a ejecutar la auditoría.

Auditoría: Proceso sistemático, independiente y documentado para obtener evidencias de auditoría y evaluarlas de manera objetiva con el fin de determinar el grado en el que se cumplen los criterios de auditoría.

Autenticación: Asegurar que una característica declarada de una entidad es correcta.

Carta de Asignación de Auditoría: Documento donde se describe la asignación de las tareas que el equipo auditor tiene que realizar.

Confidencialidad: Propiedad de la información que la hace no disponible o sea divulgada a individuos, entidades o **procesos** no autorizados.

Control o salvaguarda: Práctica, procedimiento o mecanismo que reduce el nivel de riesgo.

Control de acceso: Medios para asegurar que el acceso a los activos está autorizado y restringido en función de los requisitos de negocio y de seguridad.

Competencia: Capacidad para aplicar conocimientos y habilidades con el fin de lograr los resultados previstos.

Cuadro de mando: Es una herramienta de gestión que facilita la toma de decisiones, ya que recoge el conjunto de indicadores que sirven a la alta dirección dar una visión del estado de la seguridad de la información.

Datos: Conjunto de valores asociados a medidas base, medidas derivadas y/o indicadores.

Disponibilidad: Propiedad de ser accesible y utilizable a demanda por una entidad autorizada.

Eficacia: Grado en el cual se realizan las actividades planificadas y se logran los resultados planificados.

Escala: Conjunto ordenado de valores, continuo o discreto, o un conjunto de categorías a las que se asignan el atributo.

Evento: Ocurrencia o cambio de un conjunto particular de circunstancias.

Evidencia de auditoría: Conjunto de registros, declaraciones de un hecho u otra información que se obtenga durante el proceso de auditoría que deberá cumplir con las características de ser verificable, pertinente y objetivo.

Hallazgos de la auditoría: Es el resultado de la evaluación de la evidencia de la auditoría frente a los criterios de la auditoría.

Identificación del riesgo: Proceso que comprende la búsqueda, el reconocimiento y la descripción de los riesgos.

Incidente de seguridad de la información: Evento único o serie de eventos de seguridad de la información, inesperados o no deseados, que tienen una probabilidad significativa de comprometer las operaciones del negocio y de amenazar la seguridad de la información.

Medida: Variable a la que se le asigna un valor como resultado de una medición.

Nivel de riesgo: Magnitud de un riesgo expresado en términos de la combinación de las consecuencias y de su probabilidad.

Objetivo de control: Declaración que describe lo que se quiere lograr como resultado de la implementación de **controles**.

Organización: Persona o grupo de personas que tienen sus propias funciones con responsabilidades, autoridades y relaciones para el logro de sus objetivos.

PDCA (plan-do-check-act): El ciclo Deming o más conocido como el círculo de vicios, es un método de mejora continua de la calidad.

Plan de Auditoría: Documento donde se encuentran las decisiones más importantes sobre la estrategia para el desarrollo de la auditoría de gestión.

Proceso: Conjunto de actividades interrelacionadas o que interactúan, que transforma elementos de entrada en elementos de salida.

Política: Intenciones y dirección de una organización, como las expresa formalmente su alta dirección.

Política de seguridad de la información: Establece los principios y líneas de actuación globales en materia de seguridad de la información, alineados a los objetivos del negocio.

Probabilidad: Posibilidad de que algo pase.

Pruebas de cumplimiento: Tienen como objetivo comprobar si se implementan los controles tal y como se indican en la normativa de referencia.

Requisito: Necesidad o expectativa que está establecida, generalmente implícita u obligatoria.

Riesgo: Es la medida de la posibilidad para que se materialice la amenaza.

Salvaguarda: Es un mecanismo de protección frente a las amenazas, existen diferentes tipos dependiendo si se desea prevenir o corregir un incidente.

Seguimiento: Determinación del estado de un sistema, un proceso o una actividad.

Seguridad de la información: Preservación de la confidencialidad, la integridad y la disponibilidad de la información.

Seguridad Informática: Se ocupa de la seguridad de los sistemas de información.

Sistema de Gestión de Seguridad de la Información (SGSI): Es un conjunto de políticas y acciones relacionadas entre sí que permiten alcanzar el objetivo en materia de seguridad de la información.

Vulnerabilidad: Debilidad de un activo o de un control que puede ser explotada por una o más amenazas.